

≡ go-ledger

THE LEDGER BOOK

Building a production payment ledger in Go

Double-entry accounting with invariants impossible to violate. Built in the open, week by week.

Sohag Hasan

2026 · github.com/sohag-pro/go-ledger



The Ledger Book

Building a production payment ledger in Go

Sohag Hasan

Edition	1.0, first edition, 2026
Format	Digital edition, A5 (148 by 210 millimeters) book trim, set in 11 point for a comfortable measure. A print edition is planned but not yet produced.
ISBN	Not yet assigned. Reserved for the print and EPUB editions once a print run is scheduled.
Contents	Weeks 1 to 14, four special editions, ADRs 001 to 027
Status	The full 14-week series is complete
Book text	© 2026 Sohag Hasan. Free to read and free to share.
Source code	MIT License • github.com/sohag-pro/go-ledger
Author	Sohag Hasan, Dhaka, Bangladesh
Portfolio	sohag.pro
Live service	go.sohag.pro
Weekly series	notes.sohag.pro/series/go-ledger
Support	buymeacoffee.com/sohagpro
Cover gopher	The Go gopher by Takuya Ueda, licensed CC BY 3.0. Original mascot design by Renee French.

This book is provided as is, without warranty of any kind. The code it describes is real, running, and tested, but you run it at your own risk.

Everything here was built and written in public, one week at a time. The text is generated from Markdown, typeset with LuaLaTeX, and assembled straight from the same repository as the code, so the book and the software never drift apart.

*For my father and mother,
who taught me that small, honest entries add up.*

What's Inside

Foreword	34
Who This Is For	36
A Note Before You Begin	37
How to Read This Book	39

I WEEK 0

41

1 The Build Plan	42
1.1 Why plan at all for a solo project .	42
1.2 The bet	43
1.3 The decisions I locked and refused to relitigate	44
1.4 Four phases across fourteen weeks ..	45
1.5 What is deliberately out	46

1.6 The risks I wrote down, and roughly how they went	47
1.7 Why this is Week 0	48

II WEEK 1

49

2 Why I'm Building a Production Go Payment Ledger	50
2.1 Why a ledger, of all things?	50
2.2 Why Go?	53
2.3 The 14-week plan	54
2.4 Week 1: the unglamorous part	54
2.5 My AI companion	56
2.6 Why you should build one too	56
3 Week 1 Interview Q&A	58
3.1 Theme 1: Domain design	58
3.2 Theme 2: Project structure and scaffolding	60
3.3 Theme 3: HTTP server decisions	62
3.4 Theme 4: Tooling and build	64
3.5 Theme 5: Trade-offs and scope	66

4	Modeling Double-Entry Accounting in Go	69
4.1	The one rule	69
4.2	First decision: how do you even store money?	70
4.3	Modeling the transaction	72
4.4	Proving it holds, hundreds of times	74
4.5	What I deliberately left out	76
4.6	The honest split	77
4.7	Next week	78
5	Week 2 Interview Q&A	79
5.1	Domain design	79
5.2	Data integrity and the invariant	81
5.3	Money representation (ADR-002)	83
5.4	Testing	85
5.5	Trade-offs and defending decisions	87

6	Postgres Schema for a Multi-Tenant Ledger	91
----------	--	-----------

6.1	The one decision that shapes the rest	91
6.2	Three tables, not five	93
6.3	Multi-tenant from the first migration	93
6.4	The small choices that add up	95
6.5	Proving it works against a real Postgres	96
6.6	The AI companion, week 3	97
6.7	Where this leaves us	98
7	Week 3 Interview Q&A	99
7.1	Schema design	99
7.2	Multi-tenancy and data integrity	101
7.3	Repository and adapter design	104
7.4	Testing	106
7.5	Trade-offs and stack defense	108

V WEEK 4

110

8	Atomic Transaction Posting in Go	111
8.1	The thing that must never happen	111
8.2	Two ways to be safe	112
8.3	Retrying without making it worse	113

8.4 Belt and suspenders: enforce it in the database too	115
8.5 The afternoon one in six payments failed	117
8.6 What a fresh pair of eyes caught ..	119
8.7 Where this leaves us	119
9 Week 4 Interview Q&A	121
9.1 Concurrency model	121
9.2 Enforcing the invariant in the database	123
9.3 Architecture and error handling ...	126
9.4 Observability and operations	128
9.5 Testing	129
9.6 Defending the stack	130

VI WEEK 5

132

10 Designing a REST API for a Payment Ledger	133
10.1 Resources and verbs, not remote procedures	133
10.2 Money on the wire	135
10.3 The statement, and the number that is not stored	136

10.4	Paging without lying to the user	137
10.5	When the query generator pushed back	138
10.6	The docs cannot drift	139
10.7	It is real now	139
10.8	The AI companion, week 5	140
10.9	Where this leaves us	140
11	Week 5 Interview Q&A	142
11.1	API design	142
11.2	Account statement	145
11.3	Data and error handling	147
11.4	Server and operations	149
11.5	Defending the stack	150

VII WEEK 6

153

12	Idempotency Keys and the Immutable Audit Log	154
12.1	The retry problem is not rare, it is the default	154
12.2	The naive version has a hole in it	155
12.3	The part I got wrong on the first pass	158

12.4	The audit log: write it once, never touch it again	158
12.5	Proving it, not hoping it	160
12.6	My AI companion this week	161
12.7	Where this leaves us	161
13	Week 6 Interview Q&A	163
13.1	Idempotency design	163
13.2	Data integrity and the audit log	166
13.3	Concurrency and correctness	169
13.4	API and pagination	171
13.5	Trade-offs	172

VIII WEEK 7

174

14	Adding gRPC to a Go Ledger Service	175
14.1	Why both, instead of picking one	175
14.2	The contract comes first	177
14.3	Translating errors, not inventing them	178
14.4	Idempotency, the gRPC way	179
14.5	Proving it runs	179
14.6	My AI companion this week	180
14.7	Where this leaves us	181

15	Week 7 Interview Q&A	182
15.1	Architecture and the shared domain	182
15.2	Protobuf, buf, and codegen	184
15.3	Error handling and idempotency	186
15.4	Interceptors, lifecycle, and the tenant seam	187
15.5	Testing and trade-offs	189

IX WEEK 8

192

16	Distributed Tracing for a Go Service	193
16.1	What “one trace” actually looks like	193
16.2	Instrument the edges, then the mid- dle	195
16.3	The part I’m quietly proud of: what is <i>not</i> in that span	196
16.4	The two decisions I went back and forth on	196
16.5	The thing that makes logs and traces click together	197
16.6	One boring-on-purpose detail: don’t trace everything	198
16.7	Where this leaves the ledger	199

17	Week 8 Interview Q&A	200
17.1	Tracing architecture and propagation	200
17.2	The hybrid metrics decision (defend it)	202
17.3	Exporter selection and failure modes	204
17.4	Data integrity and what leaves the process	206
17.5	Logs and traces together	207
17.6	Shutdown and failure modes (hard follow-ups)	208

X WEEK 9

211

18	Testing a Payment Ledger End to End	212
18.1	Coverage is a liar (but a useful one)	213
18.2	Property tests, or how the ledger caught itself lying	214
18.3	Chaos: kill the database at the worst possible moment	215
18.4	Load: 500 requests a second, without cheating	218

18.5	The pyramid, and why each layer is load-bearing	219
18.6	My AI companion	220
18.7	Where this leaves the ledger	221
19	Week 9 Interview Q&A	222
19.1	Coverage strategy	222
19.2	Property-based testing	224
19.3	Chaos testing (the hard part)	227
19.4	Load testing	230
19.5	CI and trade-offs	231

XI WEEK 10

234

20	The Server Lived in My Head. This Week I Wrote It Down.	235
20.1	The Docker part, quickly	236
20.2	Why production is not a container	237
20.3	The Terraform I deleted before writing it	238
20.4	Turning the runbook into a playbook	238
20.5	The safeguard that a text file could never hold	239
20.6	Keeping the secrets out of a public repo	241

20.7	What this week was really about	241
21	Week 10 Interview Q&A	243
21.1	Docker and the image	243
21.2	The central decision: Docker is not production	245
21.3	Infrastructure-as-code with Ansible	246
21.4	The shared box	248
21.5	Data and durability	249
21.6	Testing and verification	251
21.7	Trade-offs	252

XII WEEK 11

254

22	Multi-Currency and FX in a Go Ledger	255
22.1	First, a one-paragraph refresher on what a ledger even is	256
22.2	What is a currency, to a ledger?	256
22.3	The punch: one transaction, two currencies	257
22.4	The trick banks actually use: a clearing account	258
22.5	Now, the exchange rate itself, slowly	259

22.6	The part that will get you fired if you get it wrong: never touch money with a float	260
22.7	The last decimal: how to round, and where the leftover goes	261
22.8	Writing the rate down, because a rate is a promise	262
22.9	What I deliberately did not build	263
22.10	The lesson I keep relearning	263
23	Week 11 Interview Q&A	265
23.1	The core modeling problem	265
23.2	The exchange rate	267
23.3	Integer-only conversion (the money-safety core)	269
23.4	Idempotency, rates, and durability	271
23.5	Testing and trade-offs	273

XIII WEEK 12

277

24	Nested Accounts in a Go Ledger	278
24.1	The rule it collides with	278
24.2	What a nesting looks like	279
24.3	Rolling up without storing anything	280

24.4	The database refuses to draw a circle	281
24.5	The subtle part: what has to sum to zero	282
24.6	Where it fits	283
25	Week 12 Interview Q&A	284
25.1	Domain and data model	284
25.2	Rollup computation	286
25.3	Data integrity	288
25.4	Reporting	290
25.5	Testing and trade-offs	291

XIV WEEK 13

295

26	Approval Workflows and an Outbox Event Stream in Go	296
26.1	The rule: big movements wait	296
26.2	Approve means replay, not resurrect	298
26.3	The two bugs that only showed up under a hard look	300
26.4	Eventing without Kafka	301
26.5	Where the money can and cannot go	303
26.6	My AI companion	304

27	Week 13 Interview Q&A	306
27.1	Domain and data model	306
27.2	Approval lifecycle and concurrency	308
27.3	The event stream and audit chain	312
27.4	Security, API, and testing	315

XV WEEK 14

318

28	I Built a Production Go Payment Ledger in 14 Weeks. Here's What I'd Do Differently.	319
28.1	The control that did nothing	319
28.2	The footgun I'm leaving in on purpose (and why that's a decision, not an accident)	322
28.3	Breaking my own rule about ADRs	323
28.4	The cloud I planned and never used	324
28.5	The week that actually hurt	324
28.6	The alerts nobody is watching	325
28.7	What I'd keep, exactly as it is	326
28.8	The honest close	327
29	Week 14 Interview Q&A	328
29.1	Webhook delivery and eventing	328

29.2	Security hardening	331
29.3	The retrospective: engineering judgment	333
29.4	Trade-offs and locked decisions (defend these)	335

XVI SPECIAL EDITION 1

338

30	I Audited My Own Payment Ledger Like It Held Real Money. The Front Door Was Wide Open.	339
30.1	The good news first	339
30.2	The bad news: the front door had no lock	340
30.3	Fix 1: a lock that does not lock out the demo	341
30.4	Fix 5: the tamper-evident audit log, and the trap it set	343
30.5	The trap: correctness that quietly costs throughput	344
30.6	What the other three fixes were	346
30.7	The lesson I keep relearning	346
31	Special Edition Q&A: Hardening a Payment Ledger for Real Money	348

31.1	The audit mindset	348
31.2	Authentication and tenant isolation	349
31.3	The demo constraint	351
31.4	Idempotency and input	352
31.5	The tamper-evident audit chain (and its cost)	353
31.6	Trade-offs and consequences	356

XVII SPECIAL EDITION 2

358

32	I Push to Main and Ninety Seconds Later It Is Live. Here Is Every Step in Between.	359
32.1	Two different journeys: a pull request vs a push to main	360
32.2	The checks, briefly	361
32.3	The deploy, step by step	361
32.4	The security details that are easy to skip	363
32.5	How to replicate this on your own server	364
32.6	Why so small on purpose	365
33	Special Edition Q&A: How the Deploy Pipeline Works	367

33.1	The shape of the pipeline	367
33.2	The deploy, step by step	369
33.3	Security	371
33.4	Trade-offs and replication	373

XVIII SPECIAL EDITION 3

377

34 I Audited My Own Ledger Like a Fintech Expert. It Failed. 378

34.1	What a white-label money core has to survive	379
34.2	Finding one: the ledger was turning 100 dollars into 15 dollars	380
34.3	Finding two: the audit chain forked the instant a second instance started	382
34.4	Finding three: you cannot delete a customer from an append-only ledger	384
34.5	The rest of the teardown	385
34.6	How I actually did it without breaking the thing	386
34.7	What I actually learned	387

35 Special Edition Q&A: Auditing and Hardening the Ledger to a White-Label Money Core 389

35.1	The audit mindset	389
35.2	The FX money bug	391
35.3	Multi-instance and the audit chain	392
35.4	Compliance and crypto-shredding ..	395
35.5	Isolation, durability, and the rest	396
35.6	Process and trade-offs	398

XIX SPECIAL EDITION 4

401

36	The Exchange Rate Was Hiding in an Environment Variable	402
36.1	The rate lived in a file	402
36.2	A worked example, so the words mean something	403
36.3	Making the markup optional	404
36.4	Then I tried to break it	406
36.5	What it looks like now	409
37	Special Edition Q&A: FX Rates and Markup as Live Admin Config	410
37.1	Design and motivation	410
37.2	Data model	412
37.3	Correctness	413
37.4	Append-only and history	415

37.5	Security and isolation	417
37.6	The audit	418
37.7	Trade-offs (defending locked decisions)	420

XX ARCHITECTURE DECISIONS

424

38 ADR-001: Why Double-Entry Accounting 425

38.1	Status	425
38.2	Context	425
38.3	Decision	426
38.4	Consequences	426
38.5	Alternatives considered	427

39 ADR-002: Money Representation 429

39.1	Status	429
39.2	Context	429
39.3	Decision	430
39.4	Consequences	430
39.5	Alternatives considered	431

40 ADR-003: Postgres Schema and Repository Layer 432

40.1	Status	432
40.2	Context	432

40.3	Decision	433
40.4	Consequences	434
40.5	Alternatives considered	435
41	ADR-004: Concurrency Control for Transaction Posting	437
41.1	Status	437
41.2	Context	437
41.3	Decision	438
41.4	Observability	439
41.5	Measured baselines	440
41.6	Consequences	441
41.7	Alternatives considered	442
42	ADR-005: Per-Account Currency Integrity	443
42.1	Status	443
42.2	Context	443
42.3	Decision	444
42.4	Consequences	444
42.5	Alternatives considered	445
43	ADR-006: REST API Design	447
43.1	Status	447
43.2	Context	447
43.3	Decision	447

43.4	Consequences	451
43.5	Alternatives considered	451
44	ADR-007: Idempotency Keys and the Im-	
	mutable Audit Log	453
44.1	Status	453
44.2	Context	453
44.3	Decision	454
44.4	Consequences	457
44.5	Alternatives considered	458
45	ADR-008: Covering Index for Account	
	History Reads	460
45.1	Status	460
45.2	Context	460
45.3	Decision	461
45.4	Consequences	462
45.5	Alternatives considered	463
46	ADR-009: gRPC Layer over the Shared	
	Domain	464
46.1	Status	464
46.2	Context	464
46.3	Decision	465
46.4	Consequences	468
46.5	Alternatives considered	469

47 ADR-010: Observability with Open-Telemetry	471
47.1 Status	471
47.2 Context	471
47.3 Decision	472
47.4 Consequences	476
47.5 Alternatives considered	477
48 ADR-011: Testing strategy: unit, property, integration, chaos, load	479
48.1 Status	479
48.2 Context	479
48.3 Decision	480
48.4 Consequences	486
48.5 Alternatives considered	487
49 ADR-012: API authentication, mandatory idempotency, input hardening, and a tamper-evident audit chain	489
49.1 Status	489
49.2 Context	489
49.3 Decision	490
49.4 Consequences	496
49.5 Alternatives considered	498

50	ADR-013: VPS infrastructure-as-code with Ansible, and Docker as a dev-only artifact	500
50.1	Status	500
50.2	Context	500
50.3	Decision	501
50.4	Consequences	504
51	ADR-014: Multi-currency accounts and FX conversion	506
51.1	Status	506
51.2	Context	506
51.3	Decision	507
51.4	Amendment (audit remediation, task 0.2, findings A1.1 and A8.3)	514
51.5	Consequences	515
51.6	Alternatives considered	516
51.7	Out of scope (v1)	517
52	ADR-015: Audit remediation, white-label hardening, durability, and scale	518
52.1	Status	518
52.2	Context	518
52.3	Decision	519
52.4	Consequences	525

52.5	Alternatives considered	526
52.6	Out of scope (even for this remediation)	527
53	ADR-016: Durability and disaster recovery (WAL archiving, offsite encrypted backups, PITR)	528
53.1	Context	528
53.2	Decision	529
53.3	Consequences	532
54	ADR-017: Multi-instance audit chain (transactional outbox + single chainer)	534
54.1	Context	534
54.2	Decision	535
54.3	Consequences	540
55	ADR-018: PII crypto-shredding (reconciling immutability with the right to erasure)	542
55.1	Context	542
55.2	Decision	543
55.3	Consequences	545
56	ADR-019: Operator console, public-demo admin, and one-command onboarding	547
56.1	Context	547

56.2	Decision	548
56.3	Consequences	551
57	ADR-020: FX rates and markup as live	
	admin config	553
57.1	Context	553
57.2	Decision	554
57.3	Consequences	557
57.4	Alternatives considered	558
57.5	Security note	558
57.6	Out of scope (v1)	559
58	ADR-021: Admin act-as-tenant for	
	cross-tenant operator access	560
58.1	Context	560
58.2	Decision	561
58.3	Consequences	563
58.4	Alternatives considered	564
58.5	Security note	565
58.6	Out of scope (v1)	565
59	ADR-022: USD-hub FX triangulation for	
	cross-currency pairs	566
59.1	Context	566
59.2	Decision	567
59.3	Consequences	569

59.4	Alternatives considered	569
59.5	Out of scope (v1)	570
60	ADR-023: Account hierarchy and rolled-up reporting	571
60.1	Context	571
60.2	Decision	572
60.3	API surface	574
60.4	Consequences	575
60.5	Alternatives considered	575
60.6	Out of scope (this week)	576
61	ADR-024: Demo seeder writes audit events and purges visitor tenants	577
61.1	Context	577
61.2	Decision	578
61.3	Consequences	579
61.4	Alternatives considered	580
61.5	Out of scope	581
62	ADR-025: Approval workflows and a lifecycle event stream	582
62.1	Context	582
62.2	Decision	583
62.3	Events	586
62.4	API surface	587

62.5	Consequences	587
62.6	Alternatives considered	588
62.7	Out of scope (this week)	589
63	ADR-026: Security and correctness	
	hardening from an external audit	590
63.1	Context	590
63.2	Decisions	591
63.3	Consequences	595
64	ADR-027: Webhooks	596
64.1	Context	596
64.2	Decisions	597
64.3	Consequences	600
	Glossary	601
	Further Reading	608

XXI BONUS ROUND: HARD MODE

612

65	The Interview That Never Ends	613
65.1	Go internals and the runtime	613
65.2	Cross-cutting interactions	629
65.3	System design and failure modes	642

About the Author	662
Support This Book	664
Index	665

Foreword

Every once in a while, you come across a technical book that is about much more than technology. This is one of those books.

Building a payment ledger isn't the kind of project that grabs headlines, but it is one of the most challenging and rewarding systems a software engineer can build. It demands correctness, careful thinking, and the discipline to make the right decisions even when the easy path is tempting.

What I appreciate most about this book is that Sohag doesn't just show you *how* to build a ledger. He explains *why* each decision was made, the trade-offs he considered, and the lessons he learned along the way. That's how real engineering is practiced, and more importantly, how it is learned.

After more than two decades of building software and teaching developers, I've learned that languages, frameworks, and tools will continue to evolve. What never goes out of style is the ability to think clearly, design reliable systems, and solve problems with sound engineering judgment.

Remember, great software isn't built by writing more code. It's built by making better decisions.

This book helps you develop exactly that mindset.

Whether you're learning Go or simply striving to become a better software engineer, I believe you'll find genuine value in these pages.

Congratulations to Sohag for creating a thoughtful, practical, and timeless resource. I hope this book challenges the way you think and inspires you to build software that is not only functional, but dependable.

Hasin Hayder

Founder, Learn With Hasin Hayder

CTO, HappyMonster

Who This Is For

This book is for the engineer who builds on top of money systems and wants to understand the part underneath. If you have ever called a payments API and moved on without thinking about what recorded the movement, this is written for you. It is also for anyone preparing for backend or systems interviews, because the questions that expose shallow understanding are the ones this book drills.

What you should already know. You are comfortable in some back-end language and you have written a little SQL. That is enough. The code is Go, but Go is not a prerequisite for following the reasoning; the ideas are the point, and they carry to any language. Where a Go detail matters, it is explained.

What you will be able to do after. You will be able to explain double-entry accounting and why a balance is derived from history rather than stored. You will be able to defend the hard choices out loud: why `SERIALIZABLE` and how to survive its retries, why idempotency is mandatory on a money-moving endpoint, why the audit log is a tamper-evident chain and not just an append-only table. And you will be able to reason about taking a service like this to production: a real deploy, real observability, and a front door that is actually locked.

This is a build log, not a textbook. Read it the way you would talk through a system with someone who just built it and can defend every line.

A Note Before You Begin

A while back a friend paid for dinner before the rest of us could reach for our phones. On the walk home I opened a payment app, sent him my share, and watched my balance drop before I reached the bus stop. Somewhere a system had just moved money between two accounts, atomically, in a way that both of us, the company, and some future auditor could trust completely. I have spent most of my career building on top of systems like that. Using a ledger taught me to operate one. It never taught me to defend one. The gap between those two is this book.

I am Sohag Hasan. For the better part of a decade I have shipped software for fintech and payments teams, most recently as a tech lead, on things like cross-border money transfers and integrations with banks. My day to day has mostly been PHP and Laravel. But the ledger, the part that actually decides whether money is real, was always someone else's library or someone else's table. I wanted to build that part myself, and I wanted to do it in Go. I needed concurrency I could trust: thousands of postings racing on a single account, a race detector that made the failure real, tests that actually caught it. Go fought me on the sharp edges of shared state, which was exactly the lesson I came for.

So I built it in the open, one week at a time. No single week was the hard one. Each had a wall I did not see coming, and understanding arrived slowly, until one day the whole system fit in my head and I could defend any piece of it. That is the bar I was after.

Every week I shipped a piece of the ledger, wrote a post explaining the decisions, and then sat myself down with a list of hard interview questions about what I had just built. I have spent years on both sides of the interview table, and the questions that expose shallow understanding are the same ones I now ask myself. More than once, a question I could not answer sent me straight back to the code. The posts are the story. The questions are the stress test. Reviewing my own work this way changed how I review everyone else's: the bar is no longer "does it pass" but "can you defend it", with the rejected alternatives written down.

I wrote this for the engineer who reaches for a payments API and never thinks about what is underneath, the way I once didn't. If you take one idea from these pages, take this: your balance is not a number someone saved. It is the sum of every posting that ever touched your account. The history is the truth, and everything else is a cache.

Everything here is real. Every line of code, every schema, every trade-off lives in the open at github.com/sohag-pro/go-ledger, running, tested, and deployed. I have been writing and building in public for years, at notes.sohag.pro, from Dhaka, Bangladesh. This book is part of that habit, not a departure from it. If any of this sounds familiar, you are in the right place.

How to Read This Book

The book is organized the way it was built: one week at a time. Each week has two chapters.

The first chapter of each week is the essay. It tells the story of what I built that week and, more importantly, why: the decisions, the trade-offs, the things I deliberately left out. Read it the way you would read a build log from someone sitting next to you.

The second chapter is the interview. It is a set of questions a senior engineer would face if this project were on their resume, each with the key points a strong answer covers. Use it two ways: to check whether the essay actually landed, and to rehearse defending the design out loud. If you are preparing for backend or systems interviews, this is the part to drill.

After the numbered weeks come three special editions, bonus essays (each with its own interview chapter) written between the weeks: one on hardening the ledger for real money, one on how the deploy pipeline works, and one on auditing and hardening the ledger into a white-label money core. They sit outside the weekly count but earn their place.

At the back you will find the Architecture Decision Records. These are the formal, dated decisions made during the build, kept in the repository and reproduced here. When a chapter says “see ADR-003”, this is where it points. They are terse on purpose.

A few conventions. Code, identifiers, and file paths are set in a

monospaced font. Everything in these pages is real and lives in the open at github.com/sohag-pro/go-ledger. You can read the source, run it, or follow the live service at go.sohag.pro.

You can read this front to back, or jump to the week that solves the problem you have in front of you right now. Both work.

≡ go-ledger

WEEK 0

01 The Build Plan

CHAPTER 1

The Build Plan

Before I wrote a single line of this ledger, I wrote the whole plan down. Not a vague intention, not a mental note, but a real document: fourteen weeks, four phases, a checklist for every week, a list of what I would deliberately refuse to build, and a table of the risks most likely to eat my time. It is the first artifact of this project, older than the first commit, and it is the reason the project shipped instead of dying quietly around week five like most side projects do.

This chapter is that plan. It is Week 0 because the plan came before Week 1, and because a good plan is really just index zero: the thing everything else is offset from. I have tidied it and told you where reality diverged from it, but the shape is the shape I started with.

1.1 Why plan at all for a solo project

Most side projects die for one of two reasons. They are too ambitious to finish, or too trivial to matter. A plan is how you steer between those. It is not there to predict the future; it is there to bound it. When I wrote “fourteen weeks, one topic each,” I was not promising myself it would take exactly fourteen weeks. I was promising that I would not let week four’s concurrency work quietly expand until it swallowed the whole autumn.

A written plan does two useful things. It turns a big scary “build a payment ledger” into fourteen small, checkable weeks, each with a definition of done you can actually hit on a Saturday. And it gives you something to say no against. Every tempting tangent (and a payment ledger has many: Kafka, event sourcing, a fancy admin UI) gets held up against the plan and, most of the time, sent to a “maybe later” list. The plan is the thing that lets you say “not this, not yet” without feeling like you are giving up.

1.2 The bet

The goal, stated once so I could measure everything against it: ship a production-grade payment ledger in Go, fully open source, actually deployed and running, with a blog post every week explaining the week’s work. At the end there should be a live demo, a public repo anyone can clone and run, and a body of writing that shows not just the code but the reasoning behind it.

A payment ledger is a good bet for this because correctness is not optional. A bug in a CRUD app shows a stale page; a bug in a ledger creates or destroys money. The whole thing is built on one old, unglamorous idea: double-entry bookkeeping. Every transaction is two or more postings that must sum to zero. Money never appears or vanishes, it only moves, and a balance is not a number someone stored, it is the sum of every posting that ever touched an account. That single invariant is what makes the project worth doing carefully, and it is the thread that runs through all fourteen weeks.

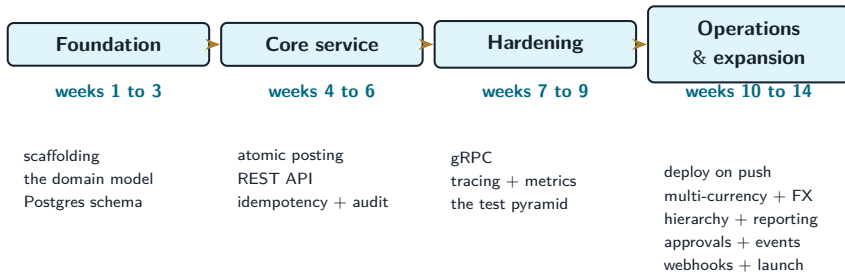
1.3 The decisions I locked and refused to relitigate

The fastest way to turn fourteen weeks into thirty is to re-argue your tools every week. So I picked the stack once, up front, and wrote down that I would not reopen these:

- **Router:** chi. Idiomatic, minimal, no magic.
- **Database:** Postgres, with pgx and sqlc for type-safe queries and goose for migrations.
- **API:** REST first, gRPC later, both calling the same domain services. Protos managed with buf.
- **Testing:** the standard library plus testcontainers-go for real-Postgres integration tests, k6 for load, and property-based tests for the balance invariant.
- **Observability:** OpenTelemetry traces, slog for structured logs, Prometheus for metrics.
- **Deployment:** a single VPS, with Docker and systemd, Postgres on the same box, shipped by GitHub Actions on every push to main.

That last one is where the plan and reality parted ways, and I want to be honest about it. The original plan said AWS ECS Fargate, RDS, and Terraform. When I got to the deployment week I looked hard at that and changed my mind: for a portfolio-scale demo that resets every few hours, a well-run VPS with a codified deploy pipeline is simpler, cheaper, and teaches the same operational discipline without the cloud-console tax. The decision record for that change is written down like every other. Locking decisions up front does not mean never changing one; it means changing it deliberately, once, with a reason, instead of drifting.

1.4 Four phases across fourteen weeks



Phase 1, Foundation (weeks 1 to 3). Get the skeleton and the truth in place. Week 1 was scaffolding: the repo, the module layout, the Makefile and lint config, a health check that returns 200, and the first architecture decision record explaining why double-entry at all. Week 2 was the domain model in Go's type system, the part I most wanted to get right: types where an unbalanced transaction is hard to even express, and a `validate` that fails fast the moment postings do not sum to zero, backed by property tests that throw hundreds of random transactions at the invariant. Week 3 put it in Postgres: an append-only schema, goose migrations, a repository layer, and the first integration test running the full happy path against a real database in a container.

Phase 2, Core service (weeks 4 to 6). Make it move money correctly. Week 4 was the hard one, and I knew it going in: atomic posting under concurrency, `SERIALIZABLE` isolation, a database `CHECK` constraint enforcing the zero-sum invariant so no code path can bypass it, and a stress test with thousands of goroutines racing on the same accounts to prove the ledger never goes wrong. Week 5 wrapped it in a REST API with real validation and RFC 7807 error responses. Week 6 added

the two patterns that make a payment API boring in the best way: idempotency keys, so a retried request never posts twice, and an immutable audit log written in the same transaction as the postings.

Phase 3, Production hardening (weeks 7 to 9). Make it observable and trustworthy. Week 7 added a gRPC surface that shares the exact same domain services as REST, so there is one place money moves, not two. Week 8 was OpenTelemetry: one trace from the HTTP handler down to the SQL query, logs correlated by trace id, Prometheus metrics. Week 9 was the testing pyramid taken seriously: coverage brought up, property-based tests, a k6 load test, and a chaos test that kills Postgres mid-transaction to prove rollback and idempotent-retry actually hold.

Phase 4, Operations and feature expansion (weeks 10 to 14). Ship it, then deepen it. Week 10 was Docker and the deploy: a tiny distroless image and a pipeline that migrates ahead of the swap, health-checks, and rolls back on failure, so a push to main lands in production. With the service live, weeks 11 to 14 stopped standing up infrastructure and started expanding what the ledger can model: multi-currency and FX conversion with the invariant now enforced per currency, nested accounts with rolled-up balances and reporting, approval workflows for over-threshold transactions plus an in-database outbox event stream, and finally webhooks and the public launch.

1.5 What is deliberately out

Scope discipline is the difference between shipping and abandoning, so the plan was as explicit about what I would not build as about what I would. The expansion weeks pulled a lot in on purpose: multi-

currency and FX, reporting and analytics endpoints, account hierarchy, approval workflows, an outbox event stream, and webhooks all made it into v1.

But some things stayed out, each one tempting, each one a month I did not have:

- A product web UI or admin dashboard. The one exception is a thin operator console that only calls the public API and holds no logic of its own.
- Multi-region or cross-region replication.
- Kafka or any external event-streaming broker. The in-database outbox covers eventing without a second system to run.
- Event sourcing and CQRS.

Every one of those is a legitimate thing to build. None of them belongs in a fourteen-week v1, and writing them down as explicitly out of scope is what kept them out when they got tempting around week eleven.

1.6 The risks I wrote down, and roughly how they went

A plan that does not name its risks is optimism, not planning. I wrote down the ones most likely to hurt, and they were the right ones. Week four's concurrency work was flagged as the most likely to eat double its estimate, and it was the week I was most careful with, which is exactly why it did not blow up. Week eight's OpenTelemetry setup was flagged as a configuration rabbit hole, with a rule to time-box it

and ship logs-only if tracing fought back. And the ever-present risk, the one every interesting project carries, was the tangent: the pull toward Kafka, toward event sourcing, toward one more clever thing. The mitigation was the same every time, and it worked: re-read the scope section, write the idea on the “maybe later” list, and move on.

1.7 Why this is Week 0

I am putting the plan in the book, at the front, because the plan is part of the work. Anyone can show you finished code. What is harder to show, and more useful to see, is the thinking that came before it: the bets, the boundaries, the decisions made once and defended. The chapters that follow are the weeks as they actually happened, with the interview questions each week would put you through. This chapter is the map they were all drawn against.

The plan held, roughly. The deployment target changed. A few decision records ended up with different numbers than I first guessed. The scope grew in weeks eleven to fourteen in ways I only half-anticipated. But the shape held, the invariant never broke, and fourteen weeks later there is a real ledger, live and open, that I can explain every line of. That is what a plan is for.

≡ go-ledger

WEEK 1

01 Why I'm Building a Production Go Payment Ledger

02 Week 1 Interview Q&A

CHAPTER 2

Why I'm Building a Production Go Payment Ledger

Last night I had dinner with two friends, and one of them paid the whole bill, 1,800 taka, before the rest of us could reach for our phones. So on the way home I opened my payment app, typed 600 taka, and sent him my share. My balance dropped before I reached the bus stop. Then I stopped and thought about what just happened. Somewhere, a system recorded that money left my account and entered his, atomically, in milliseconds, in a way that both of us, the payment company, and possibly an auditor three years from now can trust completely.

That system is called a ledger, and I'm going to build one. In public, open source, over fourteen weeks, with a blog post every week. This is post 1 of 14.

2.1 Why a ledger, of all things?

Most side projects die for one of two reasons: they're too ambitious to finish, or too trivial to matter. A todo app teaches you nothing new. A "build your own database" project takes two years and ships never.

A payment ledger sits in the sweet spot. It's small enough to build in fourteen weeks, and deep enough that doing it *right* forces you

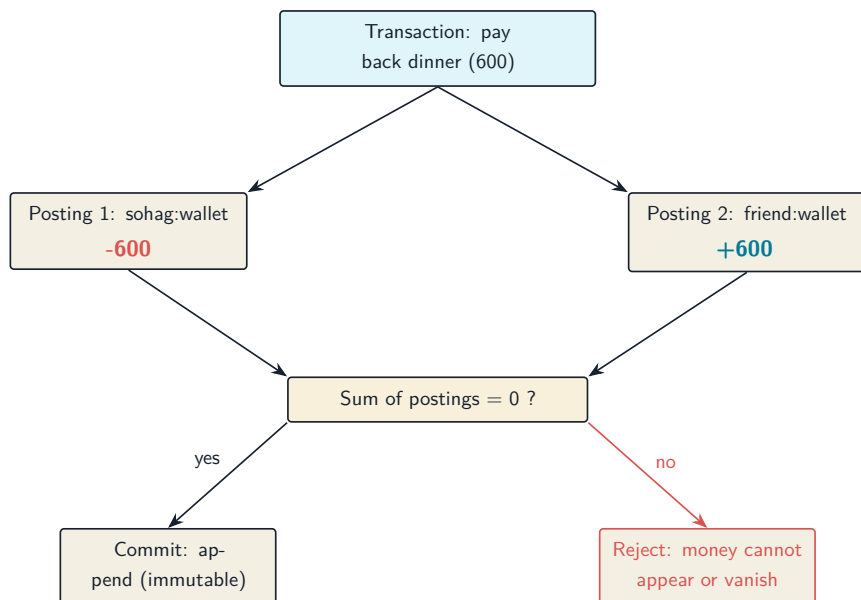
through almost everything that makes backend engineering hard: data integrity, concurrency, idempotency, observability, and deployment.

Every fintech company has a ledger at its core, and most are built on an idea older than the printing press: **double-entry bookkeeping**. The rule is simple. Money never appears or disappears. It only *moves*. Every transaction is recorded as two or more postings that must sum to zero. Your balance isn't a number someone updated; it's the sum of every posting that ever touched your account. The history *is* the state.

Back to my dinner. Here's what paying my friend back his 600 taka looks like as a double-entry transaction:

Posting	Account	Amount
1	sohag:wallet	-600
2	friend:wallet	+600
Sum		0

Two postings, summing to zero. If a bug ever produces a transaction where the sum isn't zero, money was created or destroyed out of thin air, and the system must reject it before it persists:



That one constraint is why this project is interesting to build:

- **Correctness is non-negotiable.** A bug in a CRUD app shows a stale page. A bug in a ledger creates or destroys money. The invariant must hold under any failure, any concurrency, any retry.
- **The hard problems are real ones.** What happens when two requests post to the same account simultaneously? When a client retries a payment because the network dropped the response? When the database dies mid-transaction? These aren't interview puzzles; they're Tuesday.
- **It's bounded.** The domain fits in your head. Accounts, transactions, postings, balances. No ML, no infinite feature surface. The depth is vertical, not horizontal.

2.2 Why Go?

I want a language where the production story is boring. Go gives me a single static binary, a stellar standard library (`net/http`, `log/slog`, `database/sql` and friends), first-class concurrency for the stress tests I have planned, and an ecosystem where the “right” choice for most infrastructure questions is well-trodden.

The stack is locked upfront, because relitigating decisions mid-project is how fourteen weeks becomes thirty:

- **Router:** `chi` (idiomatic, minimal)
- **Database:** Postgres with `pgx` + `sqlc` for type-safe queries, `goose` for migrations
- **API:** REST first, gRPC later (with `buf` for proto management)
- **Testing:** standard library + `testcontainers-go`, `k6` for load, property-based tests for the balance invariant
- **Observability:** OpenTelemetry traces, `slog` structured logs, Prometheus metrics
- **Deployment:** Docker image, deployed to a VPS via GitHub Actions CI/CD

No Kubernetes, no Kafka, no event sourcing, no multi-currency. Not because they're bad, but because scope discipline is the difference between shipping and abandoning. Single currency, one region, no admin UI. Everything cut from v1 becomes a follow-up post if the project earns it.

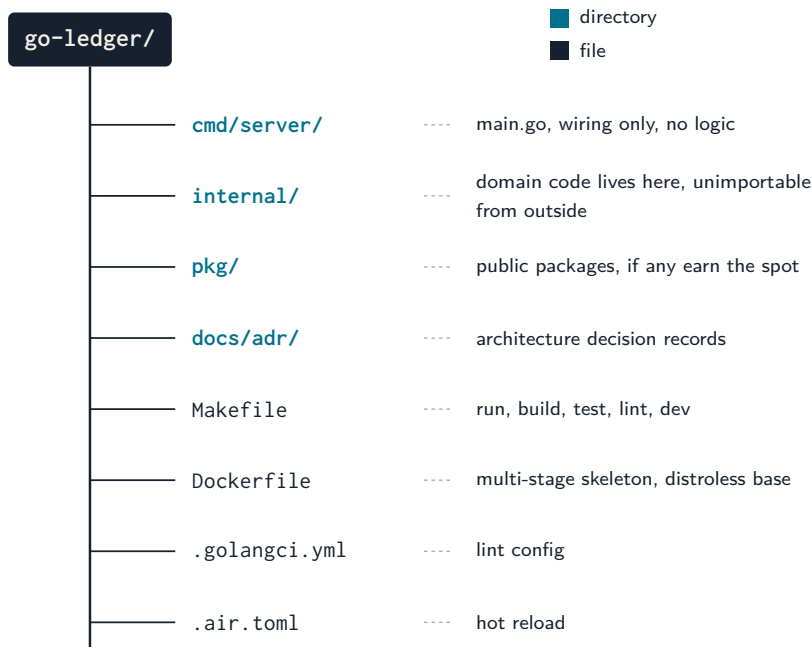
2.3 The 14-week plan

1. **Scaffolding**: repo, module layout, tooling, hello ledger (*this post*)
2. **Domain model**: double-entry accounting in Go types; invariants the compiler helps enforce
3. **Postgres schema + repository layer**: append-only postings, integration tests against real Postgres
4. **Transaction posting service**: atomicity, `SERIALIZABLE` isolation, correctness under 10,000 concurrent posts
5. **REST API**: chi, validation, RFC 7807 errors, OpenAPI
6. **Idempotency keys + immutable audit log**: the two patterns that make fintech APIs boring (in a good way)
7. **gRPC layer**: shared domain services behind both protocols
8. **OpenTelemetry**: one trace from HTTP handler to SQL query
9. **Testing**: unit, integration, property-based, load, and a little chaos
10. **Docker + deploy**: multi-stage builds, distroless, live to production
11. **Multi-currency + FX**: per-currency invariant, env-configured rates
12. **Nested accounts + reporting**: rolled-up balances, trial balance
13. **Approvals + event stream**: threshold gate, outbox events
14. **Webhooks + launch**: signed delivery, retrospective

2.4 Week 1: the unglamorous part

This week was scaffolding, deliberately light. The goal: anyone can clone the repo, run `make run`, and hit a health check.

The layout follows the standard Go convention:



The server itself is about seventy lines of standard library: an `http.ServeMux` (the 1.22+ pattern-matching routes mean I don't even need `chi` yet), `slog` JSON logging from day one, and graceful shutdown on `SIGTERM`, because writing it now is free and bolting it on later never happens.

```
1 $ curl localhost:8080/healthz
2 {"status": "ok"}
```

Not impressive. But it builds clean, lints clean (`golangci-lint` with `gosec` and friends enabled from commit one), and ships with the project's first architecture decision record: **ADR-001, why double-entry**. Writing ADRs for a solo project feels ceremonial until you're in week 9 trying to remember why you rejected event sourcing. Future me

will thank present me.

2.5 My AI companion

Full transparency: I'm not building this alone. I have an AI pair, **Claude**, running in my terminal via Claude Code.

This week it handled the unglamorous parts: installed the Go toolchain, scaffolded the project layout, wrote the Makefile and lint config, drafted the first ADR, and caught its own lint failures before I saw them. That's the deal I've settled on: Claude accelerates the mechanical work, and I own every decision that matters. The architecture, the invariants, the trade-offs in the ADRs, and the understanding stay mine. A ledger where I can't explain *why* every line exists would defeat the entire point of this project.

I'll be honest about the split as the series goes. When Claude writes something substantial, I'll say so. When I overrule it, that's probably worth a paragraph too; those disagreements tend to be where the interesting engineering lives. If you're curious how an AI-assisted workflow holds up across a fourteen-week production build, that's now a quiet subplot of this series.

2.6 Why you should build one too

Because “I read about idempotency keys” and “I watched 100 goroutines try to corrupt my ledger and fail” are different kinds of knowl-

edge. The second kind is what production engineering actually is, and you can't get it from blog posts, including this one. You get it by building the thing, breaking it, and fixing it.

The repo is open source at **github.com/sohag-pro/go-ledger**. Follow along, steal the plan, or build your own. Next week: modeling double-entry accounting in Go's type system, and making the balance invariant impossible to violate.

CHAPTER 3

Week 1 Interview Q&A

Practice set for defending go-ledger in a senior engineering interview. Everything here is answerable from this week's actual deliverables: `cmd/server/main.go`, the project layout, the Makefile, the Dockerfile, `.golangci.yml`, and `docs/adr/001-why-double-entry.md`.

3.1 Theme 1: Domain design

3.1.1 1. Warm-up: Walk me through why you chose double-entry accounting for this ledger instead of a simple balances table.

What a strong answer covers:

- A mutable balance row tells you what the balance is, never how it got there; the audit trail and the state drift apart.
- Double-entry makes every transaction a set of postings that must sum to zero, so money structurally cannot appear or vanish.
- Balances become derived values (sum of postings), so the history is the source of truth.
- ADR-001 records this reasoning, including the rejected alternatives.

3.1.2 2. Your ADR says postings are append-only and balances are never stored as mutable primary state. What does that buy you, concretely?

What a strong answer covers:

- Append-only writes sidestep read-modify-write races on a balance row entirely.
- Every balance is explainable: it is an aggregation over immutable facts.
- A corrupted cache can be rebuilt from postings; the reverse is not true.
- The trade-off is that reads become aggregations, accepted in ADR-001 with a rebuildable cache as the escape hatch.

3.1.3 3. Challenge a locked decision: Double-entry is centuries old and adds friction. Clients now have to submit balanced postings instead of “add 600 to account X”. Why is that complexity worth it for a v1?

What a strong answer covers:

- The friction is the feature: an unbalanced request is a bug surfaced at the API boundary instead of corrupted money discovered months later.
- “Add 600 to X” has no answer to “from where?”, which is exactly the question auditors and reconciliation ask.
- The domain is fintech; correctness is the product. A todo app can take the simpler model.

- The model matches what payment partners and accountants already expect, reducing integration friction later.

3.1.4 4. Hard follow-up: ADR-001 claims append-only postings reduce concurrency control to “serializing transaction inserts”. Two requests race to post against the same account at the same moment. What can still go wrong, and what is your plan?

What a strong answer covers:

- Inserts of postings themselves do not conflict, but any read-then-decide logic does (e.g. “reject if balance would go negative” reads a balance that another in-flight transaction is changing).
- This is a write skew shaped problem; append-only does not make it disappear.
- The plan (Week 4) is a DB transaction at `SERIALIZABLE` isolation plus row locks on involved accounts, with the invariant also enforced by a Postgres `CHECK` constraint as a backstop.
- Knowing the failure mode before writing the code is why the ADR and plan exist.

3.2 Theme 2: Project structure and scaffolding

3.2.1 5. Warm-up: Explain your repo layout. Why `cmd/server/`, `internal/`, and `pkg/`?

What a strong answer covers:

- `cmd/server/main.go` is wiring only: config, server start, shutdown. No business logic, so the entry point stays trivially readable.
- `internal/` is compiler-enforced privacy; no external module can import the domain code, which keeps the public API surface deliberate.
- `pkg/` exists but is empty; packages must earn public status, not default to it.
- This mirrors the standard Go project convention, so any Go developer can navigate it immediately.

3.2.2 6. Why did you write an ADR for a solo side project? Who is it for?

What a strong answer covers:

- Future self in week 9, deciding whether to relitigate event sourcing, reads why it was rejected in week 1.
- Interviews and open source contributors get the reasoning, not just the result.
- ADRs force the alternatives to be written down at decision time, when the trade-offs are freshest.
- Cheap to write now, expensive to reconstruct later.

3.2.3 7. You wrote graceful shutdown handling in `main.go` in week 1, before there is any real traffic. Premature?

What a strong answer covers:

- The shutdown path (`signal.NotifyContext` on `SIGINT/SIGTERM`, `srv.Shutdown` with a 10s timeout) is about 15 lines now and free to write.
- Retrofitting it later competes with feature work and never happens; meanwhile every deploy hard-kills in-flight requests.
- For a ledger specifically, killing a request mid-transaction is the exact class of bug the project exists to prevent.
- It also makes the service well-behaved under Docker and CI from the first deploy, since both deliver `SIGTERM`.

3.3 Theme 3: HTTP server decisions

3.3.1 8. The stack locks in `chi` as the router, but `main.go` uses the standard library `http.ServeMux`. Contradiction?

What a strong answer covers:

- Go 1.22+ `ServeMux` supports method-prefixed patterns (`GET /healthz`), enough for two routes.
- `chi` earns its place when the middleware chain arrives (logging, recovery, request ID) in Week 5.

- Adding a dependency before its value exists is scope creep at the dependency level.
- The handlers will not change when chi lands; only the wiring in `main.go` does.

3.3.2 9. Challenge a locked decision: Why chi at all then? The 1.22 ServeMux handles routing, and you clearly know it. Defend the dependency.

What a strong answer covers:

- chi adds composable middleware, route groups, and URL param handling that ServeMux still lacks, all on stdlib types (`http.Handler` everywhere).
- Because chi is stdlib-compatible, the exit cost is near zero; handlers never know chi exists.
- The alternative is hand-rolling middleware chaining and mounting, which is rebuilding chi badly.
- Locked decisions exist to prevent mid-project relitigating; the ADR-style reasoning happened once, upfront.

3.3.3 10. Why does your `http.Server` set `ReadHeaderTimeout`, and what would happen without it?

What a strong answer covers:

- Without it, a client can open a connection and trickle header bytes forever (slowloris), pinning server resources.

- gosec flags the omission; the lint config enforces it from commit one.
- 5 seconds bounds the attack window without affecting legitimate clients.
- Related timeouts (read, write, idle) will matter once real handlers exist; this is the minimum safe default for a health-check server.

3.3.4 11. Hard follow-up: Your server goroutine sends errors into a channel, and main selects on that channel and a signal context. Why this shape instead of just calling `ListenAndServe` and handling the error?

What a strong answer covers:

- `ListenAndServe` blocks, so it must run in a goroutine if main also waits on signals.
- The buffered error channel (size 1) lets the goroutine exit even if main has already moved on, avoiding a goroutine leak.
- The select races startup failure (port in use) against shutdown signal; both paths produce a clean exit with the error logged.
- `http.ErrServerClosed` is filtered because it is the expected result of Shutdown, not a failure.

3.4 Theme 4: Tooling and build

3.4.1 12. Your Makefile builds with `CGO_ENABLED=0` and tests with `-race`. Those flags look contradictory. Explain.

What a strong answer covers:

- `CGO_ENABLED=0` for builds produces a fully static binary, which is what lets the Dockerfile use a distroless static base image.
- The race detector requires `cgo`, so `make test` simply does not set the variable; build and test have different goals.
- Race detection from day one is cheap insurance for a project whose week 4 milestone is 10,000 concurrent posts.
- Knowing why each flag exists beats cargo-culting a Makefile.

3.4.2 13. Why distroless for the final Docker image instead of alpine or scratch?

What a strong answer covers:

- Distroless static ships CA certificates, `tzdata`, and a nonroot user, which scratch lacks and the app will need (TLS to Postgres, HTTPS egress).
- No shell and no package manager shrinks the attack surface compared to alpine.
- The nonroot tag means the container does not run as root by default.
- Image size target (<20MB) supports fast pulls and deploys in the Week 11 CI/CD pipeline.

3.4.3 14. Your lint config enables `gofumpt`, `gosec`, `revive`, and `friends` from the first commit. Why front-load lint strictness instead of adding it when the codebase grows?

What a strong answer covers:

- Lint debt compounds; enabling `gosec` on 10,000 existing lines produces a wall of findings nobody fixes.
- It already paid off in week 1: `errcheck` caught unchecked `Fprint` returns and `revive` demanded the package comment.
- Style arguments (`gofumpt`) are settled by the tool, not by future code review back-and-forth.
- CI (Week 9) will reuse the exact same config, so local clean means CI clean.

3.5 Theme 5: Trade-offs and scope

3.5.1 15. Hard follow-up: Your v1 cuts multi-currency, and ADR-001 punts money representation to ADR-002. An interviewer pushes: “You are building a ledger and have not decided how to represent money. Is that not the first decision?”

What a strong answer covers:

- The balance invariant (postings sum to zero) is representation-independent; it holds for int64 cents and for decimals alike, so the

domain model is not blocked.

- Deferring with a written deadline (ADR-002, Week 2) is different from not deciding; the decision lands before the first `Money` type is written.
- Single currency in v1 removes the hardest representation pressure (FX, mixed-currency transactions) deliberately, recorded in the scope discipline list.
- Sequencing decisions to land exactly when code needs them is the discipline that keeps a 14-week plan at 14 weeks.

≡ go-ledger

WEEK 2

01 Modeling Double-Entry Accounting in Go

02 Week 2 Interview Q&A

CHAPTER 4

Modeling Double-Entry Accounting in Go

A few years ago I shipped a bug that moved money and forgot to take it from anywhere. The code added a credit to one account and, because of a botched early return, never wrote the matching debit. Nothing crashed. No test failed. The balance just quietly grew, like a bathtub with the drain unplugged, until someone in finance noticed the numbers didn't tie out and the hunt began.

That bug is the reason this week exists. Last week I explained *why* I'm building a payment ledger and got a "hello ledger" health check responding. This week is the part that would have caught that bug at compile time, or close to it: the domain model. No database yet, no HTTP. Just Go types and the one rule they exist to protect. This is post 2 of 14.

4.1 The one rule

Double-entry accounting has a single invariant that everything else hangs off:

Every transaction is two or more postings, and those postings must sum to zero.

Money never appears or vanishes. It moves. If I pay a friend back

600 taka, one account goes down by 600 and another goes up by 600, and the two cancel out. The sum is zero. If the sum is ever anything but zero, money was created or destroyed, and that transaction is a bug wearing a transaction's clothes.

My whole goal for the week: make a transaction that doesn't balance hard to even build, and impossible to validate. If the type system and one small method stand guard, the bathtub bug from my past can't happen here.

4.2 First decision: how do you even store money?

Before modeling a transaction I had to answer a deceptively boring question: what *is* an amount? This got its own architecture decision record (ADR-002), because getting it wrong is expensive and quiet.

The wrong answer is `float64`. Floating point can't represent most decimal fractions exactly. In Go, `0.1 + 0.2` is `0.30000000000000004`. That rounding error is invisible on one transaction and catastrophic across a million of them. Money and floats do not mix.

The answer I picked: store every amount as a signed `int64` count of the currency's smallest unit. For US dollars that's cents. So \$10.50 is the integer `1050`. Exact, fast, no allocation, and it maps straight onto a Postgres `BIGINT` when the database arrives next week. The tradeoff is that I have to guard against overflow myself, which turns out to be a few lines.

Here's the type. The fields are unexported so a `Money` can only be built through a constructor that validates the currency:

```
1 type Money struct {
2     amount    int64    // signed minor units: cents for USD
3     currency  Currency
4 }
5
6 func NewMoney(amount int64, currency Currency) (Money, error) {
7     if err := currency.Validate(); err != nil {
8         return Money{}, err
9     }
10    return Money{amount: amount, currency: currency}, nil
11 }
```

The interesting part is arithmetic. Adding two amounts can overflow `int64`, and an overflow that silently wraps a balance from a huge positive to a huge negative is exactly the kind of horror this project is meant to avoid. So `Add` checks and returns an error instead of wrapping:

```
1 func (m Money) Add(other Money) (Money, error) {
2     if m.currency != other.currency {
3         return Money{}, ErrCurrencyMismatch
4     }
5     sum := m.amount + other.amount
6     // Overflow happened if both operands share a sign but the result
7     // flipped.
8     if (m.amount > 0 && other.amount > 0 && sum < 0) ||
9        (m.amount < 0 && other.amount < 0 && sum > 0) {
10        return Money{}, ErrOverflow
11    }
12    return Money{amount: sum, currency: m.currency}, nil
13 }
```

Two things fall out of this for free. Different currencies can't be added, so a multi-currency mistake (a thing explicitly out of scope for v1)

can't silently corrupt a sum. And overflow is a typed error you can test, not undefined behavior you discover in production.

4.3 Modeling the transaction

A **posting** is a single signed entry against one account. The sign carries the direction: a positive amount is a debit, a negative amount is a credit. One field, not two, because the sign already tells you everything.

```
1 type Posting struct {  
2     AccountID string  
3     Amount    Money  
4 }  
5  
6 type Transaction struct {  
7     ID        string  
8     Postings []Posting  
9 }
```

Back to paying my friend 600 taka. As postings:

Posting	Account	Amount
1	sohag:wallet	-600
2	friend:wallet	+600
Sum		0

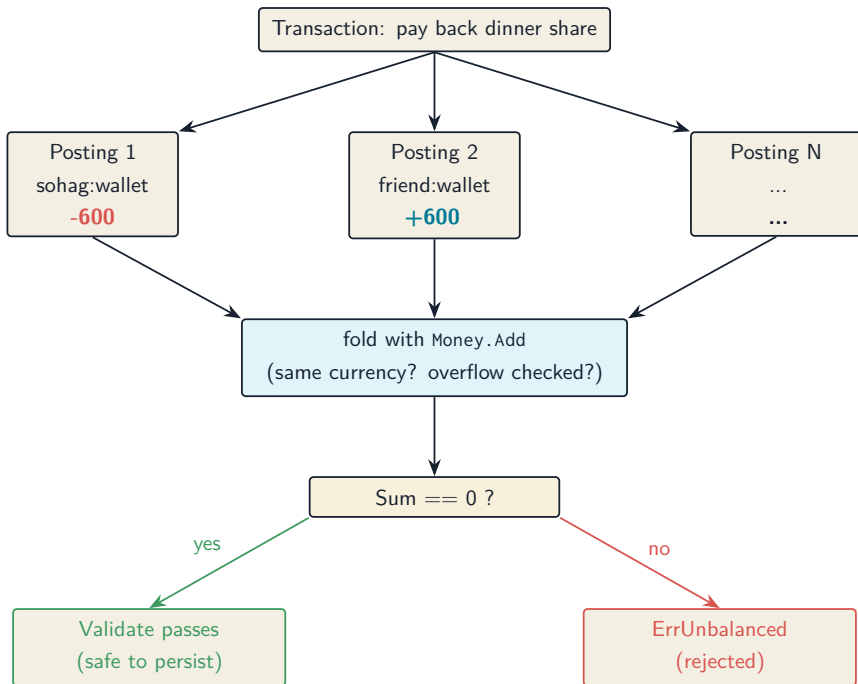
Now the chokepoint. `Transaction.Validate()` is the single place in the domain where the invariant lives. It needs at least two postings, every

posting has to name an account, every leg has to be the same currency, and the signed amounts have to sum to exactly zero:

```
1 func (t Transaction) Validate() error {
2     if len(t.Postings) < 2 {
3         return ErrTooFewPostings
4     }
5     for _, p := range t.Postings {
6         if err := p.Validate(); err != nil {
7             return err
8         }
9     }
10    sum := t.Postings[0].Amount
11    for _, p := range t.Postings[1:] {
12        next, err := sum.Add(p.Amount) // surfaces currency mismatch and
                                        overflow
13        if err != nil {
14            return err
15        }
16        sum = next
17    }
18    if !sum.IsZero() {
19        return ErrUnbalanced
20    }
21    return nil
22 }
```

Notice how the currency check and the overflow check come for free. I don't write them in `Validate` at all. They happen because the running sum is built with `Money.Add`, and `Add` already refuses to mix currencies or wrap. The small type did the work so the big method didn't have to.

Here's the same flow as a picture:



Every arrow that could go wrong has a named error waiting for it: `ErrTooFewPostings`, `ErrInvalidPosting`, `ErrCurrencyMismatch`, `ErrOverflow`, `ErrUnbalanced`. When something fails, the caller knows exactly which rule it broke.

4.4 Proving it holds, hundreds of times

Table-driven unit tests cover the cases I can think of: a balanced two-leg transaction, a balanced three-leg one, an unbalanced one, a single posting, a currency mismatch, an empty account ID. Good, but those are the cases *I* imagined. The bug from my past was one I

hadn't imagined. So the balance invariant gets a second kind of test.

Property-based testing flips the script. Instead of asserting “this specific input gives this specific output,” you assert a property that must hold for *all* inputs, then let the library throw hundreds of randomized cases at it and try to find one that breaks the rule. I'm using pgregory.net/rapid.

The generator builds a transaction that is balanced by construction: pick a random number of legs, give each a random amount, then make the last leg the exact negation of everything before it. The sum is zero on purpose. The property: any transaction built this way must pass `Validate`.

```
1 func TestProp_BalancedAlwaysValid(t *testing.T) {
2     rapid.Check(t, func(t *rapid.T) {
3         tx := Transaction{ID: "tx", Postings: genBalancedPostings(t)}
4         if err := tx.Validate(); err != nil {
5             t.Fatalf("balanced transaction rejected: %v", err)
6         }
7     })
8 }
```

Then the mirror image: take a balanced transaction, bump exactly one leg by a non-zero amount, and assert it *always* fails. A balanced ledger you can nudge into imbalance and it still passes would be a disaster.

```
1 func TestProp_PerturbedAlwaysInvalid(t *testing.T) {
2     rapid.Check(t, func(t *rapid.T) {
3         postings := genBalancedPostings(t)
4         idx := rapid.IntRange(0, len(postings)-1).Draw(t, "idx")
5         delta := rapid.Int64Range(1, 1_000_000).Draw(t, "delta")
6         bumped, _ := NewMoney(postings[idx].Amount.Amount()+delta, "USD")
7         postings[idx].Amount = bumped
8     })
9 }
```

```
8     tx := Transaction{ID: "tx", Postings: postings}
9     if err := tx.Validate(); err == nil {
10         t.Fatal("perturbed transaction passed Validate, expected
           failure")
11     }
12 })
13 }
```

If `rapid` ever finds a counterexample, it shrinks it down to the smallest input that still breaks and hands it to me. That's the part I love: the test doesn't just say "something's wrong," it says "here is the simplest case that's wrong." For an invariant this important, I want a tireless adversary trying to break it on every run, not just the handful of examples I was clever enough to write down.

Everything passes, the domain package sits at 98% coverage, and the linter (gosec included) is clean.

4.5 What I deliberately left out

No `Account` balance field. Anywhere. A balance is never stored as mutable state; it's the sum of every posting that ever touched the account, derived when you ask. That's the whole point of double-entry, and storing a balance you also derive is how the two drift apart and lie to you. The `Account` type this week is identity and classification only: an ID, a name, a type (asset, liability, equity, income, expense), and a currency.

No persistence, no concurrency control, no money math beyond add, subtract, and negate. Those have their own weeks. This week was

about getting the shapes right, because every layer above this one (the repository, the service, the API) is going to lean on these types being correct.

4.6 The honest split

Same as last week: I own the decisions, Claude does the mechanical lifting. The choice of `int64` minor units over a decimal library, the signed-posting convention, the idea of making `validate` the single chokepoint, those are mine and they're written down in ADR-002 so future me can't forget the reasoning.

What Claude did, working from a detailed plan I reviewed first, was the test-driven grind: write the failing test, watch it fail, write the minimal code, watch it pass, commit, repeat. It also caught a real edge case I'd waved off. My `Money.String` formatter negated the amount to print a minus sign, which breaks for the single most-negative `int64` value, whose negation doesn't fit in an `int64`. An absurd amount for a real ledger, but "absurd inputs shouldn't produce nonsense" is exactly the standard this project holds itself to, so we fixed it with an unsigned-magnitude trick and added a test pinning the behavior. Small thing. But small things quietly wrong is the whole genre of bug I'm trying to engineer out of existence.

4.7 Next week

The types are solid and proven. Next week they meet reality: a Postgres schema with append-only postings, a repository layer with sqlc, and the first integration test that creates accounts, posts a real transaction, and reads a balance back, all against an actual database spun up in a container.

The repo is open at github.com/sohag-pro/go-ledger. The domain model from this post lives in `internal/domain`, and **ADR-002** explains the money decision in full.

CHAPTER 5

Week 2 Interview Q&A

Interview-style questions for the Week 2 work: the pure `internal/domain` package (`Money`, `Currency`, `Account`, `Posting`, `Transaction`) and ADR-002. Every question is answerable from this repo's code, ADRs, and tests.

5.1 Domain design

5.1.1 1. Walk me through how you modeled a double-entry transaction in Go. What are the core types and how do they relate?

What a strong answer covers:

- `Money` (signed `int64` minor units plus `Currency`), `Account` (identity and classification), `Posting` (one signed `Money` entry against an account ID), `Transaction` (an ID plus a slice of `Posting`).
- A `Transaction` is two or more `Postings`; the sign on `Posting.Amount` carries direction (positive = debit, negative = credit).
- Balance is never a stored field; it is derived by summing postings (see ADR-001).

- The invariant (postings sum to zero) is enforced in one place:
`Transaction.Validate()`.

5.1.2 2. Why is `Posting.Amount` a single signed value instead of an explicit `Debit/Credit` direction field plus a positive amount?

What a strong answer covers:

- One signed field makes the invariant a plain sum: `Validate` folds the postings with `Money.Add` and checks the result is zero.
- An explicit direction enum would force `validate` to split sums by side and reconcile them, more code and more room for error.
- The sign convention is documented on the `Posting` type so it is not folklore.
- Tradeoff acknowledged: a direction enum reads more explicitly to an accountant; the signed model was chosen for a simpler, harder-to-break invariant check.

5.1.3 3. Why are `Money`'s fields unexported, and why does construction go through `NewMoney`?

What a strong answer covers:

- Unexported `amount` and `currency` mean a `Money` can only be built through `NewMoney`, which validates the currency shape.
- It keeps `Money` an immutable value type: operations return new values, nothing mutates in place.

- Prevents an invalid `Money` (bad currency) from ever existing in the first place, a “make illegal states unrepresentable” move.
- The accessors `Amount()`, `Currency()`, `IsZero()` give read access without exposing mutation.

5.1.4 4. The zero value of `AccountType` is invalid by design. Explain that choice.

What a strong answer covers:

- The constants start at `iota + 1`, so `Asset` is 1, not 0.
 - An uninitialized or zero `AccountType` fails `Validate()` with `ErrInvalidAccountType` instead of silently passing as a real type.
 - Defends against the Go footgun where a struct field defaults to a meaningful enum value nobody set on purpose.
 - `IsDebitNormal()` and `String()` also treat the zero/undefined value safely (not debit-normal, “unknown”).
-

5.2 Data integrity and the invariant

5.2.1 5. Where exactly is the balance invariant enforced, and why concentrate it in one place?

What a strong answer covers:

- `Transaction.Validate()` is the single chokepoint: at least two postings, every posting valid, single currency, signed amounts sum to exactly zero.
- One enforcement point means one place to audit, test, and reason about; no scattered checks that can drift.
- It returns the first rule broken via named sentinel errors (`ErrTooFewPostings`, `ErrInvalidPosting`, `ErrCurrencyMismatch`, `ErrOverflow`, `ErrUnbalanced`).
- The domain check is layer one; ADR-001 notes a Postgres CHECK constraint will enforce it again at the database in a later week (defense in depth).

5.2.2 6. Validate never explicitly checks for currency mismatch or overflow, yet it catches both. How?

What a strong answer covers:

- The running sum is built with `Money.Add`, which already returns `ErrCurrencyMismatch` on differing currencies and `ErrOverflow` on int64 overflow.
- `Validate` just propagates the first error from the fold, so the small type does the work and the method stays short.
- This is composition: correctness pushed down into `Money` so every consumer inherits it.
- Demonstrates the value of error-returning arithmetic over panicking or silently wrapping.

5.2.3 7. Why does the ledger derive balances by summing postings instead of storing a balance column you update?

What a strong answer covers:

- A stored mutable balance can drift from the postings that are supposed to explain it; the history would stop being the source of truth.
 - Append-only postings give a built-in audit trail: every balance is reconstructable.
 - A single-sided “add 10 to A” update has no structural guarantee the money came from anywhere; double-entry makes that impossible (ADR-001).
 - Tradeoff: balance reads become aggregations, not single-row lookups; acceptable for v1, and a rebuildable cache can come later if it gets hot.
-

5.3 Money representation (ADR-002)

5.3.1 8. Why int64 minor units for money instead of a float or a decimal library?

What a strong answer covers:

- Floats can't represent most decimal fractions exactly ($0.1 + 0.2 \neq$

0.3); rounding error accumulates across many postings, unacceptable for money.

- `int64` minor units (cents) are exact, allocation-free, and map cleanly onto Postgres `BIGINT` with no conversion.
- A decimal library (for example `shopspring/decimal`) is exact too but allocates a `big.Int` per op and maps to `NUMERIC`; more machinery than single-currency v1 needs.
- The cost of `int64` is overflow risk, handled explicitly in the arithmetic.

5.3.2 9. What is the downside of `int64` minor units, and how did you handle it?

What a strong answer covers:

- `int64` caps the representable magnitude near $9.2e16$ minor units, far beyond any real balance, but arithmetic can still overflow.
- `Add`, `Sub`, `Neg` are overflow-guarded and return `ErrOverflow` rather than wrapping or panicking.
- `Add` detects overflow with sign logic: overflow happened if both operands share a sign but the result's sign flipped.
- `Neg` special-cases `math.MinInt64`, whose negation does not fit in an `int64`.

5.3.3 10. Your Money carries a Currency even though v1 is single-currency. Why pay that cost now?

What a strong answer covers:

- Cross-currency arithmetic returns `ErrCurrencyMismatch`, so a future multi-currency mistake cannot silently corrupt a sum.
 - It is cheap insurance: the field and the check cost little and make the invariant currency-aware from day one.
 - Multi-currency is explicitly out of scope (ADR-002, build plan), so there is no per-currency scaling logic yet, just the guard.
 - Shows scope discipline: build the cheap guardrail, defer the expensive feature.
-

5.4 Testing

5.4.1 11. You wrote both table-driven tests and property-based tests for the same invariant. Why both, and what does each catch?

What a strong answer covers:

- Table-driven tests pin specific known cases: balanced two-leg and multi-leg, unbalanced, too-few postings, currency mismatch, empty account ID.
- Property tests (pgregory.net/rapid) assert a rule for hundreds of randomized inputs, catching cases the author never imagined.
- Two properties: any balanced transaction passes `validate`; any one-leg perturbation of a balanced transaction fails.
- `rapid` shrinks a failure to the minimal counterexample, so a regression points straight at the smallest breaking input.

5.4.2 12. Explain the `genBalancedPostings` generator. How do you know it produces genuinely balanced transactions, and what keeps it from triggering false overflow?

What a strong answer covers:

- It draws $n-1$ random legs, tracks the running `int64` sum, then adds a final leg equal to the negation of that sum, so the total is zero by construction.
- A separate property (`TestProp_SumIsZero`) verifies the generator's own output sums to zero.
- Amounts are bounded to roughly $\pm 1e9$ over at most 8 legs, so the running sum stays well within `int64` and the fold never hits a spurious `ErrOverflow`.
- The perturbation delta is always nonzero and within bounds, so a perturbed transaction is genuinely unbalanced, not accidentally rebalanced.

5.4.3 13. The domain package sits around 98% coverage. What is the uncovered slice, and why is that acceptable?

What a strong answer covers:

- The small gap is an error path in `Sub` reached via `Neg` (the `MinInt64` underflow), already exercised indirectly by the overflow test cases.
- Coverage is a signal, not a goal; the invariant itself is covered by both example and property tests.

- Chasing the last percent on an implicitly-tested error branch is low value versus the property coverage already in place.
 - Honest about what is and is not exercised rather than gaming the number.
-

5.5 Trade-offs and defending decisions

5.5.1 14. Defend the double-entry model itself. Why not a simpler balances table with debit/credit helper functions?

What a strong answer covers:

- A mutable balances table has no structural audit trail and no guarantee money came from somewhere; bugs create or destroy money silently (ADR-001 context).
- Double-entry makes an unbalanced transaction rejectable before it persists; the invariant is the schema, not a convention.
- Append-only postings sidestep read-modify-write races on a balance row.
- It matches what accountants, auditors, and payment partners already expect, lowering integration friction.

5.5.2 15. You pulled in `pgregory.net/rapid` in Week 2 even though the plan first names it in Week 9. Justify adding a dependency early.

What a strong answer covers:

- The balance invariant is the single most important property in the system; it deserves adversarial randomized testing from the moment it exists, not seven weeks later.
- `rapid` is a test-only dependency, so it adds zero weight to the production binary.
- Introducing it once and using it consistently beats hand-rolling generators now and swapping later.
- Defensible reversal of a plan detail with a clear reason, which is the point of the question.

5.5.3 16. A `Money.String` edge case came up during review: formatting `math.MinInt64`. What was the bug and how did you fix it without changing the method signature?

What a strong answer covers:

- The original `String` negated the amount to print a minus sign, but negating `math.MinInt64` overflows `int64` and produces nonsense.
- `String` must satisfy `fmt.Stringer`, so it cannot start returning an error; the fix had to stay signature-compatible.
- The fix computes the absolute value as a `uint64` (unsigned negation yields the correct magnitude even for `MinInt64`), with a `// nolint:`

`gosec` and a comment explaining the intentional signed-to-unsigned reinterpretation.

- A test pins the `MinInt64` output so the behavior cannot silently regress; the broader lesson is that absurd inputs still must not produce garbage.

≡ go-ledger

WEEK 3

01 Postgres Schema for a Multi-Tenant Ledger

02 Week 3 Interview Q&A

CHAPTER 6

Postgres Schema for a Multi-Tenant Ledger

Open your banking app and look at the balance. It feels like a saved number, a single field in a row somewhere with your name on it, that goes up when money arrives and down when it leaves. That mental model is wrong, and the gap between that model and how a real ledger works is most of what Week 3 was about.

In a proper ledger your balance is not stored anywhere. It is computed, every time, by adding up every entry that ever touched your account. The history is the truth. The balance is just a question you ask of that history. Last week I built the double-entry domain model in Go types. This week I had to put it on disk, in Postgres, in a way that keeps that property honest. This is post 3 of 14.

6.1 The one decision that shapes the rest

Here is the fork in the road. When someone posts a transaction, you can do one of two things with their balance.

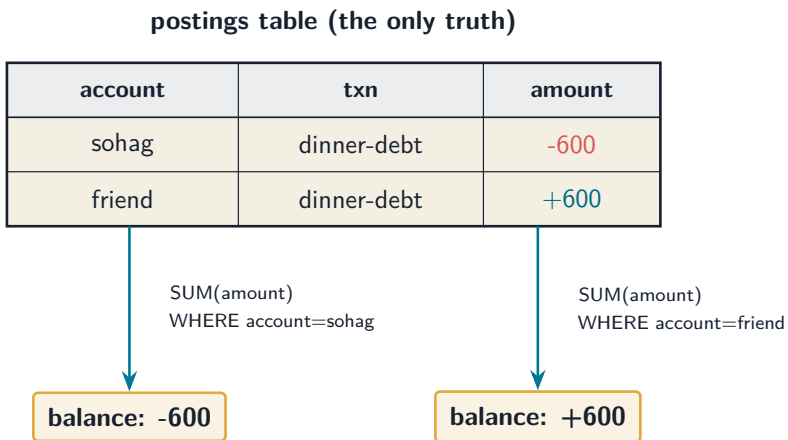
Option A: keep a balance column. Each account row has a balance field. Every posting reads it, adds the amount, and writes it back. Reads are trivial, one column lookup.

Option B: keep only the postings. Postings are append-only rows. The balance is $\text{SUM}(\text{amount})$ over an account. Nothing is ever updated in place.

Option A is faster to read and it is the one most people reach for first. It is also the exact bug double-entry exists to prevent. The moment you store a balance, you have two copies of the truth: the number in the column, and the sum of the postings. The day those two disagree, and they will, after a crash mid-write, a missed update, a racy retry, you have no way to tell which one is right. Money is now ambiguous, which in a ledger is the worst thing money can be.

So go-ledger uses Option B. Postings are append-only. Balances are derived. There is exactly one source of truth, and it cannot drift from itself.

Picture my dinner debt from post 1, the 600 taka I owed a friend, now sitting in the actual tables:



No balance column anywhere. Ask the question, get the answer.

The trade is real and worth saying out loud: reads are now an aggregate, not a lookup. At v1 scale that is a non-issue. If it ever bites, the fix is a cached rollup that is *rebuilt from the postings*, never a mutable primary balance. The history stays sacred.

6.2 Three tables, not five

My build plan listed five tables for this week: `accounts`, `transactions`, `postings`, `idempotency_keys`, and `audit_log`. I built three.

The last two belong to Week 6. I do not know their columns yet, because I have not written the code that uses them. Designing a table before its consumer exists just means I get to `ALTER` it later anyway, so there is no real saving in rushing it. Migrations are cheap and ordered. Each table arrives with the feature that needs it. That is the whole argument, and it is the kind of small discipline that keeps a fourteen-week project from quietly turning into a thirty-week one.

So `0001_initial.sql` creates `accounts`, `transactions`, and `postings`. That is it.

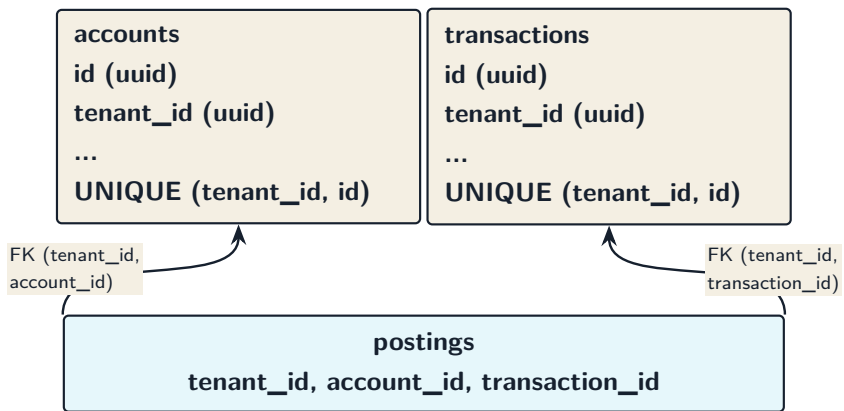
6.3 Multi-tenant from the first migration

The blog title says multi-tenant, and that is the part most schema posts skip. A real ledger does not hold one person's accounts. It holds many independent tenants' books in the same database, and tenant A must never, under any bug, see tenant B's money.

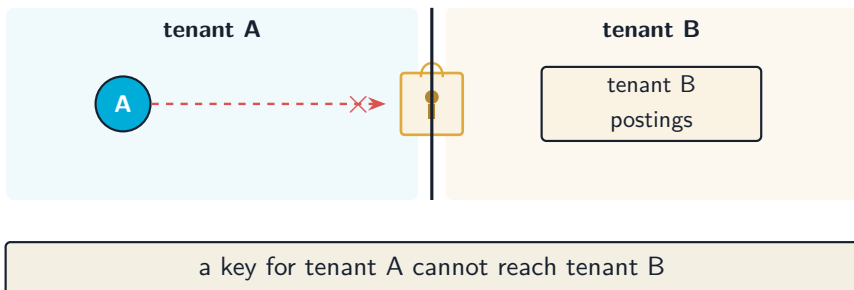
There is no login or auth in go-ledger yet. So why is there a `tenant_id`

on every single table already? Because adding it later is the migration nobody wants to write. Retrofitting tenancy onto a populated ledger means a new column, a backfill across every row, and rebuilt foreign keys, all on live data. Adding the column now, while the tables are empty, costs nothing. The column goes in on day one even though the code that resolves a tenant comes much later.

But a column is just a label. The interesting part is making the database itself refuse to mix tenants. Here is the trick:



A posting must match its account's tenant AND its transaction's tenant.
A cross-tenant posting is not discouraged, it is impossible to insert.



Instead of a plain foreign key on `id`, accounts and transactions carry a `UNIQUE (tenant_id, id)`, and postings reference the pair. Now Postgres will reject a posting that points at an account in a different tenant. Tenant isolation stops being a thing every query has to remember and becomes a guarantee the database enforces. The query that forgets its `WHERE tenant_id = ?` is still a bug, but the catastrophic version, a posting that silently links two tenants' books, simply cannot be written.

6.4 The small choices that add up

A few smaller decisions, each with a fork worth a sentence:

UUIDv7 keys, generated in Go. Keys are UUIDs, not auto-incrementing integers, and the app generates them before insert using UUIDv7. Version 7 is time-ordered, so it keeps the nice index locality that makes serial keys fast, while staying globally unique and not coupled to the database. Generating them in Go means the caller knows the ID without a round-trip, and tests are deterministic. The cost is 16 bytes instead of 8. Worth it.

Currency on the transaction, not the posting. The domain already guarantees every posting in a transaction shares one currency. So I store the currency once, on the transaction, and a posting stays a single signed integer amount. Less duplication, and the single-currency rule is visible in the shape of the data.

Account type as text with a CHECK, not a Postgres enum. A column constrained by `CHECK (type IN ('asset', 'liability', ...))` reads fine in plain SQL, and adding a type later is an ordinary migration

instead of the awkward `ALTER TYPE` dance an enum forces. Low churn, so the enum's only real benefit does not apply.

No balance CHECK yet. The rule that a transaction's postings must sum to zero lives in the Go domain for now, in `Transaction.Validate()`. The database-level constraint that makes it impossible regardless of caller is deliberately Week 4 work, landing with the concurrency handling where it belongs. I am being honest about that gap rather than pretending the schema is already bulletproof.

6.5 Proving it works against a real Postgres

A schema you have not run is a guess. The Week 3 definition of done was a single integration test that exercises the whole happy path end to end, against a real Postgres, not a mock.

The test uses `testcontainers-go` to spin up an actual `postgres:16-alpine` in a container, runs the migration with `goose`, then does the real thing: create two accounts, post a balanced two-leg transaction, read both balances back, and assert they are `+10000` and `-10000` and that they net to zero. That last assertion is the whole point of the project, checked end to end:

```
1 cashBal, _ := repo.Balance(ctx, tenant, cash.ID)      // +10000
2 revBal, _  := repo.Balance(ctx, tenant, revenue.ID)   // -10000
3
4 if cashBal.Amount()+revBal.Amount() != 0 {
5     t.Errorf("ledger does not net to zero")
6 }
```

There is a second test that creates an account under one tenant and

tries to read it as another tenant, expecting “not found”. The isolation I designed into the foreign keys is not just a claim in this post, it is a test that fails if I ever break it.

One honest detail: the test skips, rather than fails, when no Docker daemon is reachable, so a teammate without Docker still gets a green `make test`. The risk is that a skip can hide a broken integration path, so CI runs Docker and exercises the real thing for real. On my own laptop that meant getting a container runtime going (I use colima, not Docker Desktop), watching the first run pull the Postgres image, and finally seeing three green `PASS` lines against a live database. That is the moment the schema stopped being a guess.

6.6 The AI companion, week 3

The running subplot of this series is that I build this with Claude Code as a pair, and I stay honest about the split. This week Claude wrote a lot of the mechanical surface: the migration SQL, the `sqlc` setup, the repository adapter, the integration test. But the decisions in this post, append-only over a balance column, `tenant_id` on day one, composite foreign keys for isolation, three tables not five, are mine, argued out before any code got written and recorded in **ADR-003**. The deal holds: Claude accelerates the typing, I own the why. A ledger I could not explain line by line would defeat the point.

6.7 Where this leaves us

The ledger now has a home on disk that cannot lie to itself. Balances are derived, postings are immutable, tenants are isolated by the database, and there is a test that runs the whole path against real Postgres and proves it.

What is missing is the hard part: what happens when two requests post to the same account at the same time. Right now the balance invariant is enforced in Go, optimistically, with nothing stopping two concurrent writers from racing. Next week is atomicity and concurrency: wrapping posting in a database transaction at `SERIALIZABLE` isolation, adding the database-level `CHECK` that makes an unbalanced transaction impossible, and then pointing 10,000 concurrent posts at the same accounts to see if the invariant holds. That is where ledgers get genuinely interesting.

The repo is open source at github.com/sohag-pro/go-ledger. Follow along or steal the schema.

CHAPTER 7

Week 3 Interview Q&A

Interview-style questions for the Week 3 work: the `0001_initial` migration, the `sqlc` query layer, the `domain.Repository` port and its internal `/postgres` adapter, the `testcontainers` integration test, and ADR-003. Every question is answerable from this repo's code, ADRs, and tests.

7.1 Schema design

7.1.1 1. Walk me through the schema you landed on for Week 3. What are the three tables and how do they relate?

What a strong answer covers:

- `accounts` (identity, type, currency, tenant), `transactions` (a single-currency grouping, tenant), `postings` (signed `bigint` amount linking a transaction to an account).
- A transaction has two or more postings; balances are not stored, they are `SUM(amount)` over an account (carries ADR-001 into the DB).
- Postings are append-only: no `UPDATE` or `DELETE` query is written against them.

- Every table carries `tenant_id`; the whole ledger is scoped by tenant.

7.1.2 2. You chose append-only postings with derived balances over a mutable balance column. Why?

What a strong answer covers:

- A stored balance is a second copy of the truth that can drift from the postings, and once it drifts there is no way to tell which is right. That is exactly the bug double-entry exists to prevent.
- A mutable balance turns every posting into a read-modify-write that has to be serialized on the account row.
- Derived balance is always reconstructable from history; the posting log is the single source of truth.
- Tradeoff named: reads become an aggregate (`SUM`) instead of a column lookup. Fine at v1 scale; the escape hatch is a materialized rollup rebuilt from postings, never a mutable primary balance (recorded in ADR-003).

7.1.3 3. The build plan lists five tables but the migration creates three. Defend that.

What a strong answer covers:

- `idempotency_keys` and `audit_log` are Week 6 work; their columns are not known until the code that uses them exists.
- Designing a schema before its consumer invites an `ALTER` later anyway, so there is no real saving from doing it early.

- Migrations are cheap and ordered; adding tables in their own migration keeps each change reviewable and tied to a feature.
- YAGNI applied deliberately, not by accident: the decision is written down in ADR-003.

7.1.4 4. Why does currency live on the transaction and the account, but not on each posting?

What a strong answer covers:

- The domain already guarantees all postings of a transaction share one currency (`Transaction.Validate`), so storing it per posting would be redundant.
 - A posting stays a single signed `bigint` amount; its `Money` is reconstructed from the transaction's currency on read (see `GetTransaction` in `repository.go`).
 - The account also carries its own currency, which is what `Balance` uses to build the returned `Money`.
 - Keeps the posting row minimal and the single-currency-per-transaction rule structurally visible.
-

7.2 Multi-tenancy and data integrity

7.2.1 5. There is no auth yet, so why is `tenant_id` on every table from day one?

What a strong answer covers:

- Retrofitting tenancy onto a populated ledger (adding the column, backfilling, rebuilding foreign keys) is a painful, risky migration nobody wants to write later.
- The column and the foreign-key discipline are cheap now and define the scoping seam the service and API will use.
- Repository methods are already tenant-scoped (`tenantID` is the first argument on every method), so the contract is set before any consumer depends on it.
- Auth and tenant resolution land later; the storage shape does not have to wait for them.

7.2.2 6. Explain the composite foreign keys on postings. What do they buy you that a plain FK on `id` would not?

What a strong answer covers:

- `accounts` and `transactions` have `UNIQUE (tenant_id, id)`; `postings` references `(tenant_id, account_id)` and `(tenant_id, transaction_id)`.
- This makes it impossible to insert a posting that points at an account or transaction in a different tenant: the database rejects it, not just application code.
- Tenant isolation becomes a data-integrity guarantee enforced by Postgres, not a convention you hope every query remembers.

- Demonstrated by `TestTenantIsolation`: a second tenant cannot read another tenant's account even with the correct id.

7.2.3 7. Account type is stored as text with a CHECK constraint instead of a Postgres enum. Why?

What a strong answer covers:

- `CHECK (type IN ('asset','liability','equity','income','expense'))` is readable in plain SQL and queryable without special casts.
- Adding or changing a type is an ordinary migration, versus the awkward `ALTER TYPE ... ADD VALUE` dance (which cannot run in a transaction in older Postgres and cannot remove values).
- The Go side maps the enum with `AccountType.String()` on write and `ParseAccountType` on read, so the text values and the domain enum stay in lockstep.
- Low-churn set, so the enum's main benefit (compact storage) is not worth its rigidity.

7.2.4 8. The schema has no CHECK that postings sum to zero. Isn't that the whole point of the ledger? Where is the invariant enforced?

What a strong answer covers:

- For Week 3 it is enforced in the domain: `CreateTransaction` calls `Transaction.Validate()` before writing anything.
- The database-level CHECK is deliberately Week 4 work, landing with the transaction-posting service and its concurrency handling

where it actually belongs.

- Defense in depth is the goal: the domain check catches it early with a typed error; the DB constraint will make it impossible regardless of caller.
 - Honest about the gap: until Week 4, a buggy caller that bypassed `CreateTransaction` could write an unbalanced set; that is why the constraint is scheduled, not skipped.
-

7.3 Repository and adapter design

7.3.1 9. Why is `Repository` an interface in `internal/domain` rather than just a struct in the `postgres` package?

What a strong answer covers:

- Ports and adapters: the domain owns the contract, the infrastructure implements it. Dependencies point inward.
- The domain stays free of `pgx` and `uuid` types; the port is a plain Go interface over domain types and `context`.
- The service layer (Week 4) can be tested against a fake repository without a database.
- A compile-time `var _ domain.Repository = (*Repository)(nil)` keeps the adapter honest about satisfying the port.

7.3.2 10. IDs are uuid in Postgres but string on the domain types. Walk through how that boundary is handled and why UUIDv7 generated in the app.

What a strong answer covers:

- The domain models ids as plain `string` so it carries no uuid dependency; the adapter parses to `uuid.UUID` at the boundary and stringifies on the way out.
- The app generates UUIDv7 before insert (`uuid.NewV7()`), writing it back to the passed-in pointer when the caller left the id empty.
- v7 is time-ordered, so it keeps b-tree index locality close to a serial key while staying globally unique and decoupled from the DB.
- Generating in Go (not `gen_random_uuid()`) means the caller knows the id without a round-trip and tests are deterministic.

7.3.3 11. How does `CreateTransaction` guarantee a transaction and its postings are written atomically?

What a strong answer covers:

- It opens a pgx transaction (`pool.Begin()`), runs the transaction insert and every posting insert through `q.WithTx(tx)`, then commits.
- `defer tx.Rollback(ctx)` covers every early-return error path; rollback after a successful commit is a harmless no-op.
- `Transaction.Validate()` runs before any DB work, so an invalid transaction never opens a connection.
- Result: there is no window where a transaction row exists without its postings, or vice versa.

7.3.4 12. Why does Balance read the account first and then sum postings, rather than just running the SUM?

What a strong answer covers:

- The account is the source of the currency, needed to build the returned Money.
 - It distinguishes “account exists but has no postings” (balance zero) from “no such account” (`ErrAccountNotFound`); a bare SUM over zero rows would return 0 and hide a missing account.
 - The query uses `COALESCE(SUM(amount), 0)::bigint` so an account with no postings reads as 0, not NULL.
 - Tradeoff: two round-trips instead of one. Acceptable for correctness; could become a single joined query if it ever mattered.
-

7.4 Testing

7.4.1 13. Describe the Week 3 integration test and how it proves the definition of done.

What a strong answer covers:

- `TestHappyPath` spins a real `postgres:16-alpine` via `testcontainers-go`, runs the goose migration, then creates two accounts, posts a balanced two-leg transaction, and reads both balances back.
- It asserts the specific balances (+10000 and -10000) and that they

net to zero, which is the defining double-entry property end to end.

- It also round-trips the transaction through `GetTransaction` and re-runs `Validate()` on the reconstructed value.
- Backed by `TestGetAccountNotFound` and `TestTenantIsolation` for the error and isolation paths.

7.4.2 14. The test skips instead of fails when Docker is absent. Defend that choice and explain the risk.

What a strong answer covers:

- A developer without a running Docker daemon still gets a green `make test`; the suite does not punish them for missing infrastructure.
- The skip is explicit and logged with a clear reason, so it is visible, not silent.
- Risk: a skip can mask a genuinely broken integration path if CI does not run Docker, so CI must run it for real (it does).
- The skip key off the container failing to start, not a `testing.Short()` flag, so the real run needs no special invocation beyond Docker being up.

7.4.3 15. Migrations run through goose in the test but the app talks to Postgres through pgx. Why two database access paths, and how do they coexist?

What a strong answer covers:

- goose is built on `database/sql`, so the test opens a `sql.DB` with the `pgx` stdlib driver (`_ "github.com/jackc/pgx/v5/stdlib"`) just to run mi-

grations, then closes it.

- The repository itself uses a `pgxpool.Pool` (the native `pgx` path) for all real queries.
 - Migrations are embedded with `go:embed` (`postgres.Migrations`) so `goose` runs them without a path on disk, the same FS the server can use at startup later.
 - Clean separation: schema management and query execution are different concerns and do not have to share a driver.
-

7.5 Trade-offs and stack defense

7.5.1 16. Defend `pgx` + `sqlc` over an ORM like GORM. What do you give up?

What a strong answer covers:

- `sqlc` generates type-safe Go from hand-written SQL, so the queries are explicit, reviewable, and exactly what runs; no hidden N+1 or surprise queries from an ORM's lazy loading.
- `pgx` gives full access to Postgres features and a fast native protocol path, plus first-class transaction control used directly in `CreateTransaction`.
- For a ledger, predictable SQL and tight control over transactions and isolation matter more than the CRUD convenience an ORM optimizes for.
- Given up: less automatic scaffolding, you write the SQL and the

migrations yourself. Accepted as a feature, not a cost, for this domain.

7.5.2 17. Someone argues UUIDv7 primary keys are over-engineering and a bigserial would be simpler and faster. How do you respond?

What a strong answer covers:

- `bigserial` couples id assignment to the database, forcing a round-trip to learn the id and making cross-tenant uniqueness and external references messier.
- `UUIDv7` keeps most of `serial`'s index locality (time-ordered) while being globally unique and client-generatable, which keeps the domain and tests independent of the DB.
- For a multi-tenant system that may later shard or expose ids externally, opaque non-sequential keys avoid leaking volume and ordering and avoid id collisions across tenants.
- Honest cost: 16 bytes versus 8, and slightly larger indexes. Acceptable for the isolation and decoupling gained; documented in ADR-003.

≡ go-ledger

WEEK 4

01 Atomic Transaction Posting in Go

02 Week 4 Interview Q&A

CHAPTER 8

Atomic Transaction Posting in Go

Imagine an account with 100 taka in it, and two withdrawals of 100 taka arriving at the exact same instant. Both read the balance, both see 100, both say “yep, enough money,” and both go through. The account is now at minus 100. Nobody wrote a bug, exactly. Each withdrawal was correct on its own. They were just allowed to happen at the same time, and the system let them both believe they were alone.

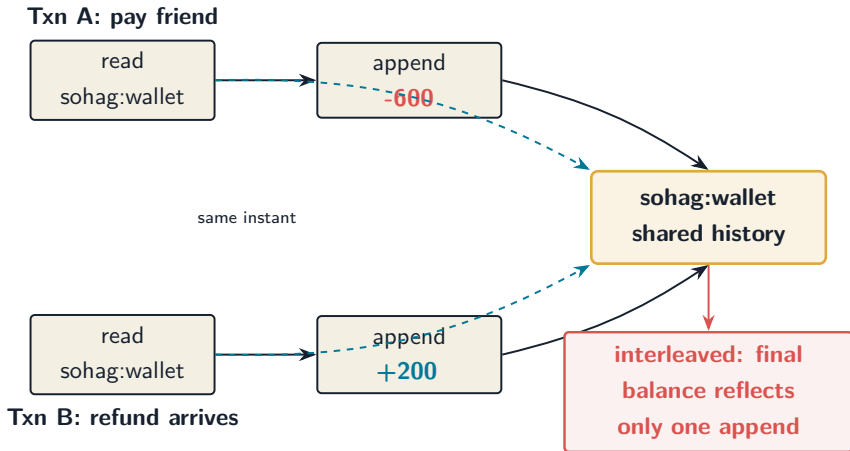
That is the whole problem of week 4. Last week I put the ledger on disk and proved a single transaction posts correctly. This week the question is harder: what happens when a hundred of them land on the same accounts at once, and how do I make absolutely sure the books still balance? This is post 4 of 14.

8.1 The thing that must never happen

The ledger’s one rule, from day one, is that every transaction’s postings sum to zero. Money moves, it never appears or vanishes. Under concurrency the failure mode is subtle. It is not that one transaction is wrong. It is that two correct transactions, interleaved, produce a state neither of them intended.

Here is my dinner-debt example from earlier in the series, now with

a twist. Say two different transactions both touch my wallet at the same moment: I pay back a friend 600 taka, and at the same time a refund of 200 lands.



Both transactions are individually balanced. The danger is in the interleaving. So the real work this week was not writing the posting logic. It was choosing how the database serializes conflicting transactions, and then proving it holds.

8.2 Two ways to be safe

There are two classic answers, and they are opposites.

The **pessimistic** one: lock the rows. Before touching an account, grab an exclusive lock on it (`SELECT ... FOR UPDATE`), do the work, release. Anyone else who wants that account waits their turn. It works, but correctness now depends on me remembering to lock the right rows,

in the right order, on every single code path, forever. The day someone adds a new way to write a posting and forgets the lock, the race is back, silently.

The **optimistic** one: don't lock, just let the database watch. Run every transaction at `SERIALIZABLE` isolation, the strictest level Postgres offers. Postgres tracks the reads and writes of concurrent transactions and, if committing them all would produce a result that no serial (one-at-a-time) ordering could, it aborts one of them with a specific error. Nothing blocks. Conflicts surface as a `retry-this` error.

I went optimistic. The reason is in the failure mode: with locking, a forgotten lock fails silently and corrupts money. With `SERIALIZABLE`, the database refuses to let an unsafe interleaving commit, no matter what the application code does or forgets. Correctness stops being something I have to remember and becomes something the database guarantees. I wrote this up in **ADR-004**.

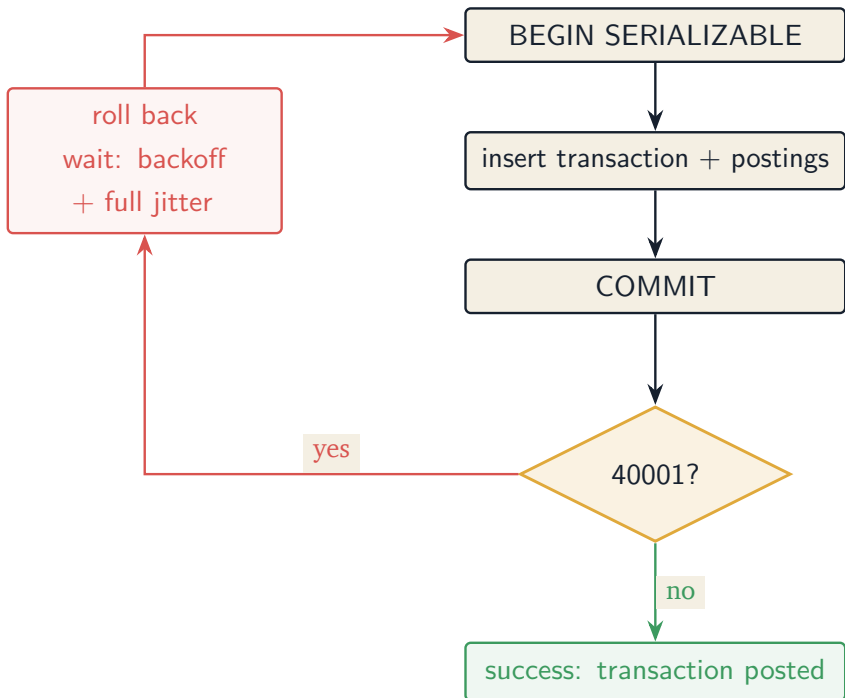
The catch is that “abort with a `retry-this` error” means I have to actually retry.

8.3 Retrying without making it worse

When Postgres aborts a transaction for a serialization conflict, it returns `SQLSTATE 40001`. The fix is to roll back and run the whole thing again, because the second time around the conflicting transaction has usually finished and yours can now commit cleanly.

One subtlety bit me immediately: the conflict often does not show up when you run your statements. It shows up at `COMMIT`. So the retry

logic has to watch both the work and the commit:



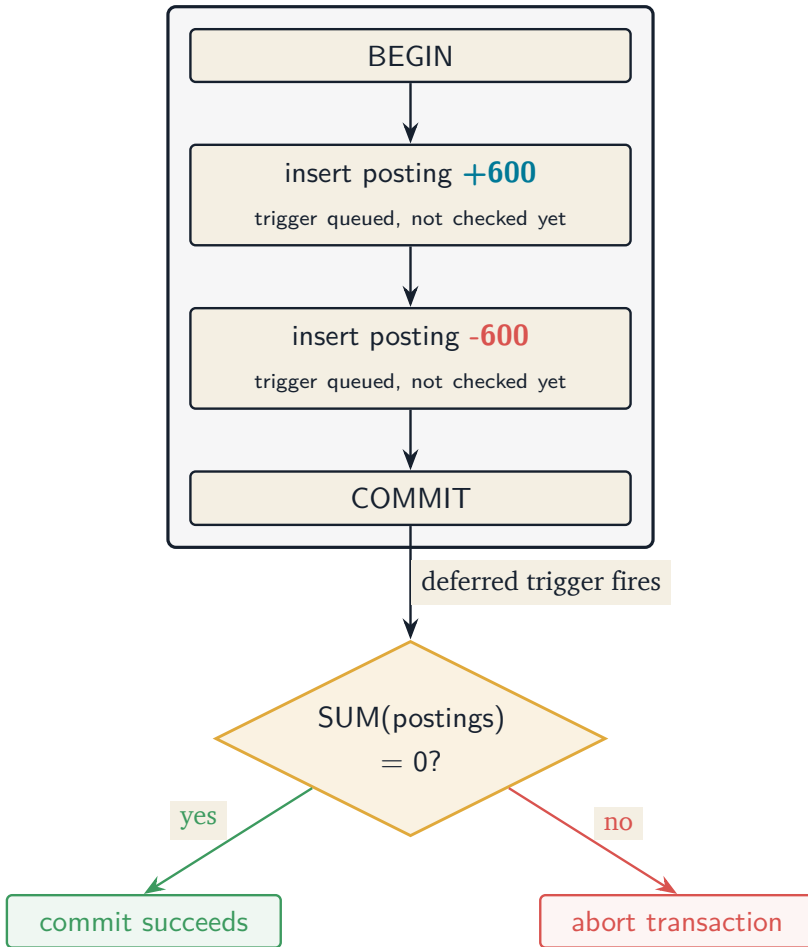
The “wait a bit” matters more than it looks. If a hundred transactions all conflict and all retry after exactly the same delay, they just collide again, in lockstep, forever. So the backoff is exponential with **full jitter**: each retry waits a random amount up to a growing cap. The randomness is the point. It scatters the retryers so they stop landing on top of each other. Bounded retries, and if they ever run out, the caller gets a typed “conflict, try again” error that the API will map to a 503, not a confusing 500.

8.4 Belt and suspenders: enforce it in the database too

The domain already checks the sum-to-zero rule in Go before anything touches the database. But I wanted the database itself to refuse an unbalanced transaction, so that a bad migration, a direct `psql` session, or some future second service physically cannot write one.

The trouble is that the rule spans many rows. A normal `CHECK` constraint only sees one row at a time, and a single posting of plus 600 is not “wrong,” it is half of a pair. The sum only makes sense once all the postings are in.

The answer is a **deferred constraint trigger**. It is queued up and fires once, at `COMMIT`, after every posting is written, and it checks that each transaction’s postings sum to zero:



Now the invariant is guaranteed in two independent places: the Go domain catches it early with a clean error, and the database guarantees it absolutely. There is a test that bypasses all my Go code, inserts a single lopsided posting with raw SQL, and confirms the commit is rejected.

8.5 The afternoon one in six payments failed

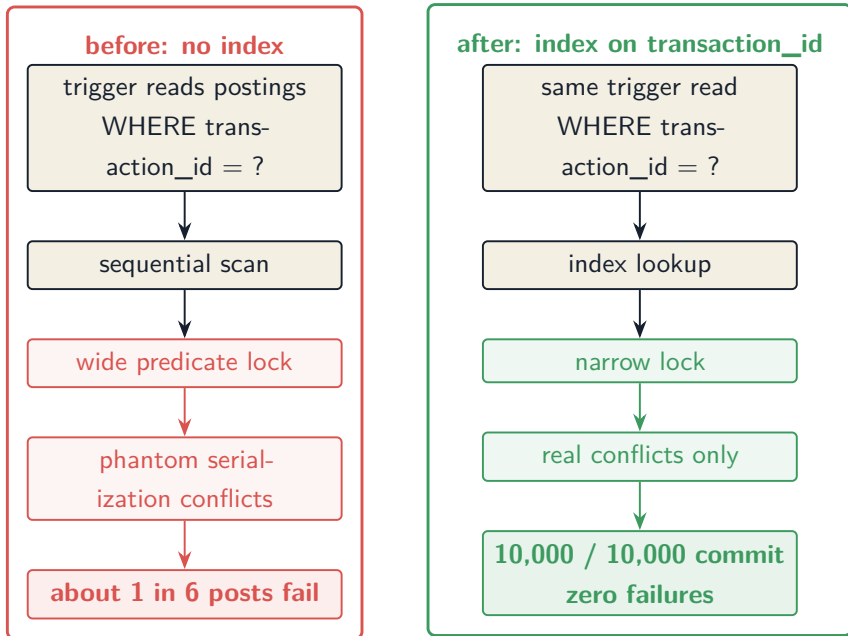
Then I wrote the stress test the week was really about: 100 goroutines, 10,000 balanced transactions, all hammering a shared pool of accounts. The bar was zero invariant violations.

The first run was ugly. Roughly **one in six posts failed**, all with the same serialization error, even after retries. Nearly 2,000 transactions gave up. My first instinct was that my retry logic was weak, so I improved the backoff. It got better, not fixed. Still over a hundred failures, and the run took a full minute.

The real cause was somewhere I never would have guessed: a missing index.

My balance trigger reads postings filtered by their transaction id. There was no index on that column, so Postgres did a sequential scan to find them. And here is the part that is easy to miss: under `SERIALIZABLE`, a scan does not just read rows, it takes a broad **predicate lock** over the range it scanned. Two transactions writing completely unrelated postings would both scan, both lock wide swaths of the table, and Postgres would see overlapping read/write footprints and abort one of them as a conflict. The transactions were not actually fighting over the same data. The unindexed read was inventing the conflict.

I added one index on `postings(transaction_id)`. The failures dropped to **zero**, and the run went from about 62 seconds to 5.



That is the lesson I will keep from this week. Under `SERIALIZABLE`, an unindexed read is not merely slow. It actively manufactures conflicts that have nothing to do with your actual data. Indexes are not a performance nicety here, they are load-bearing for correctness-under-load.

One honest footnote on speed: my local numbers were p50 around 35ms, p99 around 68ms, which is above the sub-10ms target I had in mind. The cause is that I run Postgres in a Linux VM on my Mac, and every commit waits for the disk to fsync the write-ahead log through that virtualization layer. I am reporting the real numbers rather than turning off durability to get a prettier graph. For a ledger, the durable write is the entire point.

8.6 What a fresh pair of eyes caught

Before merging, I had my AI pair do a senior-level review of everything through week 4, specifically from a fintech angle. It caught a genuinely good one. Currency lived on accounts and on transactions, but nothing in the database tied them together, so a USD transaction could technically post into a EUR account. Invisible today because everything is USD, but exactly the kind of gap that becomes a real bug the day multi-currency arrives. That became a second small trigger and its own short decision record. The review also pushed the metrics endpoint off the public port (it leaks volumes and latencies) and turned a few raw database errors into typed ones the API can map cleanly.

That is the deal I keep describing in this series: the AI accelerates the work and pressure-tests my thinking, and I own every decision and can explain why each line exists. The currency catch is a good example. It suggested the gap, I decided how to close it and wrote down why.

8.7 Where this leaves us

The ledger now posts transactions atomically, stays correct under heavy concurrency, enforces its core invariant in two independent layers, and has the metrics to watch contention. The stress test runs 10,000 concurrent posts and the books balance to the cent, every time.

What is still missing is a way to actually call any of this over the network. Everything so far is exercised by tests. Next week is the REST API: chi, real endpoints to create accounts and post transactions, proper validation, and RFC 7807 error responses, all sitting on top of the service this week built. That is when the ledger stops being a test suite and starts being something you can curl.

The repo is open source at [**github.com/sohag-pro/go-ledger**](https://github.com/sohag-pro/go-ledger). Follow along, or go read your own database's docs on predicate locks before they teach you the hard way.

CHAPTER 9

Week 4 Interview Q&A

Interview-style questions for the Week 4 work: the `TransactionService`, the `RunInTx` `SERIALIZABLE` retry loop, the deferred balance trigger and the per-account currency trigger, the Prometheus metrics, the 10,000-post stress test, and ADR-004 and ADR-005. Every question is answerable from this repo's code, ADRs, and tests.

9.1 Concurrency model

9.1.1 1. Walk me through what happens when two requests post transactions that touch the same account at the same time.

What a strong answer covers:

- Each `Post` runs in its own `SERIALIZABLE` transaction via `RunInTx`; Postgres's SSI tracks read/write dependencies between them.
- If committing both would violate serial-equivalent ordering, Postgres aborts one with `SQLSTATE 40001`, often only at `COMMIT` time.
- The adapter catches that, rolls back, waits a jittered backoff, and

replays the whole unit of work; the loser eventually commits once the winner is done.

- The ledger is never left unbalanced: a conflicting transaction either commits in full or not at all.

9.1.2 2. Why **SERIALIZABLE** plus retry instead of **READ COMMITTED** with **SELECT FOR UPDATE**?

What a strong answer covers:

- **SERIALIZABLE** makes correctness the database's job; the application cannot forget to lock the right rows in the right order, which is the failure mode of pessimistic locking (ADR-004).
- Pessimistic locking serializes access to hot accounts by blocking; optimistic lets non-conflicting work proceed and pays only for actual conflicts.
- The trade is that conflicts cost retries rather than blocked connections, and `fn` must be safe to run more than once.
- Defends against the “what if someone adds a new write path” risk: a future code path can't silently skip a lock it never knew about.

9.1.3 3. **Serialization conflicts often surface at COMMIT, not mid-transaction. How does RunInTx account for that?**

What a strong answer covers:

- The retry loop watches both the result of `fn` and the result of `tx.Commit`; either returning 40001/40P01 triggers a replay.

- A naive loop that only checks `fn`'s error would miss the common case and leak the failure to the caller.
- `isSerializationFailure` classifies via `pgconn.PgError` codes (40001 serialization failure, 40P01 deadlock), the two worth retrying.
- On a non-retryable error it returns immediately; there is a test (`TestRunInTxNonRetryablePropagates`) that pins this.

9.1.4 4. Your retry backoff is exponential with full jitter. Why the jitter specifically?

What a strong answer covers:

- Without jitter, a crowd of transactions that conflicted will all back off the same amount and retry in lockstep, colliding again, a thundering herd.
- Full jitter (`retryBackoff` returns a random duration in `[0, exp]`, capped) de-synchronizes retriers so they spread out and clear.
- Backoff is bounded (25 attempts, cap 100ms) and respects context cancellation while waiting.
- Exhaustion returns a typed `domain.ErrConflict`, not a raw pg error, so transport can map it to 503.

9.2 Enforcing the invariant in the database

9.2.1 5. The balance invariant is already in the Go domain. Why also enforce it in Postgres, and how?

What a strong answer covers:

- Defense in depth: the domain gives a fast, clean error, but the database guarantees the invariant holds against a bad migration, a direct `psql` write, or a second service (ADR-004).
- A row-level `CHECK` can't express it because the sum spans many posting rows.
- Migration 0002 uses a `DEFERRABLE INITIALLY DEFERRED` constraint trigger that fires at `COMMIT`, after all postings are in, and rejects any transaction whose postings don't sum to zero.
- Proven by `TestUnbalancedRejectedByTrigger`, which inserts raw unbalanced rows and asserts `COMMIT` fails.

9.2.2 6. Why `DEFERRABLE INITIALLY DEFERRED` rather than a trigger that fires on each insert?

What a strong answer covers:

- A transaction is built from multiple posting inserts; after the first insert the set is not yet balanced, so an immediate per-row check would reject every valid transaction.
- Deferring to `COMMIT` means the check sees the complete set, regardless of how many statements inserted the rows.
- It is independent of insert order and of which client wrote the rows.
- The trade: it is `FOR EACH ROW` (constraint triggers must be), so it runs `N` times for an `N`-leg transaction; `N` is tiny, so the repeated

SUM is negligible, and the migration comments say so to stop a wrong “optimization.”

9.2.3 7. (Hard) The stress test went from roughly 1 in 6 posts failing to zero failures after one change. What was it, and why did it matter so much?

What a strong answer covers:

- The balance trigger reads postings by `transaction_id`, and there was no index on that column, so the read was a scan.
- Under SSI, a scan takes broad predicate locks, which manufacture false-positive serialization conflicts between transactions that don’t actually conflict.
- Adding `postings_transaction_idx` (migration 0002) made the trigger’s read a narrow index lookup, collapsing the conflict rate to zero and cutting runtime from about 62s to 5s.
- The lesson: under `SERIALIZABLE`, an unindexed read is not just slow, it actively creates conflicts. Indexes are load-bearing for concurrency, not just performance.

9.2.4 8. You added a second trigger for currency. What gap did it close?

What a strong answer covers:

- Currency lives on accounts and on transactions, but postings carry only an amount, so nothing tied a transaction’s currency to each account’s currency (ADR-005).

- Without it, a USD transaction could post into a EUR account; invisible at single-currency v1, but a latent integrity hole.
- Migration 0003 adds an immediate AFTER INSERT trigger that rejects a posting whose account currency differs from its transaction currency.
- It is immediate (not deferred) because the account and transaction already exist at insert time, and its reads are primary-key equalities, so the SSI footprint is negligible. Covered by `TestCurrencyMismatchRejectedByTrigger`.

9.3 Architecture and error handling

9.3.1 9. Where does the transaction boundary live, and why is the service thin?

What a strong answer covers:

- The domain owns a `Tx` unit-of-work interface and `Repository.RunInTx`; the adapter owns isolation and retry; the service composes the work inside `RunInTx`.
- `TransactionService.Post` validates up front, times the operation, records metrics, logs, and maps errors; it holds no SQL and no isolation knowledge.
- This keeps the `SERIALIZABLE`/retry detail in one place (the adapter, which knows pg error codes) and makes the service the single entry point REST and gRPC will both call.
- `RunInTx` is a general seam, so Week 6 can write the audit-log row inside the same transaction as the posting.

9.3.2 10. How do callers tell a transient conflict apart from a real failure, and why does that distinction matter for an API?

What a strong answer covers:

- Retry exhaustion returns `domain.ErrConflict` (transient), wrapping the `SQLSTATE` for logs; a duplicate id returns `domain.ErrDuplicateTransaction`.
- A transport layer maps `ErrConflict` to 503 (retry me) and a validation failure to 4xx, not a blanket 500.
- Returning a typed error instead of a raw `postgres: ... string` means callers match on `errors.Is`, not on text.
- An unbalanced transaction returns the domain error unchanged from `Post`, so it becomes a 4xx, not a server error.

9.3.3 11. You validate the transaction in the service, but not inside the retried unit of work. Walk through that decision.

What a strong answer covers:

- Validation happens once at the public entry points (`TransactionService.Post` and the convenience `Repository.CreateTransaction`), before the transaction starts.
- `txRepo.CreateTransaction` trusts that `t` is already valid, so validation does not re-run on every retry.
- Fast-fail: an unbalanced transaction never opens a database connection.

- The cost is that `txRepo` is an internal type with a documented precondition rather than a defensively-validating public one.

9.4 Observability and operations

9.4.1 12. What did you instrument, and where is the metrics endpoint exposed?

What a strong answer covers:

- A histogram `transaction_post_duration_seconds` labeled by outcome, and a counter `transaction_post_serialization_retries_total` so contention is visible, plus standard `go_/_process_` collectors.
- The scrape endpoint runs on a separate server bound to loopback (`127.0.0.1:9090`), not the public API port, because metrics leak volumes, latencies, and retry rates (ADR-004).
- The public liveness check stays `GET /healthz`; in production `/metrics` returns 404 on the public interface.
- A scraper reaches metrics over the private network or an SSH tunnel.

9.4.2 13. (Hard) Your stress test runs 100 goroutines but you say the real concurrency is lower. Explain.

What a strong answer covers:

- The true ceiling on simultaneous transactions is the connection pool's `MaxConns`, not the goroutine count; extra goroutines block on

pool acquisition.

- The test sets `MaxConns` to 25 explicitly and logs it, so “100 goroutines” means up to 25 transactions truly concurrent at Postgres (ADR-004).
- Quoting the goroutine count would overstate the contention; the honest number is the pool cap.
- `NewPool` also sets statement, lock, and idle-in-transaction timeouts so a stuck operation can’t hold a connection indefinitely.

9.5 Testing

9.5.1 14. How do you test the retry logic deterministically, given real serialization conflicts are racy?

What a strong answer covers:

- `RunInTx` takes a function, so a test can pass an `fn` that returns a synthetic `pgconn.PgError{Code: "40001"}` on the first call and `nil` after, exercising retry-then-commit without a real conflict.
- `TestRunInTxRetriesThenCommits` asserts exactly two attempts and that the retries counter moved by one; `TestRunInTxExhaustionReturnsConflict` asserts a persistent conflict ends as `ErrConflict`.
- The full stress test still exercises real contention end to end; the unit tests pin the edges the stress test hits only incidentally.
- These lifted the adapter’s coverage without depending on flaky timing.

9.5.2 15. (Hard) The integration tests passed locally but failed in CI with “connection reset by peer.” What happened and how did you fix it?

What a strong answer covers:

- The container helper waited only for port 5432 to be listening, but Postgres opens that port during initdb and then restarts it, so the port-open signal precedes real readiness.
- Locally on a slow, serial container runtime it never raced; in CI, parallel container startup hit the gap and goose got connection resets.
- Fix: wait on the log line “database system is ready to accept connections” with `WithOccurrence(2)` for the initdb-then-server double start.
- Broader point: container readiness is about the service accepting queries, not a TCP port being open; the test’s correctness depended on the wait strategy.

9.6 Defending the stack

9.6.1 16. Someone argues **SERIALIZABLE** is too slow and you should drop to **READ COMMITTED** for throughput. How do you respond?

What a strong answer covers:

- For a ledger, correctness under concurrency is the product; **READ**

COMMITTED would let anomalies (lost updates, write skew) through that double-entry exists to prevent.

- The measured cost is retries under contention, and with the right index plus jittered backoff the test commits all 10,000 posts with zero failures.
- If a specific hot path ever needs it, the optimization is a narrower one (better indexing, batching, or targeted FOR UPDATE), not weakening isolation globally.
- The latency baselines (p50 about 35ms, p99 about 68ms on a VM) are dominated by WAL fsync, not isolation, and durability is non-negotiable for money.

9.6.2 17. Defend pgx over database/sql here, given Week 4 leans on transaction control.

What a strong answer covers:

- `RunInTx` needs explicit `BeginTx` with `pgx.Serializable`, typed error codes via `pgconn.PgError`, and a pool it can tune (`NewPool` sets `MaxConns` and `timeouts`); `pgx` exposes all of this cleanly.
- The `sqlc`-generated queries bind to the `pgx` transaction via `WithTx`, so the same typed queries run inside or outside a transaction.
- `database/sql` would abstract away the Postgres-specific error codes and some pool controls the retry logic relies on.
- `goose` still uses `database/sql` for migrations via the `pgx` `stdlib` driver, so each tool is used where it fits.

≡ go-ledger

WEEK 5

01 Designing a REST API for a Payment Ledger

02 Week 5 Interview Q&A

CHAPTER 10

Designing a REST API for a Payment Ledger

Open your banking app and scroll the statement. Every row has a little running balance on the right: after this coffee you had 4,210, after that salary you had 54,210, and so on down the list. It feels like each of those numbers was saved next to the transaction when it happened. It was not. That number does not exist anywhere until you ask for it, and producing it correctly, in pages, fast, turned out to be the most interesting thing I built this week.

For four weeks go-ledger has been a thing that only its own tests could talk to. This week I gave it a REST API and put it online. As of now you can actually curl it at `go.sohag.pro`. This is post 5 of 14.

10.1 Resources and verbs, not remote procedures

A ledger has a small, sharp set of nouns: accounts and transactions. So the API is boring in the good way, just those resources and the standard verbs:

accounts	
POST	/v1/accounts create an account
GET	/v1/accounts/{id} read one
GET	/v1/accounts/{id}/balance current balance
GET	/v1/accounts/{id}/statement postings, with running balance

transactions	
POST	/v1/transactions post a balanced transaction
GET	/v1/transactions/{id} read one

two nouns, accounts and transactions; the verbs are
just plain HTTP methods, never a custom action

People sometimes ask why not GraphQL, since it is the fashionable default for a new API. GraphQL earns its keep when clients need to shape wildly different views over a big, interconnected graph, and when over-fetching is a real problem. A ledger is the opposite of that. The resource set is tiny and well defined, the relationships are obvious, and the queries that matter (“what is this account’s balance”, “show me this account’s statement”) are known up front. GraphQL would buy me a flexible query language I do not need and hand me N+1 queries and caching headaches I would rather not have. REST over JSON maps cleanly onto these resources, it is curtable and cacheable, and everyone already understands it. gRPC is still coming later for internal service-to-service calls, sharing the same core, but the public front door is REST.

10.2 Money on the wire

Here is the first decision that matters for a payment API: how does an amount look in JSON? go-ledger sends money as a signed integer count of the smallest unit, plus a currency code:

```
1 { "amount": 10000, "currency": "USD" }
```

That is 100.00 dollars, as 10,000 cents. No decimal point, no floating point, no string parsing at the edge. It maps one to one onto the `int64` the ledger uses internally, so the API is exactly as precise as the ledger is. This is the same choice Stripe and most payment APIs make, and for the same reason: the moment you let `100.00` become a float somewhere, you have invited rounding error into a place where money lives. A debit posting is a positive amount, a credit is negative, and a transaction's postings still have to sum to zero. Posting that coffee sale looks like this:

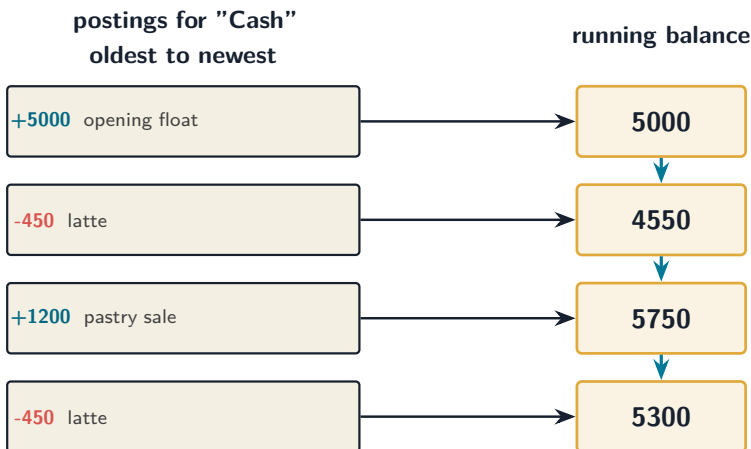
```
1 POST /v1/transactions
2 {
3   "currency": "USD",
4   "postings": [
5     { "account_id": "...cash...", "amount": 450, "description": "latte"
6       },
7     { "account_id": "...revenue...", "amount": -450, "description": "latte"
8       }
9   ]
10 }
```

Two legs, plus 450 and minus 450, summing to zero. The API hands the request to the same domain code and the same database triggers from the earlier weeks, so all the invariants still hold. The HTTP layer

is thin on purpose: it translates JSON to domain types, calls a service, and maps any error to a clean status code. An unbalanced transaction comes back as a 422, a missing account as a 404, a write conflict as a 503, all as RFC 7807 `problem+json`.

10.3 The statement, and the number that is not stored

Back to that running balance. A statement is a list of the postings that touched one account, newest first, and next to each one, the balance of the account as of that posting. Remember the rule from week 3: balances are never stored, they are summed from the postings. So the running balance on row N is the sum of every posting up to and including row N.



each running balance is the previous balance plus this posting; the total carries forward down the column

In SQL, that running total is a window function: `SUM(amount) OVER (ORDER BY created_at, id)`. It sums the postings in order, carrying the total forward row by row. Easy enough, until you remember the statement is paginated. A page shows maybe 50 rows out of an account's thousands. If I compute the window over just the 50 rows on the page, the running balances are wrong, they restart from that page instead of from the beginning of the account's history. The window has to see the whole history even when I only return a slice of it. So the query computes the running balance over all of the account's postings first, then slices out one page.

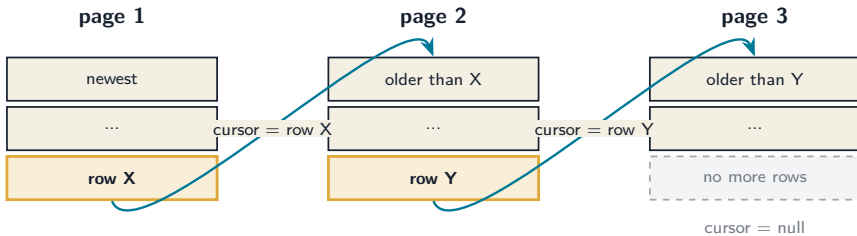
That is honestly expensive: each page scans the account's full history to rebuild the running totals, because I refuse to store a balance anywhere (storing one is exactly the drift bug double-entry exists to prevent). At this project's scale it is a non-issue, and the index from week 4 makes the scan a tight range. If it ever becomes a problem, the fix is a cached rollup rebuilt from the postings, never a mutable stored balance. The history stays the only truth.

10.4 Paging without lying to the user

The other half of statements is how you ask for the next page. The obvious way is “limit 50, offset 50, offset 100”, and it is also subtly broken. If someone posts a new transaction while you are paging, every offset shifts by one, and you either see a row twice or miss one entirely. For a bank statement, silently skipping a line is not a great look.

So go-ledger uses keyset pagination. Instead of “skip 50 rows”, each

page hands back an opaque cursor that points at the exact last row it showed, and the next page asks for “everything older than this row”:



each page anchors on the last row of the page before it, not on an offset count

The cursor is the row's (`created_at`, `id`) pair, base64-encoded so the client treats it as opaque. Because it anchors on a real row rather than a count, new inserts at the top do not shift anything underneath you. Pages stay stable. When a page comes back shorter than the limit, that is the end, and the response says `next_cursor: null`.

10.5 When the query generator pushed back

A small war story. I write SQL by hand and use `sqlc` to generate type-safe Go from it. My first version of the statement query put the window function in a subquery and used a tuple comparison, `(created_at, id) < (cursor)`, for the keyset. Postgres is perfectly happy with that. `sqlc` was not: its analyzer could not resolve the subquery alias and refused to generate. I tried expanding the comparison out longhand. Still no. What finally worked was moving the window into a CTE (a `WITH` block) with plain unqualified columns.

The lesson stuck with me: sqlc has its own SQL analyzer, separate from Postgres, and a query the database accepts can still need restructuring for the generator to understand it. That is the tax for type-safe queries with no ORM in the middle, and I will pay it, but it is worth knowing the tax exists. I cover the actual behavior with an integration test against a real Postgres, because sqlc only proves it can parse and type the query, not that it returns the right rows.

10.6 The docs cannot drift

One thing I am quietly proud of: I never write the OpenAPI spec by hand. The API is built with huma, where each endpoint is a typed Go function, and the spec is generated from those same functions. There is a test that fails the build if the committed spec does not match what the handlers produce. So the interactive docs at `/playground` and the spec at `/openapi.json` are always exactly the running API, not a hopeful description of it that rots over time. Adding an endpoint and forgetting to document it is not possible here, the test catches it.

10.7 It is real now

The quiet milestone this week is that go-ledger stopped being a test suite. For four weeks the server ran with no database at all, deliberately, because nothing it served needed one. This week the endpoints need real persistence, so the server now connects to Postgres, runs its own migrations on startup, and refuses to boot without a database, because a ledger API with no ledger behind it should not pretend to

work.

That also meant standing up Postgres on the actual server for the first time: a native install, a dedicated database and user listening only on localhost, tuned down to fit a 1 GB box, with a nightly backup. Then I pushed, the pipeline built and deployed, and a few seconds later I created an account and posted a transaction against the live API and watched the balance come back correct. The thing works in the world now, not just on my laptop.

10.8 The AI companion, week 5

Same arrangement as every week: I build this with Claude as a pair and stay honest about the split. This week it wrote a lot of the mechanical surface, the handler structs, the error mapping, the fake repository for the HTTP tests, and it was genuinely useful when sqlc started rejecting my query, working through the CTE rewrite with me. The shape of the API, the choice to avoid GraphQL, money as integer minor units, keyset over offset, the decision to keep balances derived even when it makes statements more expensive, those were mine, argued out and written down in **ADR-006**. The deal holds: it accelerates, I decide and understand.

10.9 Where this leaves us

The ledger has a front door now. You can create accounts, post transactions, read balances, and pull a paginated statement with a

running balance, all over a clean REST API with generated docs, live on the internet.

What it does not have yet is safety against the thing that haunts every payment API: the retry. A client posts a payment, the network drops the response, the client retries, and now you have charged someone twice. Next week is idempotency keys and an immutable audit log, the two patterns that make a payments API boringly safe to call. That is where this gets properly fintech.

The repo is open source at [**github.com/sohag-pro/go-ledger**](https://github.com/sohag-pro/go-ledger). Go curl it, or go read why your favorite API uses keyset pagination and never told you.

CHAPTER 11

Week 5 Interview Q&A

Interview-style questions for the Week 5 work: the v1 REST API built with huma on a chi router, the account statement endpoint (running balance + keyset paging), per-posting descriptions, money on the wire, the default-tenant seam, error mapping, the server's database wiring with startup migrations, and ADR-006. Every question is answerable from this repo's code, ADRs, and tests.

11.1 API design

11.1.1 1. Walk me through the v1 API surface and how a request flows from chi to the database.

What a strong answer covers:

- chi is the router with a middleware chain (request id, recovery, slog request logging); huma rides on it via the humachi adapter and owns operations, validation, and error formatting.
- A request hits a typed huma operation (input struct validated from tags), the handler calls an application service (AccountService / TransactionService), which calls the repository port, which runs sqlc

queries on pgx.

- Six endpoints: create/get account, balance, statement, create/get transaction.
- The transport is thin: handlers translate between JSON and domain types and map errors; no SQL or business rules live there.

11.1.2 2. huma generates the OpenAPI spec from the handlers. Why did you choose that over hand-writing the spec or using go-playground/validator plus a separate generator?

What a strong answer covers:

- One source of truth: validation, problem+json errors, and the spec all come from the same typed handler, so the published docs cannot drift from the running API (there is a drift test that fails CI if `api/openapi.yaml` is stale).
- The build plan's literal wording (go-playground/validator, separate generator) predates the huma decision; huma's tag validation supersedes it and removes three moving parts.
- chi stays the router, so the locked decision holds; huma is a layer on top, not a replacement.
- Cost named: huma owns request decode/encode and uses its own validation tag dialect, so very custom responses mean working within its model.

11.1.3 3. How is money represented on the wire, and why?

What a strong answer covers:

- A signed integer count of minor units plus a currency code (`{"amount": 10000, "currency": "USD"}`), mapping 1:1 to the internal `int64`.
- No floating point and no decimal string parsing at the boundary, so the API is as exact as the ledger.
- This is the common payment-API convention (Stripe and others).
- The alternative (decimal strings) was rejected: it adds parsing and per-currency scale validation for no gain (ADR-006).

11.1.4 4. There is no auth yet, but the schema is multi-tenant. How does a request get a tenant?

What a strong answer covers:

- A single default tenant (`DEFAULT_TENANT_ID`, with a fixed fallback) is injected by the API layer into every service call; tenancy is not in URLs or a client header.
- When auth lands, it populates the same tenant value from a token instead, with no change to any resource URL.
- Rejected alternatives: a trusted `x-Tenant-ID` header (unauthenticated, spoofable) or tenant-in-path (bakes tenancy into the resource hierarchy).
- The repository methods are already tenant-scoped, so the seam is in place.

11.2 Account statement

11.2.1 5. Explain the statement endpoint: what it returns and how it paginates.

What a strong answer covers:

- `GET /v1/accounts/{id}/statement` returns the account's postings, newest first, each with the running balance as of that posting, plus an optional `next_cursor`.
- Paging is keyset (cursor) on `(created_at, id)`: the cursor is an opaque base64 token of the last entry's position, and the next page returns entries strictly older than it.
- A full page hands back a cursor; a short page returns `next_cursor: null`, signaling the end.
- Keyset paging is stable under concurrent inserts in a way offset paging is not.

11.2.2 6. Why keyset pagination instead of limit/offset?

What a strong answer covers:

- Offset can skip or duplicate rows when new postings are inserted mid-paging; keyset anchors on a real row position, so pages stay stable.
- Keyset is also cheaper at depth: no scanning past `N` rows to reach the offset.
- The cursor encodes `(created_at, id)`; `id` (the posting id) is the unique tiebreaker, so two postings sharing a timestamp still page determin-

istically.

- The trade is a slightly more complex cursor and that you page forward in one direction.

11.2.3 7. (Hard) The running balance needs every prior posting, but a page returns only N rows. How do you compute it correctly, and what does that cost?

What a strong answer covers:

- The query is a CTE that computes `SUM(amount) OVER (ORDER BY created_at, id)` over the account's full posting history, then a keyset filter and limit select one page from it.
- A window function applied only to the page's rows would compute a per-page sum, not the absolute running balance; the window must see the whole history.
- Because balances are derived and never stored (ADR-003), this scans the account's history per page, served by the `(tenant_id, account_id)` index.
- It is $O(\text{history})$ per page, fine at v1 scale; the future optimization if it ever bites is a materialized running balance rebuilt from postings, never a mutable primary balance.

11.2.4 8. (Hard) sqlc rejected your first statement query. What was the issue and how did you resolve it?

What a strong answer covers:

- The first version used a windowed derived subquery aliased `s`

and a row-value tuple comparison (`s.created_at, s.id`) < (...) in the WHERE; sqlc's analyzer could not resolve the alias there.

- Rewriting the keyset as an expanded comparison did not help; moving the window into a CTE with unqualified columns did.
- The lesson: sqlc uses its own analyzer, so some valid Postgres (windowed derived tables, row-value comparisons) needs restructuring to generate.
- The behavior is verified by an integration test against real Postgres, since sqlc only checks that it can parse and type the query.

11.3 Data and error handling

11.3.1 9. You added a per-posting description. Where is it validated and bounded?

What a strong answer covers:

- `domain.Posting` carries an optional `Description`, bounded at `MaxPostingDescriptionLen` (256) and checked in `Posting.Validate`.
- Migration 0004 adds the column with a matching CHECK (`char_length (description) <= 256`), so the database enforces the same bound.
- It appears on every posting in requests and responses, including statement entries.
- Defense in depth, consistent with how the other invariants are enforced in both the domain and the database.

11.3.2 10. How do domain errors become HTTP responses?

What a strong answer covers:

- A single `toHumaErr` mapper turns domain errors into huma status errors, which render as RFC 7807 `application/problem+json`.
- Not-found to 404, duplicate id to 409, an exhausted serialization conflict (`ErrConflict`) to 503, validation and invariant failures (unbalanced, currency mismatch, too few postings, bad description) to 422, and anything unrecognized to a 500 that does not leak internals.
- Returning the domain error unchanged from the service lets the handler map it; an unbalanced transaction becomes a 422, not a server error.
- This keeps error semantics in one place rather than scattered across handlers.

11.3.3 11. The plan listed five endpoints; you shipped six. Why, and is that scope creep?

What a strong answer covers:

- The sixth is the account statement, a core ledger feature (listing a single account's entries with a running balance); a ledger without one is hard to defend.
- It reuses the existing schema and the derived-balance model, so it is a natural extension, not a new subsystem.
- It is bounded: keyset paging, a max page size, and the same tenant

and currency handling as the rest.

- Knowing when an addition is in the spirit of the system versus genuine creep is the judgment being shown.

11.4 Server and operations

11.4.1 12. The server now depends on Postgres. How are migrations applied, and why that way?

What a strong answer covers:

- `cmd/server` runs the embedded goose migrations on startup, before serving, using a short-lived `database/sql` handle over the `pgx` `stdlib` driver.
- On a single instance this is the simplest correct option: the binary that needs a column also creates it, atomically with the deploy.
- It does not scale to multiple instances (they would race); the upgrade path is moving the same `goose.Up` into a CI step.
- `DATABASE_URL` is required and the server fails fast without it: a ledger API with no database must not serve.

11.4.2 13. Walk me through how the server is wired now: router, services, and the two HTTP servers.

What a strong answer covers:

- `run` loads config, applies migrations, opens the tuned pool (`NewPool`, bounded conns + timeouts), builds the account and transaction

services, and constructs the chi router.

- The router mounts the landing page, the Scalar playground, and the huma API (`/v1/*`, `/healthz`, `/openapi.*`); metrics stay on a separate loopback server (ADR-004).
- Middleware: request id, recovery, and a structured slog logger that records method, path, status, size, duration, and request id.
- `RealIP` is intentionally omitted because it trusts spoofable forwarding headers without a trusted-proxy allowlist.

11.4.3 14. (Hard) How did you test the API without standing up a database for every test?

What a strong answer covers:

- Handler tests run against an in-memory `fakeRepo` that implements the `domain.Repository` port, so the full HTTP path (routing, validation, error mapping, serialization) is exercised with no database.
- The fake covers the happy path and every 4xx: bad enum/pattern to 422, missing resource to 404, unbalanced to 422, plus statement pagination with running balances.
- The real database paths (the statement window query, the balance trigger, concurrency) are covered separately by testcontainers integration tests.
- This keeps the handler tests fast and deterministic while still proving the SQL against real Postgres elsewhere.

11.5 Defending the stack

11.5.1 15. Why a REST API at all, and not gRPC or GraphQL for the public surface?

What a strong answer covers:

- REST over JSON is the lowest-friction public surface: curlable, cacheable, universally understood, and it maps cleanly to the ledger's resources (accounts, transactions) and verbs.
- gRPC is still coming for internal/service-to-service use (a later week), sharing the same domain core; the two are not exclusive.
- GraphQL's flexible query graph buys little for a small, well-defined resource set and adds $N+1$ and caching complexity; the API avoided it deliberately (the blog title says as much).
- The OpenAPI spec and playground give REST much of the discoverability people reach to GraphQL for.

11.5.2 16. Defend pgx + sqlc again now that there is a window function and keyset pagination in play.

What a strong answer covers:

- sqlc generates type-safe Go from hand-written SQL, so the window/CTE statement query is explicit and reviewable, and its parameters and row type are checked at generate time.
- When sqlc could not analyze the first query shape, the SQL was restructured rather than hidden behind an ORM that might have generated something slower or surprising.
- pgx gives the typed error codes and pool tuning the rest of the system relies on (serialization retries, timeouts).

- An ORM would abstract the exact SQL away, which is the opposite of what a ledger wants for its read and write paths.

≡ go-ledger

WEEK 6

01 Idempotency Keys and the Immutable Audit Log

02 Week 6 Interview Q&A

CHAPTER 12

Idempotency Keys and the Immutable Audit Log

You are paying for something on your phone, you tap Pay, and the spinner just sits there. No confirmation, no error, nothing. Did it go through? Your thumb hovers over the button. Tap it again and maybe you pay twice. Do nothing and maybe you did not pay at all. We have all been in that half second of doubt, and the reason most of us tap again without really panicking is that somewhere a backend engineer already solved this for us. The second tap does not charge you twice. That property has a name, idempotency, and this week I built it into go-ledger, along with its close cousin: an audit log that can record what happened and never let anyone quietly rewrite it.

This is post 6 of 14. Last week the ledger got a REST API and went live at go.sohag.pro. This week is about making that API safe to retry and easy to trust.

12.1 The retry problem is not rare, it is the default

Here is the uncomfortable truth about networks: a request that times out did not necessarily fail. Your `POST /v1/transactions` left the phone, reached the server, posted the transaction, and then the response

got lost on the way back. From the client's point of view that looks identical to a request that never arrived. So the client retries, because retrying is the correct thing to do when you are not sure. And now the server sees the same payment twice.

Without protection, that is two transactions, two movements of money, one angry customer. The fix is an idempotency key: the client generates a unique string once per intended action and sends it on every retry of that action.

```
1 POST /v1/transactions
2 Idempotency-Key: 7f3a9c2e-pay-dinner-share
3 { "currency": "BDT", "postings": [ ... -600 ... +600 ... ] }
```

The contract is simple to state and surprisingly interesting to build:

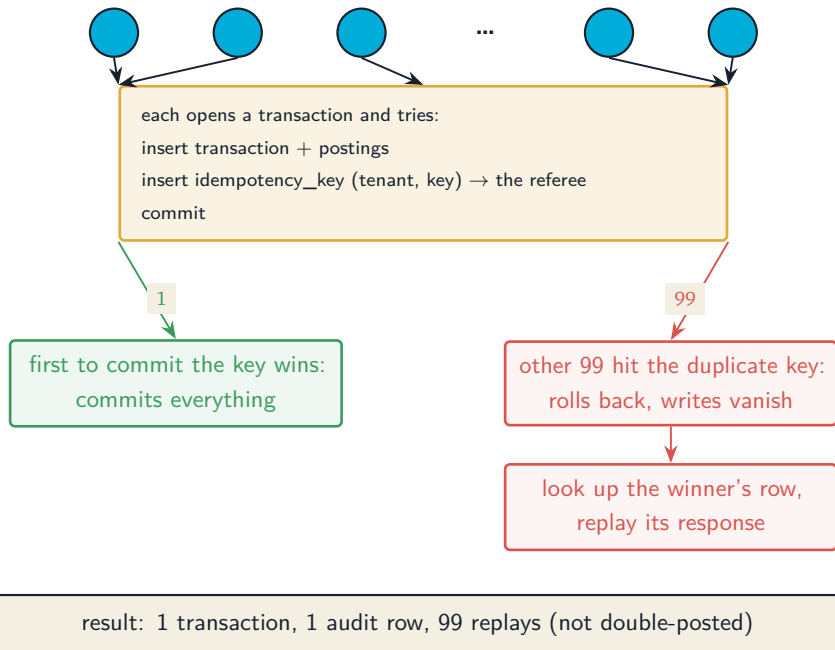
- First time the server sees this key: do the work, remember the result.
- Same key again, same request: do not do the work again, return the original result.
- Same key, but a different request body: refuse, because the client is confused and reusing a key for two different things is a bug worth shouting about (HTTP 409).

12.2 The naive version has a hole in it

The obvious implementation is: look up the key in a table, if it is there return the saved response, if not then post the transaction and save the response. Read, then decide, then write.

That works fine until two copies of the same request arrive at nearly the same instant, which is exactly what a double tap or an aggressive retry produces. Both requests look up the key. Neither finds it, because neither has finished yet. Both decide “new key, go ahead.” Both post the transaction. You are back to charging twice, except now it only happens under load, which is the worst kind of bug because your tests never see it.

The check and the write have to be one atomic step, and the database is the only thing in this picture that can make that guarantee. So instead of checking first, I let the database’s uniqueness constraint be the referee. The idempotency key row goes into a table whose primary key is the tenant plus the key. Inserting it inside the same database transaction that posts the ledger transaction means the whole thing commits together or not at all:

100 identical requests, same Idempotency-Key

The key insight is that the losing requests do not just get rejected. When a request loses the race, its entire transaction rolls back, so the transaction and postings it optimistically wrote vanish too. Then it reads back the row the winner committed, loads that original transaction, and returns it as if it had done the work. From the client's side, all 100 retries got a clean, identical answer. Under the hood, money moved exactly once.

To make the “same key, different body” case work, the stored row also holds a fingerprint of the original request: a hash of the currency and every posting. On a repeat, if the incoming request hashes to the same fingerprint it is a genuine retry and gets the replay. If it hashes

differently, someone reused a key for a different payment, and the ledger returns 409 rather than silently doing the wrong thing. I spent a little care making that fingerprint framing collision-resistant, so that two different transactions can never accidentally hash the same, but that is a detail for the repo.

12.3 The part I got wrong on the first pass

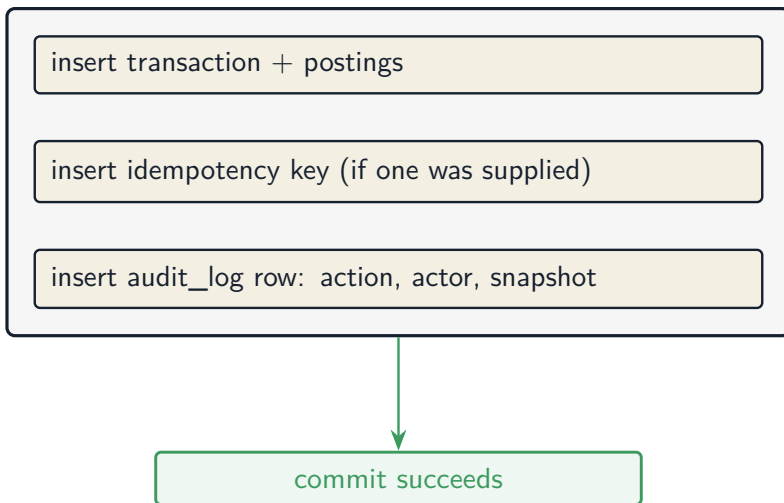
My first version of the fingerprint glued the fields together with a separator byte, which is the kind of thing that looks fine and passes every test you think to write. Then I pictured a hostile input: what if a field itself contains that separator byte? You could, in principle, craft two different transactions that produce the same glued-together string, collide their fingerprints, and slip a different payment through on a reused key. The fix was to length-prefix every field so the boundaries can never be faked. Nobody would hit this by accident, but “nobody would hit this by accident” is not a sentence you want anywhere near the code that decides whether a payment is a duplicate. I only caught it because I went looking for it, which is the whole argument for building these things yourself.

12.4 The audit log: write it once, never touch it again

The second pattern this week is the audit log. A ledger already keeps immutable postings, so why a separate log? Because the postings tell you *what the balances are*, and the audit log tells you *what happened*

and who did it. When an auditor or an incident review asks “show me every action that touched this account, in order, with the full before and after,” you want a single, honest, tamper-evident answer.

Two design decisions make it trustworthy. First, the audit row is written inside the same database transaction as the posting it describes. There is no separate “log this later” step that could fail on its own and leave you with a transaction nobody recorded. If the posting commits, its audit row committed with it. If anything fails, both roll back. They are one fact.

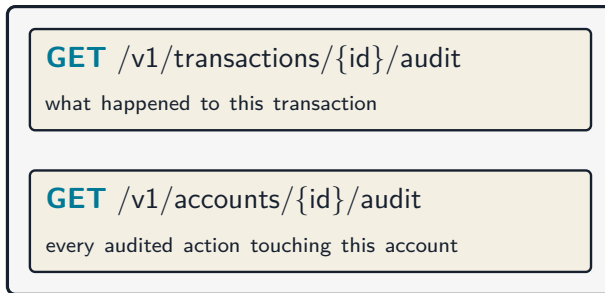


posting and its audit record are now
the same indivisible piece of history

Second, “append-only” is not just a promise in the application code, it is enforced by the database. A Postgres trigger rejects any attempt to UPDATE or DELETE a row in the audit log. Even a direct `DELETE FROM audit_log` from a psql prompt bounces off it. The only sanctioned

exception is the demo seeder that resets `go.sohag.pro` every few hours, and it has to explicitly flip a per-transaction flag to be allowed through. The application's normal path can never set that flag, so in production the log is genuinely immutable, not immutable-until-someone-writes-the-wrong-migration.

You can read the log back by transaction or by account:



The by-account view is paginated with the same keyset cursor as last week's statement endpoint, because "list everything that ever happened to a busy account" is exactly the kind of query that needs a ceiling before it faces a real production account.

12.5 Proving it, not hoping it

The definition of done for this week was a specific, slightly mean test: fire 100 requests with the same idempotency key at the same time, then check the database. Not "it returned 200 a hundred times," but the thing that actually matters: exactly one transaction row exists, exactly one audit row exists, and 99 of the responses were replays of the first. That test runs against a real Postgres in a container, with

the race actually happening, not mocked away. Watching it come back green, with the counts landing on exactly one, is a different feeling than reading that unique constraints work. That gap, between knowing a thing and having watched it hold under fire, is the entire reason I am building this in the open.

12.6 My AI companion this week

Same deal as always: I own the decisions, Claude does a lot of the typing. This week the collaboration was interesting because the work was mostly judgment, not code volume. I decided the key had to be inserted inside the posting transaction rather than checked beforehand, and Claude implemented that cleanly and wrote the 100-goroutine hammer test. But the fingerprint collision I described above surfaced during review: a reviewer pass (also Claude, wearing a different hat) flagged the separator-byte weakness, I agreed it was real, and we hardened it before it ever shipped. That is roughly the rhythm I have settled into. I set the invariants and the definition of done, the machine moves fast inside those rails, and the interesting moments are the disagreements and the “wait, what about this input” catches. A payment duplicate check is precisely the code you do not hand over without understanding every line, and I do.

12.7 Where this leaves us

go-ledger now survives retries the way a real payment API has to, and keeps a record of itself that nobody can quietly edit. The API got no

bigger in surface area, just harder to misuse, which is the good kind of boring. Next week the ledger grows a second front door: a gRPC layer sitting on the exact same domain services, so REST and gRPC are two protocols over one source of truth rather than two implementations drifting apart.

The repo is open source at [**github.com/sohag-pro/go-ledger**](https://github.com/sohag-pro/go-ledger), and the live API is at go.sohag.pro. Go tap Pay twice on something and trust the ledger to have your back.

CHAPTER 13

Week 6 Interview Q&A

Interview-style questions for the Week 6 work: the optional `Idempotency-Key` header on `POST /v1/transactions`, the exactly-once design that inserts the key row inside the posting's `SERIALIZABLE` transaction, the request fingerprint and 409-on-mismatch contract, the append-only `audit_log` written in the same transaction and enforced by a Postgres trigger, the seeder's gated purge, the keyset-paginated audit reads, and the 100x concurrent test. Every question is answerable from this repo's code, migrations (`0006`), and tests.

13.1 Idempotency design

13.1.1 1. Walk me through what happens when a client sends `POST /v1/transactions` twice with the same `Idempotency-Key`.

What a strong answer covers:

- The key is optional: when the header is present the handler builds a `*domain.Idempotency` and passes it into `TransactionService.Post`; when absent it passes `nil` and the post proceeds as before.

- First request: inside one `SERIALIZABLE` transaction it inserts the transaction and postings, inserts the `(tenant_id, idempotency_key)` row, and writes the audit row, then commits.
- Second request with the same key: the key insert hits the primary-key collision, the whole transaction rolls back, the service looks up the stored row, loads the original transaction, and returns it with `Idempotent-Replayed: true`.
- Same key with a different body: returns 409, because the stored fingerprint does not match.

13.1.2 2. Why insert the idempotency key inside the posting transaction instead of checking a table first and then posting?

What a strong answer covers:

- Check-then-act has a race: two concurrent copies of the same request both read “key absent,” both decide to post, and both create a transaction. The bug only appears under concurrency, which is where retries actually happen.
- Making the check and the write one atomic step needs the database as the referee; the unique primary key `(tenant_id, idempotency_key)` is that referee.
- Because the key insert shares the transaction with the postings, a losing request’s postings roll back too, so nothing partial survives.
- The result is exactly-once without an application-level lock or a distributed mutex.

13.1.3 3. How does the losing request end up returning the right response after it rolls back?

What a strong answer covers:

- `InsertIdempotencyKey` maps the PK collision (constraint `idempotency_keys_pkey`) to the internal sentinel `domain.ErrDuplicateIdempotencyKey`.
- `Post` catches that specific error (only when `idem != nil`) and calls a `replay` helper.
- `Postgres` blocks the second insert on the same key until the first transaction resolves, so by the time the loser sees the duplicate error the winner has already committed; the loser's follow-up read (outside the transaction) is guaranteed to see the committed row.
- `replay` loads the original transaction via the stored `transaction_id`, overwrites the caller's `*t`, increments `IdempotencyReplays`, and reports `replayed = true`.

13.1.4 4. What is the request fingerprint, and why not just compare the raw request bodies?

What a strong answer covers:

- `Transaction.Fingerprint()` is a SHA-256 over the transaction's semantic content: the currency and each posting's account, signed amount, and description, in order. The transaction id is deliberately excluded.
- Comparing raw bytes would be fragile: whitespace, key order, or an echoed id would make two logically identical requests look different and defeat the replay.

- Comparing the semantic content instead means a genuine retry matches even if serialized slightly differently.
- The stored fingerprint is what distinguishes a true retry (replay) from key reuse with a different body (409 via `ErrIdempotencyConflict`).

13.1.5 5. You length-prefix each field when computing the fingerprint. What attack does that prevent?

What a strong answer covers:

- The first version joined fields with a separator byte; if a field can itself contain that byte, an attacker could shift the boundaries so two different transactions produce the same hash.
- A fingerprint collision on a reused key would let a different payment slip through as a “replay,” which is a correctness and security hole in the duplicate check.
- The fix writes each field’s length as a fixed-width prefix before its bytes, so field boundaries cannot be forged regardless of content.
- There is a targeted test with adversarial pairs (embedded NUL, boundary-shift) proving the framed fingerprints stay distinct.

13.2 Data integrity and the audit log

13.2.1 6. Why a separate audit log when postings are already immutable?

What a strong answer covers:

- Postings answer “what are the balances”; the audit log answers “what happened, when, and who did it.”
- For an incident review or an auditor, a single ordered record of actions with a snapshot is more useful than reconstructing intent from raw postings.
- In v1 it is create-only: one row per posted transaction, `action = transaction.created`, before `NULL`, after a JSON snapshot, `actor` the tenant id until auth lands.
- It is deliberately not a generic before/after diff framework yet, because nothing mutates in place (YAGNI).

13.2.2 7. How do you guarantee that every posted transaction has an audit row, and no transaction exists without one?

What a strong answer covers:

- The audit insert runs inside the same `RunInTx` closure as the transaction and postings, so they commit together or roll back together.
- There is no “log it afterwards” step that could fail independently and leave a gap.
- On the replay path no audit row is written, because that transaction rolled back and no new posting occurred; the audit log records only real creations.
- The `after` column is `NOT NULL` and the service always marshals a snapshot, so a row can never be half-written.

13.2.3 8. “Append-only” is easy to say. How is it actually enforced?

What a strong answer covers:

- A Postgres trigger on `audit_log` rejects `UPDATE` and `DELETE` (`BEFORE UPDATE OR DELETE ... FOR EACH ROW`), raising an exception; migration 0006 defines it.
- Enforcement is at the database, not just a convention in the app, so even a direct `DELETE FROM audit_log` in psql is refused.
- This mirrors the balance and currency triggers from earlier weeks: defense in depth against a buggy caller or a bad migration.
- The trigger raises with a named constraint so the failure is identifiable rather than an opaque error.

13.2.4 9. The demo seeder wipes the tenant every few hours, but the audit log rejects deletes. How do you reconcile that?

What a strong answer covers:

- The trigger has one gated exception: it allows the mutation only when the transaction-local GUC `audit.allow_purge` is set to `on`.
- The seeder sets `SET LOCAL audit.allow_purge = 'on'` at the start of its reset transaction, before the deletes; `SET LOCAL` is transaction-scoped, so it cannot leak to other pooled connections.
- The application’s normal path never sets the GUC, so in production the log stays immutable; `current_setting(..., true)` returns `NULL` when unset and the trigger falls through to the exception.

- The seeder’s delete order puts `idempotency_keys` and `audit_log` before transactions to respect the foreign keys, and there is a test that reseeds over planted rows to prove the gated purge works.

13.3 Concurrency and correctness

13.3.1 10. Your definition of done was “hammer the same key 100 times, get exactly one transaction.” What exactly does that test assert, and why that shape?

What a strong answer covers:

- It fires 100 concurrent `Post` calls with the same key against a real Postgres (testcontainers), then asserts exactly one transaction row, exactly one audit row, and that 99 responses were replays returning the same id.
- Asserting “returned 200 a hundred times” would pass even if it created 100 transactions; the counts are what prove exactly-once.
- It runs the real race rather than mocking it, so it exercises the unique-constraint referee and the rollback-then-replay path under genuine contention.
- Watching the counts land on one is the difference between believing unique constraints work and having seen it hold under fire.

13.3.2 11. RunInTx retries on serialization failures. Why does a duplicate idempotency key not get retried into an infinite loop?

What a strong answer covers:

- RunInTx only retries when the error is a serialization failure or deadlock (SQLSTATE 40001 / 40P01); it classifies via `isSerializationFailure`.
- A PK collision surfaces as `domain.ErrDuplicateIdempotencyKey`, which is not a `*pgconn.PgError` serialization code, so it is returned immediately, not retried.
- A genuine 40001 on the key insert is still wrapped such that it is detected and retried; on the next attempt it sees the committed key and gets a clean duplicate, which the service replays.
- So the two failure modes are cleanly separated: transient conflicts retry, a real duplicate replays.

13.3.3 12. Could a serialization retry cause a transaction to get two audit rows?

What a strong answer covers:

- No: RunInTx fully rolls back the transaction between attempts and re-runs the whole closure, so a retried attempt starts clean with nothing from the previous attempt persisted.
- The audit insert lives inside that closure, so it is replayed as part of the same all-or-nothing unit; only the attempt that finally commits leaves a row.

- The closure must be safe to run more than once, which it is: it does not mutate external state that survives a rollback.
- This is the same idempotent-closure contract the posting path already relied on from Week 4.

13.4 API and pagination

13.4.1 13. The audit log is queryable by transaction and by account. Why is the by-account endpoint paginated but the by-transaction one is not?

What a strong answer covers:

- A transaction has a fixed, tiny number of audit rows (one, in v1), so it is bounded by nature and a plain list is fine.
- An active account can accumulate audit rows for every transaction that ever touched it, so an unbounded query is a memory and latency risk on a real production account.
- The by-account endpoint reuses the same keyset cursor machinery as the Week 5 statement endpoint (`opaque cursor`, `next_cursor`, `newest-first`), rather than an offset.
- This was flagged in review as the one production concern before merge and closed by adding the cursor.

13.4.2 14. How does the Idempotent-Replayed header end up in the OpenAPI spec without hand-editing it?

What a strong answer covers:

- The create handler returns a `CreateTransactionOutput` with a `Replayed` `bool` field tagged as a response header; huma generates the spec from that typed output, so the header appears automatically.
- The `Idempotency-Key` request header is likewise a tagged input field, and the operation description documents the retry and 409 contract.
- `make_openapi` regenerates the committed `api/openapi.yaml`, and a drift test fails if it is stale, so the published spec cannot diverge from the handlers.
- This keeps the single-source-of-truth property from Week 5 intact.

13.5 Trade-offs

13.5.1 15. Reviewers noted several deferred items: the trigger's gated branch would silently no-op an UPDATE, `InsertIdempotencyKey` checks the constraint name rather than a generic unique-violation, and there is no `PostDuration` bucket for replay latency. Why ship with those open?

What a strong answer covers:

- Each was judged safe to defer with a reason: the gate is only ever used for DELETE by the seeder, so a gated UPDATE cannot occur

today; the constraint name only appears on a 23505, so the check is behaviorally equivalent to a unique-violation guard.

- The replay-latency gap is observability polish, not correctness; volume is already covered by the `IdempotencyReplays` and `IdempotencyConflicts` counters.
- The bar for shipping was the core invariants (exactly-once, atomicity, append-only, tenant isolation), all verified end to end by a whole-branch review, not zero cosmetic findings.
- Naming the deferrals explicitly, rather than silently leaving them, is the point: they are tracked follow-ups, not forgotten corners.

≡ go-ledger

WEEK 7

01 Adding gRPC to a Go Ledger Service

02 Week 7 Interview Q&A

CHAPTER 14

Adding gRPC to a Go Ledger Service

Picture two services inside a bank that need to talk to each other a few thousand times a second: a payments service telling the ledger “move this money.” You could have them speak JSON over HTTP, the same way your phone talks to the ledger. It works. It is also a bit wasteful: text parsing, no shared schema, no generated client, every field name a string agreement that nobody checks until it breaks in production. For machine-to-machine traffic on the hot path, teams reach for gRPC instead: a binary protocol with a typed contract both sides generate their code from. This week I gave go-ledger a gRPC front door, right next to the REST one it already had.

This is post 7 of 14. Last week was idempotency and the audit log. This week is a second way to talk to the same ledger, and the whole trick is that it is the *same* ledger.

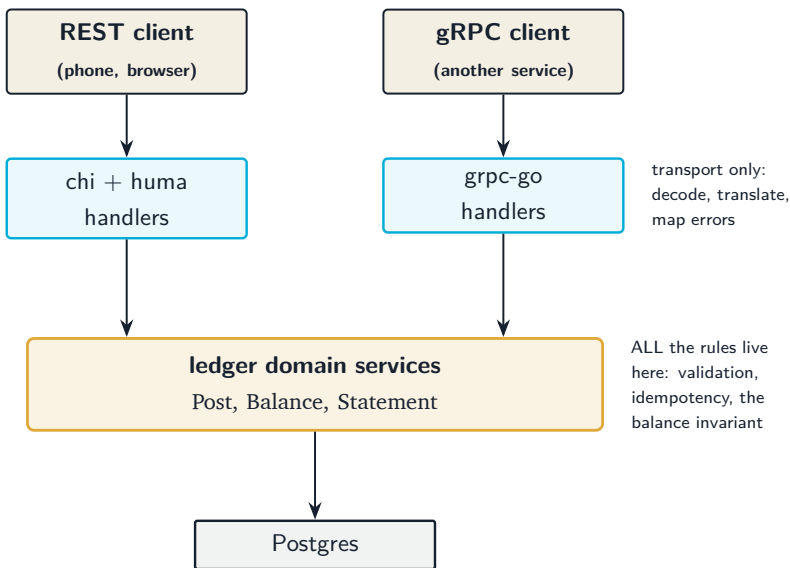
14.1 Why both, instead of picking one

REST is the friendly public front door: curlable, cacheable, understood by everyone, great for a phone app or a dashboard. gRPC is the service-to-service door: a strict `.proto` contract, generated clients in many languages, HTTP/2 under the hood, and no argument about field names because the schema is the source of truth. A real payment platform usually wants both, and go-ledger is meant to look like a

real one.

The danger with two APIs is obvious the moment you say it out loud: two front doors, two chances to implement “post a transaction” slightly differently, and now one of them has a bug the other does not. That is how a system slowly grows two personalities.

The way out is to make sure neither front door contains any actual logic. Both are thin translators that speak to one brain.



The REST handler already worked this way from Week 5: it decodes JSON, calls `TransactionService.Post`, and turns the result back into JSON. So the gRPC handler is the same shape with a different translator: decode protobuf, call the *same* `TransactionService.Post`, turn the result into protobuf. The exactly-once idempotency, the atomic audit write, the postings-sum-to-zero rule: none of that is reimplemented, because it lives in the service both doors call. The best part of this whole week

was a diff that added a new package and changed zero lines of domain code.

14.2 The contract comes first

With gRPC you write the schema before the code. Here is the shape of posting a transaction, in protobuf:

```
1 message Posting {
2     string account_id = 1;
3     int64 amount      = 2;    // minor units, signed: debit positive, credit
        negative
4     string description = 3;
5 }
6
7 message PostTransactionRequest {
8     string currency = 1;
9     repeated Posting postings = 2;
10 }
11
12 message PostTransactionResponse {
13     Transaction transaction = 1;
14     bool      replayed      = 2;    // true if an idempotency key matched an
        earlier post
15 }
```

Notice money is still a signed `int64` plus a currency string, exactly like the REST API. Same decision, same reason as post 5: no floats anywhere near money. The `.proto` is just a stricter way to write down the contract the REST API already had.

I used `buf` to manage and generate from the protos, which is the modern, boring choice: `buf lint` keeps the schema tidy, and `buf generate`

produces the Go server and client stubs using remote plugins, so there is no `protoc` toolchain to install on every machine. One `make proto` and the generated code is regenerated, byte for byte identical, every time.

A quick honest note: the plan called for generating clients in Go, Node, and Python. I shipped Go only. Verifying three language toolchains actually work is a lot of surface for a week already marked “heavy,” and the goal this week was one working client, not a polyglot demo. Node and Python are a config change I can add later. Cutting scope you said out loud is not failure, it is the plan working.

14.3 Translating errors, not inventing them

REST speaks HTTP status codes; gRPC speaks its own status codes. The domain, sensibly, speaks neither: it returns typed errors like “this transaction does not balance” or “that account does not exist.” So each front door has exactly one small function that translates domain errors into its own dialect, and they translate the *same* errors the same way:

Domain error	REST	gRPC
account not found	404	NotFound
idempotency key reused with a different body	409	AlreadyExists
postings do not sum to zero	422	InvalidArgument
write conflict, retries exhausted	503	Unavailable
anything unexpected	500	Internal

Because both mappers read from the same list of domain errors, the two protocols cannot quietly disagree about what “that is not allowed” means. And the unexpected case is deliberately vague on both sides: a client gets “internal error,” never a stack trace or a database detail.

14.4 Idempotency, the gRPC way

Last week’s `Idempotency-Key` header lets a client safely retry a payment. gRPC has no headers, but it has metadata, which is the same idea: key-value pairs that ride alongside the call. So the gRPC `PostTransaction` reads an `idempotency-key` from the request metadata and hands it to the very same `Post` method the REST handler uses. Retry the same call with the same key, and the second one comes back with `replayed = true` and the original transaction, because the exactly-once logic is not in the gRPC layer at all. It is in the service, and the service does not care which door you came through.

14.5 Proving it runs

The definition of done was concrete: post a transaction with `grpcurl`, and have a generated Go client work in an example. The server turns on gRPC reflection, which lets `grpcurl` discover the API with no `.proto` file in hand:

```
1 $ grpcurl -plaintext localhost:9091 list
2 ledger.v1.LedgerService
3
4 $ grpcurl -plaintext -d '{"currency":"USD","postings":['
5   {"account_id":"...cash...", "amount":10000},
```

```
6 {"account_id": "...revenue...", "amount": -10000}}]}' \
7 localhost:9091 ledger.v1.LedgerService/PostTransaction
```

And the automated proof: an integration test that stands up the real gRPC server over an in-memory connection, backed by a real Postgres in a container, drives it with the generated Go client (create two accounts, post between them, read the balance back), and checks the ledger nets to zero. Same test I would write for REST, one door over. The gRPC server runs on its own port next to REST and the metrics endpoint, and shuts down gracefully with them on a stop signal.

14.6 My AI companion this week

The split was sharp this week. I owned the decisions that shape the system: standard grpc-go over the fancier one-port alternative, a separate port instead of multiplexing, Go-only clients to respect the scope warning, and the rule that no domain code may change. Claude did most of the typing inside those rails: the proto, the buf setup, the handlers, the interceptors, the bufconn test. The interesting moments were, as usual, in review. A reviewer pass caught that the gRPC endpoints had no upper bound on page size while REST capped them, a real divergence and a denial-of-service foot-gun, and that a panic inside a handler was being swallowed with no log at all. Both got fixed before merge. That is the pattern I keep coming back to: the machine is fast and tireless, and my job is to know what “correct” means and to keep looking until I am sure it holds.

14.7 Where this leaves us

go-ledger now has two front doors over one brain. A phone can curl it, a service can call it over gRPC, and both get the identical rules, the identical errors, and the identical idempotency guarantees, because there is only one implementation of any of that. Next week the ledger learns to explain itself under load: OpenTelemetry tracing, structured logs tied to a trace id, and one unbroken trace from an incoming call all the way down to the SQL query.

The repo is open source at github.com/sohag-pro/go-ledger, and the REST side is live at go.sohag.pro.

CHAPTER 15

Week 7 Interview Q&A

Interview-style questions for the Week 7 work: the gRPC front door built on standard `grpc-go`, generated from `protobuf` with `buf`, the thin `internal/grpcserver` adapter over the same `ledger` services `REST` uses, the `toStatus` error mapping, idempotency over metadata, the `recovery/logging/tenant` interceptors, the shared `internal/paging` cursor, server reflection and health, the `bufconn` integration test, and `ADR-009`. Every question is answerable from this repo's code and `ADRs`.

15.1 Architecture and the shared domain

15.1.1 1. You now have REST and gRPC. Walk me through how a `PostTransaction` request flows in each, and where they converge.

What a strong answer covers:

- `REST`: `chi` + `huma` decodes `JSON` into a typed input, the handler builds domain types and calls `TransactionService.Post`. `gRPC`: `grpc-go` decodes `protobuf`, the handler builds the same domain types and

calls the same `Post`.

- They converge at the `ledger` services: all validation, idempotency, the audit write, and the balance invariant live there, not in either transport.
- Each transport only decodes, translates to and from domain types, and maps errors to its own status dialect.
- The gRPC layer (`internal/grpcserver`) added a package and changed zero domain or service code.

15.1.1.2 2. Why add gRPC at all when REST already works?

What a strong answer covers:

- REST is the public, curlable, cacheable front door for phones and dashboards; gRPC is the service-to-service door with a typed contract, generated multi-language clients, and HTTP/2.
- A payment platform typically wants both, and the project aims to look like a real one.
- gRPC's schema-first contract removes stringly-typed field agreements that only break at runtime.
- The cost is a second surface to run and secure, which the design accepts and scopes (ADR-009).

15.1.1.3 3. What is the risk of running two APIs, and how does the design neutralize it?

What a strong answer covers:

- The risk is drift: two front doors can implement the same operation

differently, so a bug lives in one but not the other, and the system grows two personalities.

- The design makes both transports thin translators with no business logic, so there is only one implementation of any rule.
- This is possible because Week 5 already made the REST handlers thin; the gRPC handler is the same shape with a protobuf translator.
- Evidence: the gRPC handlers call `s.accounts/s.txns/s.audit`, the same service handles `api.Deps` holds.

15.2 Protobuf, buf, and codegen

15.2.1 4. Why buf with remote plugins instead of a local protoc toolchain?

What a strong answer covers:

- `buf generate` with remote plugins (`buf.build/protocolbuffers/go`, `buf.build/grpc/go`) needs no local `protoc` install, so generation is reproducible on any machine and in CI.
- `buf lint` keeps the schema consistent; `buf.yaml` sets lint STANDARD and breaking FILE.
- `make proto` regenerates byte-for-byte identical output, verified by a no-diff check.
- Generated Go lives under `internal/genproto/ledger/v1/` (package `ledgerv1`), which keeps it unimportable outside the module while the in-repo example can still use it.

15.2.2 5. How does money cross the wire in the proto, and why the same as REST?

What a strong answer covers:

- Signed `int64` amount plus a string currency, identical to the REST contract and to the internal `int64`.
- No floating point near money, the same decision as ADR-002 and post 5.
- A `Posting` is `{account_id, amount, description}`; a debit is positive, a credit negative, and postings still sum to zero (enforced by the unchanged domain).
- The proto is just a stricter written form of the contract REST already had.

15.2.3 6. The plan asked for Go, Node, and Python clients. You shipped Go only. Defend that.

What a strong answer covers:

- The definition of done needs only `grpcurl` and a working Go client; verifying three language toolchains is a large surface for a week flagged heavy with scope-creep risk.
- Node and Python are a `buf.gen.yaml` change that can be added later without touching the server.
- Cutting a stated-out-loud scope item is the plan's scope discipline working, not a failure.
- Nothing about the server design blocks adding them later; the contract already exists.

15.3 Error handling and idempotency

15.3.1 7. How do domain errors become gRPC status codes, and how do you keep that consistent with REST?

What a strong answer covers:

- A single `toStatus` helper maps domain sentinels to gRPC codes, mirroring the REST `toHttpErr`: `NotFound`, `AlreadyExists`, `InvalidArgument`, `Unavailable`, `Internal`.
- Both mappers read the same domain error list, so the two protocols cannot disagree about what a given failure means.
- Uses `errors.Is` so wrapped errors still match.
- The default case returns a generic `codes.Internal` “internal error” with no stack or database detail, matching REST’s no-leak 500.

15.3.2 8. gRPC has no headers. How did you carry the idempotency key, and why does exactly-once still hold?

What a strong answer covers:

- gRPC metadata carries an `idempotency-key`, the direct analog of the REST `Idempotency-Key` header; the handler reads it from the incoming metadata.
- It is threaded into the same `TransactionService.Post`, which owns the key-inside-the-transaction mutex from Week 6.

- The response carries a typed `replayed bool` (the equivalent of the `REST Idempotent-Replayed` header).
- Because the exactly-once logic lives in the service, not the gRPC layer, retrying over gRPC gets the same guarantee as over REST, proven by the `bufconn` replay test.

15.3.3 9. Metrics and the audit log: did the gRPC path get those for free or did you wire them again?

What a strong answer covers:

- For free: `PostDuration`, `IdempotencyReplays`, and the audit write all happen inside the service layer, so a gRPC post emits the same Prometheus metrics and writes the same audit row with no gRPC-side code.
- This is the direct payoff of keeping the transports thin.
- A gRPC post is indistinguishable from a REST post at the domain and persistence layers.
- The only gRPC-specific observability is the per-RPC logging interceptor.

15.4 Interceptors, lifecycle, and the tenant seam

15.4.1 10. Describe the interceptor chain and why the order matters.

What a strong answer covers:

- Chained unary interceptors: recovery (outermost), logging, then tenant, then the handler.
- Recovery turns a handler panic into `codes.Internal` and logs the method, the recovered value, and a stack, so a panic is observable rather than silent.
- Logging emits one structured slog line per RPC (method, code, duration), mirroring the REST request-logging middleware.
- Tenant injects the default tenant into the context; handlers read it via `tenantFrom`, the same seam REST uses, so real auth later replaces only this interceptor.

15.4.2 11. There is no auth yet. How does a gRPC handler know which tenant it is acting as, and is that safe?

What a strong answer covers:

- The tenant interceptor is installed unconditionally in `NewGRPCServer`, so every handler runs with a tenant in context; handlers call `tenantFrom(ctx)`.
- Today it injects a single configured default (`DEFAULT_TENANT_ID`), identical to REST's `deps.DefaultTenant`.
- When auth lands, it resolves the tenant from a token in that one interceptor, with no handler change.
- The repository methods are already tenant-scoped, so the seam is in place end to end.

15.4.3 12. The service runs three listeners now. How are they started and shut down?

What a strong answer covers:

- REST on `:8080`, metrics on `127.0.0.1:9090`, and gRPC on `GRPC_ADDR` (default `:9091`), each in its own goroutine feeding a shared error channel.
- On `SIGTERM` all three stop: the HTTP servers via `Shutdown` with a 10s deadline, gRPC via `GracefulStop`.
- `GracefulStop` is run in a goroutine with a fallback to `stop()` if the shutdown deadline expires, so a stuck in-flight RPC cannot hang shutdown past the budget.
- The error channel is buffered for all three producers so a multi-failure cannot leak a blocked goroutine.

15.5 Testing and trade-offs

15.5.1 13. How did you prove the gRPC layer works, given `grpcurl` is an external binary?

What a strong answer covers:

- Automated: an integration test stands up the real `NewGRPCServer` over an in-process `bufconn` listener, backed by a real Postgres in a test-container, driven by the generated Go client (create two accounts, post, read balance, assert net zero).
- A second test sends the same idempotency-key metadata twice and

asserts `replayed=true` and the same transaction id.

- `grpcurl` stays a documented manual smoke; server reflection is registered so it works with no proto files, satisfying the DoD.
- A Go client example under `examples/grpc-client` is the “generated Go client works in an example” deliverable.

15.5.2 14. You chose standard `grpc-go` over `ConnectRPC`. Defend the choice.

What a strong answer covers:

- Standard `grpc-go` matches the plan’s “gRPC server with interceptors”, works with `grpcurl` via reflection, and is the widely-understood, boring infrastructure choice.
- `ConnectRPC` would serve gRPC, gRPC-Web, and HTTP/JSON on one port, which is elegant, but REST already covers the HTTP/JSON case and it is a larger opinionated dependency.
- A separate port for gRPC was chosen over `cmux/h2c` multiplexing to keep the HTTP/1.1 and HTTP/2 split clean on a single VPS.
- These are recorded in ADR-009 so they are not relitigated later.

15.5.3 15. A reviewer found the gRPC read endpoints had no upper bound on page size while REST capped them. Why did that happen and why does it matter?

What a strong answer covers:

- REST enforces maxima through huma validation tags (500 for accounts, 200 for statement and audit); the gRPC handlers only

defaulted a limit when it was non-positive, with no ceiling.

- A gRPC client could send a huge limit and trigger an unbounded scan and allocation, which is both a protocol divergence and a denial-of-service vector.
- The fix clamps the gRPC limits to the same maxima via named constants, with a comment noting they mirror the REST tags (which are string literals and cannot be shared as Go constants).
- The lesson: parity between two transports is not automatic for validation that lives in one transport's framework; it has to be re-established deliberately.

≡ go-ledger

WEEK 8

01 Distributed Tracing for a Go Service

02 Week 8 Interview Q&A

CHAPTER 16

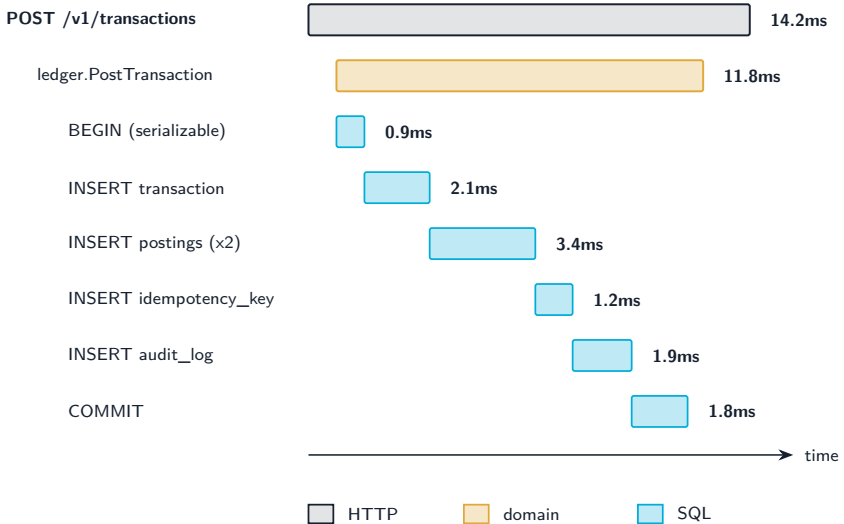
Distributed Tracing for a Go Service

A friend pings you: “hey, that payment felt slow just now.” You open the logs. What you get is a hundred requests worth of lines, all interleaved, all from the same few seconds. You can see that *something* took a while, but you can’t tell which lines belong to that one payment, or whether the time went to Postgres, to the domain logic, or to the network in between. You are staring at a haystack and someone is describing one specific piece of straw.

That is the exact pain distributed tracing solves. A trace ties every step of one request together under a single id, so you can pull that one thread out of the pile and see the whole thing: where it went, how long each hop took, and where it stalled. This week I wired it into go-ledger, and the goal was concrete: post one transaction, and get back one trace that runs from the HTTP handler, through the domain service, down to every SQL query, all linked. This is post 8 of 14.

16.1 What “one trace” actually looks like

Say you post the dinner-repayment transaction from Week 1: move 600 taka from my wallet to my friend’s. That single API call touches four layers. Tracing records each layer as a *span* (a timed unit of work with a name), and nests the child spans inside their parent. Lined up on a timeline, one post looks like this:



Now the “it felt slow” conversation is a five-second look instead of a guessing game. If the `COMMIT` span is fat, you have write contention. If an `INSERT` is fat, maybe an index is missing. If the gap between the HTTP span and the first SQL span is fat, the time went somewhere in your own code, not the database. The shape of the waterfall tells you where to look before you have read a single line of code.

The tool that produces this is OpenTelemetry (OTel): a vendor-neutral standard for traces, metrics, and logs, with a Go SDK. You instrument your code once against the standard, and you can send the data to whatever backend you like. Locally I send it to Jaeger, which draws exactly the waterfall above in a browser. Remotely I send it to Honeycomb’s free tier. The app code does not change between the two; only an environment variable does.

16.2 Instrument the edges, then the middle

Most of the tracing you want comes from the boundaries, and the boundaries already have libraries. I wrapped the HTTP router with `otelhttp` and added `otelgrpc` to the gRPC server (Week 7 left a clean seam for exactly this), so every inbound request opens a span automatically. For the database, `otelpgx` plugs into the `pgx` connection pool as a query tracer and emits one span per SQL statement, which is where those `INSERT` and `COMMIT` rows in the waterfall come from.

That covers the top and the bottom. The one span I wrote by hand is the middle one, `ledger.PostTransaction`, because that is my domain's unit of meaning and no library knows it exists:

```
1 ctx, span := s.tracer.Start(ctx, "ledger.PostTransaction",
2   oteltrace.WithAttributes(
3     attribute.String("tenant_id", tenantID),
4     attribute.Int("transaction.posting_count", len(t.Postings)),
5     attribute.Bool("idempotency.present", idem != nil),
6   ),
7 )
8 defer span.End()
```

The `ctx` that comes back carries the span, and because every layer already passes `context.Context` down the call chain, the SQL spans that happen later automatically nest under this one. That is the whole magic of context propagation: you thread one value through, and the tree assembles itself.

16.3 The part I’m quietly proud of: what is *not* in that span

Look again at those attributes. Tenant id, a count, a boolean. No amount. No account balance. No account id as a value. That restraint is deliberate.

Honeycomb is a US company’s servers. The moment I ship a span there, I have handed a third party whatever I put in it. For a payment system, “600 taka from account A to account B” is exactly the kind of data you do not casually export to someone else’s cloud because a default made it easy. So the rule I baked in, and wrote into the architecture decision record, is simple: **identifiers and counts, never money**. `otelpgx` is configured to leave query arguments off, so the actual values bound into a SQL statement never leave the process either. You can trace the *shape* of the work without leaking the *contents*.

This is the kind of thing that is trivial to get right when you decide it on purpose in week 8, and quietly awful to discover in an incident review two years later.

16.4 The two decisions I went back and forth on

Should everything go through OpenTelemetry? OTel does metrics too, not just traces. The tidy-looking move is to route *all* my metrics through it and have one instrumentation API. I didn’t. I already had four hand-built Prometheus metrics from earlier weeks, including the transaction-latency histogram that any alert I ever write will be based

on. The OTel Prometheus exporter renames things: it appends unit suffixes and adds its own labels. Renaming a metric is how you silently break an alert and only find out when the thing it was supposed to page you about happens in silence.

So I split it. The four existing metrics stay exactly as they are, same names. The new “how many requests, how many errors, how fast” numbers for HTTP and gRPC (the classic Rate-Errors-Duration trio) come from the OTel side and get merged into the same `/metrics` endpoint. Two styles living together on purpose beats one clean style that breaks my alerting. Boring and stable won.

What happens when tracing isn’t configured? My first instinct was: if there’s no endpoint set, just print spans to stdout so you can still see them. I talked myself out of it. On the server, stdout is where my structured logs go. Dumping a flood of span JSON into that same stream, silently, because someone forgot to set a variable, is a great way to make a misconfiguration invisible. So the behavior is: an endpoint set means export to it; the explicit `OTEL_TRACES_EXPORTER=console` means print to stdout for local eyeballing; and *nothing* set means tracing is off with one clear warning line at startup. A missing config should be loud and boring, not a silent surprise.

16.5 The thing that makes logs and traces click together

Here is the payoff for the “which lines belong to my payment” problem I opened with. Every span has a `trace_id`. If I stamp that same id onto every log line emitted during the request, then finding a slow trace in

Jaeger and finding its logs become the same lookup.

I did this with a tiny wrapper around Go's slog handler. On every log record, it checks the context for an active span and, if there is one, adds the trace and span ids:

```
1 func (h traceHandler) Handle(ctx context.Context, rec slog.Record) error {
2     if sc := trace.SpanContextFromContext(ctx); sc.IsValid() {
3         rec.AddAttrs(
4             slog.String("trace_id", sc.TraceID().String()),
5             slog.String("span_id", sc.SpanID().String()),
6             slog.Bool("sampled", sc.IsSampled()),
7         )
8     }
9     return h.inner.Handle(ctx, rec)
10 }
```

A dozen lines, no new dependency, and now a log line looks like {"msg": "transaction posted", "trace_id": "a1b2...", "tenant_id": "..."}.

Copy the `trace_id`, paste it into Jaeger, and you are looking at the exact waterfall for that exact request. Logs tell you *what happened*; the trace tells you *where the time went*; the shared id is the bridge.

16.6 One boring-on-purpose detail: don't trace everything

There is a demo seeder in `go-ledger` that resets and repopulates the sample data every few hours, writing a few hundred transactions each time. If I trace all of that at full volume, plus a span for every single SQL query, I will happily burn through Honeycomb's free tier on data nobody will ever look at. So sampling is configurable through the

standard OTel environment variables (in production I send a quarter of traces, not all of them), and the health-check and metrics endpoints are excluded from tracing entirely. Otherwise ninety percent of your “traces” are just a load balancer asking if you’re alive. Keep the signal, drop the noise.

16.7 Where this leaves the ledger

One transaction post now produces one trace across HTTP, the domain, and SQL, and its log lines carry the same id. It runs to Jaeger with `make jaeger` and a single environment variable, and to Honeycomb by changing that variable and adding an API key. No money leaves the process. The existing metrics and their future alerts are untouched.

The repo is open source at github.com/sohag-pro/go-ledger, and the full reasoning for the hybrid metrics, the loud no-op, and the no-money-in-spans rule lives in **ADR-010**. Next week: testing for real. Unit, integration, load, and pointing enough concurrency at the ledger to try to make it lie about someone’s balance.

CHAPTER 17

Week 8 Interview Q&A

Interview-style questions for the Week 8 work: the `internal/observability` setup (Resource, TracerProvider, env-selected exporter, W3C propagator), the trace-correlating `slog` handler, the hybrid metrics decision (native Prometheus collectors plus an OTel meter for RED via one shared registry), spans across HTTP (`otelhttp`), gRPC (`otelgrpc`), the domain (`ledger.PostTransaction`), and SQL (`otelpgx`), the no-money-in-spans rule, sampling and the excluded noise paths, the deferred telemetry flush on shutdown, and ADR-010. Every question is answerable from this repo's code and ADRs.

17.1 Tracing architecture and propagation

17.1.1 1. Walk me through what happens, span by span, when a single transaction is posted over HTTP

What a strong answer covers:

- `otelhttp` wraps the chi router and opens the root server span; the `otelRouteName` middleware renames it to the matched route pattern once routing resolves.

- The handler calls `TransactionService.Post`, which opens the ledger. `PostTransaction` span with `s.tracer.Start(ctx, ...)`; the returned `ctx` carries the span.
- `otelpgx` on the `pgx` pool emits a child span per SQL statement (BEGIN, INSERTs, COMMIT), nested because the same `ctx` threads down.
- The result is one trace: HTTP to domain to SQL, all linked, satisfying the ADR-010 definition of done.

17.1.2 2. Nothing explicitly passes a “current span” between these layers. How does the SQL span know it belongs under `ledger.PostTransaction`?

What a strong answer covers:

- Context propagation: `tracer.Start` returns a new `ctx` with the span embedded, and every layer already threads `context.Context` down the call chain.
- `otelpgx` reads the active span from the `ctx` it is handed and starts its spans as children of it.
- This is why the manual domain span reassigns `ctx` (`ctx, span := ...`) rather than discarding it.
- The same mechanism carries the trace across process boundaries via the W3C `traceparent` header, set up by the composite `TraceContext` propagator.

17.1.3 3. Why instrument at four layers instead of just wrapping the HTTP handler?

What a strong answer covers:

- A single top-level span tells you a request was slow but not where the time went; the value is in the waterfall.
- The edges (`otelhttp`, `otelgrpc`, `otelpgx`) come from libraries almost for free; only the domain span is hand-written because no library knows what `PostTransaction` means.
- Per-query DB spans localize latency to a specific statement (a fat COMMIT means write contention, a fat INSERT hints at an index).
- The one manual span is the unit of business meaning, and it carries the safe attributes the libraries cannot know to add.

17.2 The hybrid metrics decision (defend it)

17.2.1 4. OpenTelemetry can emit metrics too. Why did you keep four hand-built Prometheus collectors instead of routing everything through OTel for a single instrumentation API?

What a strong answer covers:

- The four existing metrics (including `transaction_post_duration_seconds`) are SLO metrics tied to earlier latency baselines and any future alert.
- The OTel Prometheus exporter renames output: unit suffixes,

`otel_scope_*` labels, a `target_info` series. Renaming an alert-bearing metric silently breaks the alert.

- The single-API win does not pay for breaking working alerting in a payment service, so the domain metrics stay native with their exact names.
- RED for HTTP and gRPC still comes from the OTel side (`otelhttp` / `otelgrpc`) and merges into the same registry, so you get unified request metrics without the rename.

17.2.2 5. Then how do the native collectors and the OTel-produced metrics end up on one `/metrics` endpoint?

What a strong answer covers:

- `metrics.MeterProvider()` builds an OTel Prometheus exporter with `otelprom.WithRegisterer(registry)`, pointing it at the package's existing private registry.
- The same registry already holds the native collectors and the Go/process collectors, so one `Handler()` serves all of them.
- `WithoutScopeInfo()` and `WithoutTargetInfo()` drop the exporter's clutter.
- OTel runtime instrumentation is deliberately not enabled, so `go_*` and `process_*` stay single-sourced from the native collectors and cannot double-register.

17.2.3 6. A skeptic says “two metric systems in one service is a smell.” Defend the coexistence.

What a strong answer covers:

- It is a deliberate trade of API purity for operational stability: the invariant-critical metrics keep stable names, the convenient RED metrics come from instrumentation libraries.
- The seam is narrow: both write into one registry and one endpoint, so a scraper sees a single surface.
- The alternative (full unify) has a concrete, silent failure mode (broken alerts); the coexistence has only a readability cost.
- ADR-010 records the reasoning so the choice is defensible later, not mysterious.

17.3 Exporter selection and failure modes

17.3.1 7. Describe the three exporter modes and why a missing endpoint is a no-op instead of printing spans to stdout.

What a strong answer covers:

- Endpoint set (`OTEL_EXPORTER_OTLP_ENDPOINT`): OTLP/HTTP exporter, the only production mode.
- `OTEL_TRACES_EXPORTER=console`: stdout exporter, opt-in for local eyeballing.
- Neither: a no-op tracer plus one `warn` line at startup.

- On the server stdout carries the JSON logs; silently flooding it with span dumps because a variable was forgotten hides a misconfiguration. A missing config should be loud and boring, not a silent surprise.

17.3.2 8. Why OTLP over HTTP rather than gRPC, given you already run a gRPC server?

What a strong answer covers:

- OTLP/HTTP is the lower-ops, firewall-friendly choice and is Honeycomb-native.
- Running gRPC elsewhere in the app does not make an OTLP/gRPC exporter the better fit; there is no payoff here.
- Both Jaeger and Honeycomb accept OTLP/HTTP on 4318, so the same code path serves local and remote.
- It keeps the exporter a single, well-understood dependency.

17.3.3 9. The sampler is not set in code. How is sampling controlled, and why leave it to the SDK default?

What a strong answer covers:

- `NewTracerProvider` is built without a `WithSampler` option, so the SDK honors `OTEL_TRACES_SAMPLER` and `OTEL_TRACES_SAMPLER_ARG`, defaulting to parent-based always-on.
- Production sets a ratio (documented at 0.25) because the demo seeder writes hundreds of transactions on an interval and each fans out to per-query DB spans, which would exhaust the Honeycomb

free tier.

- Health and metrics paths are excluded from tracing regardless, so traces are real request work.
- Leaving it to env means operators tune cost without a rebuild.

17.4 Data integrity and what leaves the process

17.4.1 10. What span attributes does PostTransaction set, and what is deliberately excluded? Why does it matter here more than in most services?

What a strong answer covers:

- Included: `tenant_id`, `transaction.posting_count`, `idempotency.present`. Excluded: amounts, balances, account ids as values.
- `otelpgx` runs with query arguments off, so bind values (account ids, amounts, idempotency keys) never leave the process.
- Honeycomb is a third-party US SaaS; a span is data handed to someone else's cloud, and "600 from A to B" is exactly what a payment system should not casually export.
- The rule (identifiers and counts, never money) is written into ADR-010 so richer trace data requires a deliberate data-residency decision, not a default.

17.4.2 11. `otelpgx` can attach the SQL statement and its parameters. How did you configure it, and what is the residual exposure?

What a strong answer covers:

- Configured with `otelpgx.NewTracer(otelpgx.WithTrimSQLInSpanName())` and, crucially, without `WithIncludeQueryParameters`, so the v0.11.1 default of parameters-off holds.
- The statement text can still appear (table and column names), but not the bound values, so no account id or amount is emitted.
- Residual exposure to name is the request path on the HTTP span (which contains ids); those are identifiers, not money, and are inherent to the chosen `otelhttp`.
- The trade is documented: trace the shape of the work, not its contents.

17.5 Logs and traces together

17.5.1 12. How do log lines correlate to traces, and what is the one edge case your `slog` handler comment warns about?

What a strong answer covers:

- `NewTraceHandler` wraps the JSON handler; on each record it reads the span context from `ctx` and, if valid, adds `trace_id`, `span_id`, and `sampled`.

- Because handlers log with the request ctx (InfoContext, ErrorContext), the ids appear automatically; copy the `trace_id` into Jaeger to find the request.
- The edge case: if a caller used `WithGroup`, the inner handler would nest the correlation ids under that group instead of at the top level, defeating a flat lookup.
- The ledger's loggers log flat attributes, so it does not arise today, but the comment keeps it that way on purpose.

17.5.2 13. Why a hand-written 12-line handler instead of the `otel slog` bridge?

What a strong answer covers:

- The goal is correlation (trace ids on existing logs), not remote log export.
- `otel slog` turns log records into OTel log records shipped over OTLP, a third signal pipeline this week does not ship.
- The wrapper adds no dependency and keeps logs on stdout where the existing tooling reads them.
- It delegates `Enabled`, `WithAttrs`, and `WithGroup` to the inner handler, so grouped and pre-attributed loggers keep working.

17.6 Shutdown and failure modes (hard follow-ups)

17.6.1 14. A code review caught that telemetry was being shut down before the servers drained. Explain the bug and the fix.

What a strong answer covers:

- Original order flushed the trace and meter providers inside the graceful block, before `srv.Shutdown` and the gRPC graceful stop, so requests still draining produced spans and metrics against already-closed providers and lost them.
- Worse, all steps shared one 10s budget, so an unreachable OTLP endpoint could spend most of it flushing and starve the real request drain the budget exists to protect.
- The fix moves the flush into a `defer` with its own bounded context, so it runs after the servers have stopped accepting work (their shutdown runs earlier in `run`'s body) and also covers early-return error paths.
- Net effect: in-flight requests keep their spans, and a hung exporter cannot eat the drain budget.

17.6.2 15. Two requests hit the same hot account concurrently and one is retried after a serialization conflict. What does the trace show, and does tracing change the concurrency behavior?

What a strong answer covers:

- Each request is its own trace; the retried one shows the `SERIALIZABLE` transaction spans replayed (a second `BEGIN-to-COMMIT`

cycle under the same `ledger.PostTransaction span`), and the native `transaction_post_serialization_retries_total` counter ticks.

- Tracing is observation only: spans and attributes do not touch the `SERIALIZABLE` isolation, the retry loop, or the balance invariant, so behavior is unchanged.
- The domain span records an error status only on a failed post or a validation rejection, not on a retried-then-committed post, so a successful retry is not a false error.
- The waterfall makes contention visible (a fat or repeated `COMMIT`), which is the practical payoff of the per-query spans.

≡ go-ledger

WEEK 9

01 Testing a Payment Ledger End to End

02 Week 9 Interview Q&A

CHAPTER 18

Testing a Payment Ledger End to End

Here is a small program. It adds two amounts of money together.

```
1 a := MinInt64    // the most negative number an int64 can hold
2 b := MinInt64
3 sum, err := a.Add(b)
4 // sum is 0. err is nil.
```

Two enormous negative numbers, added together, and my ledger said the answer was zero and nothing went wrong. No error, no warning, just a clean, confident, completely wrong result. On a payment system, “we added two things and silently got zero” is the exact shape of a bug that makes money disappear.

I did not find this by staring at the code. I found it because this week I stopped asking “do my tests pass?” and started asking “what would it take to make this thing lie to me?” That is a different question, and it is the whole point of a testing week.

This is post 9 of 14. The ledger already has a domain model, a Postgres schema, concurrency control, REST and gRPC APIs, idempotency, and tracing. What it did not have was proof that any of it holds up when things go wrong. So this week is five kinds of test, each doing a job the others cannot.

18.1 Coverage is a liar (but a useful one)

The obvious place to start is coverage: what percentage of my lines does the test suite actually run? I set a gate in CI: the build fails if coverage on the core code drops below 80%.

But here is the trap. Coverage counts lines *touched*, not behavior *checked*. I can hit 80% by testing every getter and constructor while never once testing the branch that rejects an unbalanced transaction. On a ledger, the dangerous lines, the rollback path, the overflow check, the currency mismatch, are exactly the ones that are annoying to reach and easy to skip. A high number can mean “well tested” or it can mean “well padded,” and the number itself will not tell you which.

So I did two things. First, the gate is not one flat number. The money-critical packages carry higher floors than the plumbing:

package	floor	why
internal/domain	90%	the double-entry invariant lives here
internal/ledger	85%	posting, idempotency, rollback
internal/postgres	80%	the SQL and the DB constraints
everything else	80%	transport, wiring, plumbing
generated code	excluded	it tests the code generator, not me

Second, and more important, I treated the coverage number as a *floor to clear on the way to real tests*, not the goal itself. Hitting 90% on the domain package was worth doing only because getting there meant writing tests for the branches that actually matter. The percentage is a smoke alarm: useful for telling you a whole room is untested,

useless for telling you the tests you do have are any good.

For that second question, you need a different tool.

18.2 Property tests, or how the ledger caught itself lying

Most tests are examples. You write down an input, you write down the answer you expect, you check they match. That is fine, but you only ever check the handful of cases you thought of. The bug that bites you is the one you did not think of.

Property-based testing flips this around. Instead of “for input 5, expect 10,” you state a *property* that must hold for **all** inputs, and the library throws hundreds of random cases at it trying to find one that breaks it. For a ledger, the properties write themselves:

- Add any two amounts in the same currency, and either you get the exact mathematical sum, or you get a loud overflow error. Never a silent wrong answer.
- Apply any random sequence of balanced transactions, and every account’s balance always equals the sum of its own postings, and the total across all accounts is always zero.
- Adding two amounts in different currencies always fails.

I wrote the first one as: for any two `int64` amounts, if their true sum fits in an `int64`, `Add` returns it exactly; if it does not, `Add` returns an overflow error. Then I let the library hunt.

It found `MinInt64 + MinInt64` in a few thousand tries.

The bug was in my overflow check. I was detecting overflow by looking at signs: two positives that produce a negative overflowed, two negatives that produce a positive overflowed. Reasonable, and wrong in one specific case. `MinInt64 + MinInt64` in two's complement wraps all the way around and lands on exactly zero. Zero is not positive, so my “two negatives became positive” check missed it, and the function returned zero with no error. The fix is the textbook signed-overflow test: adding a negative number should never make the result larger.

I want to be clear about what happened here, because it is the best argument for property testing I have. I wrote that money type weeks ago. I tested it. It passed. It shipped. It had a bug that could destroy money, sitting quietly in the one input I never thought to try, and no example-based test I would have written by hand was ever going to catch it. The randomness caught it in seconds.

18.3 Chaos: kill the database at the worst possible moment

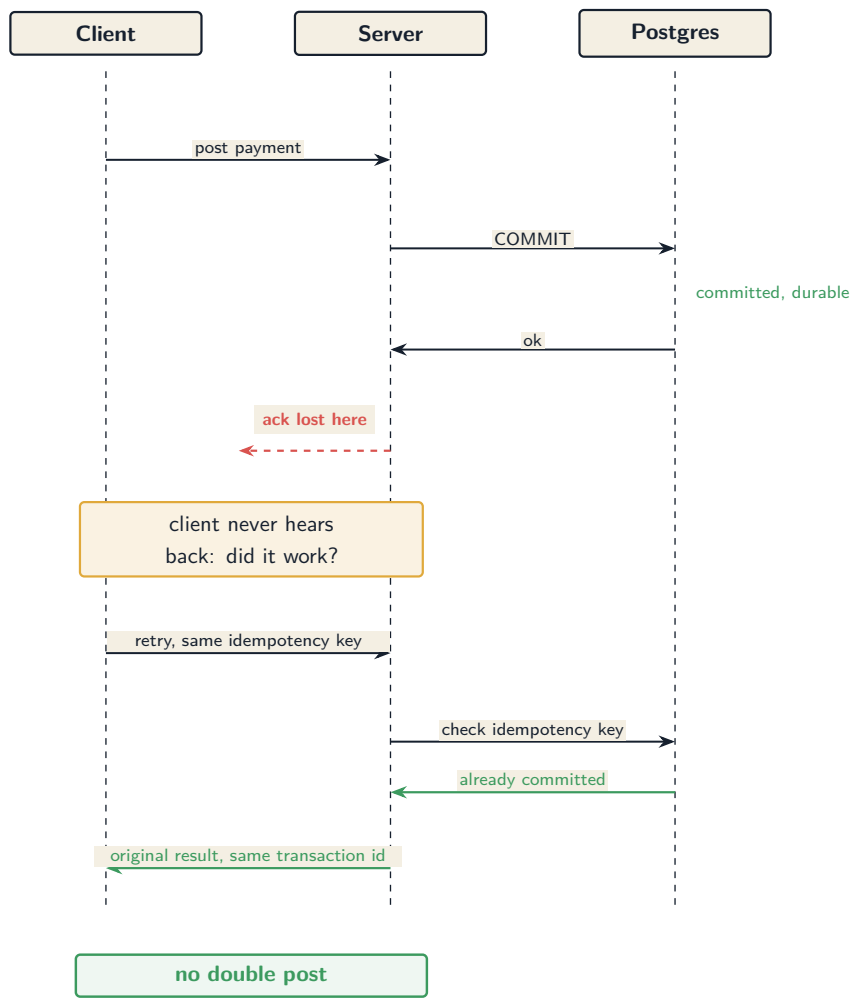
Property tests check the logic. They do not check what happens when the infrastructure fails halfway through. For that, you have to actually break something, on purpose, at a precise moment.

The scenario I care about is the one that keeps ledger engineers up at night. A client sends a payment. The server commits it to Postgres. And then, before the “success” reply gets back to the client, the network drops. The commit *happened*. The money *moved*. But the client has no idea. All it knows is that its request died. So it does

the natural thing: it retries.

If your system is not careful, that retry posts the payment a second time, and now your friend paid for dinner twice.

the commit lands, the ack does not: the retry replays safely



I tested two versions of this. In the first, the connection dies *before* the commit reaches Postgres. The correct outcome is a clean rollback: nothing persists, not a single half-written posting, because a payment that only half-happened is not allowed to exist. In the second, the commit *lands* but the acknowledgement is lost, the diagram above, and the correct outcome is that the retry recognizes the idempotency key and returns the original transaction instead of creating a new one.

The tricky part is making “the connection dies at exactly the right moment” happen *reliably*. My first instinct was to just kill the Postgres container mid-request. That is a bad idea: it is a race. Sometimes you kill it before the commit, sometimes after, sometimes you miss the window entirely and test nothing, and occasionally it fails in CI for reasons nobody can reproduce. A flaky chaos test is worse than no chaos test, because it teaches you to ignore red builds.

So instead I put a programmable network proxy (a tool called *toxiproxy*) between the app and the database, and I cut the connection at a controlled point in the protocol, driven by the code, not by timing. For the rollback case, I sever the link the instant the app tries to send its COMMIT, so the commit never reaches the server. For the ambiguous case, I cut only the *reply* path: the COMMIT flows to Postgres and durably commits, but the acknowledgement coming back gets dropped. That second one is the money-losing scenario made real and repeatable, and the test proves the retry does not double-post. Same failure, every run, no luck involved.

18.4 Load: 500 requests a second, without cheating

The last question is boring but real: does it hold up under load? The target I set was 500 payments per second with a 99th-percentile latency under 100 milliseconds, run locally against the full stack in Docker.

Load testing a ledger is easy to fake, in two specific ways, and I was determined not to.

The first fake: idempotency keys. If every request in your load test reuses the same key, you are not testing the payment path at all. After the first one, every request is a cheap “oh, I’ve seen this key, here’s the cached answer” lookup that never touches the real write logic. You would get a gorgeous throughput number that measures the wrong thing entirely. So every request in my test carries a unique key, with a deliberate small slice of duplicates mixed in to exercise the replay path honestly.

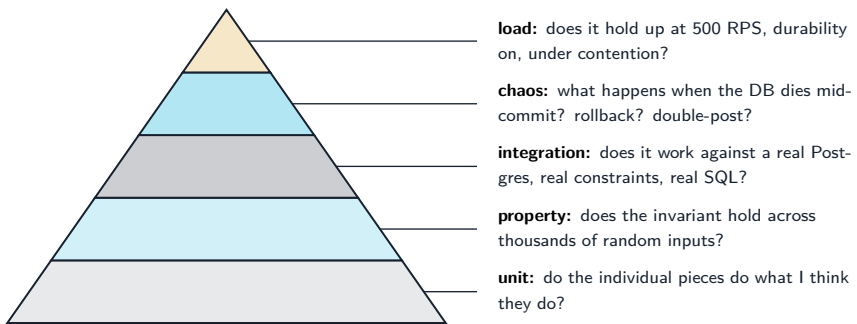
The second fake, and this one is a genuine temptation, is durability. That 100-millisecond target is dominated by one thing: how long Postgres takes to physically flush each commit to disk. There is a setting that makes commits return before they are safely on disk, and flipping it would make my latency numbers look fantastic. It would also mean that a power cut could lose a committed payment. On a ledger, that is not a performance tuning knob, it is a lie. Durability stays on. The number is what it is: 500 requests a second, p99 well under the target, with every commit actually on disk.

I also run two shapes of load, not one. A “fan-out” test spreads payments across many accounts to measure raw throughput. A “hot account” test slams a single account, because that is where real systems fall over: everyone contends for the same row lock, and the tail latency blows up. The system that looks fast when work is spread out is not the same system as the one under contention, and only testing the easy shape tells you nothing about the hard one.

18.5 The pyramid, and why each layer is load-bearing

Five kinds of test, each catching what the others structurally cannot:

five layers, each catching a different failure



A unit test would never have found the ambiguous-commit double-post, that needs a real database and a real network failure. A chaos test would never have found the `MinInt64` overflow, that needs thousands of random inputs. A load test would never have told me the invariant holds, only that it is fast. Each layer sees a different failure. Skip one

and you have a blind spot exactly the size of the thing it would have caught.

18.6 My AI companion

As with every week, I built this with **Claude** in my terminal, and the honest split is worth describing, because this was a week where the division of labor really mattered.

I owned the decisions and the skepticism. When Claude drafted the chaos test by literally killing the Postgres container, I pushed back: that is a race, use a proxy and cut the connection deterministically. When it wrote the ambiguous-commit case as a plain retry with no actual failure injected, an automated review I ran flagged it, and I sent it back to inject the real ack-loss, because the whole value of that test is the failure. I made the calls on the coverage floors, on keeping durability on, and on a coverage badge that uses no long-lived secrets.

Claude owned the execution, and it was genuinely good at it: writing the several thousand lines of test code across the packages, wiring up toxiproxy, reconciling my plan against the actual code when my assumptions about environment variables and API shapes were slightly off, and running the whole thing task by task with a review after each one. And, satisfyingly, one of those reviews is what caught the weakened chaos test before it could ship. The overflow bug in my money type was found by the property test *it* wrote, running against the code *I* wrote weeks ago. Neither of us gets to feel too clever.

18.7 Where this leaves the ledger

The invariant that this whole project is built on, money never appears or disappears, is now something I have *watched* survive an overflow, a mid-commit database death, a lost acknowledgement, and 500 requests a second. That is a different kind of confidence than “the tests pass.” It is closer to “I tried to break it in the specific ways it could break, and it did not.”

The full strategy is written up in **ADR-011**, and the repo, with a coverage badge that is finally honest, is at **github.com/sohag-pro/go-ledger**.

Next week the project leaves the laptop for good: Docker and the real infrastructure that puts this thing on a server.

CHAPTER 19

Week 9 Interview Q&A

Interview-style questions for the Week 9 work: the coverage gate with money-path floors (`scripts/coverage.sh`, `make cover`), property tests with `rapid` (`internal/domain/money_prop_test.go`, `model_prop_test.go`) and the real overflow bug they exposed in `Money.Add`, the deterministic toxiproxy chaos test (`internal/ledger/chaos_test.go`) covering pre-commit rollback and ambiguous-commit idempotency, the k6 load test (`test/load/post_transactions.js`) with its fan-out and hot-account scenarios, the restructured CI pipeline, the self-hosted coverage badge, and ADR-011. Every question is answerable from this repo's code and ADRs.

19.1 Coverage strategy

19.1.1 1. Your CI fails the build if coverage drops below a threshold. Walk me through what your gate actually measures and why it is not just one number.

What a strong answer covers:

- One statement-weighted total from a single merged profile (`go`

test ./internal/... -coverprofile), read from go tool cover -func's total : line, not an average of per-package percentages (which would weight a 20-line package like a 2000-line one).

- Per-package floors, not a flat number: domain at 90%, ledger at 85%, postgres at 80%, everything else counts toward the global 80%.
- Generated code (internal/genproto, internal/postgres/sqlc) is stripped from the profile before the number is computed, because it tests the code generator, not the author.
- The higher floors sit exactly on the money path, where a missed branch costs real money.

19.1.2 2. Why put a higher floor on internal/domain than on internal/grpcserver? Isn't coverage coverage?

What a strong answer covers:

- Coverage counts lines touched, not invariants checked; the value of a covered line depends on what breaks if it is wrong.
- A missed branch in the double-entry invariant or the overflow check can create or destroy money; a missed branch in transport formatting shows a slightly wrong error string.
- Concentrating the pressure where a bug is catastrophic is a deliberate risk-weighting, not a uniform metric.
- The flat-floor alternative lets the money packages sit at the floor while transport code carries the average, which is the opposite of what you want.

19.1.3 3. A skeptic says “80% coverage is meaningless, you can hit it with tests that assert nothing.” How do you respond, given your own gate is a percentage?

What a strong answer covers:

- Agreeing with the premise: the number is a floor to clear on the way to real tests, a smoke alarm for whole untested rooms, not a proof of test quality.
- Quality is enforced elsewhere: property tests for invariants, a review pass on every task that specifically flags assertions checking nothing or padding.
- The gate catches “a whole package is untested”; it cannot catch “these tests are weak,” and pretending otherwise is the trap.
- Concrete evidence the tests are real: the property test found an actual overflow bug, which a padding test never would.

19.2 Property-based testing

19.2.1 4. You found a genuine bug in your money type this week. Tell me exactly what it was and how the test caught it.

What a strong answer covers:

- `Money.Add(MinInt64, MinInt64)` returned `Money{amount: 0}` with a nil error: a silent wrong answer on a value that should overflow.
- The old check detected overflow by sign (two negatives producing

a positive); `MinInt64 + MinInt64` wraps in two's complement back to exactly 0, which is not positive, so the check missed it.

- The property “for any two `int64` amounts, `Add` returns the exact sum or an overflow error, never a silent wrong answer” is what rapid was fuzzing when it hit the case in a few thousand tries.
- The fix is the standard signed-overflow test: adding a positive must not decrease the value and adding a negative must not increase it (`sum < m.amount / sum > m.amount`), which catches the `MinInt64` wrap.

19.2.2 5. Why did property testing find this when your existing example-based unit tests, which passed, did not?

What a strong answer covers:

- Example tests only exercise the inputs the author thought of; the bug lived in the one boundary value nobody hand-picks.
- Property tests state a rule over the whole input space and let the library search for a counterexample, so they explore inputs a human would not write down.
- `MinInt64 + MinInt64` is a classic two's-complement corner that is easy to reason past and hard to guess.
- After the fix, a deterministic boundary test pins that exact pair so the regression is caught every run, not just probabilistically.

19.2.3 6. Your stateful property test applies a random sequence of transactions and checks the invariant after each step. What class of bug does that catch that a single-transaction test cannot?

What a strong answer covers:

- A bug where each individual operation is valid but the aggregate over a sequence drifts, for example an accumulation error that only shows once two transactions touch the same account.
- The model persists across steps (`LedgerModel` tracks running per-account balances), so an overwrite-instead-of-accumulate bug surfaces the moment two steps overlap.
- The checked invariants are the project's core: each balance equals the sum of its own postings, and the signed total across all accounts is zero.
- It mirrors how a real ledger accumulates state, rather than testing one operation in isolation.

19.2.4 7. Your concurrency property test runs under the race detector. Why is that combination necessary, and how did you make the test itself race-clean by construction?

What a strong answer covers:

- The property (no lost updates when many goroutines post concurrently) is about a concurrency invariant, so it must run where a data race would be detected.

- The test pre-generates all transactions before spawning goroutines, because `rapid.T` is not safe to call from multiple goroutines.
- The shared model is mutex-guarded, so removing the lock would be an unambiguous race the detector flags, which is what makes the test meaningful rather than lucky.
- Passing the loop value as a parameter avoids the closure-capture footgun.

19.3 Chaos testing (the hard part)

19.3.1 8. Describe the two database-failure scenarios your chaos test covers and why they have different correct outcomes.

What a strong answer covers:

- Pre-commit failure: the connection dies after `BEGIN` and the writes but before `COMMIT` reaches Postgres; correct outcome is a clean roll-back, zero partial postings, because a half-written transaction is not allowed to exist.
- Ambiguous commit: the `COMMIT` lands and is durable, but the acknowledgement is lost, so the client does not know it succeeded; correct outcome is that a retry with the same idempotency key returns the original transaction, not a second one.
- The second is the money-losing case: the natural client reaction to an unknown outcome is to retry, and without idempotency that double-posts.
- The distinguishing assertion: case A asserts zero rows persisted,

case B asserts exactly one row persisted despite the client-side error.

19.3.2 9. Why toxiproxy instead of just killing the Postgres container mid-request? Defend the added dependency.

What a strong answer covers:

- Killing a container is timing-racy: you often land before the commit or after it and test nothing, while occasionally going red in CI for no reproducible reason.
- A flaky chaos test is worse than none, because it trains you to ignore red builds.
- A programmable proxy lets you cut the connection at a controlled point in the protocol, driven by code, not wall-clock timing, so the failure is deterministic and repeatable.
- It is also faster (no image restart) and can inject direction-specific failures, which the ambiguous-commit case needs.

19.3.3 10. The ambiguous-commit case requires the COMMIT to reach Postgres while the acknowledgement is lost. How do you inject that deterministically rather than hoping the timing works out?

What a strong answer covers:

- A `pgx QueryTracer` fires on the `commit` statement before the bytes hit the wire; that hook installs the toxic, so it is causally ordered ahead

of the commit, not racing it.

- The toxic is scoped to the downstream direction only (server to client), so the COMMIT flows upstream to Postgres unaffected and durably commits, while the reply is dropped.
- A downstream `reset_peer` can only fire on the first downstream byte, which is Postgres's reply, so by construction the commit already landed before anything is cut.
- The test proves the commit landed (it asserts one persisted transaction) and that a retry is idempotent, distinguishing it from the rollback case.

19.3.4 11. Your chaos test asserts the idempotency-key write and the transaction commit are atomic. Why does that specific property matter, and what regression would the test catch?

What a strong answer covers:

- If the key write and the transaction commit were in separate database transactions, a crash between them would either double-post (key not recorded, retry re-posts) or wedge the key (recorded but no transaction).
- The ambiguous-commit test is the guard: it only passes if both rows commit together or neither does.
- This is the invariant that makes idempotency actually safe under failure, not just under happy-path retries.
- Under no injected failure the property would pass trivially, which is why the earlier weak version of this test (a plain replay) was rejected in review.

19.4 Load testing

19.4.1 12. What is the single most common way to accidentally fake a ledger load test, and how does your k6 script avoid it?

What a strong answer covers:

- Reusing one idempotency key: after the first request, every other is a cheap replay lookup that never touches the write path, so you measure the wrong code.
- The script generates a unique key per request (from VU and iteration counters plus randomness, no remote dependency), with a deliberate small slice of duplicates to exercise replay honestly.
- The accounts are created for real in k6 `setup()` and their returned UUIDs are used, so transactions hit real rows, not fabricated ids that would fail validation.
- Postings are balanced two-leg transactions in a single currency, so nothing is rejected for the wrong reason.

19.4.2 13. You could hit your p99 latency target easily by turning off `synchronous_commit`. Why is that off the table?

What a strong answer covers:

- That setting lets a commit return before it is durably on disk, so a power cut could lose a committed payment.

- On a ledger that is not a performance knob, it is trading the durability guarantee for a benchmark number, which is a lie about what the system does.
- The load number is reported as a machine-dependent local measurement with durability intact, not a hard SLO gamed by relaxing safety.
- The honest number (500 RPS, p99 well under target, durability on) is worth more than a faster dishonest one.

19.4.3 14. Why run both a fan-out and a hot-account load scenario instead of one?

What a strong answer covers:

- Fan-out spreads payments across many accounts and measures raw throughput with minimal lock contention.
- Hot-account slams a single account, where everyone contends on the same row lock and tail latency blows up, which is where real systems fail.
- The fast, uncontended shape is not the same system as the contended one, so testing only the easy shape hides the failure mode that matters.
- The service already has a hot-account path from earlier weeks, so the load test exercises it on purpose.

19.5 CI and trade-offs

19.5.1 15. Your CI runs the whole test suite, including chaos and integration tests that need Docker, in one job rather than splitting unit from integration. Why, and what did you give up?

What a strong answer covers:

- The tests are Docker-gated by a skip, not separated by build tags, so integration and chaos tests run when Docker is present (the GitHub runner has it) and skip cleanly when it is not.
- Splitting unit from integration would mean either running the suite twice or inventing build tags the codebase does not use, so one honest `test` job is the better trade.
- Coverage is measured with Docker present, so the number reflects the real, integration-exercised code, not the low no-Docker figure.
- `cmd/` is compiled and smoke-run as a build check but kept out of the coverage profile, because wiring with no unit tests would drag the gate down for no signal.
- The cost is a slower single job and container contention risk, mitigated by capping test parallelism and waiting on the Postgres readiness log rather than a port.

19.5.2 16. Your coverage badge is self-hosted rather than using Codecov or a gist plus personal access token. Walk me through the design and why you avoided the alternatives.

What a strong answer covers:

- The badge job computes the same statement-weighted, generated-excluded number the gate uses and writes a shields.io endpoint JSON to a dedicated `badges` branch using the built-in `GITHUB_TOKEN`.
- No standing personal access token with gist scope sits on a public repo, and no external SaaS dependency or token is added, matching the project's self-hosted ethos.
- The badge must apply the same exclusion filter as the gate, or it would report a different (lower) number than the one enforced; a badge that disagrees with the gate is a defect.
- Codecov gives nicer PR annotations but adds an external account and token for a portfolio repo, which is not a trade worth making here.

≡ go-ledger

WEEK 10

01 The Server Lived in My Head. This Week I Wrote It Down.

02 Week 10 Interview Q&A

The Server Lived in My Head. This Week I Wrote It Down.

My ledger has been live at go.sohag.pro for a few weeks now. Real HTTPS, real Postgres, real deploys on every push to main. And there is a thing I have been not thinking about, the way you do not think about a smoke alarm with a dead battery.

The server was set up by hand. One evening, over SSH, as root, I created the users, wrote the systemd unit, configured nginx, installed Postgres, ran certbot, and tuned the memory so the 1 GB box would not fall over. Then I wrote most of it down in a text file so I would not forget. Most of it.

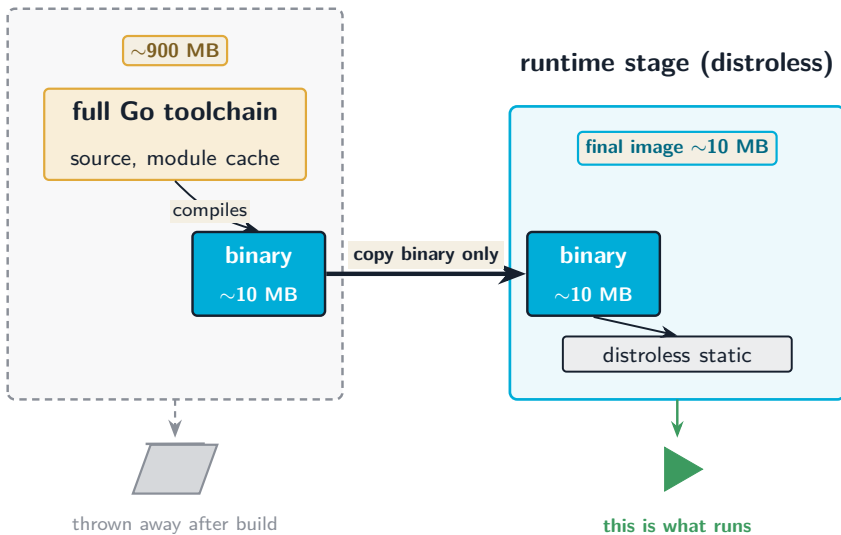
Here is the uncomfortable question I finally asked myself: if that box died tonight, how would I rebuild it? And the honest answer was, from that text file and from memory, at whatever hour it happened, hoping I did not miss the one `chmod` that matters. That is not a disaster recovery plan. That is a disaster with a paragraph of notes.

Week 10 was supposed to be “Docker and Terraform for AWS.” I did the Docker part, dropped the Terraform part, and spent the real effort turning the server that already exists into code that can rebuild it. This is post 10 of 14.

20.1 The Docker part, quickly

The Dockerfile had been a skeleton since week one, with a comment that literally said “fleshed out in Week 10.” So I fleshed it out. Multi-stage build, distroless base, non-root, build cache mounts, and the binary stripped down. The point of a multi-stage build is that the heavy toolchain never ships. You compile in a fat image and copy only the finished binary into a tiny one.

build stage (golang:1.26)



The final image is about 10 MB, and there is a `make image-size` target that fails the build if it ever creeps past 20 MB, so the budget is enforced, not aspirational. There is also a `docker compose --profile dev up` that brings up the whole local world at once: the app, Postgres, Jaeger for traces, and Prometheus scraping the metrics. Clone, one

command, and you have the full stack running locally.

But here is the thing I want to be honest about: none of that Docker work touches production. My server does not run Docker. It runs the bare binary.

20.2 Why production is not a container

This surprises people, so let me defend it. The box has 1 GB of RAM, and it is shared: it also serves my portfolio site. On a machine that small, a container runtime is pure overhead for no benefit I would actually use. The app is already a single static Go binary. It already runs under systemd with a genuinely strict sandbox: no new privileges, a read-only filesystem, no access to devices, memory that cannot be both writable and executable. That is strong isolation at zero memory cost.

Docker earns its place for local development, where “works on my machine” is a real problem worth solving, and for the load-test stack in CI. It does not earn a daemon on my production box. So the image is a dev and CI artifact, and I wrote that decision down in an ADR instead of letting the plan file quietly imply otherwise. Which brings me to the AWS I did not build.

20.3 The Terraform I deleted before writing it

The original plan said Terraform modules for AWS: a VPC, ECS Fargate, RDS, a load balancer, the works. I had already decided weeks ago to deploy to a plain VPS instead, and it has worked great. So writing Terraform now would mean building infrastructure code for a cloud I will never provision, which then slowly drifts away from the real box because nobody runs it. That is worse than no code. It is code that lies.

Terraform is for creating cloud resources. I do not have cloud resources to create. I have one server that already exists and needs to be configured correctly and reproducibly. That is a different job, and it has a different tool.

20.4 Turning the runbook into a playbook

The tool for “configure an existing machine, the same way, every time” is Ansible. So I took my prose runbook, the one with the gaps, and rewrote it as an Ansible playbook: a set of roles that each describe one slice of the server as a desired state.

- **base:** the firewall (only SSH, HTTP, HTTPS open), fail2ban, automatic security updates.
- **postgres:** Postgres 16, a dedicated database and role, the memory tuning for a 1 GB box, and a daily backup.
- **app:** the two users, the app directory, the root-owned environment file, and a sudoers rule that lets the deploy user restart exactly one

service and nothing else.

- **systemd**: the hardened service unit.
- **nginx**: the site config that proxies to the app.
- **tls**: certbot for the certificate.

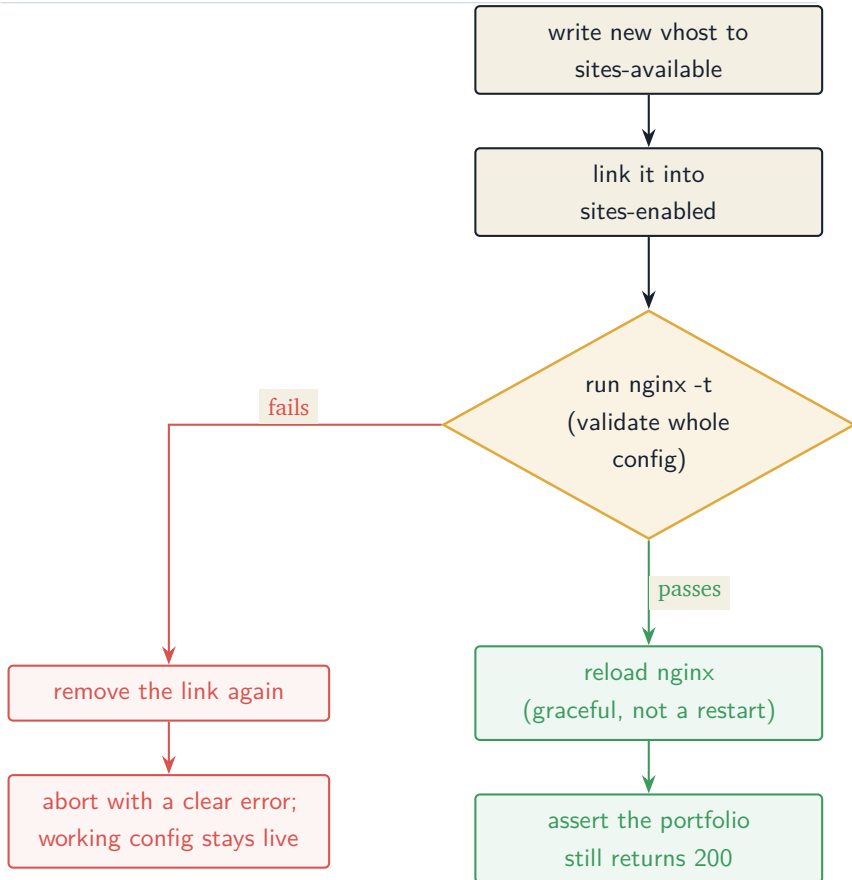
The difference between the text file and the playbook is not just format. A runbook is a list of commands I ran once. A playbook is a description of how the box should be, that I can run again and again, and each run only changes what has drifted. Run it on a fresh machine and it builds the whole thing. Run it on the live box and it reports “nothing to change,” which is its own kind of proof that the code and reality agree.

There is one detail I am a little proud of, because it is the kind of thing a runbook cannot capture but code can enforce.

20.5 The safeguard that a text file could never hold

Remember that the box is shared. My ledger and my portfolio live on the same nginx. And the portfolio uses HSTS preload, which is a browser rule that says, roughly: every subdomain here must always serve valid HTTPS, forever, no exceptions, no “click to proceed anyway.” Which means if I ever push a broken nginx config while fiddling with the ledger’s site, I do not just break the ledger. I can take down the portfolio too, with no override button for visitors.

A prose runbook can say “be careful with nginx.” Code can actually be careful. So the nginx role does this:



If the new config does not validate, the playbook tears its own change back out and stops, so the box is never left holding a broken config that some later reload would activate. And after every change, it makes an HTTP request to the portfolio and refuses to call itself successful unless that other, unrelated site is still answering 200. The reload is graceful, never a restart, because a restart drops in-flight connections. These are the safeguards I would tell a careful human to remember. Now they are not something to remember. They just happen.

20.6 Keeping the secrets out of a public repo

One catch: the repo is public, and a playbook that configures my server naturally wants to know my server's address, my database password, and my deploy key. None of that can be committed.

So the split is simple. The roles and the playbook are generic and tracked: they describe the shape of the box with no secrets in them. The actual inventory (the server's address) and the vault (the password, the key) are gitignored, exactly like the runbook always was. What gets committed are `example` files that show the shape without the contents. Anyone can read exactly how my box is built. Nobody can read where it is or how to log in.

20.7 What this week was really about

The Docker image is nice. The one-command local stack is genuinely useful. But the thing that changed how I feel about this project is smaller and quieter: the server is no longer a thing that only exists as a running process and a half-remembered evening. It is described, in code, in the repo, in a form I could hand to a stranger, or to myself at 2am after the box died.

That is the actual product of infrastructure-as-code. Not automation for its own sake. It is that the knowledge stops living in one person's head, where it decays, and starts living in a file, where it does not.

The repo, playbook and all, is at github.com/sohag-pro/go-ledger, and the reasoning is in **ADR-013**. Four build weeks are

still ahead: multi-currency and FX, nested accounts and reporting, approvals and an event stream, then webhooks and the launch.

CHAPTER 21

Week 10 Interview Q&A

Interview-style questions for the Week 10 work recorded in ADR-013: a hardened distroless Docker image used for local dev and CI only, a one-command local stack, and an idempotent Ansible playbook that codifies a hand-built VPS. Every question is answerable from this repo's code (`Dockerfile`, `docker-compose.yml`, `deploy/prometheus.yml`, `infra/ansible/`) and ADR-013.

21.1 Docker and the image

21.1.1 1. Walk me through your Dockerfile. What does the multi-stage split buy you, and how do you keep the final image under 20 MB?

What a strong answer covers:

- A fat build stage (the full Go toolchain) compiles the binary; only the finished binary is copied into a distroless runtime stage, so the toolchain never ships.
- `go.sum` is copied alongside `go.mod` before `go mod download` so the dependency layer is pinned and cacheable; BuildKit cache mounts speed

rebuilds.

- `-trimpath -ldflags "-s -w"` strips the binary; the distroless static base adds only a couple of MB, landing around 10 MB.
- `make image-size` builds and fails if the image exceeds 20 MB, so the budget is enforced in CI, not just hoped for.

21.1.1.2 2. Your distroless base runs non-root and is pinned by digest. Why both?

What a strong answer covers:

- Non-root (`:nonroot`) means a container compromise does not start as root; defense in depth even for a dev image.
- Pinning by digest makes the build reproducible: `:nonroot` is a moving tag, a digest is a fixed artifact, so the same Dockerfile produces the same base months later.
- The trade-off is that the digest must be refreshed deliberately when you want base updates, which is the correct direction for reproducibility.
- The build-stage `golang` tag is intentionally left as a floating tag (a documented, lower-stakes choice than the runtime pin).

21.1.1.3 3. What does the dev compose stack give a new contributor, and how does it avoid colliding with the load-test stack?

What a strong answer covers:

- `docker compose --profile dev up` starts the full local world: app, Post-

- gres, Jaeger (traces), and Prometheus scraping the app's `/metrics`.
- The dev services carry profiles: `["dev"]` and the load-test services carry profiles: `["load-test"]`, so each stack starts only under its own profile and the two never boot together.
 - This matters because Docker Compose always starts profile-less services: if the dev services had no profile they would boot during `--profile load-test` up too and collide on host ports 8080 and 5432, which is exactly a bug this design avoids.
 - The dev app sets `METRICS_ADDR=0.0.0.0:9090` because the default `127.0.0.1:9090` is unreachable across containers, so Prometheus can reach it by service name.

21.2 The central decision: Docker is not production

21.2.1 4. You built a production-quality Docker image and then do not run it in production. Defend that.

What a strong answer covers:

- The production box is a 1 GB shared VPS; a container runtime is overhead with no benefit the deployment would use.
- The app is already a single static Go binary under a hardened systemd unit (NoNewPrivileges, ProtectSystem=strict, MemoryDenyWriteExecute, and the rest), which is strong isolation at zero memory cost.
- Docker earns its place for reproducible local dev and the CI load-test stack, so that is where it lives; it is a dev and CI artifact by design.

- The decision is recorded in ADR-013 rather than left implicit, so nobody mistakes the image for the deploy path.

21.2.2 5. The 14-week plan called for Terraform modules and an AWS ECS/RDS deploy. You wrote none of it. Why is that the right call and not just cut corners?

What a strong answer covers:

- The deployment decision was already a single VPS via GitHub Actions, live for weeks; Terraform for AWS would provision infrastructure that never gets created.
- Unused infrastructure code drifts from reality because nobody runs it, so it becomes code that lies, which is worse than no code.
- Terraform provisions cloud resources; there are none to provision. The actual job is configuring one existing host, which is configuration management, a different tool.
- The plan file is treated as superseded by ADR-013, written before the code, so the divergence is on the record.

21.3 Infrastructure-as-code with Ansible

21.3.1 6. Why Ansible and not a shell provisioning script, given the box was originally built by hand with shell commands?

What a strong answer covers:

- Ansible is idempotent by construction: a role describes desired state, and a re-run only changes what has drifted, so “run again” is safe.
- A shell script is a replay of the original keystrokes; the value now is a durable description of how the box should be, not a re-execution of how it was built once.
- Roles document each slice of the box (firewall, database, app, systemd, nginx, tls) as readable desired state, better than an accretion of `if not exists shell`.
- A clean second run reporting “no changes” is itself evidence that the code and the live box agree.

21.3.2 7. What does “idempotent” concretely mean in your playbook? Point to specific tasks that would misbehave if you got it wrong.

What a strong answer covers:

- The environment file is created with `force: false` so the playbook seeds `PORT=8080` once but never clobbers real secrets (`DATABASE_URL` and friends) added later.
- The `systemd` role enables the unit but does not start it, because the binary is delivered by CI, not Ansible; starting before a binary exists would fail-loop.
- `certbot` uses a `creates: guard` and `--keep-until-expiring`, so it does not re-request a certificate that is already valid.
- The `nginx vhost` template also uses `force: false` so a re-run does not overwrite the `certbot-managed 443` block.

21.3.3 8. How do you keep server secrets and the box's identity out of a public repo while still committing the playbook?

What a strong answer covers:

- Roles and the playbook are generic and tracked: they describe the shape of the box with no secrets in them.
- The real inventory (the server address) and the vault (the database password, the deploy key) are gitignored, exactly as the prose runbook always was.
- Committed *.example files show the structure without the contents, so a reader learns the shape but not the address or credentials.
- A leak scan over tracked files confirms no IP and no private key ever entered git; the boundary is verified, not assumed.

21.4 The shared box

21.4.1 9. Your VPS also serves a portfolio site with HSTS preload. Explain the risk that creates and how the nginx role defends against it.

What a strong answer covers:

- HSTS preload means every subdomain must always serve valid HTTPS with no click-through override, so a broken nginx config or cert on the shared box can take down the unrelated portfolio too.
- The role validates the whole config with `nginx -t` before any reload,

and reloads gracefully rather than restarting, so live connections are never dropped.

- After every change it asserts the portfolio still returns 200 and refuses to report success otherwise.
- These are safeguards a prose runbook could only ask a human to remember; code enforces them every run.

21.4.2 10. (Hard) Walk through exactly what happens if `nginx -t` fails during a run. Why does the box not end up in a broken state?

What a strong answer covers:

- The enable-and-validate step is wrapped in a block with a rescue: the vhost is linked into `sites-enabled`, then `nginx -t` runs against the full config.
- If validation fails, the rescue removes the symlink it just created and fails the play with a clear message, so the broken config is torn back out.
- Because the play aborts on the rescue's failure before the `flush_handlers` step, the queued reload never fires, and nginx keeps serving its previously valid config.
- The net effect: a bad vhost cannot linger in an active location where a later certbot renewal or reboot would load it.

21.5 Data and durability

21.5.1 11. Postgres is co-located on a 1 GB box. What did you tune, and why those values?

What a strong answer covers:

- `shared_buffers=128MB`, `work_mem=8MB`, `max_connections=20`, chosen so Postgres, the app, and the portfolio all fit in 1 GB without the box thrashing.
- `max_connections=20` comfortably exceeds the app pool's default of 10 while staying small enough to bound total memory.
- Postgres keeps `listen_addresses='localhost'` and 5432 is never opened in the firewall, so the database is not reachable off-box.
- A daily `pg_dump` backup keeps 14 days and, after the hardening pass, writes dumps with a restrictive `umask` so the ledger data is not world-readable.

21.5.2 12. (Hard) You claim the playbook is safe to re-run against the live box. Which task is most likely to report a false “changed,” and does that undermine the claim?

What a strong answer covers:

- The Postgres role's user task can report `changed` on every run because `scram-sha-256` hashing makes the stored password hard to compare, so the module cannot always tell it is unchanged.
- That is cosmetic noise, not an actual mutation of state, so idempotence of the resulting system still holds.
- Honest framing: “no changes on re-run” is the goal for meaningful

state, and a known cosmetic exception is documented rather than hidden.

- It can be quieted with an option if the noise matters, at the cost of never updating the password through that task.

21.6 Testing and verification

21.6.1 13. Infrastructure code does not have unit tests in the usual sense. How did you gain confidence in the playbook before trusting it near a live shared box?

What a strong answer covers:

- Every role passes `ansible-playbook --syntax-check` and `ansible-lint` clean, catching structural and naming errors early.
- A check-mode-first workflow is documented, so the first thing anyone does against the live box is a dry run with `--diff`, not an `apply`.
- The `nginx` and `tls` roles carry their own runtime assertion (the `portfolio-200` check), so the playbook verifies the most dangerous side effect itself.
- A full from-scratch provision is exercised deliberately and manually, never against a throwaway host in CI, because there is no cloud to spin one up.

21.6.2 14. The image-size gate and the compose stack are new. How are they wired so a regression is caught rather than discovered later?

What a strong answer covers:

- `make image-size` builds the image and exits non-zero above 20 MB, so a dependency or asset that bloats the binary fails a command rather than silently shipping.
- The compose stack was verified live (health check returns 200, Prometheus target reports up), so the wiring is proven, not assumed.
- The dev metrics address and the Prometheus scrape target are set to match, so observability works out of the box for a new contributor.
- Application tests and lint stay green because Week 10 touched no Go source, which is itself a signal that the change is scoped to infra.

21.7 Trade-offs

21.7.1 15. What are the standing negative consequences of this week's choices that a reviewer should know about?

What a strong answer covers:

- Production stays un-containerized, so if the service ever outgrows one box, the bare-binary model is what gets revisited; the Ansible roles are the starting point for a second host.

- The playbook is a control-machine dependency (Ansible and two collections must be installed) and is validated by check mode and re-runs, not by an automated from-scratch CI provision.
- The nginx and tls assertions presume the portfolio is already live on the box, so the playbook targets the existing shared host rather than a truly bare machine, which is documented.
- The demo and deploy story still assumes a single instance; multi-instance would require revisiting both the deploy and the in-process serialization from earlier weeks.

≡ go-ledger

WEEK 11

01 Multi-Currency and FX in a Go Ledger

02 Week 11 Interview Q&A

CHAPTER 22

Multi-Currency and FX in a Go Ledger

Here is a thing that has quietly bugged me my whole adult life. I send someone in another country 100 US dollars. My app says they will receive, let us say, 92 euros. But if I do the math on today's exchange rate, it should have been 92 euros and 34 cents. Where did the 34 cents go? And a harder question: when a real bank does this a million times a day, where do all those little slivers of a cent add up to, and who is keeping track so that not a single one is created or destroyed by accident?

This week I built that machine. `go-ledger` can now hold accounts in different currencies and move money between them, converting as it goes, without ever breaking the one rule this whole project is built on: money is never created and never destroyed, it only moves. This is post 11 of 14.

I want to write this one for people who have never touched foreign exchange or core banking, because it turns out the ideas are genuinely beautiful once someone lays them out slowly, and almost nobody does. If you already know what a *nostro* account is, skim. If you do not, you are exactly who I am writing for.

22.1 First, a one-paragraph refresher on what a ledger even is

A ledger is a list of movements of money. The core rule is double-entry: every transaction is made of two or more entries, called postings, and those postings must add up to exactly zero. If I pay my friend 600 taka, that is not one event, it is two: minus 600 from my account, plus 600 to theirs. They sum to zero, so no money appeared or vanished, it just moved. Your balance is not a number stored somewhere that someone edits. It is the sum of every posting that ever touched your account. The history is the truth, and the balance is just a question you ask of that history. Hold onto “postings must sum to zero,” because the entire drama of this week is about that one sentence surviving contact with two different currencies at once.

22.2 What is a currency, to a ledger?

Before this week, every account in go-ledger had a currency label, but the whole system was really single-currency: a transaction picked one currency, and every account it touched had to be in that same currency. You could have a US dollar account and a euro account sitting side by side, but no single transaction was allowed to touch both.

That restriction is fine until the day you want to actually do the thing everyone wants: move value from the dollar account to the euro account. And the moment you try, double-entry punches you in the face.

22.3 The punch: one transaction, two currencies

Say I want to convert 100 US dollars into euros at a rate of 0.92 euros per dollar. The naive posting looks obvious:

1	minus 100 USD	from my dollar account
2	plus 92 EUR	to my euro account

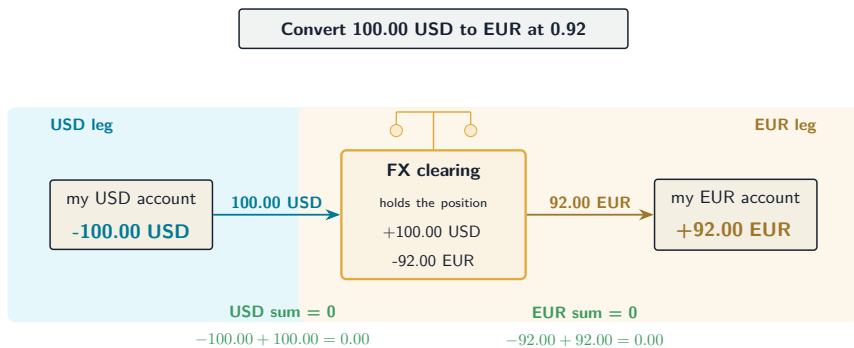
Now apply the sacred rule. Do these postings sum to zero? Well... no. They cannot even be added together. 100 dollars and 92 euros are different things. It is like saying “I removed 100 apples and added 92 oranges, therefore nothing changed.” That is not a balanced transaction, that is just an assertion that two unrelated numbers are somehow equal because a rate said so. If you let that through, your ledger no longer has a provable invariant. It has a vibe.

So the first real decision of the week was: the zero-sum rule cannot be “all postings sum to zero” anymore. It becomes “for each currency, that currency’s postings sum to zero.” The dollars must balance among themselves. The euros must balance among themselves. A cross-currency transaction is really two balanced sub-transactions wearing one coat.

But wait: minus 100 USD does not balance to zero by itself, and plus 92 EUR does not either. So how does anything balance? This is where core banking hands you a genuinely elegant, centuries-old trick.

22.4 The trick banks actually use: a clearing account

Real banks do not magically turn dollars into euros. Nobody can. What they do is keep a special internal account, historically called a *nostro* or clearing account, that holds a position in each currency. When you convert dollars to euros, the bank does not shrink your dollars and grow your euros directly. It routes the movement through the clearing account, in two separate, each-fully-balanced currency legs:



Look at what happened. The dollar postings sum to zero on their own. The euro postings sum to zero on their own. Double-entry is completely intact in each currency. And yet value moved from my dollar account to my euro account. The clearing account is the pivot: it took in 100 dollars and paid out 92 euros. It now holds a position of plus 100 dollars and minus 92 euros. That position is the bank's foreign exchange exposure, and it is a real, honest, on-the-books thing, not a fudge. If you revalue that position at the current rate later, its drift up or down is literally the bank's FX profit or loss.

In go-ledger, the clearing account is a system account, one per tenant per currency, created automatically the first time it is needed, hidden from your normal balance views, and fully expected to sit at a non-zero, often negative, balance forever. That is not a bug. That is the FX book.

So a convert is not two postings, it is four, and the invariant it must satisfy is per-currency zero-sum. My `Transaction.Validate()` and a database trigger both now group the postings by currency and check each group independently. The books balance in every currency or the transaction does not commit. Nothing gets to lean on “trust me, the rate makes it even.”

22.5 Now, the exchange rate itself, slowly

Here is the part newcomers never get told plainly. There is no such thing as “the” exchange rate. There is a mid rate, which is the fair midpoint, and then there is the rate you actually get, which is always a little worse. The gap is called the spread, and it is how the house makes money.

Think of a currency booth at the airport. The board shows two numbers: the price they will buy dollars from you at, and the higher price they will sell dollars to you at. You always trade on the side that is worse for you. That difference, the spread, is their margin, and you pay it on every single trade, in both directions. Convert dollars to euros and back to dollars, and you come out with less than you started, even if the mid rate never moved an inch. You paid the spread twice.

I built exactly this. Each currency pair has a mid rate and a spread measured in basis points (a basis point is one hundredth of one percent, so 25 basis points is 0.25 percent). When you convert, the server takes the mid, widens it against you by the spread, and that widened rate is what you get. The customer always lands on the worse side, in both directions. And crucially, the rate comes from the server, never from you: if a client could hand me the rate to use, a client could hand me a rate that steals money. The rate is the house's call, always.

And where does that spread money go? Straight into the clearing account, as a slightly better position for the house. It is not a magic fee that disappears. It is an FX gain sitting right there on the books, auditable, reconcilable, real.

22.6 The part that will get you fired if you get it wrong: never touch money with a float

Here is where software meets the razor blade. To convert, you multiply an amount by a rate. The obvious code is `amount * rate`, where rate is something like 0.92. And that line, written with a floating point number, is a career-ending bug in a payment system.

Floating point numbers cannot represent most decimals exactly. $0.1 + 0.2$ in floating point is not 0.3 , it is 0.30000000000000004 . In most software that is a harmless wart. In money, it is a slow leak: fractions of a cent, appearing and disappearing at random, across millions of transactions, until your ledger no longer sums to zero and nobody can tell you why. This entire project has stored money as whole integers of the smallest unit (cents, not dollars) since week two, precisely to keep floating

point out of the money path. It would be a betrayal to let it sneak back in through the exchange rate.

So the rate is not a float either. I store it as a big integer, scaled up. A rate of 0.92 is stored as 92,000,000 (the rate times 100 million). A spread is a whole number of basis points. The conversion is then pure integer arithmetic: multiply the amount by the scaled rate, apply the spread as an integer fraction, and divide back down. No decimals, ever.

There is one catch. Multiplying a large amount by a scaled rate can produce a number too big to fit in a normal 64-bit integer, which would silently wrap around into a wrong, possibly negative, answer. So the multiplication is done in an arbitrary-precision big integer, which cannot overflow, and only the final, safely-rounded result is checked to fit back into a normal integer. If it does not fit, the conversion is rejected loudly rather than wrapping into a lie.

22.7 The last decimal: how to round, and where the leftover goes

When you divide to get the final amount, you almost never land on a whole cent. 100 dollars at some rate might come out to 91.7 euros and a fraction. You have to round. And the way you round matters more than you would think.

The tempting choice is “round half up”: 0.5 always rounds up. But that has a subtle bias. Over millions of conversions, always rounding halves upward pushes a systematic drift in one direction, a tiny thumb

on the scale that adds up. So payment systems use banker's rounding instead: round half to the nearest even number. 2.5 rounds to 2, but 3.5 rounds to 4. Over many values, the ups and downs cancel out, and there is no built-in bias. I implemented banker's rounding carefully, including for negative amounts (postings are often negative), because getting the sign wrong there is its own quiet bug.

And the fraction that gets rounded away, the leftover sliver? It does not vanish. It lands in the clearing account, as part of that account's position. This is the answer to my lifelong question about the missing 34 cents. They are not gone. They moved into the FX book, where they are counted as part of the house's gain or loss, down to the last unit. Money is conserved. I proved it: one of this week's tests converts an amount from dollars to euros and back, and asserts that the total the customer lost equals, exactly, the position now sitting in the clearing accounts. Nothing leaked. It just moved, which is the only thing money is ever allowed to do.

22.8 Writing the rate down, because a rate is a promise

One more core-banking habit worth naming. When you convert money, the rate you used is a material fact. If there is ever a dispute ("why did I only get 92 euros?"), the honest answer has to be "here is the exact mid rate, the exact spread, the exact rate applied, the source of that rate, and the moment it was in effect." So every conversion permanently records all of that on the transaction and in the audit log. The rates themselves live in a database table that is append-only: a new rate is a new row, never an overwrite, so the full history of what

rate was live at any past moment is always reproducible. And the code that fetches a rate sits behind a small interface, so today it reads a table seeded from configuration, and tomorrow it could pull live rates from a real provider without a single change to the conversion logic.

22.9 What I deliberately did not build

This is version one, and scope discipline is the difference between shipping and drowning. There is no live market data feed yet, just a configured rate table with the seam ready for a real provider. There is a single spread per pair, not a real bid and ask sourced from a market. There is no separate profit-and-loss report on the FX position yet; the position simply sits in the clearing accounts, waiting for next week's reporting work to reveal it. Currency conversion goes directly between two currencies, or via a single inversion, not through chains of three. Each of those is a real feature and a real follow-up. None of them is a hole in the invariant, which is the only thing I refuse to compromise.

22.10 The lesson I keep relearning

Every week this project teaches me the same thing in a new outfit. The hard part is never the flashy feature. It is defending the invariant while the feature tries to bend it. Multi-currency wanted me to say “the rate makes it balance, trust me.” Double-entry does not accept trust, it accepts proof. The clearing account was the way to keep the

proof: not by hand-waving that dollars equal euros, but by making the dollars balance as dollars, the euros balance as euros, and letting one honest account hold the difference where anyone can see it.

If you are building anything that moves money, or moves anything that must be conserved, resist every clever shortcut that would make the books balance by assertion instead of by construction. Route the difference through an account you can point at. Keep floating point a hundred miles from the money. And write down the rate, because a rate is a promise, and promises in finance are made to be checked.

The whole thing, clearing accounts and integer rates and all, is at **github.com/sohag-pro/go-ledger**, and the reasoning is in **ADR-014**. Next week: nested accounts and reporting, where that quietly accumulating FX position in the clearing accounts finally gets a report that reveals it.

CHAPTER 23

Week 11 Interview Q&A

Interview-style questions for the Week 11 work recorded in ADR-014: per-currency double-entry, FX clearing accounts, a server-side rate with a spread, integer-only banker's-rounded conversion, an append-only rate store behind a provider seam, and request-based idempotency on convert. Every question is answerable from this repo's code (`internal/domain/fx.go`, `internal/domain/transaction.go`, `internal/ledger/convert.go`, `internal/fx/`, `internal/postgres/migrations/0010_*`) and ADR-014.

23.1 The core modeling problem

23.1.1 1. Before this week the ledger was effectively single-currency per transaction. What exactly changed in the invariant, and why could you not just keep “all postings sum to zero”?

What a strong answer covers:

- A cross-currency transaction has postings in two currencies; you cannot add dollars and euros, so a single global sum is meaningless.

- The invariant became per-currency zero-sum: for each currency in the transaction, that currency's postings sum to zero.
- `Transaction.Validate()` now groups postings by currency (a `map[Currency]Money`, reusing `Money.Add` within a group) and checks each group is zero.
- The database `assert_txn_balanced` trigger changed from a single `SUM` to `GROUP BY currency HAVING sum(amount) <> 0`, so the domain and the DB enforce the same rule.

23.1.2 2. A plain “debit the USD account, credit the EUR account” does not balance in either currency. How does a cross-currency transaction stay balanced?

What a strong answer covers:

- Every currency leg routes through a system FX clearing account, so each currency nets to zero on its own.
- The four postings: source account minus X USD, clearing plus X USD (USD nets zero); clearing minus Y EUR, destination plus Y EUR (EUR nets zero).
- The clearing account ends holding a position (plus USD, minus EUR) which is the FX exposure, on the books, not a fudge.
- This is standard nostro-style accounting: the difference lives in an auditable account, not in an assertion that the rate makes things equal.

23.1.3 3. What is the FX clearing account, and why is it fine for it to sit at a permanent, often negative, balance?

What a strong answer covers:

- It is a per-tenant, per-currency system account (a normal Liability type with `is_system = true`), created lazily on first use.
- It holds the running FX position; its non-zero balance is the exposure, and its drift revalued at current rates is the FX gain or loss.
- It is hidden from user balance listings and expected to carry an open position, so no “no negative balance” rule applies to it.
- The rounding residual and the spread margin both accumulate here, which is how money stays conserved.

23.2 The exchange rate

23.2.1 4. The rate is applied server-side from a table, never supplied by the client. Defend that.

What a strong answer covers:

- A client-supplied rate is a money-theft vector: a caller could hand over a rate that moves value in their favor.
- The server owns the rate; the client sends only the accounts and the source amount, and the target currency comes from the `to` account, not client input.

- The rate lives in an append-only `fx_rates` table behind a `RateProvider` interface, so the origin can later become a live provider with no change to the conversion code.
- The mid comes from the provider; the spread is the ledger's own policy (a markup), applied by the conversion service, not the provider.

23.2.2 5. What is the spread, and how do you guarantee it always disadvantages the customer, including when a rate is only stored one direction?

What a strong answer covers:

- The spread is the markup between the fair mid rate and the rate the customer actually gets; it is the house's margin, paid in both directions.
- The rule: normalize to quote-per-base first (inverting the stored pair if only the reverse exists), then reduce the quote the customer receives by the spread.
- Reducing quote-out is always worse for the customer regardless of direction, so a round trip loses roughly two spreads.
- Both directions are unit tested; the round-trip reconciliation test asserts the loss equals the clearing position.

23.2.3 6. Where does the spread “go”? Trace the money.

What a strong answer covers:

- Applying a worse rate means the destination leg credits slightly fewer units than the mid would; the clearing account keeps the

difference.

- That difference is an FX gain sitting in the clearing account, auditable, not a fee that disappears.
- Money is still conserved per currency; the spread just changes the clearing position.
- Reporting on that position is deferred to Week 12; for now it accumulates honestly in the clearing accounts.

23.3 Integer-only conversion (the money-safety core)

23.3.1 7. Why is there no float64 anywhere in the conversion, and how do you multiply an amount by a fractional rate without one?

What a strong answer covers:

- Floating point cannot represent most decimals exactly, so it leaks fractions of a unit over many operations; money has been integer minor units since ADR-002.
- The rate is a scaled integer (`mid_rate_e8`, the rate times $1e8$) and the spread is integer basis points, so the conversion is pure integer arithmetic.
- `converted = source * mid * (10000 - spread) / (1e8 * 10000)`, computed in `math/big.Int` so the large intermediate cannot overflow.
- Env rates are parsed to the scaled integer by string manipulation, never `parseFloat`.

23.3.2 8. (Hard) The multiply-then-divide overflows a normal 64-bit integer for large amounts. Walk through how the code handles that without a wrong answer.

What a strong answer covers:

- `source * mid_e8 * (10000 - spread)` can reach around 10^{30} , far past `int64`, so the whole product and division run in `math/big.Int`.
- The rounded result is only converted back to `int64` after a `q.IsInt64()` check; if it does not fit, `Convert` returns `ErrOverflow` rather than wrapping.
- Using `big.Int` also avoids the `uint64(-a)` negation trap that breaks at `math.MinInt64`, which a hand-rolled 128-bit path would hit.
- The tests cover a `MaxInt64` amount (rejected as overflow) and a `MinInt64` source (converts correctly at rate 1.0).

23.3.3 9. Why banker's rounding instead of round-half-up, and why does the sign matter?

What a strong answer covers:

- Round-half-up has a systematic upward bias that accumulates directionally over many conversions; banker's rounding (round half to even) has no built-in bias.
- 2.5 rounds to 2 but 3.5 rounds to 4, so ties balance out over many values.
- Postings are frequently negative, so the rounding must be sign-symmetric: minus 2.5 to minus 2, minus 3.5 to minus 4; getting

the sign wrong is its own quiet bug.

- It is implemented on the integer quotient and remainder and unit tested at the tie boundaries for both signs.

23.3.4 10. The conversion is a single rounding step, not “round the rate, then round the amount.” Why does that matter?

What a strong answer covers:

- Rounding twice introduces a compounded bias; folding rate, spread, and amount into one multiply-divide rounds exactly once.
- The reproducible truth of a conversion is (mid, spread, source) through the one formula; the stored `applied_e8` is an informational display value, not what the amount derives from.
- A single `big.Int` computation both avoids the double rounding and the overflow at once.
- The stored snapshot records the inputs and the output, so the exact result is always reconstructable.

23.4 Idempotency, rates, and durability

23.4.1 11. Convert is idempotent, but its fingerprint is built from the request, not from the posted amounts. Why the difference from a normal transaction?

What a strong answer covers:

- The converted amount depends on the rate at post time; if the fingerprint hashed the built postings, a retry after the rate moved would produce a different amount and a different fingerprint.
- That would make a legitimate retry look like “same key, different body” and return a 409, which violates the idempotency contract.
- So the convert fingerprint hashes the request (from, to, source amount), resolved before the rate lookup; on a key hit it replays the stored transaction without re-converting.
- A genuinely different request reusing a key still correctly conflicts (409), and double-post is prevented by the per-tenant serialized transaction.

23.4.2 12. Why is the `fx_rates` table append-only, and how do you find “the rate in effect now”?

What a strong answer covers:

- Overwriting a rate would destroy history; append-only keeps a full, reproducible record of what rate was live at any past time, which matters for disputes and audit.
- Seeding and any future provider insert a new row with a new `effective_at`, never an update.
- The current rate is the row with the greatest `effective_at` $\leq$ now, ordered `effective_at` DESC, `id` DESC so a re-seed within the same second resolves deterministically to the last inserted.
- Each conversion also snapshots the applied rate and a foreign key to the source row, so provenance is on the transaction itself.

23.4.3 13. (Hard) You dropped the transaction-level currency column. What was the blast radius, and how did you avoid silently mislabeling an FX transaction?

What a strong answer covers:

- Every reader of a transaction currency breaks: the repository read-back, the REST and gRPC response shapes, the audit payload, and the demo seeder.
- Currency moved onto each posting; `GetTransaction` rebuilds each posting's Money from its own row's currency, and the response DTOs carry per-posting currency (a real `reserved` field in the proto for the removed one).
- The idempotency fingerprint moved to per-posting currency, keeping the description field so a reused key with a different description still conflicts rather than replaying the wrong transaction.
- A consumer sweep listed every reader before the drop, and a boot test caught the seeder, which runs in a startup goroutine and is not covered by unit tests.

23.5 Testing and trade-offs

23.5.1 14. (Hard) A property test that only generates balanced transactions and perturbs one posting can pass even if `Validate` sums all currencies together. How do you actually prove the per-currency rule?

What a strong answer covers:

- If every generated case has each currency balanced, the raw total is also zero, and a one-posting perturbation breaks both by the same amount, so a currency-blind global sum passes every case.
- The discriminating case perturbs two different currencies in opposite, raw-unit-canceling directions (USD plus 100, EUR minus 100): each currency is individually unbalanced but the naive global sum stays zero.
- Real `validate` must reject that; a global-sum implementation would wrongly accept it, letting money vanish across currencies while looking balanced in aggregate.
- The test was verified to fail against a deliberately-mutated global-sum `validate` and pass against the real one, which is what proves it discriminates.

23.5.2 15. The FX round-trip reconciliation test is the money-safety proof. What does it actually assert, and what would count as a tautology that proves nothing?

What a strong answer covers:

- It converts an amount from one currency to another and back, then

asserts the total the customer lost equals the net position sitting in the FX clearing accounts, read from the database.

- It also asserts every currency still nets to zero across the whole book, including the clearing accounts, so nothing leaked.
- A tautology would be asserting that two numbers derived by the same arithmetic are equal (a telescoping identity), which holds regardless of whether the code is correct; that was found and removed.
- The real content is the conservation check against persisted balances plus bounds on the spread and rounding residual, which exercise the actual conversion behavior.

23.5.3 16. Name the biggest thing you deliberately left for later, and one standing consequence a reviewer should know about.

What a strong answer covers:

- Left for later: live rate-provider integration (the seam exists, the implementation does not), FX profit-and-loss reporting (the position sits in clearing, Week 12 reveals it), real bid/ask from a market, and currency triangulation beyond a single inversion.
- Standing consequence: the idempotency fingerprint change is breaking across the deploy that ships it, accepted deliberately pre-real-money, with a versioning scheme deferred.
- Every aggregate is now per-currency; nothing may sum across currencies, so a tenant total is a vector of per-currency balances, not a scalar.
- The clearing accounts are write-hot per tenant, but same-tenant

posts already serialize (ADR-012), so this adds no new contention class.

≡ go-ledger

WEEK 12

01 Nested Accounts in a Go Ledger

02 Week 12 Interview Q&A

CHAPTER 24

Nested Accounts in a Go Ledger

Open any budgeting app and look at the summary screen. It says you spent 620 on “Food” this month. But you never made a payment to something called Food. You bought groceries, you got coffee four times, you ordered dinner twice. “Food” is not a thing money moved to. It is a bucket that holds other buckets, and the number next to it is everything underneath, added up.

That is an account hierarchy, and this week I gave the ledger one. “Assets” holds “Cash” and “Bank”. “Bank” holds “Checking” and “Savings”. You read the balance of “Bank” and you want the total across everything below it, not just whatever happened to be posted directly to the “Bank” row.

Sounds like a small feature. It runs straight into the one rule this whole project is built on.

24.1 The rule it collides with

From day one, go-ledger never stores a balance. An account is just identity: a name, a type, a currency. Its balance is derived, computed by summing every posting that ever touched it. The history is the truth; the number is always recomputed from it. That is what makes the ledger trustworthy: there is no balance field for a bug to corrupt,

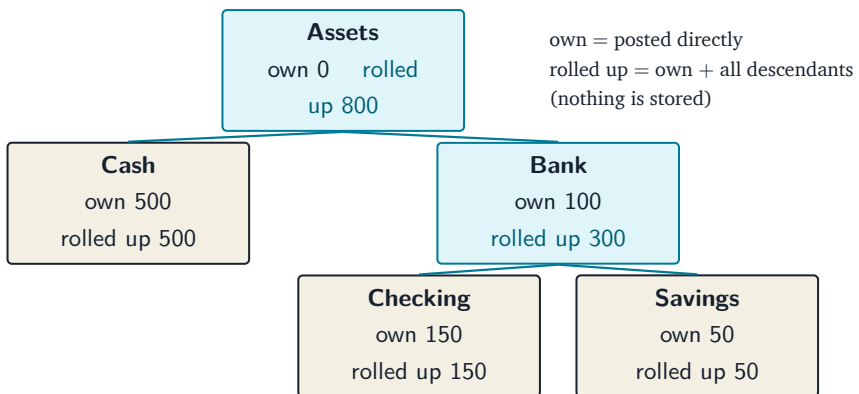
no counter that can drift away from reality.

So when someone asks “what is the rolled-up balance of Bank”, the tempting answer is to keep a running total on the Bank row and update it every time a child gets a posting. That answer is wrong here. It reintroduces exactly the stored, mutable number the ledger was designed to never have, and it drifts the first time a posting or a re-parenting misses the update.

The right answer is to keep the balance derived, and make the rollout a question you ask, not a value you store.

24.2 What a nesting looks like

Give an account an optional `parent_id` pointing at another account. A chart of accounts becomes a tree:



“own” is what was posted directly to that account. “rolled up” is that account plus everything under it. Bank’s own balance is 100, but

rolled up it is $100 + 150 + 50 = 300$. Assets was never posted to at all (own 0), but rolled up it is the whole subtree: $500 + 300 = 800$.

Notice a parent can still have its own postings. Bank has 100 of its own on top of its children. There is no rule that a parent must be an empty folder; its rollup is simply its own postings plus all of its descendants'. An account you never post to is just a parent that happens to have zero of its own.

24.3 Rolling up without storing anything

Two ways to compute the rollup, and I use both.

For one account, a recursive query walks the tree in the database. Gather the account and all of its descendants by following `parent_id` downward, then sum the postings of that whole set:

```
1 WITH RECURSIVE subtree AS (  
2   SELECT id FROM accounts WHERE tenant_id = $1 AND id = $2  
3   UNION ALL  
4   SELECT a.id FROM accounts a  
5     JOIN subtree s ON a.parent_id = s.id AND a.tenant_id = $1  
6 )  
7 SELECT COALESCE(SUM(p.amount), 0)  
8 FROM postings p  
9 WHERE p.tenant_id = $1 AND p.account_id IN (SELECT id FROM subtree);
```

Nothing is stored. The number is computed fresh from the postings every time you ask, same as an ordinary balance read, just over a subtree instead of a single account.

For the whole tree at once (the console's accounts page, the reports),

running that recursive query once per account would be a query per node. Instead I pull every account's own balance in one flat query, then roll up in memory: build the parent-to-children map, and for each node compute own plus the sum of its children, recursively, memoized. That is linear in the number of accounts, one database read, and it hands back the tree in parent-before-child order with each node's depth so the console can just indent and print it.

24.4 The database refuses to draw a circle

A tree has one way to go badly wrong: a cycle. Make A the parent of B, then make B the parent of A, and “roll up A” chases its own tail forever. The recursive query would spin; the in-memory rollup would recurse without end.

So the database will not let a cycle exist in the first place. A trigger runs before any insert or any change to `parent_id`, walks up the ancestor chain from the proposed parent, and if it ever reaches the row itself, it rejects the change. It also rejects an account trying to be its own parent, and a child whose currency does not match its parent's (a subtree is single-currency, which is what lets a rollup be one number instead of a pile of per-currency totals). The application checks too and returns a clean error, but the database is the guarantee no code path can slip past.

Same tenant is handled without any trigger at all. The parent link is a composite foreign key on `(tenant_id, parent_id)`, so a parent has to live in the same tenant as its child by construction. You cannot point an account at another tenant's account even if you try; the constraint

simply will not allow the row.

24.5 The subtle part: what has to sum to zero

Reports show the rolled-up number now. The trial balance lists every account with its own balance and its rolled-up balance side by side. But there is a trap.

The trial balance's real job is to prove the books balance: for each currency, every account's balance summed together must be exactly zero. That is the double-entry invariant made visible. If it is not zero, money was created or destroyed and something is very wrong.

You cannot run that proof on rolled-up balances. A rollup counts a child's money twice: once in the child's own row, once in the parent's rolled-up row. Sum all the rollups and you will get a number that is not zero, and it will look like the books are broken when they are perfectly fine.

So the rule is: rollups are for reading, own balances are for proving. The zero-proof is computed from own (leaf) balances exactly as it always was; the rolled-up column is an extra figure for a human to read the tree, and it never touches the invariant check. Two numbers on the same row, and only one of them is allowed near the proof.

24.6 Where it fits

An operator opens the accounts page and sees a real chart of accounts, indented, with each parent showing the total underneath it. They read a parent's balance rolled up and get the whole subtree. They move an account under a new parent, and the rollup reflects it on the next read, because there was never a stored number to update. And through all of it, no balance is stored, and the books still prove out to zero on the numbers that are supposed to.

The whole thing is written up in **ADR-023**, and the repo is open source at **github.com/sohag-pro/go-ledger**. Next: approval workflows and an outbox event stream, holding a big transaction for a second signature before it posts.

CHAPTER 25

Week 12 Interview Q&A

Interview-style questions for the account-hierarchy week (ADR-023): nested accounts with rolled-up balances, computed on read, without ever storing a balance. Every question is answerable from this repo's code and ADR-023, plus `internal/postgres/migrations/0032_account_hierarchy.sql`, `internal/postgres/queries/accounts.sql`, `internal/ledger/account_service.go` (`buildTree`), `internal/ledger/report_service.go`, and `internal/api/accounts.go`.

25.1 Domain and data model

25.1.1 1. Explain how you added an account hierarchy without adding a stored balance. Why did that matter?

What a strong answer covers:

- A nullable self-referential `accounts.parent_id` makes the chart of accounts a tree; a parent's balance is not a new field.
- The ledger's first principle (ADR-001, ADR-003) is that a balance is never stored, it is the sum of an append-only posting history, so

there is no number for a bug to corrupt.

- A rolled-up balance is therefore a question you ask (a query), not a value you keep, so it cannot drift.
- The rollup stays exactly as trustworthy as an ordinary balance read: both derive from `SUM(postings.amount)` at read time.

25.1.2 2. Why is a subtree constrained to a single currency, and what does that buy you?

What a strong answer covers:

- The trigger rejects a child whose currency differs from its parent's, so every account in a subtree shares one currency.
- A single-currency subtree rolls up to one number; mixed currencies would force a rollup to be a map of currency to amount (you cannot sum USD and EUR).
- It matches the per-currency zero-sum invariant the ledger already enforces.
- Mixed-currency grouping was deliberately left out of scope for this reason (ADR-023 alternatives).

25.1.3 3. A parent account can also carry its own postings. Defend that choice over making parents pure grouping nodes.

What a strong answer covers:

- A parent's rolled-up balance is its own postings plus every descendant's, so the rollup definition is simply "sum the whole subtree,

root included.”

- It keeps the posting rules unchanged: any account can be posted to, no special “you cannot post to a parent” rule at posting time.
- An empty grouping node is just a parent nobody posts to, so the pure-group behavior is still available without a new rule.
- Pure-group semantics would add a posting-time check and a re-parenting check for no real gain.

25.2 Rollup computation

25.2.1 4. You compute a single account’s rollup with a recursive CTE and the whole tree with an in-memory Go rollup. Why two mechanisms?

What a strong answer covers:

- `RolledUpBalance` (one account) uses `WITH RECURSIVE` to gather the account and its descendants, then sums their postings: one query, exact, for a targeted read.
- The tree (console accounts page, reports) would be one recursive query per node; instead `AllAccountBalances` fetches every account’s own balance in one read, and `buildTree` rolls up in memory.
- `buildTree` is $O(n)$: build the parent-to-children map, memoize `rollup(id) = own + sum(rollup(children))`, and emit nodes parent-before-child with depth.
- Both paths sum the same postings over the same subtree, so they return the same number (the whole-branch review verified they agree).

25.2.2 5. Challenge: a recursive CTE per read is slower than a stored rollup column or a closure table. Why did you reject those?

What a strong answer covers:

- A materialized rollup column reintroduces the stored, mutable balance the ledger exists to avoid, and it drifts the moment a post or a re-parent misses an update.
- A closure table is more moving parts (an ancestor/descendant table to maintain on every parent change) than the scale needs.
- The recursive CTE keeps balances derived and always correct, at a cost that is an indexed read over a tenant's postings, the same shape as an ordinary balance read.
- ADR-023 names the closure table as the escape hatch if constant-time rollups ever matter, kept behind the same repo method so the API would not change.

25.2.3 6. Walk through buildTree. How does it guarantee correct rollups and parent-before-child order, and can it loop forever?

What a strong answer covers:

- It builds own, children, and acctByID maps in one pass, collecting roots (nil parent, or an orphan whose parent is absent, promoted to a root so nothing is dropped).
- rollup(id) is memoized so each subtree is summed once; walk(id, depth) emits the node then recurses into children, giving parent-

before-child order and correct depth.

- Because each node has exactly one parent pointer, any hypothetical cycle forms a component disjoint from every root, so the root-driven walk never enters it: it terminates and never duplicates a node.
- The real cycle guard is the database trigger; `buildTree` only has to be safe if the impossible happens.

25.3 Data integrity

25.3.1 7. How do you prevent a cycle in the hierarchy, and why enforce it in the database rather than only in the service?

What a strong answer covers:

- A trigger fires `BEFORE INSERT OR UPDATE OF parent_id`, walks up the ancestor chain from the proposed parent, and rejects if it reaches the row itself; it also rejects a self-parent and a currency mismatch.
- The service checks too and returns a clean error, but the trigger is the guarantee no code path (a raw update, a future endpoint, the seeder) can bypass.
- A `hops` cap terminates a chain corrupted outside the trigger's protection, so the walk cannot spin.
- Enforcing in the database is the same defense-in-depth stance as the balance and currency triggers already in the schema.

25.3.2 8. How is same-tenant parentage enforced, and why not do it in the trigger too?

What a strong answer covers:

- The parent link is a composite foreign key (`tenant_id`, `parent_id`) REFERENCES accounts (`tenant_id`, `id`), reusing the UNIQUE (`tenant_id`, `id`) that has existed since migration 0001 for postings.
- The FK makes a cross-tenant parent structurally impossible: the tuple must match on `tenant_id`, so you cannot point at another tenant's account even by id.
- It is a declarative constraint the planner enforces on every write, cheaper and harder to get wrong than trigger logic.
- Combined with row-level security, an acting tenant's trigger walk only ever sees its own accounts anyway.

25.3.3 9. Hard: an unknown `parent_id` and a currency mismatch both fail a create. How do you make sure each surfaces as the right error, not a generic 500?

What a strong answer covers:

- The trigger's currency check does a lookup on the parent; a non-existent parent must NOT be misread as a currency mismatch (its currency comes back NULL, which IS DISTINCT FROM any real currency would wrongly reject).
- The fix is a FOUND check: if the parent row is absent, fall through and let the foreign key raise 23503 instead, which maps to `ErrParentNotFound`.

- A real currency or cycle violation raises 23514 (`check_violation`), mapped to `ErrInvalidHierarchy`.
- Both sentinels map to 422 in `toHumaErr`, so a caller sees a clear, well-typed error, not a 500. (This exact bug was caught and fixed during implementation.)

25.4 Reporting

25.4.1 10. The trial-balance report now shows a rolled-up column, but the zero-proof still uses own balances. Explain why the proof cannot use rollups.

What a strong answer covers:

- The trial balance proves the books balance: per currency, every account's balance summed must be exactly zero (the double-entry invariant made visible).
- A rollup counts a child's money twice, once in the child's own row and once in the parent's rolled-up row, so summing rollups is not zero even when the books are correct.
- The per-currency net and imbalance are therefore computed from own (leaf) balances, unchanged; the rolled-up column is additive display only and never feeds the proof.
- Two numbers on a row, and only own balances are allowed near the invariant check.

25.4.2 11. What does the `/v1/accounts/tree` endpoint return, and why return a flat list with depth instead of a nested JSON tree?

What a strong answer covers:

- It returns every account in parent-before-child order, each with `parent_id`, `depth`, `own_balance`, and `rolled_up_balance`.
- A flat, pre-ordered list with a `depth` field lets a client render the tree by indentation without walking or reconstructing it, which the thin console does directly.
- It is one read (`AllAccountBalances`) plus the $O(n)$ rollup, so the whole hierarchy costs one query.
- A nested structure would push tree-walking onto every client and complicate pagination; the flat form is simpler and already ordered.

25.5 Testing and trade-offs

25.5.1 12. How did you test that the rollup is correct and that the hierarchy rules actually hold?

What a strong answer covers:

- Integration tests over real Postgres: the trigger rejects self-parent, 2-node and 3-node cycles, and a cross-currency child; a valid nesting succeeds; the composite FK blocks a cross-tenant parent.
- `RolledUpBalance` across A to B to C asserts a parent equals own plus all descendants and a leaf equals its own balance.

- Service unit tests over a fake repository exercise `buildTree` order, depth, and multi-root rollups without a database.
- A dedicated migration test exercises the down path (drop trigger, function, index, constraint, column) and up/down/up idempotency, matching the convention of the other schema migrations.

25.5.2 13. Challenge: you use `pgx` + `sqlc`, yet the tree rollup is written in Go, not SQL. Why not push the whole rollup into a single recursive SQL query?

What a strong answer covers:

- A per-account recursive rollup would be one query per node for a whole-tree view, N recursive queries; the Go rollup is one flat query plus an $O(n)$ in-memory pass.
- `sqlc` still owns every query that touches the database (the flat balance read, the single-account CTE); the Go rollup is pure computation over already-fetched rows, which `sqlc` has no opinion on.
- Keeping the aggregation in Go makes it trivially unit-testable without a database (the fake-repo tests) and easy to reason about.
- The single-account path stays in SQL where a targeted, exact answer is wanted; the two mechanisms are each used where they are strongest.

25.5.3 14. A re-parent is a single parent_id update. How does the rollup stay correct afterward, and what stops a re-parent from creating a cycle or crossing currencies?

What a strong answer covers:

- Rollups are recomputed on read, so a re-parent needs no rollup maintenance; the next read reflects the new tree immediately.
- The same trigger runs ON UPDATE OF parent_id, so a re-parent that would create a cycle, cross currencies, or self-parent is rejected exactly like a create.
- The composite FK still blocks a cross-tenant move.
- SetParent returns ErrAccountNotFound when no row matches (so a bad account id is a 404), and the trigger's violations surface as 422.

25.5.4 15. Where could this design hurt at scale, and what would you change without breaking the API?

What a strong answer covers:

- A very deep tree pays a recursive-CTE cost on a single-account rollup read, and the whole-tree endpoint scans all of a tenant's postings once.
- At demo and single-operator scale this is negligible; the honest answer is to measure before optimizing.
- The escape hatch is a closure table (or a maintained rollup) behind the same repo method, so RolledUpBalance, Tree, and the endpoints would not change.

- The invariant proof stays on own balances regardless, so any rollup-acceleration change cannot threaten correctness of the books.

≡ go-ledger

WEEK 13

01 Approval Workflows and an Outbox Event Stream in Go

02 Week 13 Interview Q&A

CHAPTER 26

Approval Workflows and an Outbox Event Stream in Go

The first time a bank made me wait, I was annoyed. I was trying to send a fairly large transfer, tapped confirm, and instead of the usual “done” the app said the payment was “under review.” Nothing moved. My balance sat exactly where it was. A few hours later it went through. At the time it felt like the app was being slow. Later I understood it was being careful: somebody, or some rule, had decided that a payment that size does not just happen because one person tapped a button.

That is an approval workflow, and this week I gave the ledger one. A transaction over a configured size does not post. It waits. Someone with the authority to approve it either lets it through or turns it down, and only then does the money move, or not. This is post 13 of the build.

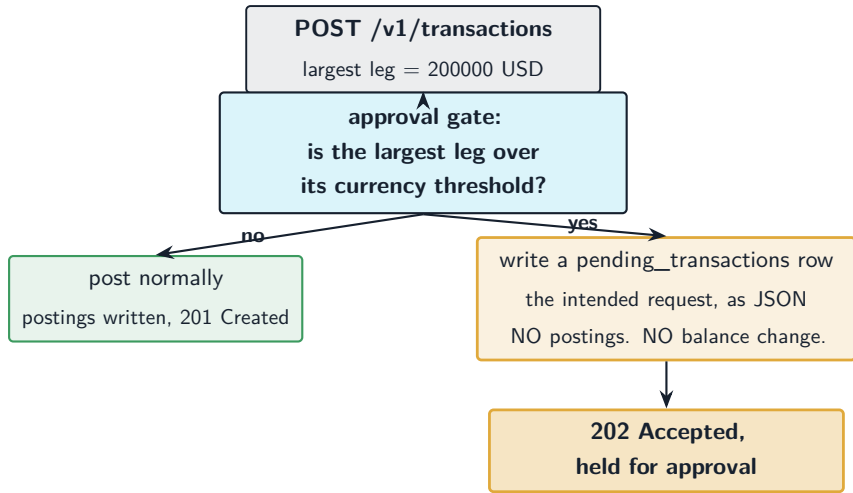
26.1 The rule: big movements wait

The whole feature turns on one number, per currency. If the largest single posting in a transaction is bigger than the threshold you set for its currency, the transaction is held instead of posted. Under the threshold, nothing changes: it posts exactly like it did last week.

Here is a concrete one. Say the USD threshold is 1,000.00 (the ledger stores money in minor units, so that is 100000 cents). Someone tries to move 2,000.00 between two accounts:

Posting	Account	Amount (cents)
1	ops:checking	-200000
2	vendor:payable	+200000
Largest leg		200000

200000 is over 100000, so this one does not post. It is held. The person who submitted it gets back a “held for approval” response, not a posted transaction. And here is the part that matters most: **nothing is written to the postings table**. No balance anywhere reflects that 2,000.00, because in this ledger a balance is never a stored number. It is the sum of an account’s postings. If I want the held money to not exist yet, the simplest, safest thing is to make sure not a single posting exists yet.



So a held transaction is stored as *intent*, not as a ledger entry. A row in a new `pending_transactions` table holds the original request (the legs, the reference, the effective date) as a JSON payload, plus which threshold it tripped and who submitted it. Postings, transactions, balances: untouched.

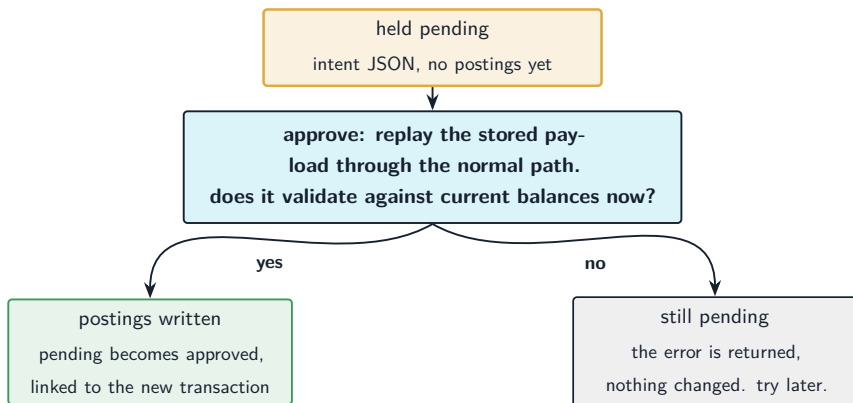
26.2 Approve means replay, not resurrect

When an approver approves the held transaction, what should happen? The tempting answer is “flip a status flag and mark it posted.” That answer is wrong for this ledger, and seeing why is the interesting part.

The held row is just intent. To actually post it, I take that stored payload and run it back through the *normal* posting path, the exact same code an ordinary transaction uses. Same validation, same bal-

ance and currency database triggers, same audit trail. Approval is a replay of the original request, not a special second way to write a transaction.

That buys two things. First, there is only one place in the codebase that ever writes a transaction, so there is only one place that can be wrong. Second, and this surprised people I described it to: the replay validates against **current** balances, not the balances from when the transaction was first submitted. If the account had enough money on Monday but has been drained by Wednesday when the approval finally happens, the approval fails. It should. The pending row is a request to move money now, checked now, not a promise cashed against a stale snapshot.



26.3 The two bugs that only showed up under a hard look

I want to be honest about the parts that were not clean the first time, because that is where the real engineering lived this week.

The first: what happens if two people approve the same held transaction at the same instant? Or one approves while another rejects? My first version took a database row lock, checked the status, released the lock, and then did the write in a separate step. That gap is a door. Two decisions could both walk through it and race, and you could end up with a posted transaction whose pending row says “rejected,” a real payment orphaned from any record that it was ever allowed. The fix was to hold the lock across the whole decision, and for the one case that cannot (the approve has to post in its own transaction), to re-check under the lock afterward and let the already-posted money win, so a real transaction is never left orphaned.

The second was subtler and I did not catch it myself. My AI pair, running a final review across the whole week’s diff, flagged it: the held path never recorded the caller’s idempotency key. Idempotency keys are the thing that makes a retry safe. The client sends a payment, the network eats the response, the client retries with the same key, and the server is supposed to recognize the retry and not do the work twice. But a *held* transaction skipped the code that stores the key. So a retried large payment created a *second* pending row, and approving both would post the money twice. That is the worst class of bug this project can have: it makes money out of nothing. The fix was to dedupe the hold on the caller’s key, so a retry returns the same pending instead of minting a new one. I will come back to the AI-pair

honesty at the end, but that one is worth flagging here: the bug was on the main retry path, not some exotic race, and a per-task review would never have seen it because the seam only exists when you look at the whole feature at once.

There is also a switch for the classic “four eyes” rule: require that the approver is a different person than the submitter. It is off by default (the public demo runs on a single key, so it has to be able to approve its own), but the control exists and is one config flag away.

26.4 Eventing without Kafka

Now the second half of the week, and the part I am most pleased with. Every one of these approval moments (requested, approved, rejected, cancelled, expired) should be an *event*. Something the outside world can subscribe to. When a big payment gets held, a system somewhere probably wants to ping a human. When it is approved, a downstream service wants to know.

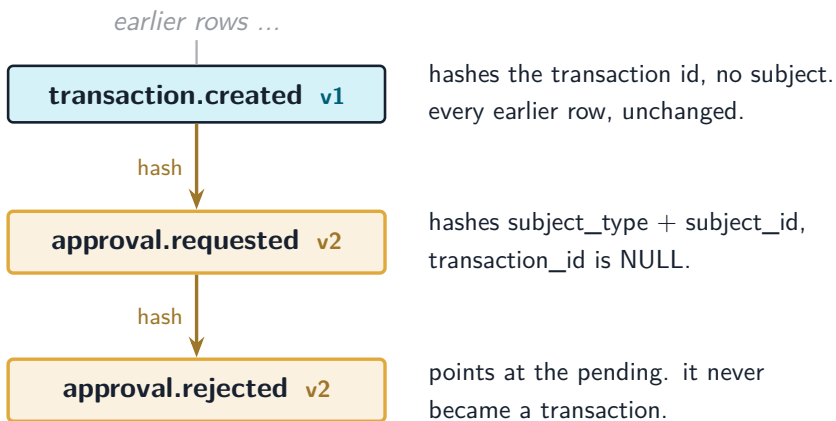
The reflex reach here is Kafka, or some event broker. I do not have one, and I do not want one. Here is the thing though: I already had a durable, ordered, append-only event stream sitting in the database. I built it weeks ago and called it the audit log.

The way it works (the outbox pattern) is that when a transaction posts, it writes a row to an outbox table in the *same* database transaction as the postings. Either both land or neither does. A background worker then drains that outbox in commit order and builds the tamper-evident, hash-chained audit log, and a webhook worker reads that

log by sequence number and delivers events to subscribers. That is already an event stream with exactly-once semantics off a committed transaction. Approval events just need to ride the same rails.

The catch: that audit chain was built to record *transactions*. Every row pointed at a transaction id. But a rejected approval never becomes a transaction. There is nothing to point at. So I had to teach the chain to carry events that are about something other than a transaction.

That meant three new columns and a careful choice. The `transaction_id` became nullable. Two new columns, `subject_type` and `subject_id`, let a row say “this event is about a pending transaction, id such-and-such” instead of naming a transaction. And a `hash_version` column, because the audit log is tamper-evident: every row’s hash is computed over its own fields, and if I changed how the hash was computed, every existing row from the last twelve weeks would fail to verify.



the chain still verifies end to end

So version 1 is the old preimage, exactly as it was, and every trans-

action row stays version 1 and re-hashes to the same value it always did. Version 2 folds in the subject and tolerates a missing transaction id, and only the new lifecycle events use it. The verifier reads each row's version and checks it with the matching recipe. I wrote a test that builds a chain mixing v1 transaction rows and v2 approval rows, verifies the whole thing, then tampers with one v2 row's subject and confirms the verifier catches it. The crown jewel of the project (a ledger history you can prove was not altered) had to keep holding while the chain learned a new trick.

And because approval events now live in the same log the webhook worker already reads, they get delivered to subscribers for free. No new stream, no broker, no second delivery path. The webhook that used to carry “a transaction was posted” now also carries “a large payment is waiting for you,” and it did not cost a single new moving part.

26.5 Where the money can and cannot go

Pulling it together, here is the shape of what shipped this week:

- A transaction over its currency's threshold is held as intent, with no postings, so no balance ever reflects unapproved money.
- Approving it replays the real posting path against current balances. It can fail, and failing leaves the request pending, not half-applied.
- The decision is serialized under a row lock, and a posted transaction can never be orphaned from its record.
- A retried large payment returns the same held request, so an approval can never double-post.

- Every step is an event on the existing tamper-evident chain, delivered by the existing webhook worker, with zero new infrastructure.
- The whole feature is off by default. If you never set a threshold, the ledger behaves exactly as it did last week.

26.6 My AI companion

Same deal as every week: I own the decisions, Claude accelerates the work, and I am honest about the split. This week the split was interesting.

I made the calls that mattered: hold intent instead of flipping a status, replay through the one real posting path, reuse the audit chain as the event stream rather than add a broker, keep the old hash version frozen. Those are in the architecture decision record, **ADR-025**, written before any code, as usual.

But two of the bugs above were caught by the review loop, not by me writing carefully. The concurrency gap where a decision could orphan a posted transaction, and the idempotency gap where a retried large payment could double-post, both surfaced when a reviewer looked at the finished work with fresh eyes. The idempotency one in particular came out of a review that read the entire week's diff at once, precisely the view that no single task ever has. I have said before that "I watched 100 goroutines try to corrupt my ledger and fail" is a different kind of knowledge than reading about it. This week's version of that is: an adversarial second read of your own money-moving code will find the bug you were too close to see. Build that step in.

The repo is open at **github.com/sohag-pro/go-ledger**. Next week is the last of this stretch: webhooks in full, the launch, and a look back at the whole build.

CHAPTER 27

Week 13 Interview Q&A

Interview-style questions for the approvals week (ADR-025): an env-configured threshold gate that holds over-threshold transactions as pending intent, approval that replays the normal post path, and extending the tamper-evident audit chain to carry non-transaction lifecycle events that webhooks deliver. Every question is answerable from this repo's code and ADR-025, plus `internal/postgres/migrations/0033_api_keys_approve_scope.sql` through `0036_pending_idempotency.sql`, `internal/ledger/approval_config.go`, `internal/ledger/approval_hold.go`, `internal/ledger/approval_service.go`, `internal/ledger/service.go` (the gate in Post), `internal/domain/audit.go` (`ComputeAuditRowHash`), `internal/audit/chainer.go`, `internal/webhook/fanout.go`, and `internal/api/approvals.go`.

27.1 Domain and data model

27.1.1 1. Walk me through what happens when a transaction exceeds the approval threshold. Where does the held request live, and what deliberately does not happen?

What a strong answer covers:

- The gate (`ApprovalConfig.Gate`) computes the largest absolute posting amount per currency and holds if any currency's max exceeds its configured threshold; `holdForApproval` writes a `pending_transactions` ROW (migration 0035) carrying the intended request as a payload JSON, the tripped `threshold_ccy/threshold_amt`, and `created_by`.
- Crucially, nothing is written to postings or transactions: the held money has no ledger entry, so no balance reflects it (balances are derived by summing postings, ADR-001/003).
- The create endpoint returns 202 Accepted with the pending resource, not a posted transaction (`internal/api/transactions.go` maps `HeldForApprovalError`).
- The gate runs after screening and before any persistence, and is skipped on an approval replay.

27.1.2 2. Why store the held transaction as an intent payload in a separate table instead of inserting the transaction with a `status = 'pending'` column?

What a strong answer covers:

- A status column puts unapproved postings in the table, forcing every balance and report query to filter by status, reintroducing exactly the status-dependent, stored state the ledger avoids (ADR-025 alternatives).
- A separate `pending_transactions` table keeps the intent out of the ledger entirely; there is one posting path and balances never see unapproved money.
- The payload is the request, not resolved rows, so approval resolves and re-validates (important for convert, whose FX rate is

re-read at approval time).

- The `pending_transactions` CHECK constraints (`status='pending'` OR `decided_at IS NOT NULL`, `transaction_id IS NULL` OR `status='approved'`) encode the lifecycle at the schema level.

27.1.3 3. The threshold is judged on the largest single leg per currency. Why that rule and not the total value moved, or one global number?

What a strong answer covers:

- Largest leg per currency matches the per-currency zero-sum invariant: there is no cross-currency total to compare against one number (ADR-014, ADR-025).
- Gross-debit-per-currency obscures which leg is large; a single global threshold ignores that currencies differ in scale.
- A currency with no configured threshold is never gated (`ApprovalConfig.Gate` returns not-gated for unlisted currencies).
- For a cross-currency convert, each leg is judged in its own currency, so the gate composes naturally with multi-currency.

27.2 Approval lifecycle and concurrency

27.2.1 4. Approving a held transaction “replays the normal post path.” Explain what that means and one non-obvious consequence.

What a strong answer covers:

- `ApprovalService.Approve` unmarshals the stored payload and calls the same `Post/Convert/Reverse` entry an ordinary request uses, wrapped in `withApprovalReplay(ctx)` so the gate is skipped (else it would re-hold and loop).
- One code path writes a transaction, so one place can be wrong; validation, balance and currency triggers, and the audit event all happen exactly once, in one place.
- The non-obvious consequence: the replay validates against current balances, not the balances at submission time. An approval can fail because funds moved, and that is correct behavior, not a bug.
- On replay failure the pending stays pending and the error is returned; nothing is half-applied.

27.2.2 5. Two operators click “approve” and “reject” on the same held transaction at the same instant. Walk me through how the system keeps that from corrupting state.

What a strong answer covers:

- Each decision takes `SELECT ... FOR UPDATE` on the pending row (`GetPendingForUpdate`) and holds the lock across the status write; `Reject/Cancel` do lock, re-check status, update, and emit the event in

ONE RunInTx (lockedTransition).

- Approve cannot hold the lock across its replay (the post needs its own transaction), so it uses three phases: check under lock, replay unlocked, then re-lock and re-verify status before writing.
- If a concurrent decision terminalized the pending while the approve was mid-replay, the money is already posted and cannot be un-posted, so “post wins”: the pending is forced to approved and linked, so a posted transaction is never orphaned from its record (logged as a warning).
- A decision on an already-terminal pending returns `ErrPendingAlreadyDecided` (409); the loser of a race sees a terminal state.

27.2.3 6. Approving posts a transaction in one database transaction, then marks the pending approved in a second. What if the process crashes between them?

What a strong answer covers:

- The two-transaction split is unavoidable because the replay reuses `Post`, which opens its own `RunInTx`; marking the pending approved is a separate write.
- A crash after the post but before the mark leaves a posted transaction with a still-pending row. `Approve` is idempotent and crash-safe: before replaying, it checks under lock whether the pending already has a linked `transaction_id` and returns that transaction instead of posting again.
- The replay itself is deduped by a derived idempotency key (`approval :<pendingID>`), so even a re-post attempt collapses to the same transaction via the idempotency machinery.

- Net: a second approve after a crash returns the same transaction id, never a double-post.

27.2.4 7. A client submits an over-threshold payment, the network drops the response, and the client retries with the same idempotency key. What happens, and what bug did an earlier version have here?

What a strong answer covers:

- The held path originally never recorded the caller's idempotency key (that write lived only inside `RunInTx` on the real-post path), so a retry passed the `GetIdempotencyKey` precheck as not-found and created a second pending; approving both double-posted money.
- The fix (migration 0036) adds `idempotency_key` to `pending_transactions` with a unique partial index `(tenant_id, idempotency_key) WHERE idempotency_key IS NOT NULL`; `holdForApproval` dedups on the caller's key and returns the existing pending on a retry.
- The check-then-insert has a race, so a 23505 unique violation on that index is caught and the existing pending is re-read and returned, so no path creates a duplicate.
- A NULL key (no header) does not collide because the index is partial, so keyless holds still create a fresh pending each time.

27.2.5 8. What is the “four-eyes” flag, why is it off by default, and how is it enforced?

What a strong answer covers:

- `APPROVAL_REQUIRE_DIFFERENT_ACTOR` enforces segregation of duties: the approver's actor must differ from the pending's `created_by`, else `Approve` returns `ErrCannotApproveOwn` (409).
- It is off by default because the public demo runs on a single key that must be able to approve its own held transactions; the control exists and is one flag from being on.
- Reusing the `admin` scope for approval was rejected; a dedicated `approve` scope keeps “authorize a large movement” distinct from “operate the tenant” (ADR-025).
- `Cancel` is creator-only (`actor == created_by, else ErrNotPendingCreator`), a distinct terminal state from an admin reject.

27.3 The event stream and audit chain

27.3.1 9. The plan called for “event streaming.” You did not add Kafka or any broker. What did you use instead and why was it already there?

What a strong answer covers:

- The audit chain is already a durable, ordered, append-only event stream: a post writes an `audit_outbox` row in the same transaction as the postings (outbox pattern, ADR-017), a background chainer drains it in commit order into the hash-chained `audit_log`, and the webhook worker reads that log by `chain_seq`.
- Approval lifecycle events ride the same rails: they are written to the outbox and delivered by the existing webhook worker with no new source (ADR-025).

- A separate event outbox was considered and rejected in favor of one stream, accepting the cost of extending the integrity chain (ADR-025 alternatives).
- Kafka and event sourcing are explicitly out of scope for this project; the in-DB outbox covers eventing.

27.3.2 10. A rejected approval never becomes a transaction. How can the tamper-evident audit chain, which was built around transaction ids, carry an event that has no transaction?

What a strong answer covers:

- Migration 0034 makes `audit_outbox.transaction_id` and `audit_log.transaction_id` nullable and adds `subject_type/subject_id`, so a lifecycle event can say “this is about a pending transaction” instead of naming a transaction.
- The events are `approval.requested/approved/rejected/cancelled/expired`, with `subject_type='pending_transaction'` and `subject_id` the pending id; only `approval.approved` also carries the posted transaction id.
- They are written to the outbox in the same transaction as the state change, so the event is durable if and only if the decision commits.
- The chainer and verifier were taught to thread the nullable transaction id and subject fields end to end (`chainOne, ListAuditForVerifyPage`).

27.3.3 11. You changed how audit rows are hashed. How did you avoid breaking verification for the twelve weeks of existing rows?

What a strong answer covers:

- `ComputeAuditRowHash` branches on a new `hash_version` column: `v1` is the exact original preimage (tenant, action, `transaction_id`, actor, before, after, `created_at`, `prev_hash`) and is left byte-for-byte unchanged, so every existing row re-hashes to its stored value.
- `v2` folds in `subject_type/subject_id` and tolerates an empty transaction id, and only new lifecycle events use it; the version is stored per row and the verifier recomputes with the matching recipe.
- A test builds a chain mixing `v1` transaction rows and `v2` lifecycle rows, verifies the whole chain, then tampers a `v2` row's subject and confirms the verifier catches the break.
- Chain sequence and outbox id are structural and never hashed (ADR-017), so they can change without affecting any stored hash.

27.3.4 12. Once approval events are on the audit chain, how do webhooks deliver them, and what was the one change needed on the delivery side?

What a strong answer covers:

- The webhook fan-out worker already reads `audit_log` by `chain_seq` and delivers matching events to active subscriptions, so lifecycle events fan out for free (`internal/webhook/fanout.go`).
- The one change: the payload builder had to tolerate a null

`transaction_id` and carry `subject_type/subject_id`, with the nullable UUID guarded on `.Valid` before formatting (a `pgtype.UUID.String()` on an invalid value would silently emit the zero UUID).

- `WebhookPayload` gained `subject_type/subject_id` as `omitempty` and made `transaction_id` `omitempty`, so a lifecycle event serializes without a transaction id.
- Delivery guarantees are unchanged: exactly-once off the committed outbox, at-least-once delivery with the existing retry.

27.4 Security, API, and testing

27.4.1 13. How does the approve scope get provisioned and enforced, and how does the demo satisfy it without a real key?

What a strong answer covers:

- `approve` is a new api-key scope alongside `read/post/admin`, with `admin` a superset (`domain.HasScope`); the `api_keys_scopes_valid` CHECK was widened in migration 0033.
- `RequiredHTTPScope` special-cases `/v1/pending/{id}/approve` and `/reject` to require `ScopeApprove`; `cancel` stays `post` (`creator-only`, enforced in the service).
- Keys are minted via the admin API with a scopes list, so an admin issues a key carrying `approve`; enforcement is server-side in `auth.HumaMiddleware`, never client-trusted.
- In demo mode `admin` is public and the demo key is a superset, so the console Approvals panel works without an extra key; four-eyes

is off there.

27.4.2 14. How would you test that a held transaction never moves money before approval, and that approving it then does?

What a strong answer covers:

- Post over-threshold with approvals enabled: assert a `HeldForApprovalError`, a `pending_transactions` row with `status='pending'`, `transactions` unchanged, and an `approval.requested` outbox row for the pending.
- Approve: assert the transaction now exists, the pending is approved and linked, an `approval.approved` event is emitted, and a second approve returns the same transaction id (idempotent).
- Re-validation: drain the account below the held amount between hold and approve, assert the approve fails and the pending stays pending.
- Reset/purge safety: `pending_transactions` is in both the demo purge order and the seed reset loop, tested so a tenant holding a pending is fully cleared (FK to tenants).

27.4.3 15. RLS is on `pending_transactions`, but the TTL sweep that expires stale pendings runs with no tenant context. How do both hold?

What a strong answer covers:

- `pending_transactions` uses the same RLS pattern as other tenant tables: `ENABLE/FORCE ROW LEVEL SECURITY` with a policy keyed on `current_setting`

(`'app.tenant_id', true`), including the allow-when-unset branch (migration 0035, matching 0024).

- The background sweep (`SweepExpiredPending`) runs cross-tenant with no GUC set, which is exactly why the policy allows access when the setting is unset or empty; a plain `tenant_id = current_setting(...)::uuid` policy would break the sweep.
- The sweep still emits an `approval.expired` event per expired row, each in its own tenant-scoped `RunInTx`, so the events are correctly attributed.
- The whole feature is opt-in: with `APPROVAL_ENABLED=false` the gate never fires and behavior is exactly as before.

≡ go-ledger

WEEK 14

01 I Built a Production Go Payment Ledger in 14 Weeks. Here's What I'd Do Differently.

02 Week 14 Interview Q&A

I Built a Production Go Payment Ledger in 14 Weeks. Here's What I'd Do Differently.

Near the end of this build I did something I'd recommend to anyone who has just finished a big project and feels good about it: I handed the whole thing to a reviewer who had no stake in my feelings and asked them to be brutal. Not “does this look nice.” More like “pretend this is moving real money and try to lose some.”

The review came back with three critical findings. One of them was about a feature I had shipped weeks earlier, written a whole blog post about, and quietly been proud of. It turned out the feature did not do the thing it claimed to do. At all.

This is the last post in the series, so instead of a highlight reel, here is the honest version: the mistakes I'd fix if I started over, and the few decisions I'd make again without blinking.

28.1 The control that did nothing

Week 13 added approval workflows. The idea is simple and every payments shop has some version of it: a transaction over a certain size does not just post because one person asked. It gets held, and

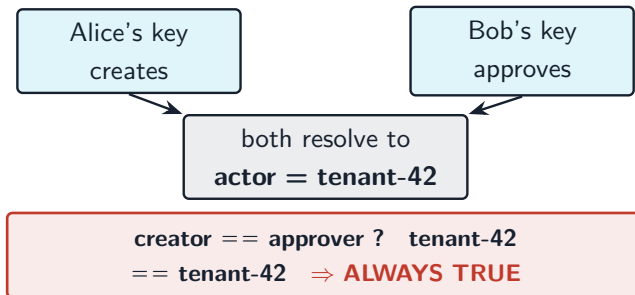
a second person has to approve it. Two sets of eyes. In the industry it's called four-eyes, or maker-checker: the person who makes the request cannot be the person who checks it.

I built the gate, held the over-threshold transaction as pending intent, and added a flag, `APPROVAL_REQUIRE_DIFFERENT_ACTOR`, that was supposed to enforce exactly that: the approver must be a different actor than the creator. I tested it. It passed. I wrote it up as a real control.

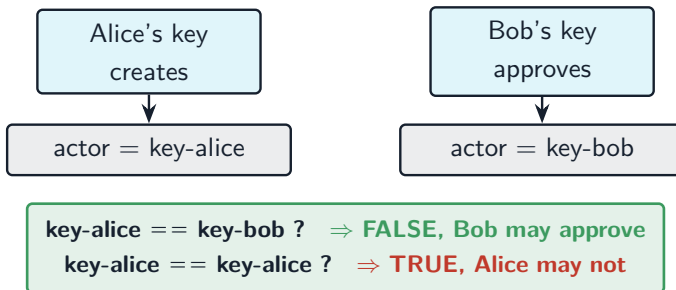
Here's the concrete scenario. Alice, using her own API key, submits a 500,000-unit transfer. It's over the threshold, so it's held. Bob, using his own key, should be able to approve it, and Alice should not. That's the whole point.

The problem was in one word: actor. Everywhere in the codebase, the "actor" recorded on an event was the tenant id, not the individual API key that made the request. So when the approval code checked "is the approver a different actor than the creator," it was comparing the tenant to the tenant. Same tenant on both sides. Always equal.

WHAT I SHIPPED (actor = tenant id)



WHAT IT SHOULD HAVE BEEN (actor = API-key id)



With the flag off, there was no segregation of duties at all: a single admin key could create the transaction and approve it. With the flag on, it was worse in a funny way: every approval looked like self-approval, so no over-threshold transaction could ever be approved by anyone. The feature was either a no-op or a deadlock, and I had confidently documented it as neither.

The fix was not hard once I saw it: carry the individual API-key id as the acting principal through the whole path, instead of collapsing everyone in a tenant into one identity. Now maker-checker compares two actual keys. But I want to be clear about why I missed it: my tests

used the tenant as the actor too, so they agreed with the bug. The test and the code shared the same wrong assumption, so of course they got along.

The lesson I keep relearning: a green test proves the code matches the test, not that either matches reality. The only thing that caught this was a fresh pair of eyes that did not already believe the feature worked.

28.2 The footgun I'm leaving in on purpose (and why that's a decision, not an accident)

The live demo resets every few hours. To do that, a background job deletes the demo tenant's data and repopulates it. Fine. But the way I wrote the reset, it deletes *every tenant that isn't the demo tenant*, across a dozen tables, including the encryption keys and the audit anchors, and it deliberately switches off the append-only guard to do it.

The only thing standing between that job and a real database is two environment variables. Point it at the wrong `DATABASE_URL` once and there is no undo.

For a demo box that holds nothing but fake, regenerated data, I decided that's acceptable, and I'm leaving it. But I want to name it honestly, because "it's fine for the demo" is a judgment I made, not a property of the code. In anything holding real money I would never let a destructive, cross-tenant, guard-bypassing delete be gated by two env vars and good intentions. It would need an allowlist, a row-count

ceiling, and a refusal to run at all if it saw a tenant it didn't recognize. The difference between a demo tool and a production tool is often exactly this: not what it does, but how hard it is to make it do the wrong thing.

28.3 Breaking my own rule about ADRs

Early on I made a rule for myself: every significant decision gets an architecture decision record written *before* the code. The reasoning is that the “why” is freshest during the design, and a decision you have to write down is a decision you actually make instead of drift into.

I kept that rule for thirteen weeks. Then I built webhooks and just... didn't. The code shipped, it worked, it had signing and retries and a delivery log, and there was no ADR explaining any of the choices. I only noticed the gap in this final week, when I went to link the webhooks ADR from the README and there wasn't one.

I wrote it retroactively (it's ADR-027, and it says right at the top that it was written after the fact). Writing it late is better than not writing it, but it's not the same. A retroactive ADR documents what you did; a real one shapes what you're about to do. By the time I wrote this one, all the interesting alternatives were already closed. The value of the rule was in the timing, and I gave that up for one week because the feature felt “obvious.” Nothing in a payment system is obvious enough to skip the paper trail.

28.4 The cloud I planned and never used

My original plan, written in Week 0, said the deployment would be AWS ECS Fargate, RDS, and Terraform. It sounded appropriately serious.

When I actually got to the deployment week, I looked hard at that and changed my mind. For a portfolio-scale service that resets every few hours and serves a demo, a single well-run VPS with Postgres on the same box and a GitHub Actions pipeline that ships on every push is simpler, cheaper, and teaches the same operational discipline: migrate before you swap, health-check, roll back on failure. The cloud-console tax was not buying me anything at this size.

I don't regret the switch. I regret how confidently the original plan asserted the opposite. "AWS ECS/Terraform" was in the plan because it sounded like what a real system uses, not because I had weighed it against the actual requirements. A plan should bound your choices, but it shouldn't pretend to have made decisions you haven't earned yet. The honest version of that plan line would have been "deploy target: TBD, decide at Week 10 against real constraints."

28.5 The week that actually hurt

If you're going to build a ledger, Week 4 is where you find out whether you're serious. That's the week two requests try to post to the same account at the same time.

Getting the balance invariant to hold under concurrency meant SERI-

ALIZABLE isolation, a retry loop for the serialization failures Postgres throws when it detects a conflict, and a genuinely nasty debugging session where the thing that was serializing my transactions was not the row I expected but a predicate lock on a range of rows I was reading to compute a balance. The fix was real work, and the stress test that proves it (thousands of goroutines racing on a handful of accounts, and the ledger never once going wrong) is the test I'm proudest of.

I wouldn't do that week differently. I'm mentioning it because everything else in the build was tractable, and this was the one place where the problem was as hard as the domain promised it would be. If you're planning your own version of this project, budget double for the concurrency week. It's the one that earns the "production" adjective.

28.6 The alerts nobody is watching

The code emits a lovely set of signals. There's a Prometheus gauge that goes non-zero the instant the balance invariant is ever violated in production, and an alert pack with a severity-one page wired to it.

Nothing scrapes it. There is no Prometheus running in front of the live service, and the offsite backups are configured but not yet provisioned, so the durability story today is a same-disk dump. I built the instrument panel and never plugged in the gauges.

This is the gap between "the code is production-grade" and "the deployment is production-grade," and they are not the same claim.

For a demo, I've accepted it. But it's the item that would keep me up at night if this held real money, precisely because it's invisible: a decorative alert doesn't warn you that it's decorative. It just quietly never fires.

28.7 What I'd keep, exactly as it is

For all of that, there's a shorter list of things I'd do again without changing a line of the approach.

- **Enforce the invariant in the database, not just the code.** The zero-sum rule lives in the domain types *and* in a Postgres constraint trigger on the postings table. Every write path, including a raw `psql` insert or a buggy seeder, has to go through it. The reviewer tried to find a way to create or destroy money and could not, and that's because the guarantee doesn't depend on any code path remembering to check.
- **Property tests and chaos tests, not just examples.** The invariant gets tested by throwing hundreds of randomized transactions at it, including the mean case where one currency goes up and another goes down so a naive global sum still looks balanced. And a chaos test kills the database connection at the exact moment of commit to prove rollback and idempotent retry actually hold. Those two caught more real bugs than any hand-written example.
- **An ADR per decision** (the twelve weeks I actually did it). Reading them back, they're the most useful artifact in the repo. Not the code, the reasoning.
- **Building in public.** Every week's post forced me to explain the week's work to a stranger, and explaining a design is the fastest

way to find the part you don't actually understand. More than once the blog post is where I caught the bug, not the code.

28.8 The honest close

Fourteen weeks ago I paid a friend back for dinner and got curious about the system that recorded it. What I have now is a real, deployed, open-source payment ledger that I can explain every line of, including the lines that were wrong.

The version of this retrospective that only listed wins would have been easier to write and worth less. The self-audit chapters, the ones where I document a failure with numbers, are the parts of this series I'd point a hiring manager at first, because anyone can show you working code. What's harder, and rarer, is showing you the bug you shipped, how you found it, and exactly what you changed. That's the whole project, really: not that the ledger is perfect, but that its history is honest, and everything else is a cache.

Thanks for reading along. The code is open, the book is free, and the demo is live (at least until the next reset wipes it).

CHAPTER 29

Week 14 Interview Q&A

Interview-style questions for the final week: webhook delivery (ADR-027) fanned out off the tamper-evident event stream, its signing and retry model, the SSRF and replay hardening from ADR-026, and the engineering-judgment lessons from the build's own retrospective. Every question is answerable from this repo's code and ADRs, chiefly `internal/webhook/worker.go`, `delivery.go`, `fanout.go`, `signer.go`, `dialer.go`, `internal/postgres/migrations/0021_webhooks.sql`, `docs/adr/027-webhooks.md`, `docs/adr/026-security-and-correctness-hardening.md`, and, for the retrospective questions, `internal/ledger/actor.go`, `internal/auth/context.go` (PrincipalID), and `internal/seed/seed.go`.

29.1 Webhook delivery and eventing

29.1.1 1. Walk me through the path an event takes from a posted transaction to a delivered webhook. What are the two background stages and why are they separate?

What a strong answer covers:

- A post writes an `audit_outbox` row in the same transaction as the postings (ADR-017). A single-leader chainer drains the outbox into the hash-chained `audit_log`, assigning `chain_seq`.
- The webhook worker fans out off `audit_log` by `chain_seq` (not the raw outbox): one `webhook_deliveries` row per matching subscription (migration 0021), then a delivery stage POSTs each due row.
- Separation means webhooks only ever fire for events already in the verified, ordered chain, and the fan-out cursor is a distinct concern from delivery retry state.
- Both fan-out and delivery run only on the leader (a Postgres advisory lock), so the cursor has a single writer.

29.1.2 2. Why deliver off `audit_log` rather than directly off `audit_outbox`?

What a strong answer covers:

- `audit_log` is the chained, `chain_seq`-ordered, durable, tamper-evident record; the outbox is a pre-chain buffer processed in commit order but not yet linearized.
- Delivering off the chain gives webhooks the same total order and durability as the integrity record: a webhook is never sent for an event not yet part of the verified chain.
- It reuses one stream for two consumers (verification and delivery) instead of a second ordering mechanism.
- The tradeoff: webhook latency is bounded below by the chainer's lag, which is acceptable because the chainer runs on a tight interval and lag is already a monitored signal.

29.1.3 3. What exactly does “at-least-once” mean here, and whose job is deduplication?

What a strong answer covers:

- A committed event is guaranteed to reach a healthy subscriber, but the same event may be delivered more than once (a retry after a lost ack, a redelivery after a crash).
- Every delivery carries `X-Ledger-Delivery-Id`, the delivery row id, stable across all retries of that event to that subscription; the receiver deduplicates on it.
- The ledger owns delivery; the receiver owns idempotency. That split is deliberate: the receiver is better placed to dedup against its own state than the ledger is to guarantee exactly-once across an unreliable network.
- Ordering per subscriber is also not guaranteed; a receiver must tolerate out-of-order and duplicate.

29.1.4 4. How is a delivery signed, and how does a subscriber defend against a replayed capture?

What a strong answer covers:

- `X-Ledger-Signature: sha256=<hex>` is an HMAC-SHA256 over "`<unix-ts>.<body>`" keyed by the subscription secret (`signer.go`, `SignatureHeaderAt`).
- `X-Ledger-Timestamp` carries the send time and is part of the signed content, so a subscriber that rejects a stale timestamp is protected against replay of a captured delivery (ADR-026).
- The secret is generated at subscription creation, shown once, and

never returned by any read path (`internal/domain/webhook.go`), so a leaked list response cannot reveal it.

- The body is re-marshaled from a fixed Go type each attempt, so every retry signs byte-identical content (Postgres does not preserve jsonb bytes).

29.1.5 5. Describe the retry and dead-letter policy. What are the states a delivery moves through?

What a strong answer covers:

- pending, then delivered on a 2xx. Any non-2xx or transport error schedules `next_attempt_at = now + backoff` and marks it failed.
- Backoff is exponential from a 10s base capped at 10 minutes (`DefaultBackoffBase/DefaultBackoffCap`); after `MaxAttempts` (8) the row is dead and never retried.
- The `webhook_deliveries` table is the delivery log: attempt count, last error, terminal state, all queryable so an operator sees what a subscriber missed.
- The delivery batch only picks up rows whose subscription is still active, so deactivating a subscription stops future retries.

29.2 Security hardening

29.2.1 6. A tenant can register any URL as a webhook target. What stops that from becoming a server-side request forgery vector?

What a strong answer covers:

- The delivery client dials through a transport whose `Control` hook rejects non-public IPs: loopback, link-local (including the 169.254.169.254 metadata endpoint), private, unique-local, CGNAT, unspecified, multicast (`dialer.go`, `isBlockedIP`).
- The check runs post-DNS on the concrete IP, closing the DNS-rebinding window that a resolve-then-check-then-dial sequence would leave open.
- Because each redirect hop dials through the same transport, the guard re-applies on redirects automatically.
- `WEBHOOK_ALLOW_PRIVATE_TARGETS` (default false) re-enables private delivery for a demo or self-hosted deployment; the default is the safe posture.

29.2.2 7. Why put the SSRF check in the dialer's `Control` hook instead of validating the URL when the subscription is created?

What a strong answer covers:

- Create-time validation checks the hostname as typed; the actual danger is the resolved IP at connect time, which DNS can change between validation and connection (rebinding).
- `Control` fires after resolution with the exact `ip:port` about to be dialed,

so it validates what is actually being connected to.

- It also covers redirects and any later change to DNS for the host, which a one-time create check cannot.
- Create-time validation is still useful as a fast fail, but it cannot be the security boundary.

29.3 The retrospective: engineering judgment

29.3.1 8. The four-eyes approval control shipped broken and passed its tests. Explain the bug and why the tests agreed with it.

What a strong answer covers:

- The “actor” recorded on events was the tenant id, not the API-key id, so `RequireDifferentActor` compared tenant to tenant: always equal (a no-op with the flag off, a total deadlock with it on).
- The tests constructed the actor as the tenant too, so they encoded the same wrong assumption the code did and passed.
- The fix threads the individual principal (`auth.PrincipalID`, `ledger.WithActor`) end to end so maker-checker compares two distinct keys.
- The meta-lesson: a green test proves code matches test, not that either matches reality; an independent review (or a test written to a different mental model) is what catches a shared assumption.

29.3.2 9. The demo seeder can delete every non-demo tenant, bypassing the append-only guard, gated only by two env vars. You accepted that for the demo. Where is the demo-versus-production line, and what would make it production-safe?

What a strong answer covers:

- The demo box holds only regenerated fake data and resets on an interval, so a destructive cross-tenant purge is acceptable there; the guard is the deployment's environment, not the code.
- “Fine for the demo” is a judgment about the deployment, not a property of the code: the same code against a real `DATABASE_URL` is catastrophic and irreversible.
- Production-safe would need an allowlist, a purge-count ceiling, and a refusal to run if it sees a tenant it does not recognize, not two env vars and good intentions.
- The general principle: a demo tool and a production tool often differ not in what they do but in how hard it is to make them do the wrong thing.

29.3.3 10. You wrote the webhooks ADR (ADR-027) after the code, breaking your own “ADR before code” rule. What is actually lost by writing it late?

What a strong answer covers:

- A pre-code ADR shapes the decision while alternatives are still open; a retroactive one only documents the choice already made.

- The value of the rule is in the timing (forcing a deliberate decision, capturing the “why” while it is fresh), not just in having a document.
- ADR-027 says at the top that it is retroactive, which is the honest disclosure but not a substitute.
- Nothing in a payment system is “obvious” enough to skip the paper trail; the one week that felt obvious is exactly where a gap slipped in.

29.4 Trade-offs and locked decisions (defend these)

29.4.1 11. Defend at-least-once over exactly-once delivery. When would exactly-once actually be worth the cost?

What a strong answer covers:

- Exactly-once across an unreliable network is effectively at-least-once plus receiver dedup anyway; the stable delivery id already gives the receiver that.
- The ledger would have to hold per-subscriber acknowledgement and ordering state to attempt exactly-once, for a guarantee the receiver still has to backstop.
- The honest framing: the system provides at-least-once and makes dedup cheap (stable id), which is the standard, correct webhook contract.
- Exactly-once earns its cost only when the receiver genuinely cannot dedup, which is rare and usually a receiver-design smell.

29.4.2 12. Defend building eventing on a Postgres outbox and the audit chain instead of Kafka or a dedicated queue.

What a strong answer covers:

- The outbox and chain already existed for the audit requirement; eventing reused them, so there is no second system to run, monitor, or reason about (scope discipline, ADR-025/027).
- One transactional write (postings plus outbox row) gives exactly the atomicity a separate broker publish would race against (the dual-write problem).
- The cost is throughput ceiling and per-subscriber features a broker gives for free; at this system's scale that ceiling is far off.
- When it would flip: sustained fan-out volume or many independent consumers with their own retention needs would justify a real broker, and the outbox is a clean seam to put one behind later.

29.4.3 13. Webhooks fan out off `audit_log` under a single leader. Isn't that a throughput bottleneck and a single point of failure? Defend it.

What a strong answer covers:

- Single-leader (advisory lock) is a correctness requirement for a single fan-out cursor, not a scaling choice; multiple writers would double-fan-out or corrupt the cursor.
- It is not a single point of failure across instances: leadership is a lock any instance can acquire, so a leader dying just means another

takes over on the next tick.

- Throughput is bounded by one worker's batch loop, which is ample here; horizontal delivery scaling (sharded cursors) is the seam if it ever isn't.
- The failure mode is bounded delay, not loss: unfanned events stay in the durable chain until a leader processes them.

29.4.4 14. If you started the whole project over, what would you change about how you planned and validated it, in one honest paragraph?

What a strong answer covers:

- The plan asserted decisions it had not earned (AWS ECS/Terraform, later abandoned for a VPS); a plan should bound choices, not fake having made them.
- Tests written by the same person with the same mental model share that model's blind spots; an independent adversarial review found what the suite could not.
- The controls that held (the invariant in a DB trigger, property and chaos tests, an ADR per decision) were the ones that did not depend on any single code path or person remembering to be careful.
- Production-grade code and a production-grade deployment are different claims: the alert pack and backups were built but not wired, and a decorative alert never warns you it is decorative.

≡ go-ledger

SPECIAL EDITION

1

- 01 I Audited My Own Payment Ledger Like It Held Real Money.
The Front Door Was Wide Open.
- 02 Special Edition Q&A: Hardening a Payment Ledger for Real
Money

I Audited My Own Payment Ledger Like It Held Real Money. The Front Door Was Wide Open.

There is a moment in every project where you stop admiring what you built and start trying to break it. I hit that moment with go-ledger last week. The tests were green, the invariant held under 10,000 concurrent transactions, the load test sustained 500 requests a second. I felt good.

So I did the thing that ruins a good mood on purpose. I sat down and reviewed my own code as if I were a hostile senior engineer being paid to find the way in, and as if real money, not demo data, flowed through it. Not “do the tests pass.” A different question: **if someone could reach this API, what could they do?**

The answer took the good mood with it. This is a special edition, a bonus post between the numbered weeks, about what that audit found and how I fixed it.

30.1 The good news first

The accounting core was genuinely solid, and I want to say that plainly because it is the part that took months to get right. Money is

stored as integer minor units, never floating point, so no rounding ghost ever creeps in. The double-entry invariant (every transaction's postings sum to zero) is enforced in two independent places: the Go domain and a Postgres constraint trigger, so even a direct `psql` write cannot create money from nothing. Balances are summed from immutable, append-only postings, never a mutable number someone could overwrite. Every write is atomic under `SERIALIZABLE`. Idempotency keys share the exact transaction that posts the money, so a retry cannot double-post.

None of that was the problem. The problem was everything in front of it.

30.2 The bad news: the front door had no lock

Here is the single line that summed up the whole risk. Every request in the service acted as one tenant, read from a config value:

```
1 deps.Transactions.Post(ctx, deps.DefaultTenant, txn, idem)
```

There was no authentication. None. Anyone who could send an HTTP request to `/v1/transactions` could move money between accounts, and anyone who could reach `/v1/accounts/{id}/balance` could read anyone's balance. The tenant was not derived from who you were, because there was no “who you were.” It was a constant.

I had shipped a bank vault with a flawless internal mechanism and left the front door propped open with a rock. And I had done it on purpose, sort of: the comments even said “until an auth layer lands.” That is a fine trade-off for a demo. It is a catastrophe the instant the

words “real money” enter the sentence.

The audit found five things, ranked the way I would rank them if this were a real pentest report:

#	severity	finding
1	Critical	no authentication or authorization at all
2	High	idempotency was opt-in, so a retry could double-post
3	High	unbounded postings array and no request body limit
4	Medium	no rate limiting, incomplete server timeouts
5	Medium	audit log was guarded but not tamper-evident

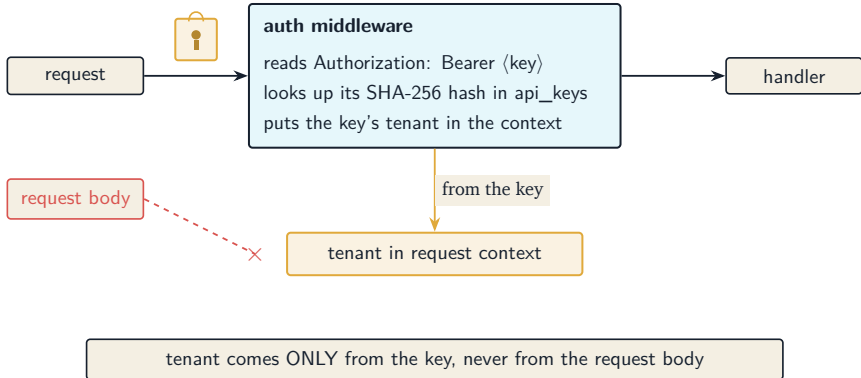
I’ll walk through the fixes, but two of them are worth slowing down for: the first, because it had a constraint that made it interesting, and the last, because fixing it broke something else.

30.3 Fix 1: a lock that does not lock out the demo

The obvious fix for “no auth” is “require auth.” Add API keys, check them, done. But go-ledger has a public try-it console at go.sohag.pro/console that anyone can use with no login, and a live demo that resets every four hours. If I required authentication everywhere, I would break the one thing that makes the project fun to show people.

The tension is real: authentication has to be mandatory for the thing to be safe, and optional for the demo to work. The trick is to notice those are not actually in conflict. I made authentication uniform (every `/v1` request needs a bearer API key, the tenant is derived only

from that key, and a key for tenant A physically cannot touch tenant B's data), and then I gave the demo a real key that happens to be public:



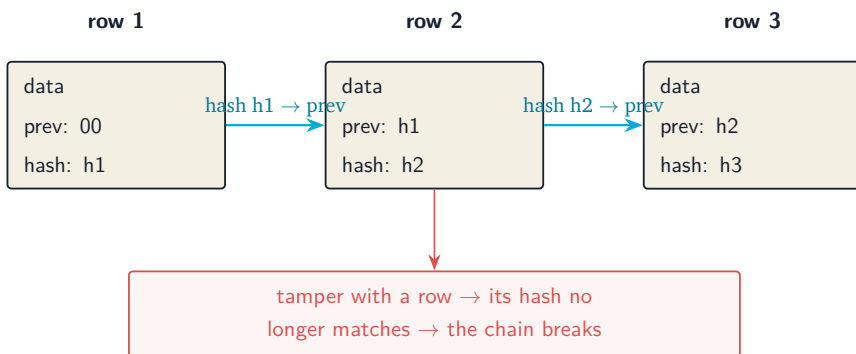
The demo key is scoped to the demo tenant, rate-limited harder than a normal key, shipped right there in the console's HTML, and wiped-adjacent (the four-hour reset clears the tenant's data but never the keys, so the demo keeps working). Exposing it is safe on purpose, because it can only ever touch a tenant that gets erased every four hours. One code path, no special cases, and the demo survives.

The keys themselves are stored as SHA-256 hashes, never plaintext. A leaked database dump leaks no usable keys. And because the tenant is derived only from the key, the authorization question ("can this caller touch this account?") collapses into a question the database already answers for free: is the account in the key's tenant? The foreign keys from week three enforce that. I did not have to write a single access-control rule.

30.4 Fix 5: the tamper-evident audit log, and the trap it set

The audit log already rejected updates and deletes with a database trigger, so it was append-only. But append-only is not the same as tamper-evident. A privileged database user could still, in principle, rewrite a row's contents in place if they could get past the trigger. I wanted the log to be able to *prove* it had not been altered.

The standard tool for that is a hash chain, the same idea underneath a blockchain minus all the noise. Each audit row stores a hash of its own contents plus the hash of the previous row. Change any row and its hash no longer matches; change it and try to fix the hash, and now the *next* row's stored “previous hash” is wrong. The tampering cannot hide.



I built it per tenant (so the four-hour demo wipe restarts one tenant's chain from scratch without touching anyone else's), added a `GET /v1/audit/verify` endpoint that walks the chain and reports the first break, and wrote tests that raw-edit a row and confirm the verifier catches

it. Building it surfaced two genuinely nasty determinism bugs, the kind a hash chain is uniquely allergic to: Postgres stores timestamps at microsecond precision, so a nanosecond timestamp hashed on the way in did not match what came back out, and the `jsonb` type silently reformats your JSON, so the bytes you hashed were not the bytes you stored. Both would have made the chain report “tampered” on data nobody touched. Fixed by truncating the timestamp and storing raw `json`.

And then the load test went red.

30.5 The trap: correctness that quietly costs throughput

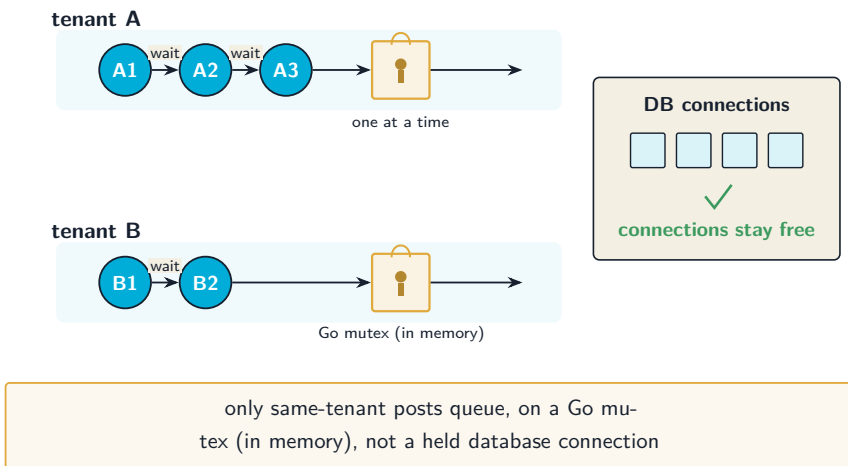
Here is the thing about a hash chain. To append row *N*, you must first read row *N* minus one, because you need its hash. That read-then-write, done inside a `SERIALIZABLE` transaction, means two transactions posting to the same tenant at the same time both read the same “latest” row and both try to append. Postgres notices the conflict and aborts one of them. Under 500 requests a second to a single tenant, that is not an occasional retry. It is a stampede. The retry budget exhausted and the ledger started returning 503s.

I had traded a security win for a throughput regression, and the load test caught it honestly. The audit chain, by its nature, serializes writes within a tenant. The question was how to make that serialization cheap instead of catastrophic.

My first instinct was a database advisory lock. It made things worse,

and understanding why is the interesting part. Under `SERIALIZABLE`, a transaction's view of the database is frozen at its first query. If a second transaction takes a lock and waits, its frozen view was already taken before the first one committed, so when it finally runs it still reads a stale chain tail and still aborts. The lock delayed the collision without preventing it.

The fix that worked moves the serialization out of the database entirely and into the application. Since the service runs as a single instance, I put a tiny in-memory lock per tenant, held only while a post runs:



The distinction that matters: transactions waiting for their turn block on an in-process lock, not on a checked-out database connection, so a busy tenant can never starve everyone else of connections. Different tenants run in parallel. Same-tenant posts serialize, which is exactly what a per-tenant hash chain requires anyway. And the `SERIALIZABLE` retry loop stays underneath as the correctness backstop, in case this ever runs as more than one instance.

Then I made the load test honest about all this by spreading its 500 requests a second across eight tenants, which is how a real ledger's traffic actually looks. The result: 38,417 requests, zero failures, 500 requests a second sustained at a 99th-percentile latency under 5 milliseconds, and not a single audit-chain conflict. The security feature and the throughput target both hold, at the same time, with everything switched on.

30.6 What the other three fixes were

The middle three are less dramatic but no less necessary. Idempotency went from optional to mandatory: a `POST /v1/transactions` with no `Idempotency-Key` header is now a `400`, because “retry safely” should be the default on an endpoint that moves money, not an opt-in a client can forget. The postings array got a maximum and the request body got a size cap, so one request can no longer become a multi-million-row transaction that eats the server's memory. And every API key now gets its own rate limit, with the demo key throttled tighter than the rest.

30.7 The lesson I keep relearning

The gap between “my tests pass” and “this is safe for real money” is not a gap in the hard, interesting core. I had spent months making the accounting bulletproof. The gap was in the boring perimeter: the lock on the door, the cap on the input, the limit on the rate. The unglamorous stuff that does not show up in a demo and absolutely

shows up in an incident.

If you are building something that moves money, or moves anything that matters, do the hostile read of your own code. Assume the attacker can reach every endpoint, because they can. Ask what they could do, not what your tests check. The list you get back is uncomfortable, and it is the most useful list you will write all quarter.

Every fix here is recorded in **ADR-012**, and the whole ledger, front door now firmly locked, is at **github.com/sohag-pro/go-ledger**.

This one was a detour worth taking.

Special Edition Q&A: Hardening a Payment Ledger for Real Money

Interview-style questions for the security-hardening work recorded in ADR-012: API-key authentication (tenant derived from the key), mandatory idempotency, input bounding, per-key rate limiting, and a per-tenant tamper-evident audit hash chain, plus the concurrency regression the audit chain caused and the in-process per-tenant mutex that fixed it. Every question is answerable from this repo's code and ADR-012.

31.1 The audit mindset

31.1.1 1. Your test suite was green and your load test hit 500 RPS. What made you audit the service anyway, and what did the audit assume that your tests did not?

What a strong answer covers:

- “Tests pass” answers “does it do what I designed”; a security audit answers “what can someone do who I did not design for.”

- The audit assumed real money and a hostile caller who can reach every endpoint, not a cooperative client.
- The accounting core (integer money, double-entry enforced twice, derived balances, atomic posting, idempotency sharing the transaction) held up; the gap was the service perimeter.
- The five findings were all perimeter concerns (auth, idempotency-as-default, input bounds, rate limiting, tamper evidence), none in the core math.

31.2 Authentication and tenant isolation

31.2.1 2. Before the fix, how did the service decide which tenant a request acted as, and why is that a Critical finding under a “real money” premise?

What a strong answer covers:

- The tenant was a single config value (`DEFAULT_TENANT_ID`), passed to every handler; there was no authentication at all.
- Anyone who could reach `/v1/transactions` could move money; anyone reaching `/v1/accounts/{id}/balance` could read any balance.
- It was a deliberate demo-stage trade-off (“until an auth layer lands”), fine for a demo, catastrophic for real money.
- Severity is about impact under the threat model, not about whether it was intentional.

31.2.2 3. You chose API keys in a hashed database table over JWTs and over keys-in-config. Defend that.

What a strong answer covers:

- API keys fit a ledger with a handful of tenants: no token issuance or signing-key rotation story to build, lower ops than JWT.
- A database table (over config) makes keys revocable and provisionable without a redeploy, and supports per-key rate limits.
- Only the SHA-256 hash is stored, so a database dump leaks no usable key; the plaintext is shown once and never recoverable.
- A short in-memory cache keeps the per-request lookup off the database, at the cost of revocation lag bounded by the cache TTL.

31.2.3 4. Once auth landed, how much authorization logic did you have to write, and why so little?

What a strong answer covers:

- Almost none: the tenant is derived only from the key, and the composite foreign keys already make cross-tenant access impossible at the database.
- “Can this caller touch this account?” reduces to “is this account in the key’s tenant?”, which the schema enforces for free.
- Per-account ACLs were deliberately rejected as redundant with the tenant foreign keys.
- The isolation is verified against real Postgres (a key for tenant A cannot see tenant B’s account), not just asserted.

31.2.4 5. The tenant comes only from the key. Why is it important that no request field can set or override it, and where is that enforced?

What a strong answer covers:

- If a request body or header could name a tenant, a caller could impersonate another tenant; the whole boundary would collapse.
- The middleware puts the resolved tenant in the request context and handlers read it from there; no handler reads a tenant from the request.
- gRPC uses the same resolver through an interceptor, so the boundary is uniform across both transports.
- Only `/v1` and non-health gRPC require a key; health, docs, static, and the console page stay open by design.

31.3 The demo constraint

31.3.1 6. Mandatory auth would break the public console. How did you keep the demo working without a second, unauthenticated code path?

What a strong answer covers:

- Authentication is uniform; the demo is reached with a real but public, low-privilege demo key scoped to the demo tenant.
- The key is rate-limited tighter than normal and the demo tenant is wiped every four hours, so exposing it in the console HTML is safe

on purpose.

- The demo key survives the wipe because the seeder resets tenant data tables only, never `api_keys`.
- One code path, no special-casing an “open” tenant (which would be a permanent open write surface).

31.4 Idempotency and input

31.4.1 7. Idempotency was already implemented. Why change it from optional to mandatory, and why not just auto-generate a key when the client omits one?

What a strong answer covers:

- On a money-moving POST, safe retry should be the default, not something a client can forget and then double-post on a dropped response.
- A missing `Idempotency-Key` is now a 400 with a clear message.
- Auto-deriving a key from the request fingerprint was rejected: it would silently collapse two genuinely separate but identical payments into one, turning a real second payment into a false replay.
- Making the client name the key keeps “same request retried” distinct from “two payments that look alike.”

31.4.2 8. What concrete resource-exhaustion vectors did the input hardening close?

What a strong answer covers:

- The postings array had a minimum but no maximum, so one request could become an enormous multi-row transaction; it now has a cap.
- There was no request body-size limit; an oversized body could exhaust memory before validation; it now returns 413.
- The server had only `ReadHeaderTimeout`; it now sets read, write, and idle timeouts so a slow client cannot hold a connection open.
- Per-key rate limiting bounds how fast any single key can hit the service.

31.5 The tamper-evident audit chain (and its cost)

31.5.1 9. The audit log already rejected updates and deletes. What does a hash chain add that an immutability trigger does not?

What a strong answer covers:

- The trigger prevents casual mutation; the chain detects a privileged rewrite that bypasses the trigger.
- Each row hashes its own content plus the previous row's hash, so any change breaks that row's hash and the next row's back-pointer.

- A `GET /v1/audit/verify` endpoint walks the chain and reports the first break, so tamper evidence is checkable, not just stored.
- It is defense in depth: prevention plus detection, not one instead of the other.

31.5.2 10. A hash chain is uniquely sensitive to any difference between what you hash and what you store. What two determinism bugs did building it surface, and how were they fixed?

What a strong answer covers:

- Postgres `timestampz` stores microsecond precision, so a nanosecond `created_at` hashed on the way in did not match the value read back; fixed by truncating to microseconds before both hashing and storing.
- The `jsonb` type reformats JSON on read, so the stored bytes differed from the hashed bytes; fixed by storing raw `json`.
- The fix principle: apply any normalization before both the hash and the store, using the identical value for each.
- The chain also hashes the tenant id first, so a row moved to another tenant's chain is detectable.

31.5.3 11. Fixing the audit chain caused a throughput regression. Explain the mechanism precisely.

What a strong answer covers:

- To append a row the write must first read the previous row's hash;

that read-then-write inside a `SERIALIZABLE` transaction conflicts when two posts hit the same tenant at once.

- Both transactions read the same chain tail and try to append; Postgres aborts one with a serialization failure (40001).
- Under 500 RPS to a single tenant the retry budget exhausts and the service returns 503, not an occasional retry but a stampede.
- The chain, by nature, serializes writes within a tenant; the problem was making that serialization cheap instead of an abort storm.

31.5.4 12. You tried a database advisory lock first and it made things worse. Why, and what actually fixed it?

What a strong answer covers:

- Under `SERIALIZABLE`, a transaction's snapshot is fixed at its first query; a waiter that blocks on a lock already took its snapshot before the holder committed, so it still reads a stale tail and still aborts.
- The advisory lock delayed the collision without preventing it, and it also risked holding a database connection during the wait.
- The fix moves serialization into the application: a per-tenant in-process mutex, held only while a post runs, on a single-instance deployment.
- Same-tenant posts queue on a Go mutex (not a held connection, so no pool starvation), different tenants run in parallel, and the `SERIALIZABLE` retry loop remains the multi-instance correctness backstop.

31.5.5 13. After the in-process mutex, single-tenant posts serialize. How did you still demonstrate 500 RPS, and why is that framing honest rather than a dodge?

What a strong answer covers:

- The load test spreads 500 RPS across eight tenants, so each tenant's serialized chain runs well under its sequential ceiling.
- That reflects how real ledger traffic actually looks (many tenants), rather than an artificial all-load-on-one-chain worst case.
- The result: 38,417 requests, zero failures, 500 RPS sustained, p99 under 5 ms, and zero audit-chain serialization errors, with auth and the chain fully on.
- Honest because the single-tenant serialization is documented as an inherent property of a per-tenant hash chain, not hidden.

31.6 Trade-offs and consequences

31.6.1 14. What are the standing negative consequences of this hardening that a reviewer should know about?

What a strong answer covers:

- A per-request key lookup, kept off the database by a cache whose TTL bounds revocation lag.
- Same-tenant posts serialize in-process; a single very high-throughput tenant is bounded, and the mechanism assumes a

single instance (multi-instance falls back to the retry loop).

- The demo key is public by design and only safe because it is tenant-scoped, rate-limited, and wiped; those three properties must stay true.
- Key management for real tenants is still manual (a row insert or a small CLI); there is no self-service issuance yet.

31.6.2 15. This work sits outside the numbered 14-week plan. Why do it as a special edition rather than fold it into a week, and what does that say about how you scope security work?

What a strong answer covers:

- The five findings came from a deliberate hostile audit, not the week's planned scope, so they earned their own record (ADR-012) and their own writeup.
- Security hardening is cross-cutting and event-driven (you do it when an audit finds something), not a tidy weekly feature.
- Doing it as a focused pass, with an ADR written before the code, keeps the decisions and their trade-offs on the record for the book.
- It models treating “make it safe for real money” as a distinct, first-class piece of work rather than a checkbox inside a feature week.

≡ go-ledger

SPECIAL EDITION

2

- 01 I Push to Main and Ninety Seconds Later It Is Live. Here Is Every Step in Between.
- 02 Special Edition Q&A: How the Deploy Pipeline Works

I Push to Main and Ninety Seconds Later It Is Live. Here Is Every Step in Between.

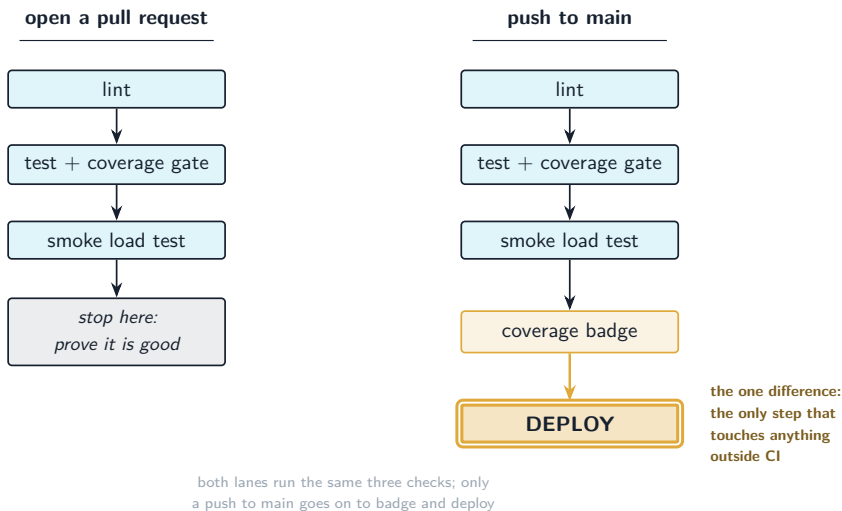
I was sitting in a cafe last week, fixed a small thing in the ledger, and typed `git push`. Then I closed my laptop and finished my coffee. Somewhere in that couple of minutes, without me touching anything else, my tests ran, a fresh binary got built, it was copied to my server, swapped into place, the service restarted, and the live site was checked to make sure it came back healthy. By the time I looked again, the fix was in production.

That is the whole promise of a deploy pipeline: the boring, error-prone, easy-to-forget steps between “I wrote the code” and “it is running for real” happen the same way every single time, because a machine does them, not a tired human at 11pm.

People assume this needs a big cloud setup. It does not. My whole thing is GitHub Actions and one small VPS. No Kubernetes, no container registry, no cloud console. This is a special edition, a bonus post between the numbered weeks, walking through every step of that pipeline, and then how you can build the same one.

32.1 Two different journeys: a pull request vs a push to main

The first thing to understand is that the same workflow file does two different jobs depending on how the code arrived. Open a pull request, and it only checks. Push to main, and it checks *and* ships.



So the pull request is a safety net: nothing merges unless the checks are green, but nothing ships either. The deploy only happens on the real thing, a push to main, and only after the checks that matter pass. That guard is written right into the job: the deploy needs: [lint, test] and only runs if the event is a push to the main branch. A red test is not a warning you can click past. It is a locked door.

32.2 The checks, briefly

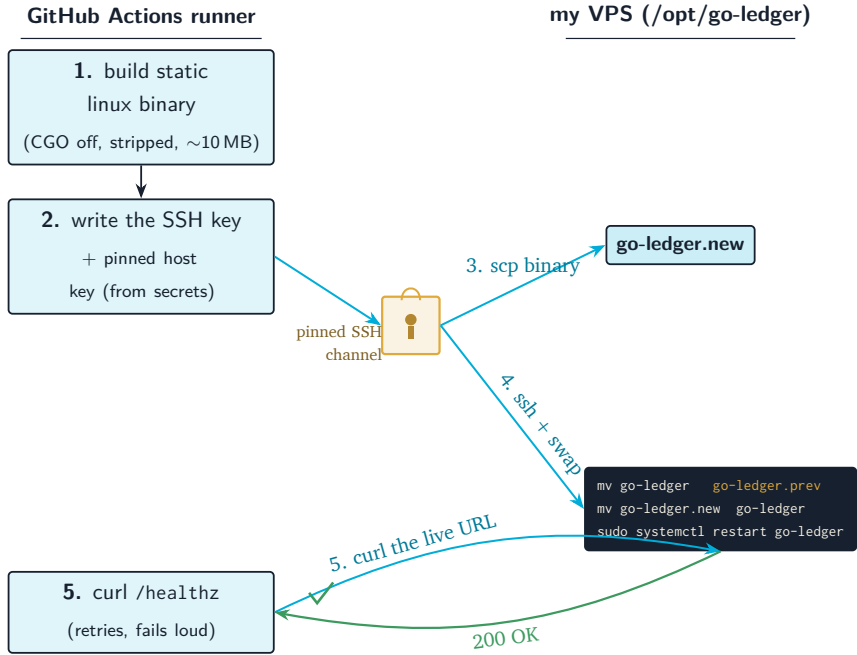
Three jobs run in parallel to prove the code is good:

- **Lint** runs golangci-lint, pinned to an exact version so the rules do not silently change under me.
- **Test** runs the whole suite with the race detector on, then enforces a coverage gate. The gate is not “some coverage exists,” it is a real floor, and generated code is stripped out first so the number reflects the code I actually wrote.
- **Smoke load** boots the full stack with Docker Compose, waits for it to be healthy, installs k6, and fires a short burst of real traffic at it. This catches the class of bug that only shows up under concurrent load, not in a single unit test.

These run on every pull request and every push. They are the “is this code safe” half. Now the interesting half.

32.3 The deploy, step by step

Here is what actually happens when the deploy job runs. It is deliberately simple, and every step is defensive.



Walk through why each step is shaped the way it is.

Build in CI, not on the server. The runner compiles a static `linux/amd64` binary with `cgo` disabled and the debug symbols stripped. My server never needs a Go toolchain, a compiler, or git. It only ever receives a finished binary. That keeps the box tiny and its attack surface small.

Ship the new binary next to the old one, do not overwrite. The binary lands as `go-ledger.new`, not on top of the running `go-ledger`. You cannot cleanly overwrite a file that is currently executing anyway, and staging it separately means the swap can be a single, fast rename.

The swap keeps the previous binary. This is the part I like most:

```
1 | mv go-ledger go-ledger.prev # keep the version that currently
```

```
works
2 mv go-ledger.new go-ledger      # promote the new one
3 sudo systemctl restart go-ledger # start it
```

If a deploy ever ships something broken, the last known-good binary is sitting right there as `go-ledger.prev`. Rolling back is copying one file over another and restarting, no rebuild, no waiting for CI. That is a thirty-second recovery instead of a panic.

The restart uses one exact, restricted command. The deploy user cannot do anything on that box except run `sudo systemctl restart go-ledger`, and nothing else. If the CI key ever leaked, the worst someone could do is restart my one service. They cannot read files, install packages, or touch the other site on the box. That restriction is a single `sudoers` line, and it is the difference between “a leaked key is annoying” and “a leaked key is a breach.”

The last step is proof, not hope. After the restart the runner curls the real public health endpoint, with retries, and the whole run fails loudly if the app does not come back. A deploy that leaves the site down is a failed deploy, and I hear about it, rather than finding out from a user.

32.4 The security details that are easy to skip

Two things here are quietly important.

The SSH connection pins the server’s host key. GitHub does not just trust whatever server answers on that address; it is given the exact expected host key up front, and if the machine that answers presents

a different one, the connection fails instead of being silently accepted. So a man-in-the-middle between GitHub and my VPS breaks the deploy rather than hijacking it. (I care about this one personally: earlier in this project my laptop's known-hosts file got overwritten with a fake key mid-session, so "pin the key" is not theoretical to me.)

And every sensitive value (the private key, the host, the user, the pinned host key) lives in GitHub Actions secrets, never in the repo. The workflow file is public. The credentials it uses are not.

32.5 How to replicate this on your own server

You do not need my code for this. The pattern is four ingredients, and it works for any single-binary service on any plain Linux box.

1. A locked-down deploy user on the server. Create a user that exists only to receive deploys. Give it key-only SSH (no password), and a single sudoers rule letting it restart exactly your one service:

```
1 deploy ALL=(root) NOPASSWD: /usr/bin/systemctl restart your-service
```

That is the whole privilege it gets.

2. A dedicated SSH keypair. Generate a keypair used only for deploys. The public half goes in that deploy user's `authorized_keys`; the private half goes into a GitHub secret. It is not your personal key.

3. Four secrets in the GitHub repo. The private key, the server host, the deploy username, and the server's pinned host key (grab it with `ssh-keyscan your-host`). The workflow reads these; nobody reading your

public repo sees them.

4. The workflow itself. One job that builds your binary, one that, only on a push to your main branch and only after tests pass, copies the binary over, swaps it with a keep-the-previous rename, restarts via that restricted sudo, and health-checks the result. The shape is exactly the diagram above.

That is it. There is no step five. The thing that makes people reach for heavier tooling, “how do I get my code onto a server safely and repeatably,” is genuinely solved by scp, a rename, a restricted restart, and a health check, as long as you are disciplined about the key and the rollback.

32.6 Why so small on purpose

I want to be clear that this is not a toy version of a “real” pipeline that I will replace later. For one service on one box, this is the real pipeline. Container registries, orchestrators, and blue-green rollouts solve problems I do not have yet: fleets of servers, zero-downtime at scale, many teams shipping at once. Adding them now would be cost with no benefit, the same reasoning that kept my production box a bare binary instead of a container.

The test is not “does it look like what a big company runs.” The test is “when I push a fix from a cafe, does it reach production, safely, without me thinking about it.” This does. That is the entire job.

The full workflow is in the repo at github.com/sohag-pro/go-ledger, in `.github/workflows/deploy.yml`, and the reasoning behind the

I Push to Main and Ninety Seconds Later It Is Live.
Here Is Every Step in Between. 366

VPS choice is in **ADR-013**. More build weeks are still ahead, ending in the launch.

CHAPTER 33

Special Edition Q&A: How the Deploy Pipeline Works

Interview-style questions for the CI/CD pipeline described in the special-edition post and defined in `.github/workflows/deploy.yml`: what runs on a pull request versus a push to main, how a single push builds a binary and ships it to a VPS over SSH, the atomic swap with a kept-previous rollback, the restricted deploy user, host-key pinning, and why the whole thing is deliberately small. Every question is answerable from this repo's workflow file and ADR-013.

33.1 The shape of the pipeline

33.1.1 1. The same workflow runs on a pull request and on a push to main, but does different things. Walk me through the difference and why it is structured that way.

What a strong answer covers:

- Both events run the checks (lint, test with the coverage gate, smoke

load); only a push to main additionally publishes the coverage badge and deploys.

- The deploy job carries `needs: [lint, test]` and an `if` guarding on a push to the `refs/heads/main` ref, so it cannot run for a pull request or on a red build.
- A pull request is a safety net that proves the code is good without shipping; the deploy only happens on the real merge to main.
- A failing check is a locked door, not a warning you can click past, because the deploy literally depends on those jobs passing.

33.1.2 2. What do the three check jobs actually verify, and why is a smoke load test in the critical path rather than just unit tests?

What a strong answer covers:

- Lint runs `golangci-lint` pinned to an exact version so the rules do not drift silently between runs.
- Test runs the full suite with the race detector, then enforces a coverage floor that strips generated code first, so the number reflects hand-written code.
- The smoke load job boots the full stack with Docker Compose, waits for health, installs `k6`, and fires real concurrent traffic, catching load-only bugs a single unit test never exercises.
- Concurrency and idempotency bugs in a ledger show up under simultaneous requests, not in isolation, so a short real-traffic burst is worth being a gate.

33.1.3 3. Why keep the coverage badge as its own job that publishes to a badges branch, instead of a third-party service?

What a strong answer covers:

- The badge job computes the same filtered percentage the coverage gate enforces (generated packages excluded) so the badge never disagrees with the gate.
- It writes a small shields-endpoint JSON to an orphan `badges` branch using the repo's own token, so no external service holds credentials or sees the coverage data.
- It runs only on a push to main and `needs: [test]`, so the badge reflects merged, tested code, not a pull request.
- It is self-hosted state in the repo, which keeps the supply chain small and under the project's own control.

33.2 The deploy, step by step

33.2.1 4. Describe exactly what the deploy job does, from a green build to a verified live site.

What a strong answer covers:

- Builds a static, stripped `linux/amd64` binary on the runner with the Go version from `go.mod`, so the server never needs a toolchain.
- Writes the SSH key and the pinned host key from secrets, then `scp`'s the binary to `/opt/go-ledger/go-ledger.new` as the deploy user.

- Over SSH it swaps the binary (keep the current one as `go-ledger.prev`, move `.new` into place) and restarts the service via restricted `sudo`.
- Curls the public `https://go.sohag.pro/healthz` with retries and fails the run loudly if the app does not come back healthy.

33.2.2 5. Why build the binary in CI and ship the artifact, rather than pulling the repo and building on the server?

What a strong answer covers:

- The server never needs Go, a compiler, or git, which keeps a 1 GB shared box small and its attack surface minimal.
- The build environment is the controlled, reproducible CI runner, not a hand-maintained server that could drift.
- Shipping a finished, stripped static binary means the deploy step is a copy and a restart, fast and predictable.
- It matches the production model from ADR-013: the box only ever runs prebuilt binaries.

33.2.3 6. The binary lands as `go-ledger.new` and the swap keeps `go-ledger.prev`. Explain both choices.

What a strong answer covers:

- You cannot cleanly overwrite a binary that is currently executing, so staging it beside the running one and swapping with a rename is the safe move.

- The rename is fast and close to atomic, so the window where the file is in flux is tiny.
- Keeping the previous binary as `go-ledger.prev` means rollback is copying one file back and restarting, a thirty-second recovery with no rebuild and no waiting for CI.
- It turns “we shipped something broken” from a panic into a known, fast, documented procedure.

33.2.4 7. (Hard) The health check runs after the restart.

What failure would it catch, what would it miss, and why put it last?

What a strong answer covers:

- It catches a binary that starts but cannot serve (bad config, unreachable database, a crash on boot), because it hits the real public endpoint with retries.
- It would miss a subtle logic regression that still returns 200, which is what the test and smoke-load jobs upstream are for.
- Putting it last makes a deploy that leaves the site down a failed run that pages the author, rather than a silent success discovered by a user.
- The retries with a delay absorb the brief restart window without hiding a genuinely dead service.

33.3 Security

33.3.1 8. The SSH connection pins the server's host key. What attack does that stop, and what breaks if you skip it?

What a strong answer covers:

- Pinning means GitHub is given the exact expected host key up front; a machine presenting a different key fails the connection instead of being trusted.
- Without it, a man-in-the-middle between GitHub and the VPS could impersonate the server and receive the binary and the session.
- Skipping it (blindly accepting unknown host keys) trades a real security boundary for convenience, which is the wrong trade for a deploy that runs unattended.
- This is not hypothetical for this project: a known-hosts file was tampered with earlier, so the pin is a lived lesson.

33.3.2 9. The deploy user can only run `sudo systemctl restart go-ledger`. Why bound it that tightly, and what is the blast radius if the CI key leaks?

What a strong answer covers:

- A single sudoers rule grants exactly one privileged command and nothing else, following least privilege for an account that exists only to receive deploys.
- If the key leaked, the worst an attacker could do is replace one binary and restart one service; they cannot read arbitrary files, install packages, or touch the co-located portfolio.

- It is the difference between a leaked key being an annoyance and being a full host compromise.
- The deploy user is key-only with no password, so there is no second, weaker way in.

33.3.3 10. How are the sensitive values handled given the workflow file is public?

What a strong answer covers:

- The private key, host, user, and pinned host key all live in GitHub Actions secrets, never in the repo.
- The workflow references them by name, so a reader of the public file learns the shape of the deploy but none of the credentials.
- The deploy keypair is dedicated to CI, not the author's personal key, so its scope is limited and it is independently revocable.
- The same discipline that keeps the Ansible inventory and vault out of the repo (ADR-013) applies here.

33.4 Trade-offs and replication

33.4.1 11. This is GitHub Actions plus one VPS, with no container registry, orchestrator, or blue-green rollout. Defend the smallness.

What a strong answer covers:

- For one service on one box, this is the real pipeline, not a place-

holder: it builds, ships, swaps safely, restarts, and verifies.

- Registries, orchestrators, and blue-green solve problems the project does not have yet: fleets of hosts, zero-downtime at scale, many teams shipping at once.
- Adding them now would be cost with no benefit, the same reasoning that keeps production a bare binary rather than a container.
- The right test is “does a push from a cafe reach production safely without me thinking about it,” which this passes.

33.4.2 12. What are the honest downsides of this deploy design that a reviewer should know about?

What a strong answer covers:

- The restart briefly drops the service, so it is not zero-downtime; acceptable for this workload, but a real limitation.
- It assumes a single instance and a single box; scaling out would need a different rollout model.
- Rollback is manual (copy `prev`, restart) and requires also reverting the bad commit so the next push does not redeploy it.
- The pipeline trusts the runner’s build; a compromised dependency would ship, which is why the checks and pinned tool versions matter.

33.4.3 13. Someone wants to copy this for their own single-binary service. What are the exact ingredients?

What a strong answer covers:

- A locked-down deploy user on the server: key-only SSH and one sudoers line permitting only the restart of their service.
- A dedicated SSH keypair used solely for deploys, public half in the deploy user's `authorized_keys`, private half in a secret.
- Four repo secrets: the private key, the host, the deploy username, and the server's pinned host key (from `ssh-keyscan`).
- A workflow that builds the binary, and only on a push to main after tests pass, copies it over, swaps with a `keep-previous` rename, restarts via restricted `sudo`, and health-checks the result.

33.4.4 14. (Hard) A deploy succeeds, the health check passes, but users report errors ten minutes later. Walk through your response with this pipeline.

What a strong answer covers:

- Immediate mitigation is the fast rollback: copy `go-ledger.prev` OVER `go-ledger` and restart, which is documented and takes seconds, restoring the last known-good binary.
- Then revert the bad commit on main so the next push does not redeploy the broken version, since the pipeline redeploys whatever main points at.
- Diagnosis uses the structured logs on the box (`journalctl` for the

service) and the traces and metrics from the observability work, since a 200 on health did not catch this.

- The lesson feeds back into the checks: if a class of bug slips past lint, tests, and smoke load, that is where the coverage should grow.

33.4.5 15. Why does the concurrency configuration cancel in-progress runs for pull requests but not for pushes to main?

What a strong answer covers:

- Pull request pushes are iterative, so cancelling a superseded run saves CI minutes and gives faster feedback on the latest commit.
- Main pushes must not be cancelled mid-flight, because a cancelled deploy could leave the swap or restart half-done on the server.
- The concurrency group is keyed differently for the two event types so they never interfere with each other.
- It reflects a general rule: cancel cheap, repeatable checks freely, but never interrupt an operation that mutates production.

≡ go-ledger

SPECIAL EDITION

3

- 01 I Audited My Own Ledger Like a Fintech Expert. It Failed.
- 02 Special Edition Q&A: Auditing and Hardening the Ledger to a White-Label Money Core

I Audited My Own Ledger Like a Fintech Expert. It Failed.

There is a specific kind of fear that shows up once a side project starts looking finished.

The go-ledger has passed every test for months. Double-entry postings that sum to zero, idempotency keys, a tamper-evident audit chain, multi-currency with FX conversion, a live demo at go.sohag.pro. On a good day I would call it production-grade. Then one evening I asked the question that ruins good days: if a real payments company wanted to run this as their own white-label ledger, and put it in front of a due-diligence auditor, what would that auditor tear apart in the first hour?

So I ran the audit. On myself. I sat down and reviewed the whole codebase the way a skeptical fintech engineer would, looking for the things that do not show up in a green test suite: the ways it loses money quietly, the ways it breaks when a second copy starts up, the ways it cannot satisfy a regulator. I wrote the findings down as if I were handing a client a report they paid for.

It failed. Not a little. Three findings were the kind you label “Blocker: do not run this with real money,” and one of them was a bug that produced the wrong amount of money and no test had ever noticed.

This post is the teardown and the fix. It is long, because the audit was

thorough and the remediation was thirty tasks and four architecture decision records. But the interesting part is not the count. It is that most of the failures were invisible from inside a passing test suite, and every one of them teaches something about what “production-grade” actually costs.

34.1 What a white-label money core has to survive

Before the findings, the bar. A hobby ledger and a white-label money core look identical in a demo. They diverge on four questions:

- **Can it lose money without anyone noticing?** Not “does it crash,” but “does it ever record the wrong amount and keep going.”
- **Can it lose your data?** If the disk dies, is the ledger gone, and how much of it.
- **Can it run as more than one process?** The moment you want zero-downtime deploys or more throughput, a second instance starts. Does the invariant survive that.
- **Can one customer ever see or affect another?** Multi-tenant isolation is not a feature you add later. It is a property every query must have.

The demo answered all four with a confident “sure.” The audit answered all four with “no.”

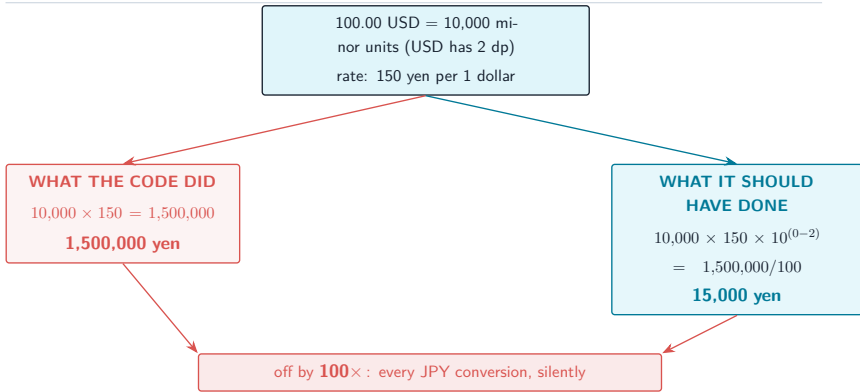
34.2 Finding one: the ledger was turning 100 dollars into 15 dollars

This is the one that still bothers me.

When I added multi-currency, I did the money math the careful way everyone tells you to: integers only, never floating point, amounts stored as minor units. One dollar is 100 cents. A conversion multiplies the source amount by a scaled-integer rate and rounds once, using banker's rounding, in big integers so nothing overflows. I wrote property tests. I wrote a reconciliation test that proved money was conserved across a round trip. Green.

Here is what I missed. "Minor units" is not the same number for every currency. The US dollar has 2 decimal places, so 100 dollars is 10,000 minor units. The Japanese yen has **zero** decimal places: one yen is the smallest unit, there are no sub-yen. Bahraini dinar has three. My conversion code assumed every currency had two, baked in, invisibly, forever.

Watch what that does. Convert 100.00 USD to JPY at a rate of 150 yen per dollar. The right answer is 15,000 yen.



The code produced 1,500,000 yen for a 100 dollar conversion. A hundred times too much. And nothing failed, because every test I had written used USD and EUR, which both happen to have two decimal places, so the difference in exponents was zero and the bug was mathematically invisible. My “money is conserved” reconciliation test passed because it converted USD to EUR and back, and two wrongs of the same magnitude cancel.

The fix was a currency registry that knows each currency’s minor-unit exponent, and one term added to the conversion: multiply by ten to the power of (destination exponent minus source exponent), folded into the same single rounding step so it stays integer-only and unbiased. Then tests that actually use JPY (0 dp) and BHD (3 dp), asserting the exact expected integer.

The lesson is not “handle currency exponents,” although, please handle currency exponents. The lesson is that a test suite proves the cases you thought of. It says nothing about the cases you did not, and the case you did not think of is exactly where the money leaks. The only defense I have found is adversarial review by someone who does not

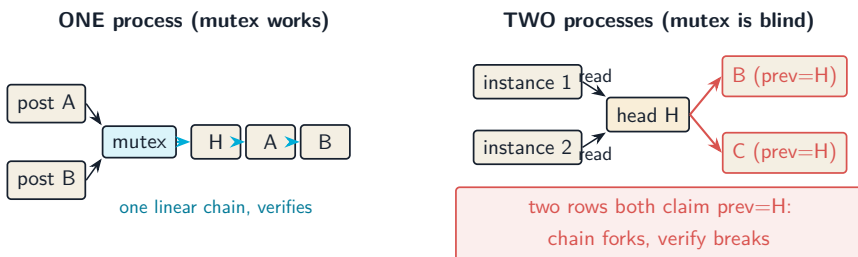
share your blind spots, even when that someone has to be you in a different chair.

34.3 Finding two: the audit chain forked the instant a second instance started

Every transaction in the ledger extends a per-tenant tamper-evident hash chain. Each audit row stores the hash of the row before it, so if anyone edits history, every hash after the edit stops matching and verification catches it. It is a nice property. It was also a trap.

To keep two concurrent posts for the same tenant from both grabbing the same “previous hash” and forking the chain, I serialized them with an in-process mutex. A lock, in memory, in one Go process. It worked perfectly, on one process.

The audit finding: that lock lives in one process’s memory. Start a second instance of the service (which you will, the first time you want a rolling deploy), and the two instances share nothing. Both read the same chain head, both append a row claiming to follow it, and the chain forks into two branches that both think they are canonical.



This is a “single-instance correctness cliff.” The service is correct right up until the moment you scale it, and then it is silently corrupt. For a system whose entire pitch is “you can trust the history,” that is disqualifying.

The fix was the biggest architectural change in the remediation: take the chain off the hot path entirely. A posting now writes an event to an append-only outbox inside the same transaction, atomically, with no chain read. A single background worker, elected leader through a Postgres advisory lock held on one dedicated connection, drains the outbox in commit order and builds the chain by itself. One writer, so no fork, no matter how many instances are posting. To get commit order right across concurrent transactions I used the database’s own transaction-visibility watermark, processing only events whose transaction id is below the oldest still-running transaction, so a slow commit can never sneak in behind a row that already got chained.

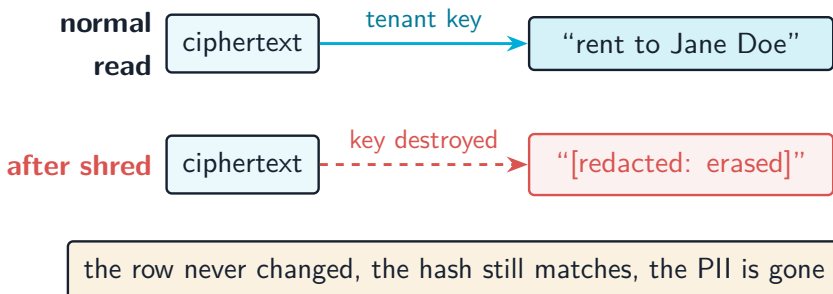
Getting that worker right took two rounds of review. The first version ran its queries on a pooled connection instead of the lock-holding one, which meant that if the leader lost its lock (a database failover, a dropped connection), it would not notice and would keep draining while a new leader also started, reintroducing the exact fork the design existed to prevent. Concurrency code has a way of looking finished long before it is.

34.4 Finding three: you cannot delete a customer from an append-only ledger

Here is a genuine conflict, not a bug. A ledger is append-only and immutable, by law and by design: you do not get to rewrite financial history. A person also has, by a different law, the right to be forgotten: ask for their personal data to be erased. A posting's free-text description can carry personal data ("rent to Jane Doe, 12 Elm Street"). You cannot delete the row, it would break the hash chain and the append-only invariant. You cannot keep the plaintext forever either.

The resolution is a technique called crypto-shredding, and it is genuinely elegant. You do not erase the data. You encrypt it, and erase the key.

Each tenant gets a data key. Descriptions are encrypted with it before they are stored, and the same ciphertext goes into both the posting and the audit snapshot, so the hash chain hashes ciphertext. "Erasing" a subject means destroying the key. Every byte stays exactly where it was, so the chain still verifies bit for bit. But the ciphertext is now unreadable by anyone, forever. The data is gone without a single row changing.



The subtle part, which the review caught, is that destroying the key must not brick the tenant. A conversion leg is labeled “convert: debit source account,” which is not personal data, but it still goes through the same encryption. If shredding just refused to encrypt anything afterward, every future conversion for that tenant would fail forever. So the keys are versioned: a shred destroys the current key (erasing everything under it) and the next write mints a fresh one. The tenant keeps operating, the erased history stays erased.

34.5 The rest of the teardown

Those three were the headliners. The full audit had forty-one findings across correctness, security, durability, operations, and compliance. A sampling of what else was wrong, and what it turned into:

- **Durability was a lie.** The only backup was a nightly `pg_dump` to the same disk as the database. If the disk died, the ledger and its backup died together, and up to a full day of transactions was gone. Now: continuous write-ahead-log archiving and encrypted base backups shipped off the box, point-in-time recovery, and a job that actually restores the backup into a throwaway database and re-verifies every balance and every audit chain, because a backup you have never restored is a hope, not a backup.
- **A forgotten `WHERE tenant_id` could cross tenants.** Every query scoped by tenant id, but “every query, forever, without exception” is not a guarantee a human can make. Now Postgres row-level security enforces it in the database: a request runs with its tenant id set, and a query that forgets the filter returns nothing across tenants instead of everything. Defense in depth, because the

app-level filter will eventually have a bug.

- **No tenant entity, no key lifecycle.** “Tenant” was a bare id scattered across tables. Now there is a real tenants table with status (you can suspend one), API keys with scopes and expiry and rotation, and an admin surface plus a CLI to onboard a tenant and issue keys without touching SQL.
- **No way to reverse a transaction, no webhooks, no way to erase or shred, no rate limit on gRPC, no alerts.** All added, each the boring-but-necessary connective tissue of a system someone else is supposed to integrate with.

34.6 How I actually did it without breaking the thing

Thirty tasks touching money code is how you turn a working ledger into a broken one. The process mattered as much as the fixes.

Every significant decision became an architecture decision record first, written before the code, so the “why this and not that” was captured while it was fresh: one master remediation record and three deep ones for durability, the multi-instance chain, and crypto-shredding. Then each task was implemented in isolation, reviewed against its spec, and, for the risky ones (the FX math, the chainer, the encryption), reviewed a second time by a reviewer whose only job was to try to break it. That second reviewer earned its keep: it found the chainer’s lost-lock fork, a deploy script that would have run migrations as root, and a fingerprint that silently ignored a field.

When it was done, I did the thing you are supposed to do and almost

never do: I ran the audit again, from scratch, as if I had never seen the code, to check that every finding was actually fixed and not just marked fixed. Then I ran it a third time with a fresh reviewer. Both came back the same. Every blocker closed in code, the money bug closed with correct arithmetic and the JPY and BHD tests that should have existed from the start, no regressions. What remains is not engineering: it is operational provisioning, the offsite backup bucket and the production monitoring stack, both written and waiting on credentials.

34.7 What I actually learned

The uncomfortable takeaway is that “all tests pass” and “production-grade” are nearly unrelated statements. My tests passed for months while the code turned 100 dollars into 15,000 yen and would have forked its own audit trail the first time it scaled. Tests prove the failures you imagined. An audit, done adversarially, by someone willing to assume you are wrong, finds the failures you did not.

You do not need to hire a fintech expert to get that second set of eyes, although it helps. You need to sit in a different chair, stop defending the code, and ask the four questions a skeptic would ask: can it lose money, can it lose data, can it run twice, can one customer touch another. Then believe the answers, even when they ruin a good evening.

The go-ledger is genuinely a white-label money core now. It took admitting it was not.

Special Edition Q&A: Auditing and Hardening the Ledger to a White-Label Money Core

Interview-style questions for the audit-remediation special edition: an adversarial production-readiness audit of go-ledger and the thirty-task remediation that followed. Every question is answerable from this repo's code and the audit-era ADRs: ADR-015 (the master remediation record), ADR-016 (durability), ADR-017 (multi-instance audit chain), ADR-018 (PII crypto-shredding), plus `internal/domain/fx.go`, `internal/domain/currency.go`, `internal/audit/chainer.go`, `internal/crypto/`, and migrations 0011 to 0030.

35.1 The audit mindset

35.1.1 1. Your test suite was green for months, yet the audit found a bug that produced the wrong amount of money. What does that tell you about the relationship between tests and correctness, and how did you compensate?

What a strong answer covers:

- Tests prove the cases you thought of; they say nothing about the cases you did not, and the money leaked in exactly the case not thought of (non-2-decimal currencies).
- Green tests and “production-grade” are nearly unrelated claims; a passing suite is necessary, not sufficient.
- Compensation is adversarial review by someone who does not share the author’s blind spots, plus re-running the audit from scratch afterward to confirm each finding is actually fixed, not just marked fixed.
- The four skeptic’s questions used to frame the audit: can it lose money, can it lose data, can it run as more than one process, can one tenant touch another.

35.1.2 2. What separates a strong hobby ledger from a white-label money core, concretely?

What a strong answer covers:

- They look identical in a demo and diverge on four properties: silent money loss, data durability, multi-instance correctness, and tenant isolation.

- Isolation is not a late feature; it is a property every query must have, which is why the remediation added row-level security as a backstop.
- Durability is not “it has a backup”; it is “the backup is offsite, encrypted, and has actually been restored and verified.”
- White-label specifically adds a real tenant entity, key lifecycle, per-tenant policy, and an integration surface (webhooks, reversal, export) another company can build on.

35.2 The FX money bug

35.2.1 3. Walk through the currency-exponent bug. Why was converting 100 USD to JPY wrong, and by how much?

What a strong answer covers:

- “Minor units” is not two decimal places for every currency: USD has 2, JPY has 0 (one yen is the smallest unit), BHD has 3. The conversion assumed 2 everywhere.
- 100.00 USD is 10,000 minor units; at 150 yen per dollar the code produced 1,500,000, but JPY has no sub-units so the answer should be 15,000 yen: off by a factor of 100.
- The missing term is ten to the power of (destination exponent minus source exponent), which was zero for every currency pair the tests used (USD and EUR are both 2 dp), so the bug was mathematically invisible.
- The reconciliation “money is conserved” test passed because a USD

to EUR round trip has two equal-magnitude errors that cancel.

35.2.2 4. How does the fix keep the conversion integer-only and unbiased while adding the exponent term?

What a strong answer covers:

- A currency registry (`internal/domain/currency.go`) maps each code to its minor-unit exponent; unknown codes default to 2, matching ISO 4217 and prior behavior.
- The exponent factor is folded into the single big-integer computation as a multiply or divide by a power of ten, so there is still exactly one rounding step (banker's rounding, sign-symmetric), no double rounding, no float.
- `Money.String` also had to honor the exponent so JPY renders with no decimals and BHD with three.
- New tests assert exact integers for JPY (0 dp) and BHD (3 dp), the cases the original suite never had.

35.3 Multi-instance and the audit chain

35.3.1 5. The audit called the in-process mutex a “single-instance correctness cliff.” Explain the failure and why SERIALIZABLE alone did not save you.

What a strong answer covers:

- The mutex serialized same-tenant posts so two could not read the same audit-chain head and fork it, but the lock lives in one process’s memory.
- With two instances, both read the same head and both append a row claiming to follow it; the chain forks into two branches that each think they are canonical, and verification breaks.
- SERIALIZABLE does not catch it because the two inserts touch different new rows and need not create a serialization dependency the database can see.
- For a system whose pitch is “you can trust the history,” a silent fork on scale-out is disqualifying (a Blocker).

35.3.2 6. Describe the outbox-chainer design that replaced the mutex, and how it guarantees a single writer without an external coordinator.

What a strong answer covers:

- Posting writes an append-only outbox row inside the same transaction, atomically, with no chain read, so the hot path no longer touches the chain (ADR-017).
- One background worker drains the outbox and builds the chain

by itself; a single consumer means no fork regardless of instance count.

- Leader election is a session-level Postgres advisory lock held on one dedicated connection: the database we already depend on is the coordinator, no ZooKeeper or etcd.
- If the leader loses the lock (failover, dropped connection), Postgres releases it and another instance takes over.

35.3.3 7. (Hard) Outbox rows get a bigserial id, but transactions commit out of order. How does the chainer avoid chaining events in the wrong order or skipping one?

What a strong answer covers:

- A naive “process id greater than the last” can permanently skip a row assigned a lower id but committed later, leaving a committed event out of the chain forever.
- The chainer processes only rows whose inserting transaction id is below `pg_snapshot_xmin(pg_current_snapshot())`, the oldest still-running transaction, ordered by (txid, id): those rows are settled and no earlier-ordered row can still appear.
- The chained rows are ordered by a database-assigned `chain_seq` sequence, not the UUID primary key, because a UUIDv7 is monotonic only within one process and a cross-host failover with clock skew could otherwise mint a lower id than the head.
- A unique `outbox_id` on `audit_log` is a defense-in-depth backstop: if two writers ever ran at once, the second attempt to chain the same event fails the insert instead of forking.

35.3.4 8. (Hard) The first version of the chainer had a subtle fork bug the review caught. What was it?

What a strong answer covers:

- The drain queries ran on a pooled connection, not the connection holding the advisory lock.
- So if the leader's lock session died, the leader did not notice and kept draining while a new leader also started, reintroducing the exact fork the design prevents.
- The fix runs every drain query on the lock-holding connection, so a lost lock fails the next query, the loop drops leadership and re-contends.
- Lesson: concurrency code looks finished long before it is; the failover path is where it actually gets tested.

35.4 Compliance and crypto-shredding

35.4.1 9. A ledger is append-only and immutable, but a person has the right to be forgotten. How do you satisfy both?

What a strong answer covers:

- You cannot delete or rewrite a row (it breaks the hash chain and the append-only invariant) and you cannot keep plaintext PII forever.
- Crypto-shredding: encrypt the PII (posting descriptions) with a per-tenant key and erase the key, not the data (ADR-018).

- The same ciphertext goes into both the posting and the audit snapshot, so the hash chain hashes ciphertext; destroying the key leaves every byte on disk unchanged, so the chain still verifies bit for bit while the plaintext is gone forever.
- Verification hashes stored bytes and never decrypts, which is why a shred cannot break it.

35.4.2 10. Why are the encryption keys versioned, and what would break without versioning?

What a strong answer covers:

- System-generated narration (“convert: debit source account”, “reversal of X”) is not personal data but still goes through the same encryption.
- If a shred simply refused to encrypt afterward, every future conversion and reversal for that tenant would fail forever: the shred would brick the tenant.
- Versioned keys mean a shred destroys the current version (erasing everything under it) and the next write mints a fresh version, so the tenant keeps operating while the erased history stays erased.
- The ciphertext is self-describing (`enc:v1:<version>:...`) so a reader knows which key version to unwrap, and legacy plaintext passes through unchanged.

35.5 Isolation, durability, and the rest

**35.5.1 11. Every query was already scoped by tenant id.
Why add row-level security on top, and how is it
wired so it does not break the background workers?**

What a strong answer covers:

- “Every query, forever, without exception” is not a guarantee a human can make; a forgotten `WHERE tenant_id` would leak across tenants, so RLS is defense in depth.
- The policy allows all rows when the `app.tenant_id` GUC is unset and restricts to that tenant when set; `FORCE ROW LEVEL SECURITY` makes even the table owner subject to it.
- The request path sets the GUC (so a forgotten filter still cannot cross tenants); the trusted background workers (chainer, webhook fan-out, sweep, restore-verify) run with it unset and keep their legitimate cross-tenant access.
- The test must connect as a non-superuser role, because superusers bypass RLS and a naive test would pass whether or not RLS works.

35.5.2 12. The audit said durability was “a lie.” What was wrong, and what does trustworthy durability look like here?

What a strong answer covers:

- The only backup was a nightly `pg_dump` to the same disk as the database: lose the disk and the ledger and its backup die together, plus up to a day of transactions.
- The fix (ADR-016) is continuous write-ahead-log archiving and

encrypted base backups shipped offsite, enabling point-in-time recovery.

- Critically, a scheduled job restores the backup into a throwaway database and re-verifies every balance and every audit chain, because a backup you have never restored is a hope, not a backup.
- The remaining gap is provisioning the offsite bucket and credentials, which is operational, not code.

35.6 Process and trade-offs

35.6.1 13. Thirty tasks touching money code is a good way to break a working ledger. What process kept that from happening?

What a strong answer covers:

- Every significant decision became an ADR written before the code, capturing the “why this and not that” while it was fresh (ADR-015 plus 016, 017, 018).
- Each task was implemented in isolation, reviewed against its spec, and the risky ones (the FX math, the chainer, the encryption) reviewed a second time by a reviewer whose only job was to break it.
- That adversarial reviewer found real defects: the chainer’s lost-lock fork, a deploy script that would have run migrations as root, a fingerprint that silently ignored a field.
- After it was done, the whole audit was re-run twice from scratch by fresh reviewers to confirm every finding was actually closed and

no regression was introduced.

35.6.2 14. (Challenge a locked decision) A skeptic says all of this is over-engineering for a project that is not handling real money yet. How do you defend building it now instead of later?

What a strong answer covers:

- The Blockers are architectural, not incremental: the single-instance chain fork and the durability model cannot be bolted on after real money arrives without a risky migration and a period of exposure.
- The FX exponent bug was already producing wrong numbers; “not real money yet” is exactly the safe window to fix a money bug, before anyone depends on the output.
- White-label buyers do due diligence; the tenant isolation, key lifecycle, and compliance scaffolding are the difference between a demo and something a company will run.
- The honest counterpoint: some items were correctly deferred as accepted follow-ups (per-party PII granularity, master-key rotation, multi-region), and the audit distinguishes Blockers from nice-to-haves rather than gold-plating everything.

35.6.3 15. What did you deliberately leave unresolved, and what is the honest state of the system after the remediation?

What a strong answer covers:

- Every Blocker and High correctness finding is closed in code, verified by two independent re-audits, with no regressions.
- What remains is operational provisioning, not engineering: the offsite backup bucket and the production monitoring stack are written and safely gated behind unprovisioned config, waiting on credentials.
- Accepted Low follow-ups: per-party (rather than per-tenant) PII shredding, master-key rotation, advisory-lock namespacing, and multi-region disaster recovery beyond a single VPS.
- The takeaway: “all tests pass” and “production-grade” are nearly unrelated, and the gap between them is closed by an adversarial audit, not more tests of the cases you already imagined.

≡ go-ledger

SPECIAL EDITION

4

- 01 The Exchange Rate Was Hiding in an Environment Variable
- 02 Special Edition Q&A: FX Rates and Markup as Live Admin Config

The Exchange Rate Was Hiding in an Environment Variable

Last week I sent a little money across a border. The app showed me a rate, I tapped confirm, and the euros landed a moment later. Out of habit I checked the rate against a search engine, and the app's number was a hair worse than the “real” one. Not a lot. Enough to notice. That small gap between the true mid-market rate and the rate you actually get is where the business lives. It has a name: the spread, or the markup. It is how the company on the other side of the screen earns its cut for moving your money between two currencies.

go-ledger has been able to do currency conversion for a while (that was the multi-currency work back in Week 11). It stores a mid rate for a pair, applies a spread against the customer, and posts the four legs of the conversion atomically. What it could not do until this week was let the operator running the ledger actually change any of that without SSH-ing into the box.

36.1 The rate lived in a file

Here is the embarrassing part. Every FX rate in the system came from a single environment variable read once at startup:

```
1 FX_RATES="USD:EUR=0.9200/25,USD:BDT=110.50/50"
```

Each entry is a pair, a mid rate, and a spread in basis points (25 bps is a quarter of one percent). At boot, the server parsed that string and wrote one row per entry into an append-only `fx_rates` table. Simple, and fine for a demo. But think about what changing a rate actually took: edit `/etc/go-ledger/env` on the server, restart the service, and hope you got the syntax right. An operator with no shell access could not do it at all. Anyone using the API or the console had no idea the setting existed.

There was a second, quieter problem. The spread was welded to every rate row. If you wanted “half a percent on everything,” you had to repeat the same number on every single pair, and to change it you had to re-enter every pair. There was no notion of a default markup that just applied across the board. That is a strange way to run a pricing business.

So this week’s job: move rates and markup out of the environment and into a live admin API, add a real default markup, and put both in the operator console. Then, because this is money, audit the result until it stops lying to me.

36.2 A worked example, so the words mean something

Say a customer converts 100.00 USD into euros. The operator has set the USD to EUR mid rate to 0.9200 and a markup of 50 basis points (0.50%). The ledger never gives the customer the mid rate; it always widens it against them by the spread:

1	<code>converted = 100.00 * 0.9200 * (1 - 0.0050)</code>
---	---

```
2      = 100.00 * 0.9200 * 0.9950  
3      = 91.54 EUR
```

At the pure mid rate the customer would have received 92.00 EUR. They got 91.54. That 0.46 EUR difference is the operator’s markup, and the whole point of this feature is letting the operator set that 50 without redeploying anything, for one currency pair or for every pair at once, for one tenant or for the whole platform.

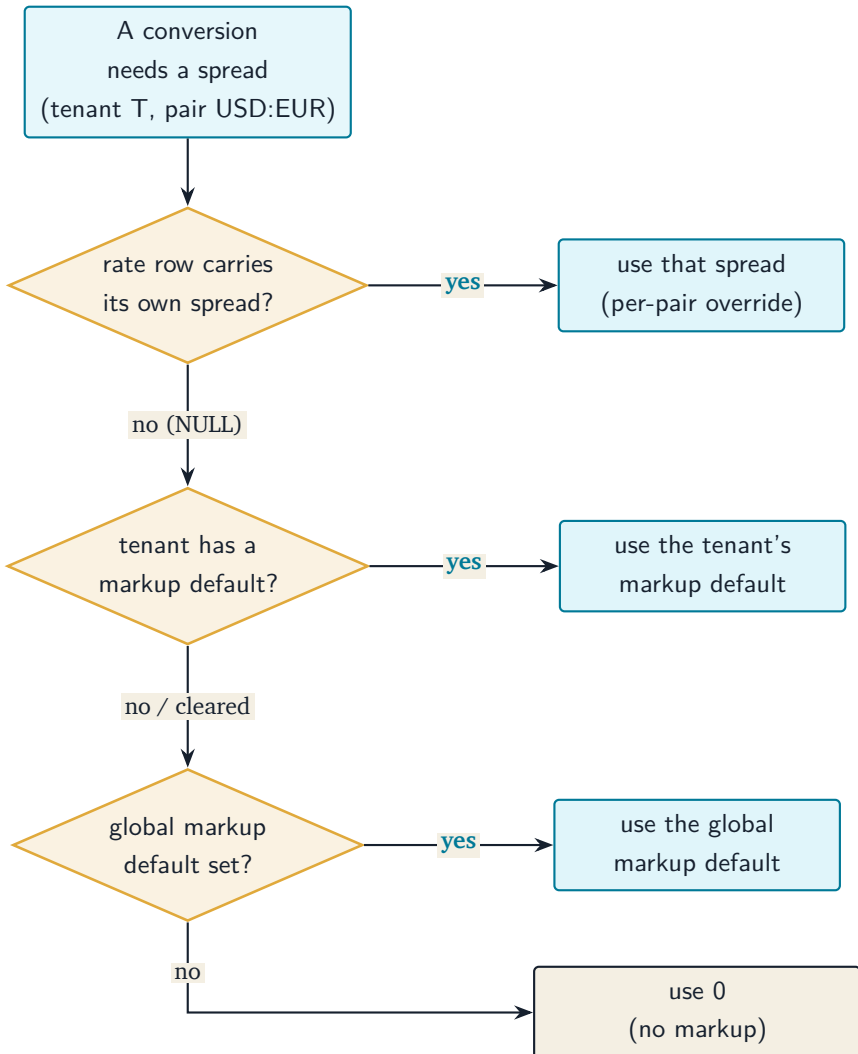
One detail that matters for a ledger: none of that math touches a floating-point number. Amounts are integer minor units, and the rate is an integer scaled by a hundred million. The console lets you type `0.9200`, but it converts that to the integer `92000000` using string math before it ever hits the API, so the money path stays exact from the browser to the database.

36.3 Making the markup optional

The neat trick that made a default markup possible was to let a rate row carry no spread at all. The `spread_bps` column on a rate became nullable. A concrete value is a per-pair override. `NULL` means “use whatever the default markup is.”

Then a new append-only table, `fx_markup_defaults`, holds the default itself: one value for the whole platform (the global default), and optionally one per tenant that overrides the global for that tenant. Both are append-only, exactly like the rates: you never update a row, you write a new one, so the full history of what the markup ever was stays on record.

When a conversion runs, the ledger resolves the actual spread to apply by walking a short chain of preferences:



The important word is “resolved.” The chain is walked at the moment a conversion happens, not when the rate is saved. So if you set a

new global default of 50 bps, every pair that does not override it immediately starts charging 50, without you touching a single rate row. That is what a default is supposed to do.

And because a recorded conversion snapshots the exact mid and spread it used into an immutable detail row, changing a default tomorrow can never rewrite what a conversion did yesterday. The history stays reproducible even though the config is now live and mutable.

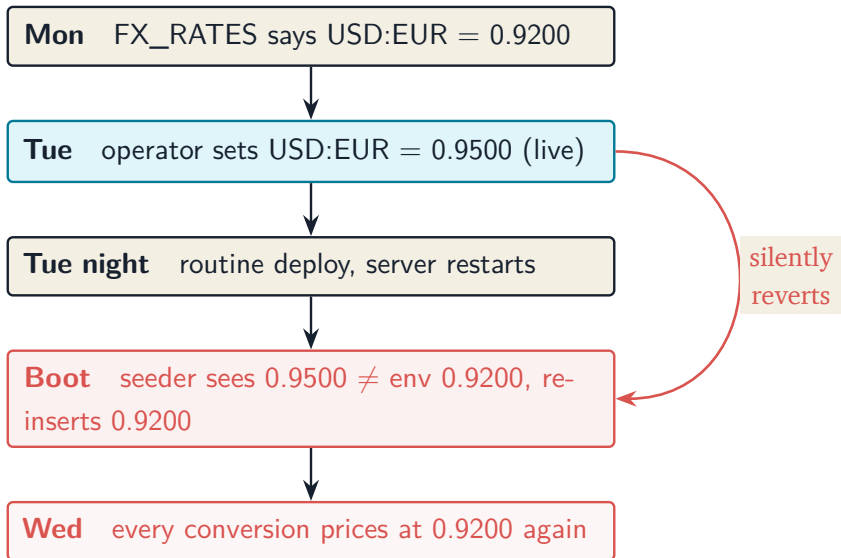
The API is four endpoints under `/v1/admin/fx`: set a rate, list current rates, set a markup default, read the markup defaults. All behind the same admin scope as the rest of the operator API. The console grew two cards in Settings, one for exchange rates and one for the markup fee, each with a toggle for “global default” versus “this tenant.” A rate change is now a form and a button.

36.4 Then I tried to break it

A feature that moves money is not done when the tests pass. It is done when someone who is paid to be suspicious cannot find a way to make it lie. So I ran the whole change past an audit with a simple brief: you are a fintech engineer doing due diligence, assume real money flows through this, find the ways it loses or mis-prices money. It found six things. Two of them mattered a lot.

The seed silently undid every live change. This is the one that would have quietly ruined the entire feature. Remember that the environment variable still seeds rates at boot, as a bootstrap. The

seeder's logic was: for each entry in `FX_RATES`, if the current rate for that pair differs from the environment value, insert the environment value. That was correct back when the seeder was the only thing that ever wrote a rate. But now the admin API is a second writer. Picture the sequence:



No log. No error.

The operator's change survived exactly until the next deploy, then vanished with no trace. The feature's whole promise, live rate edits, was being undone by the deploy pipeline. The fix was to make the seeder compare against the last rate the seeder itself wrote (the last row whose source was `env`), not against whatever the current winning rate is. Now a change to `FX_RATES` still lands, but an operator's live edit is never clobbered.

The public demo let anyone set a 99.99% markup. The live demo at `go.sohag.pro` resets every four hours and exposes the admin panels publicly, because there is nothing durable to protect between resets. Except now there was. A global markup is not scoped to the demo tenant; it is platform-wide. The demo reset only ever deleted the demo tenant's own rows, so an anonymous visitor could set a global markup of 9,999 basis points (99.99%, perfectly legal to the validation), and it would survive every reset and mis-price every other visitor's conversions until the process restarted, forever for markup since the boot seeder never touched it. The fix was to have the demo reset also clear the API-set global FX config each cycle, back to a clean baseline, while leaving the environment-seeded rates alone.

The other four were smaller: a console number field that accepted `1e3` and quietly saved `1`, a rate input that could lose precision above a couple hundred million, a down-migration that flattened default-following rates to zero markup on a rollback, and a way for a tenant markup override to get stuck because you could never clear it back to following the global. All real, all fixed, and then I audited the fixes, which found two more residual issues the first round of fixes had introduced (the demo cleanup missed a tenant-scoped variant of the same tampering, and the rollback logic resurrected a markup you had explicitly cleared). Fixed those, audited a third time, clean.

That loop is the actual lesson. The first audit found the design bug. The second audit found the bugs in the fix. Money-adjacent code earns that paranoia. A CRUD app with this class of bug shows a stale number on a page. A ledger with this class of bug charges the wrong people the wrong amount and does it silently, which is the worst way for a payment system to be wrong.

36.5 What it looks like now

An operator opens the console, goes to Settings, and sets USD to EUR to 0.9500 with no override spread. They set a global markup of 50 bps. A conversion for any tenant on that pair now applies 0.95 and 50 bps, resolved at conversion time. They give one big customer a break: a tenant markup default of 20 bps, and that tenant alone now gets the cheaper rate, everyone else still 50. Later they clear that tenant override and it falls back to the global 50 again. No file edits, no restart, and every one of those changes is a new row in an append-only history you can read back.

The rate stopped hiding in an environment variable. And the thing that quietly reset it every deploy is gone.

The repo is open source at github.com/sohag-pro/go-ledger, and the design is written up in [ADR-020](#).

Special Edition Q&A: FX Rates and Markup as Live Admin Config

Interview-style questions for the special edition that moved FX configuration in go-ledger from a boot-time environment variable to a live admin API. Every question is answerable from this repo's code and ADR-020, plus `internal/fx/provider.go`, `internal/fx/admin.go`, `internal/fx/seed.go`, `internal/domain/fx.go`, `internal/api/fx_admin.go`, `internal/seed/seed.go`, migration `0031_fx_markup_defaults.sql`, and the FX query files under `internal/postgres/queries/`.

37.1 Design and motivation

37.1.1 1. FX rates already worked, driven by the `FX_RATES` environment variable. Why was that not good enough, and what did moving to an admin API actually buy you?

What a strong answer covers:

- Changing a rate meant editing the server's environment and restarting the service: slow, needs shell access, invisible to anyone using

the API or console.

- The spread was welded onto every rate row, so “half a percent on everything” meant repeating one number on every pair and re-entering every pair to change it. No concept of a default markup.
- The admin surface (`/v1/admin/fx`) lets an operator change rates and markup live, at global or per-tenant scope, from the same place they manage tenants and keys (ADR-019’s operator console).
- It is purely additive: the same append-only tables, just a second writer alongside the boot seeder.

37.1.2 2. You kept `FX_RATES` as a boot-time bootstrap instead of deleting it. Defend that. Why keep two ways to set a rate?

What a strong answer covers:

- A fresh deploy should come up with sane rates without an operator having to POST anything first, so conversions do not fail closed on an empty table.
- Env-pinned rates are useful for reproducible environments and for an operator who prefers config to clicks.
- The env path is additive: `fx.Seed` appends rows to the same history, it does not own or replace the table.
- The cost of keeping it is one clear rule (env rows are explicit overrides, source env), which is cheaper than the failure mode of a rate-less fresh box.

37.2 Data model

37.2.1 3. The change made `fx_rates.spread_bps` nullable. What does NULL mean now, and why was nullability the right mechanism for a default markup?

What a strong answer covers:

- A concrete value is a per-pair override; NULL means “use the applicable markup default,” resolved later.
- It mirrors an existing, understood pattern and keeps the rate row as the single source for a pair’s own pricing when it wants one.
- Pre-existing rows keep their concrete value, so they read as explicit overrides and no historical conversion changes meaning.
- The alternative, a concrete spread on every row, is exactly what made a shared default impossible in the first place.

37.2.2 4. Why a separate `fx_markup_defaults` table with a nullable value, rather than, say, a column on the tenant or a per-pair markup table?

What a strong answer covers:

- The default is meant to span pairs, so keying it per pair would defeat the purpose; per-pair precision already exists through the nullable `spread_bps` override.
- It mirrors `fx_rates` exactly: append-only, server-stamped `effective_at`, a current-row index, `tenant_id` NULL for the global default.

- A nullable `default_spread_bps` lets a tenant explicitly clear its override and fall back to the global, which a NOT NULL column plus append-only could never express.
- Putting it on the tenant row would make it mutable state, breaking the append-only history the rest of the FX model relies on.

37.2.3 5. Explain “resolved at conversion time.” Why not compute the effective spread when a rate is saved and freeze it into the row?

What a strong answer covers:

- Freezing at save time is simpler (no nullable column, no second lookup) but it makes a standalone markup page a lie: setting a new default would change nothing until every rate was re-entered.
- Resolving at conversion time means “set 50 bps as the default” immediately governs every pair that does not override it, which is what a default is for.
- Reproducibility is preserved separately: the conversion snapshots the concrete spread it used, so live config changes cannot rewrite past conversions.
- The precedence chain (per-pair override, then tenant default, then global default, then 0) is the thing resolved; `domain.Convert` still receives one concrete integer spread.

37.3 Correctness

37.3.1 6. Walk through the precedence chain for the effective spread. What are the four outcomes, and where does a cleared tenant default land?

What a strong answer covers:

- Order: the rate row's own `spread_bps` if non-null; else the tenant's own markup default; else the global default; else 0.
- A cleared tenant default (a NULL `default_spread_bps` row for that tenant) must fall through to the global default, not win the tenant tier with a zero or garbage value.
- A cleared or absent global default resolves to 0, meaning no markup, not an error.
- The mid-rate precedence (tenant row, then global, then inverse-derived) is unchanged and independent of the spread resolution.

37.3.2 7. The provider (real conversions) and the admin console's "effective spread" view both resolve the same chain. How did you stop them from drifting, and why does drift matter here?

What a strong answer covers:

- Both call a single shared helper, `resolveMarkupDefault`, so there is one implementation of the precedence, not two that can diverge.
- Drift matters because the console shows the operator what a conversion "would" charge; if the view and the actual conversion disagree, the operator is making pricing decisions on a lie.
- A per-task review caught an early version of exactly this bug:

`ListRates` resolved against the winning row's `tenant_id` instead of the requested scope, so a global-fallback rate under a tenant with its own default showed the wrong number.

- A dedicated regression test now locks the tenant-scoped case (a global rate row plus a tenant markup default resolves to the tenant's default).

37.3.3 8. A conversion is recorded, then someone changes the markup default. Prove the old conversion still reproduces to the same numbers.

What a strong answer covers:

- `domain.FXDetail` snapshots the concrete mid rate, the resolved spread, the applied rate, and the rate row id into the transaction at conversion time.
- The stored conversion is those exact numbers run through the single-step `convert` formula, not a re-resolution against live config.
- The idempotent replay path returns the stored transaction before it ever calls the provider, so a replay cannot pick up a new default either.
- The precedence chain only decides which concrete spread is handed to `convert`; once handed over and snapshotted, later config changes are irrelevant to that row.

37.4 Append-only and history

37.4.1 9. Both FX tables are append-only, yet the demo seeder issues DELETES against them. Is that a contradiction?

What a strong answer covers:

- The append-only guarantee is a property of the money core for real tenants; the demo seeder is explicitly a demo tool, not core service behavior, and already deletes the demo tenant's rows to reset it.
- The DELETES run only in the demo reset path, gated on demo mode and behind a guard that refuses to touch any tenant holding a non-demo key.
- They remove only api-sourced tampering (`source = 'api'`) and leave env-seeded rows, so the reset returns to a clean baseline rather than wiping history a real operator would want.
- The distinction to articulate: append-only is an application invariant for production data, not a claim that no row is ever physically deleted in a throwaway demo.

37.4.2 10. There is no UPDATE anywhere on these tables, only INSERT. How does “change a rate” work, and what does that design give you and cost you?

What a strong answer covers:

- A change is a new row with a later `effective_at`; the current-rate query reads the latest effective row, so the newest write wins.
- It gives a complete, auditable history of every rate and markup the system ever used, and makes conversions reconstructible.

- It costs storage that grows monotonically and requires a current-row query with a correct tiebreak (`effective_at DESC, id DESC`) rather than a primary-key lookup.
- Server-stamped `effective_at` (via `COALESCE to now()`) avoids a clock-skew bug where a just-written row could be transiently invisible if the writer's clock ran ahead of the database.

37.5 Security and isolation

37.5.1 11. The new `fx_markup_defaults` table has row-level security. Why, given the application already filters by tenant in every query?

What a strong answer covers:

- RLS is defense in depth: it is the backstop if a future query on this table is written without the right tenant filter.
- It is a tenant-scoped table with a nullable `tenant_id`, the same shape as `fx_rates`, which is already under `FORCE` row-level security, so leaving this one out would be an inconsistent gap in the invariant.
- The policy allows global rows (`tenant_id NULL`) and an unset GUC, matching the `fx_rates` policy, so global defaults stay visible and the pool-backed admin writes still work.
- A per-task review actually caught the missing RLS; the spec had wrongly claimed the table needed none, based on a false premise that `fx_rates` had none.

37.5.2 12. ADR-020 admits any admin key can write global rates and the global markup, because there is no platform-superadmin tier. Why ship that, and where does it bite?

What a strong answer covers:

- For the single-operator v1 (one operator running the whole system) it is acceptable and matches how the other global-ish admin actions already behave.
- It is recorded as a deliberate gap, not forgotten, so a future multi-operator deployment knows to add a distinct platform-admin scope for global writes.
- Where it bites: the public demo exposes admin publicly, so the “any admin key writes global config” acceptance let an anonymous visitor set a global markup that mis-priced every other visitor.
- The mitigation there was operational (the demo reset clears api-set global FX config each cycle), not a new auth tier, because the tier is genuinely out of scope for v1.

37.6 The audit

37.6.1 13. The audit found a bug where the boot seeder silently reverted every live rate change. Explain the bug and the fix, and why the original logic was once correct.

What a strong answer covers:

- The seeder inserted an env entry whenever it differed from the current winning rate. That was correct when the seeder was the only writer.
- With the admin API as a second writer, a live operator edit becomes the current winner, so on the next boot the seeder saw “differs from env” and re-inserted the stale env value with a fresh timestamp, which then won.
- The operator’s change survived only until the next deploy, then vanished with no log or error, undoing the feature’s whole promise.
- The fix compares each env entry against the latest env-sourced row (the last thing the seeder itself wrote), so a genuine FX_RATES change still lands but an API-written row is never clobbered.

37.6.2 14. You audited the feature, fixed the findings, then audited again and found new issues in the fixes. What is the general lesson, and give a concrete example from this work.

What a strong answer covers:

- Money-adjacent fixes deserve the same suspicion as the original code; a fix is new code and can introduce new bugs.
- Concrete example: the first demo-tampering fix cleared only global api rates, but a tenant-scoped api rate on the demo tenant is preferred by the rate lookup, so the same tampering persisted via the tenant variant.
- Second example: the down-migration fix froze the current global markup into default-following rows, but filtered out a cleared (NULL) global, so it resurrected an older superseded markup on

rollback.

- The process answer: re-run the audit from scratch after fixing, and keep going until a full pass is clean, rather than trusting that findings marked fixed are actually fixed.

37.7 Trade-offs (defending locked decisions)

37.7.1 15. The whole money path is integer-only, and the console does string-based decimal-to-e8 conversion rather than `parseFloat(value) * 1e8`. Defend the extra work. Why not just use a float for a display rate?

What a strong answer covers:

- A float cannot represent most decimal rates exactly, so `parseFloat("0.9200") * 1e8` can land off by one in the least significant unit, and that error is on the money path.
- The rate is an integer scaled by a hundred million; the console builds the integer from the digit string (whole plus a zero-padded fraction) so no float arithmetic ever touches a value that becomes money.
- The API and database only ever accept and store integers (`mid_rate_e8`, `spread_bps`), so the browser is the only place a decimal exists, and it is converted before it leaves.
- The audit also caught the boundary risk directly: an input that could exceed the safe-integer range is rejected rather than sent corrupted, and a `1e3` entry is rejected rather than silently parsed as

1.

≡ go-ledger

ARCHITECTURE DECISIONS

- 01 ADR-001: Why Double-Entry Accounting
- 02 ADR-002: Money Representation
- 03 ADR-003: Postgres Schema and Repository Layer
- 04 ADR-004: Concurrency Control for Transaction Posting
- 05 ADR-005: Per-Account Currency Integrity
- 06 ADR-006: REST API Design
- 07 ADR-007: Idempotency Keys and the Immutable Audit Log
- 08 ADR-008: Covering Index for Account History Reads

- 09 ADR-009: gRPC Layer over the Shared Domain
- 10 ADR-010: Observability with OpenTelemetry
- 11 ADR-011: Testing strategy: unit, property, integration, chaos, load
- 12 ADR-012: API authentication, mandatory idempotency, input hardening, and a tamper-evident audit chain
- 13 ADR-013: VPS infrastructure-as-code with Ansible, and Docker as a dev-only artifact
- 14 ADR-014: Multi-currency accounts and FX conversion
- 15 ADR-015: Audit remediation, white-label hardening, durability, and scale
- 16 ADR-016: Durability and disaster recovery (WAL archiving, offsite encrypted backups, PITR)
- 17 ADR-017: Multi-instance audit chain (transactional outbox + single chainer)
- 18 ADR-018: PII crypto-shredding (reconciling immutability with the right to erasure)
- 19 ADR-019: Operator console, public-demo admin, and one-command onboarding
- 20 ADR-020: FX rates and markup as live admin config
- 21 ADR-021: Admin act-as-tenant for cross-tenant operator access
- 22 ADR-022: USD-hub FX triangulation for cross-currency pairs

- 23 ADR-023: Account hierarchy and rolled-up reporting
- 24 ADR-024: Demo seeder writes audit events and purges visitor tenants
- 25 ADR-025: Approval workflows and a lifecycle event stream
- 26 ADR-026: Security and correctness hardening from an external audit
- 27 ADR-027: Webhooks

CHAPTER 38

ADR-001: Why Double-Entry Accounting

38.1 Status

Accepted: 2026-06-11

38.2 Context

go-ledger is a payment ledger service: it must record money movements between accounts and answer “what is the balance of account X?” correctly, every time, under concurrent writes.

The naive approach is a single `balances` table with one row per account that gets incremented and decremented in place. This is how many systems start, and it fails in predictable ways:

- **No audit trail.** A mutable balance tells you *what* the balance is, not *how* it got there. Reconstructing history requires separate logging that inevitably drifts from the source of truth.
- **Money appears and disappears.** A single-sided update (“add \$10 to A”) has no structural guarantee that the money came from anywhere. Bugs create or destroy money silently.
- **Race conditions corrupt state.** Read-modify-write on a balance row under concurrency loses updates unless every code path re-

members to lock correctly. The schema itself offers no protection.

Double-entry bookkeeping, in use since the 15th century, solves all three structurally:

- Every transaction consists of two or more **postings** (ledger entries).
- Each posting debits one account and credits another.
- The sum of all postings in a transaction must equal zero.

38.3 Decision

go-ledger models all money movement as double-entry transactions:

- **Transaction**: an atomic, immutable unit of money movement.
- **Posting**: a single signed entry against one account; a transaction has two or more postings.
- **Invariant**: $\Sigma(\text{postings}) = 0$ for every transaction. Enforced in the domain types (`Transaction.Validate()`), and later at the database level with a CHECK constraint.
- Postings are append-only. Balances are *derived* (sum of postings), never stored as mutable primary state.

38.4 Consequences

38.4.1 Positive

- Money can never be created or destroyed by a write path bug; an unbalanced transaction is rejected before it persists.
- The ledger is its own audit trail: every balance is explainable as a sum of immutable postings.
- Append-only postings sidestep update races entirely; concurrency control reduces to serializing transaction inserts (Week 4).
- The model matches what accountants, auditors, and payment partners expect.

38.4.2 Negative

- Balance reads are aggregations, not single-row lookups. Acceptable for v1; if it becomes hot, a derived (and rebuildable) balance cache can be added; it stays a cache, never the source of truth.
- Slightly more conceptual overhead for API consumers: posting a payment means submitting balanced postings, not “set balance”.

38.5 Alternatives considered

- **Mutable balance table:** rejected. No audit trail, no structural integrity guarantee (see Context).
- **Event sourcing with a full event store:** rejected for v1. Double-entry postings already give us the append-only history we need without the operational complexity of projections and replay. Re-visit only if product needs demand it (see scope discipline in the

build plan).

CHAPTER 39

ADR-002: Money Representation

39.1 Status

Accepted: 2026-06-15

39.2 Context

The ledger moves money between accounts and must answer balance queries exactly. Floating point is unfit for money: $0.1 + 0.2 \neq 0.3$ in IEEE-754, and rounding error accumulates across millions of postings. We need an exact, fast representation that maps cleanly to Postgres in Week 3.

Three candidates:

- **int64 minor units**: store the amount as a signed integer count of the currency's smallest unit (cents for USD). Exact, no allocation, maps to BIGINT. Must guard against overflow on arithmetic.
- **Arbitrary-precision decimal** (for example `shopspring/decimal`): exact and overflow-free, but every operation allocates a `big.Int`, and it maps to NUMERIC. More machinery than a single-currency `v1` needs.
- **Custom decimal struct** (`int64` coefficient + scale): full control,

but we own the arithmetic, rounding, and a pile of tests for no v1 benefit.

39.3 Decision

go-ledger represents money as `int64` minor units in a `Money` value type that also carries its `Currency`. v1 is single-currency (USD), per the build plan's scope discipline, so there is no per-currency scaling to track yet.

- `Money` is an immutable value type. Operations return new `Money` values.
- Arithmetic (`Add`, `Sub`, `Neg`) is overflow-guarded and returns an error on overflow rather than panicking or wrapping.
- Cross-currency arithmetic returns `ErrCurrencyMismatch`. The check exists now so multi-currency (a future, out-of-scope item) cannot silently corrupt sums.
- Maps to `BIGINT` in Postgres (Week 3) with no conversion.

39.4 Consequences

39.4.1 Positive

- Exact arithmetic with zero allocation on the hot path.
- Clean, lossless mapping to `BIGINT`; no `NUMERIC` parsing.
- Overflow is a typed, testable error, not undefined behavior.

39.4.2 Negative

- `int64` caps the representable amount near $9.2e16$ minor units. Far beyond any realistic single-account balance, but arithmetic must still check, hence the overflow guard.
- Adding a second currency later means introducing per-currency exponents. Acceptable: multi-currency is explicitly out of scope for v1.

39.5 Alternatives considered

- **`float64`**: rejected. Not exact; unacceptable for money.
- **`shopspring/decimal`**: rejected for v1. Allocation and `NUMERIC` overhead with no benefit while we are single-currency. Revisit if multi-currency lands.
- **`Custom decimal struct`**: rejected. Owning rounding and arithmetic is cost without v1 value.

CHAPTER 40

ADR-003: Postgres Schema and Repository Layer

40.1 Status

Accepted: 2026-06-29

40.2 Context

Week 3 puts the domain model (ADR-001, ADR-002) onto disk. We need a schema for accounts, transactions, and postings, a repository layer over it, and an integration test that runs the full happy path against a real Postgres. Several choices had no obvious default and would be costly to reverse once data exists, so each is recorded here.

The hardest question is how balances are stored. Two shapes:

- **Mutable balance column:** each account row carries a balance updated in place on every posting. Reads are a single column lookup.
- **Append-only postings, derived balances:** postings are immutable rows; balance is `SUM(amount)` over an account. Nothing is updated in place.

A mutable balance is faster to read but reintroduces exactly the bug

double-entry exists to prevent: the stored number and the sum of postings can drift, and once they drift there is no way to tell which is right. It also turns every posting into a read-modify-write that must be serialized.

40.3 Decision

Postings are append-only and balances are derived. This carries the core invariant from ADR-001 into the database. The schema, with the reasoning for each non-obvious choice:

- **Three tables now, not five.** The build plan lists five tables, but `idempotency_keys` (Week 6) and `audit_log` (Week 6) are designed and built in the weeks that use them, when their columns are actually known. `0001_initial` creates only `accounts`, `transactions`, and `postings`. Migrations are cheap; guessing a schema before its code exists is not.
- **Multi-tenant from day one.** Every table carries a `tenant_id`. There is no auth or tenant resolution yet (that comes later); the column and the foreign key discipline exist now because retrofitting tenancy onto a populated ledger is a migration no one wants to write. Repository methods are all scoped by tenant.
- **UUIDv7 primary keys, generated in the application.** Keys are `uuid` columns; the app generates a UUIDv7 before insert. v7 is time-ordered, so it keeps index locality close to a serial key while staying globally unique and decoupled from the database. Generating in Go (`not gen_random_uuid()`) means the caller knows the id without a round-trip and tests are deterministic.
- **Composite foreign keys enforce tenant integrity.** `accounts` and

transactions carry a `UNIQUE (tenant_id, id)`. postings references both via `(tenant_id, account_id)` and `(tenant_id, transaction_id)`. A posting cannot point at an account or transaction in a different tenant: the database rejects it, not just application code.

- **Currency lives on the transaction, not the posting.** The domain already enforces that all postings of a transaction share one currency (`Transaction.Validate`). Storing it once on the transaction keeps a posting to a single signed `bigint` amount, and each posting's `Money` is reconstructed from the transaction's currency on read. Accounts also carry their own currency.
- **Account type is `text` with a `CHECK`, not a Postgres enum.** The five types are constrained by `CHECK (type IN (...))`. Readable in plain SQL, and adding or changing a type is an ordinary migration rather than the awkward `ALTER TYPE` dance an enum forces.
- **No balance `CHECK` constraint yet.** The sum-to-zero invariant is enforced in the domain (`Transaction.Validate`) for Week 3. The database-level `CHECK` lands in Week 4 alongside the transaction-posting service and its concurrency handling, where it belongs.

The repository follows a port-and-adapter split: `domain.Repository` is the port (the domain owns the contract); `internal/postgres` is the adapter, built on `pgx` and `sqlc`-generated queries. `CreateTransaction` validates the double-entry invariant, then writes the transaction and all its postings in one database transaction, so a half-written transaction can never exist. Tooling is goose for migrations, `sqlc` for type-safe queries, and `testcontainers-go` for the integration test (all locked in the build plan).

40.4 Consequences

40.4.1 Positive

- The stored ledger cannot disagree with itself: there is no second copy of the balance to drift from the postings.
- Tenant isolation is enforced by the database, not just by careful queries.
- The domain stays free of storage and uuid types; the port is a plain Go interface, so the service layer (Week 4) can be tested against a fake.
- UUIDv7 keeps write-side index locality without coupling ids to the database.

40.4.2 Negative

- Balance reads are an aggregate (sum) rather than a column read. Fine at v1 scale; if it ever bites, the answer is a materialized rollup that is rebuilt from postings, never a mutable primary balance.
- The integration test needs a Docker daemon. It skips (does not fail) when none is reachable, so `local make test` stays green; CI runs Docker and exercises the real path.

40.5 Alternatives considered

- **Mutable balance column:** rejected. Reintroduces drift between stored balance and posting history, the exact failure double-entry prevents, and serializes every posting behind a row update.
- **All five tables in 0001:** rejected. Designs `idempotency_keys` and

`audit_log` before the code that uses them; they get their own migrations in Week 6.

- **Single-tenant schema, add tenancy later:** rejected. Adding `tenant_id` and backfilling foreign keys on a live ledger is far more painful than carrying the column from the start.
- **DB-generated UUIDv4 (`gen_random_uuid()`):** rejected. Random keys hurt index locality and force a read-back to learn the generated id.
- **Postgres enum for account type:** rejected. `ALTER TYPE` is more friction than a `text` column with a `CHECK`, for no real gain.

CHAPTER 41

ADR-004: Concurrency Control for Transaction Posting

41.1 Status

Accepted: 2026-06-29

41.2 Context

Posting a transaction writes a transaction row and two or more postings that must sum to zero, and it must do so correctly when many requests post to the same accounts at once. Two requests racing on the same account cannot be allowed to produce a ledger that does not balance, lose a posting, or read a stale balance.

The schema (ADR-003) already makes postings append-only and balances derived, so there is no mutable balance row to corrupt. What remains is making each posting atomic and keeping the double-entry invariant intact under concurrency.

There are two classic strategies:

- **Pessimistic: lock the rows.** Run at READ COMMITTED and `SELECT ... FOR UPDATE` the involved account rows, in a fixed order to avoid

deadlock, before writing. Conflicting transactions block rather than fail, so there is nothing to retry. Correctness rides on remembering to lock the right rows, in the right order, every time.

- **Optimistic: let the database detect conflicts.** Run at **SERIALIZABLE**. Postgres's Serializable Snapshot Isolation (SSI) tracks read/write dependencies and aborts a transaction with SQLSTATE 40001 if committing it would break serial-equivalent ordering. No explicit locks; conflicts surface as errors the application retries.

41.3 Decision

go-ledger uses **SERIALIZABLE with automatic retry**. Correctness comes from the database guaranteeing serial-equivalent execution, not from the application remembering to take the right locks. A buggy or future code path cannot silently skip a lock it never knew to take.

The pieces:

- **Service owns the unit of work.** `ledger.TransactionService.Post` validates the transaction, then runs the write through the repository's `RunInTx`, which begins a **SERIALIZABLE** transaction, runs the work, and commits.
- **The adapter owns isolation and retry.** `RunInTx` (in `internal/postgres`) begins each attempt at `pgx.Serializable`. A serialization failure (40001) or deadlock (40P01) can surface either inside the work or, commonly, only at **COMMIT**, so both are watched and the whole unit of work is replayed. Retries are bounded (25 attempts) with exponential backoff and full jitter; the jitter is what stops a crowd of conflicting transactions from retrying in lockstep and colliding

again.

- **The invariant is also enforced in the database.** A DEFERRABLE INITIALLY DEFERRED constraint trigger (`assert_txn_balanced`, migration 0002) runs at COMMIT and rejects any transaction whose postings do not sum to zero. This is defense in depth: the domain checks the invariant first (`Transaction.Validate`) for a fast, clean error, but the trigger guarantees it holds even against a bad migration, a direct psql write, or a second service.
- **The trigger's read is indexed.** The trigger reads postings by `transaction_id`. Without an index that read is a scan, and under SSI a scan takes broad predicate locks that turn into a storm of false-positive serialization conflicts. Adding `postings_transaction_idx` was the single change that took the stress test from roughly 1 in 6 posts failing to zero. This is the non-obvious lesson of the week: under SERIALIZABLE, an unindexed read is not just slow, it manufactures conflicts.

SELECT FOR UPDATE is not used. The two approaches were not combined: belt and suspenders here would mean taking explicit locks and running SERIALIZABLE and retrying, which is more moving parts and redundant guarantees for no gain.

41.4 Observability

Posting is instrumented with two Prometheus collectors: a histogram `transaction_post_duration_seconds`, labeled by outcome, for latency, and a counter `transaction_post_serialization_retries_total` so a climbing retry rate makes write contention visible. These sit alongside the standard Go runtime and process collectors.

The scrape endpoint is served on a separate server bound to loopback (127.0.0.1:9090 by default), not on the public API port. A metrics endpoint leaks transaction volumes, latencies, and retry rates, so it is reached over the host's private network or an SSH tunnel, never the public interface. The public liveness check stays `GET /healthz`.

41.5 Measured baselines

Stress test: 100 goroutines posting 10,000 balanced transactions against a shared pool of 100 accounts. Result: all 10,000 commit, zero failures, and the sum of every account balance is exactly zero.

One honest caveat about the concurrency level: the real ceiling on how many posting transactions run at the database at once is the connection pool's `MaxConns`, not the goroutine count. The test sets `MaxConns` to 25 explicitly and logs it, so “100 goroutines” means up to 25 transactions truly concurrent at Postgres with the rest queued on pool acquisition. That is still meaningful contention on 100 shared accounts, and it is the number worth quoting rather than the goroutine count.

Latency on the local test machine (Postgres 16 in a colima VM): p50 about 35 ms, p99 about 68 ms. These are above the original p50 < 10 ms / p99 < 50 ms target. The dominant cost is WAL fsync on the VM's virtualized disk: every commit waits for a durable write, and a Lima VM's disk is slower than bare metal. The numbers are reported as measured rather than tuned (for example by disabling `synchronous_commit`), since durability is the point of a ledger. On bare-metal or a real server disk the same code should land much closer

to the target. Latency is logged by the test, not asserted, so the suite does not flake on machine speed.

41.6 Consequences

41.6.1 Positive

- Correctness does not depend on the application taking the right locks; the database guarantees serial-equivalent execution.
- The double-entry invariant is enforced in two independent places: the domain and a deferred database trigger.
- Retry with jittered backoff absorbs contention transparently; under the test's sustained load every transaction eventually commits.
- `RunInTx` is a general unit-of-work seam, so Week 6 can write the audit-log entry inside the same transaction as the posting it records.

41.6.2 Negative

- Under contention some transactions do extra work (retries), and pathological contention could still exhaust the retry budget and surface an error to the caller. That is the optimistic trade: conflicts cost retries, not blocked connections.
- SSI is sensitive to read patterns. Indexes that look optional for correctness (like the one on `transaction_id`) are load-bearing for concurrency. Future reads inside a posting transaction must be considered for their SSI footprint.
- `fn` passed to `RunInTx` must be safe to run more than once, since it can

be replayed.

41.7 Alternatives considered

- **READ COMMITTED + SELECT FOR UPDATE**: rejected. Pushes correctness onto the application to lock the right rows in the right order every time; a future code path that forgets reintroduces the race. Pessimistic locking also serializes access to hot accounts by blocking, rather than letting non-conflicting work proceed.
- **SERIALIZABLE + SELECT FOR UPDATE + retry**: rejected. Redundant guarantees and more moving parts than SERIALIZABLE alone needs.
- **Mutable balance with row locks**: rejected back in ADR-003; it reintroduces a second copy of the truth that can drift.
- **A non-deferred row CHECK**: impossible; the sum-to-zero invariant spans many posting rows and cannot be expressed in a single-row CHECK, hence the deferred constraint trigger.

CHAPTER 42

ADR-005: Per-Account Currency Integrity

42.1 Status

Accepted: 2026-06-29

42.2 Context

Currency lives in two places (ADR-003): every account has a currency, and every transaction has a currency (the single currency shared by all its postings). Postings themselves carry only a signed `amount`, not a currency, because the domain already guarantees all postings of a transaction share one currency.

That leaves a gap. Nothing tied a transaction's currency to the currency of each account it posts into. A USD transaction could post into an account whose currency is EUR, and the database would accept it. Today the ledger is single-currency (USD), so the gap is invisible, but it is exactly the kind of latent integrity hole that turns into a real one the moment multi-currency, a second writer, or a buggy import appears. A reviewer would not trust a ledger that lets a posting land in an account of a different currency.

The domain cannot close this on its own: `Transaction.Validate` sees

the postings and their shared currency, but it does not know each referenced account's currency, which lives in the database.

42.3 Decision

Enforce it in the database. Migration 0003 adds an immediate `AFTER INSERT` trigger `ON postings (assert_posting_currency)` that, for each inserted posting, looks up its account's currency and its transaction's currency and rejects the row if they differ.

- It is immediate, not deferred: the account and transaction both already exist when a posting is inserted (the foreign keys require it), so there is nothing to wait for.
- The lookups are equality on primary keys, so under `SERIALIZABLE` they take only narrow predicate locks on rows that posting transactions read but never write. The stress test confirmed this adds no measurable serialization contention.

This is defense in depth, consistent with how the balance invariant is handled (ADR-004): the domain keeps postings in one currency, and the database guarantees that currency matches each account, even against a direct write.

42.4 Consequences

42.4.1 Positive

- A posting can never move money in a currency the account does not hold. The guarantee holds regardless of what client or code path wrote the row.
- The schema is ready for multi-currency: when it lands, this invariant is already enforced rather than retrofitted onto live data.

42.4.2 Negative

- A small per-posting read cost at insert time (two primary-key lookups). Negligible in practice and confirmed not to add serialization conflicts.
- The currency rule now lives in two places: the domain (postings share one currency) and the database (that currency matches the account). That redundancy is the point, but it is two places to keep in mind.

42.5 Alternatives considered

- **Denormalize currency onto postings and use a composite foreign key** `postings(account_id, currency) -> accounts(id, currency)`: rejected. It would put currency back on the posting row, undoing the ADR-003 decision to keep a posting to a single signed amount, for no extra safety beyond what the trigger gives.
- **Enforce only in application code** (check each account's currency in `CreateTransaction`): rejected. That is the very thing we want the

database to guarantee; an application-only check is one forgotten code path away from a cross-currency posting.

- **Do nothing until multi-currency arrives:** rejected. Adding the constraint to a populated, multi-currency ledger later is far riskier than enforcing it now while the rule is trivially true.

CHAPTER 43

ADR-006: REST API Design

43.1 Status

Accepted: 2026-06-29

43.2 Context

Through Week 4 the ledger was exercised only by tests; the service had no network surface. Week 5 puts a REST API in front of it: create accounts, post transactions, and read accounts, balances, statements, and transactions. The router is chi (a locked decision), and the project already generates its OpenAPI spec from the handlers with huma, with a drift test and a self-hosted playground.

Several choices had no obvious default.

43.3 Decision

43.3.1 huma operations on chi

The endpoints are huma operations running on a chi router via the humachi adapter (swapped from humago). Each endpoint is a typed operation: huma derives request validation from struct tags, renders errors as RFC 7807 `application/problem+json`, and generates the OpenAPI spec, all from the same handler. chi owns routing and the middleware chain (request id, recovery, structured request logging).

This was chosen over plain chi handlers plus go-playground/validator plus hand-written `problem+json` (the build plan's literal wording). huma already solves validation, error formatting, and spec generation as one unit, and the existing drift test and playground depend on the spec being generated from handlers. The plan predates the huma decision; huma's validation supersedes the separate validator cleanly. The cost is using huma's validation tags (`minLength`, `enum`, `pattern`) rather than go-playground's, which is minor.

43.3.2 Money as integer minor units

Amounts cross the wire as a signed integer count of minor units plus a currency code (`{"amount": 10000, "currency": "USD"}`), mapping 1:1 to the internal `int64`. No floating point and no decimal parsing at the boundary. This is what most payment APIs (for example Stripe) do, and it keeps the API as exact as the ledger.

43.3.3 Single default tenant for now

The schema is multi-tenant, but there is no auth yet. Rather than expose tenancy in URLs or trust a client header, every request acts as a single default tenant (`DEFAULT_TENANT_ID`, with a fixed fallback), injected by the API layer into each service call. When auth lands it will populate the same tenant value from a token instead, without changing any resource URL.

43.3.4 Account statement with running balance and keyset paging

Beyond the planned endpoints, `GET /v1/accounts/{id}/statement` lists the account's postings, newest first, each with the account's running balance as of that posting (a window `SUM` over the account's history), and pages with keyset (cursor) pagination on (`created_at`, `id`). Keyset paging is stable under concurrent inserts in a way offset paging is not.

Because balances are derived, never stored (ADR-003), the running-balance window scans the account's full posting history per page (one index range on (`tenant_id`, `account_id`)). That is $O(\text{history})$ per page, fine at v1 scale; the future optimization, if it ever bites, is a materialized running balance rebuilt from postings, never a mutable primary balance.

43.3.5 Per-posting description

Each posting carries an optional free-text `description` (narration), bounded at 256 characters in both the domain and a database `CHECK`. It appears on every posting in requests and responses, including statement entries.

43.3.6 Server now owns its database, with startup migrations

`cmd/server` reads `DATABASE_URL` (required, fail-fast: a ledger API with no database must not serve), opens the tuned pool, and applies the embedded goose migrations on startup before serving. On a single instance this is the simplest correct option: the binary that needs a column also creates it, atomically with the deploy. If the project ever runs more than one instance, the same `goose.Up` moves into a dedicated CI step to avoid a migration race.

Production Postgres runs natively on the VPS (a dedicated database and user, listening on localhost, backed up with `pg_dump`), consistent with the native-binary deploy. This is provisioned out of band before the deploy; see the ops runbook.

43.3.7 Error mapping

Domain errors map to status codes in one helper: not-found to 404, duplicate id to 409, an exhausted serialization conflict to 503, validation and invariant failures to 422, and anything unrecognized to a

500 that does not leak internals.

43.4 Consequences

43.4.1 Positive

- One source of truth for handlers, validation, errors, and the spec; the published docs cannot drift from the running API.
- The API is as exact as the ledger (integer minor units), and statements give a real running balance with stable pagination.
- The transport stays thin: services hold the logic, handlers translate.
- Auth can be added later by changing only how the tenant is resolved.

43.4.2 Negative

- huma owns request decode/encode, so a very custom response shape means working within its model.
- Statement pages cost a scan of the account's posting history while balances stay derived. Accepted for v1; a rollup is the escape hatch.
- The server now hard-depends on Postgres, so the deploy requires the database to be provisioned and `DATABASE_URL` set first.

43.5 Alternatives considered

- **chi + go-playground/validator + hand-written problem+json:** rejected. Reintroduces three concerns huma already covers and

risks spec drift.

- **Spec-first with oapi-codegen:** rejected. Drops the existing human investment (playground, drift test, generator) and makes the spec a hand-maintained artifact, heavy for a solo build.
- **Decimal-string money in JSON:** rejected. Adds parsing and per-currency scale validation at the boundary for no gain over exact integer minor units.
- **Tenant in the URL or a trusted header now:** rejected. Bakes tenancy into the resource model or trusts an unauthenticated header; the default-tenant seam is cleaner to evolve into real auth.
- **Migrations as a separate step now:** deferred. Correct for multi-instance, but premature for a single VPS; startup migrations are simpler today.

CHAPTER 44

ADR-007: Idempotency Keys and the Immutable Audit Log

44.1 Status

Accepted: 2026-07-02

44.2 Context

Through Week 5 the ledger had a REST API but no protection against retries. A `POST /v1/transactions` that times out may have already committed: the request reached the server and posted, and only the response was lost. A correct client retries, and without protection that retry posts a second transaction, moving money twice. Week 6 adds an idempotency contract so a retry is safe, and an audit log so every posting leaves a tamper-evident record of what happened.

Both tables (`idempotency_keys`, `audit_log`) were designed in ADR-003 and left for this week; `RunInTx` was called out in ADR-004 as the seam the audit write would use. This ADR records the decisions those earlier ADRs deferred.

Several choices had no obvious default.

44.3 Decision

44.3.1 The idempotency key row is inserted inside the posting transaction

The client sends an optional `Idempotency-Key` header. When present, the key row is inserted into `idempotency_keys` inside the same `SERIALIZABLE` transaction (`RunInTx`) that inserts the transaction, its postings, and the audit row. The primary key (`tenant_id`, `idempotency_key`) is the exactly-once mutex: the first request to commit the key wins, and any concurrent duplicate hits the unique violation, rolls back its whole transaction (so its optimistically written postings vanish too), and replays.

This was chosen over the obvious check-then-act approach (look the key up, and if absent, post). Check-then-act has a race: two concurrent copies of the same request both read “key absent,” both post, and both create a transaction. The bug only appears under concurrency, which is exactly when retries happen. Making the check and the write one atomic step requires the database as the referee; the unique primary key is that referee, so no application lock or separate idempotency service is needed.

`InsertIdempotencyKey` maps the PK collision (constraint `idempotency_keys_pkey`) to an internal `ErrDuplicateIdempotencyKey`. `TransactionService.Post` catches it (only when a key was supplied), reads back the committed row, loads the original transaction, and returns it with `replayed = true`, which the API surfaces as the `Idempotent-Replayed` response header. Because Postgres blocks the second insert until the first transaction resolves, the loser’s follow-up read always sees the committed winner;

there is no visibility gap.

44.3.2 A request fingerprint distinguishes a retry from key reuse

The stored key row holds a fingerprint of the original request: `Transaction.Fingerprint()`, a SHA-256 over the currency and each posting's account, signed amount, and description, in order, with the transaction id excluded. On a repeat, a matching fingerprint is a genuine retry and gets the replay; a different fingerprint means the client reused a key for a different payment, and the service returns `ErrIdempotencyConflict`, mapped to HTTP 409.

The fingerprint length-prefixes each field rather than joining with a separator byte. A separator scheme is forgeable when a field can contain that byte: two different transactions could be crafted to collide, and a collision on a reused key would let a different payment through as a “replay.” Fixed-width length prefixes make field boundaries impossible to fake regardless of content.

44.3.3 The idempotency key is optional, not required

An absent header posts normally, exactly as before Week 6. This keeps the change backward compatible (the console and seeder callers are unaffected) and matches common payment APIs where the key is recommended but not mandatory. A keyless post is still audited.

44.3.4 The audit log is written in the same transaction and is create-only

Each posted transaction writes one `audit_log` row inside the same `RunInTx` closure as the postings: `action = transaction.created`, before `NULL`, after a JSON snapshot of the transaction, `actor` the tenant id (until `auth` lands). Because the audit insert shares the transaction, a posting and its audit record commit together or roll back together; there is no separate “log it later” step that could fail on its own and leave a transaction nobody recorded. On the replay path the transaction rolled back and no new posting happened, so no audit row is written: the log records only real creations.

It is deliberately create-only. Postings are append-only, so there is no in-place update to `diff`; a generic before/after framework would be speculative (`before` stays `NULL` for `now`).

44.3.5 Append-only is enforced by a database trigger, with one gated exception

A trigger on `audit_log` rejects `UPDATE` and `DELETE` (`BEFORE UPDATE OR DELETE ... FOR EACH ROW`), so the log is immutable even against a direct `DELETE FROM audit_log` in `psql`, not just by application convention. This is the same defense-in-depth pattern as the balance and currency triggers (ADR-004, ADR-005).

The one sanctioned exception is the demo seeder, which resets the tenant every few hours and must clear the log. The trigger allows the mutation only when the transaction-local GUC `audit.allow_purge` is set

to on; the seeder sets `SET LOCAL audit.allow_purge = 'on'` at the start of its reset transaction. `SET LOCAL` is transaction-scoped, so it cannot leak to other pooled connections, and the application's normal path never sets it, so production stays immutable.

44.3.6 Audit reads: by transaction unpaginated, by account keyset-paginated

`GET /v1/transactions/{id}/audit` returns a transaction's audit rows unpaginated, because a transaction has a fixed, tiny number of them. `GET /v1/accounts/{id}/audit` reuses the Week 5 keyset cursor on `(created_at, id)`, because an active account can accumulate a row for every transaction that ever touched it, and an unbounded query is a memory and latency risk on a real account. The by-account query joins `audit_log` to the account's postings and is tenant scoped on both the outer table and the subquery.

44.4 Consequences

44.4.1 Positive

- Retrying a payment is safe: 100 concurrent requests with the same key create exactly one transaction and one audit row, verified by an integration test that runs the real race against Postgres.
- Exactly-once needs no distributed lock or idempotency service; a unique constraint inside the existing transaction does it.
- Every posting leaves an immutable, transactionally-consistent audit

record that the database itself refuses to alter.

- The change adds no API surface that can be misused: the key is optional and the audit reads are bounded.

44.4.2 Negative

- The idempotency key table grows without bound in v1 (no TTL or expiry); the demo seeder clears it on reset, and real retention is a later concern.
- The audit after snapshot duplicates data already in the postings; accepted, as the point of an audit log is a self-contained record.
- The immutability trigger's gated branch currently permits any mutation (not just DELETE) when the GUC is set; only the seeder's DELETE uses it today, so a gated UPDATE would silently no-op. Tracked as a follow-up (fail closed on UPDATE).
- Replay and conflict paths are counted (`IdempotencyReplays`, `IdempotencyConflicts`) but not timed in the `PostDuration` histogram.

44.5 Alternatives considered

- **Check-then-act idempotency (look up, then post):** rejected. Races under concurrent retries and creates duplicate transactions exactly when it matters.
- **A separate idempotency middleware with its own table and short transaction:** rejected. The key insert would not share the posting's transaction, reopening a window where the posting commits but the key does not (or two requests both proceed); keeping the mutex inside the posting transaction is simpler and strictly

correct.

- **Required idempotency key:** rejected for v1. A breaking change to the existing contract and to the console and seeder callers, for a guarantee clients can opt into per request.
- **Fingerprint by hashing the raw request body:** rejected. Whitespace, key order, or an echoed id would make identical payments look different and break the replay; hashing the semantic content is stable.
- **Separator-byte fingerprint framing:** rejected. Forgeable when a field can contain the separator, allowing a collision on a reused key; length-prefixing is collision-safe.
- **Audit log immutability by convention only:** rejected. A trigger enforces it at the database, consistent with the ledger's other invariants, so a buggy caller or a bad migration cannot rewrite history.
- **Generic before/after audit framework now:** deferred. Nothing mutates in place, so create-only with a NULL before is enough; a diff model is speculative.
- **Unpaginated by-account audit read:** rejected. Fine for the demo, but an unbounded query is a production memory and latency risk; keyset paging matches the statement endpoint.

CHAPTER 45

ADR-008: Covering Index for Account History Reads

45.1 Status

Accepted: 2026-07-02

45.2 Context

ADR-006 documents that the account statement is $O(\text{history})$ per page: because balances are derived, never stored (ADR-003), the running-balance window scans the account's full posting history within a single index range on `(tenant_id, account_id)`, the two-column `postings_tenant_account_idx` from `0001_initial.sql`. ADR-007 added a second reader on the same shape: `GET /v1/accounts/{id}/audit` keyset-pages `(created_at, id)` through a join from `audit_log` to the account's postings.

Both queries filter on `(tenant_id, account_id)` and then need their rows ordered by `(created_at, id)`: the statement to return newest-first pages with a correct running balance, the audit-by-account read to keyset-page in the same order. The two-column index covers the filter but not the order, so Postgres has to sort every page's matched rows after the index range scan. On a busy account this sort runs on every single

page request, competing for the one CPU core the production VPS has.

A coverage/capacity audit flagged this as the read-side gap most likely to show up first as the demo tenant's ~285 seeded transactions grow, and it is cheap to close without touching query text or the derived-balance model.

45.3 Decision

Migration 0007 replaces `postings_tenant_account_idx (tenant_id, account_id)` with `postings_tenant_account_created_idx (tenant_id, account_id, created_at, id)`.

The composite's leading two columns, `(tenant_id, account_id)`, still serve the balance `SUM` and any other equality-only lookup, exactly as the old index did. The trailing `(created_at, id)` means an index range scan on the tenant/account prefix already returns rows in the exact order the statement and audit-by-account queries need, so Postgres can walk the index directly into a page of results instead of scanning then sorting. No `sqlc` query text changes: the SQL was already selecting and ordering by these columns, it was just the index that did not match.

The old two-column index is dropped in the same migration. Every query that could use it can use the composite's leading prefix instead, so keeping both would only add write-side index maintenance for no read benefit.

This does not change what is derived versus stored. Balances are

still computed by summing postings at read time; the index removes the per-page sort, it does not cache or materialize a balance. The $O(\text{history})$ scan cost ADR-006 already accepted is unchanged: this is a narrower fix for the sort that sat on top of it.

45.4 Consequences

45.4.1 Positive

- Statement and audit-by-account pages no longer sort after the index scan; the index range scan already returns rows in the order the query needs.
- No application or query-text change: `internal/postgres` and its `sqlc` queries are untouched, only the schema.
- One index does the work of two: the composite serves every read the old two-column index served, plus the ordered scans, at one index's write cost instead of two.

45.4.2 Negative

- The composite index is wider than the one it replaces (two extra columns per entry), so it costs slightly more to maintain per insert. On the production box's single core and 1GB of memory this is a small but real addition to write-side work; accepted, since posting throughput is not the bottleneck the audit flagged.
- Still $O(\text{history})$ per page in the sense that the scanned range grows with an account's full posting count, even though it is no longer

sorted. A genuinely unbounded account still needs the materialized-rollup escape hatch ADR-006 already named, not another index.

45.5 Alternatives considered

- **Keep both indexes:** rejected. The two-column index becomes fully redundant once the composite exists (same leading prefix), so this would just pay index maintenance twice for the same set of queries.
- **Materialized running balance, rebuilt from postings:** deferred. This is the actual escape hatch ADR-003 and ADR-006 already named for when $O(\text{history})$ itself becomes the problem, not just the sort on top of it. Out of scope for this change: it would introduce a second, cached number that has to reconcile with the postings, which is the exact drift ADR-003 rejected a mutable balance column to avoid. Revisit only if index-scan cost itself, not the sort, becomes the bottleneck.
- **Do nothing:** rejected. Leaves an unbounded per-page sort competing for the single core on every statement and audit-by-account request, and the fix is a single, low-risk, additive migration.

CHAPTER 46

ADR-009: gRPC Layer over the Shared Domain

46.1 Status

Accepted: 2026-07-02

46.2 Context

Through Week 6 the ledger exposed one network surface: the REST API on chi + huma (ADR-006). Week 7 adds a gRPC front door. The point is not gRPC for its own sake: it is to prove that the domain services built in Weeks 2 to 6 are transport agnostic, so REST and gRPC are two thin adapters over one source of truth rather than two implementations that drift apart. This is only cheap because ADR-006 already made the handlers thin: they translate and delegate, and all logic lives in the `ledger` services.

The build plan flags Week 7 as heavy with scope-creep risk, and says to ship REST-only if it slips. Several choices had no obvious default.

46.3 Decision

46.3.1 Standard `grpc-go`, not `ConnectRPC`

The server uses `google.golang.org/grpc` with `protoc-gen-go` and `protoc-gen-go-grpc`, generated by `buf`. It is gRPC only (no HTTP/JSON on the same handler), works with `grpcurl` through server reflection, and takes unary interceptors, which matches the plan's wording ("gRPC server with interceptors").

`ConnectRPC` (`connect-go`) was the main alternative: it serves gRPC, gRPC-Web, and HTTP/JSON on one port and is curlable with plain `curl`. It is elegant and `buf`-native, but it is a larger opinionated dependency and a different server model than the plan describes, and REST already covers the HTTP/JSON case. Standard `grpc-go` is the boring, widely-understood choice, which is what this project wants for infrastructure decisions.

46.3.2 `buf` for proto management, remote plugins, generated code under `internal/`

`buf` is a locked stack decision. `buf.gen.yaml` uses `buf` remote plugins (`buf.build/protocolbuffers/go`, `buf.build/grpc/go`) with managed mode, so `buf generate` needs no local `protoc` and is reproducible on any machine and in

CI. Proto sources live in `proto/ledger/v1/`; generated Go lands in `internal/genproto/ledger/v1/`. Placing it under `internal/` keeps the generated types unimportable outside the module while the in-repo Go client

example, being in the same module, can still import them. `make proto` runs `buf lint` then `buf generate`, and regenerating must produce no diff.

46.3.3 Go server and Go client only for v1

The plan literally lists Go, Node, and Python clients. Only the Go server and Go client are generated now. The definition of done needs only `grpcurl` and a working Go client example; generating and actually verifying Node and Python toolchains triples the smoke-test surface in a week already flagged heavy. Node and Python are a later `buf.gen.yaml` change, documented, not built now. This is a direct application of the plan's own scope warning.

46.3.4 Full REST mirror of the RPC surface

`LedgerService` exposes the same operations as REST: `CreateAccount`, `GetAccount`, `ListAccounts`, `GetBalance`, `GetStatement`, `PostTransaction`, `GetTransaction`, plus the two audit reads. Both protocols cover the same domain, which is the point of the shared-domain refactor. The audit RPCs are the first cut if the week slips, then the health service; the seven core RPCs are the DoD. Messages mirror REST exactly: `int64` amount plus `string` currency, signed postings that sum to zero, and the same opaque keyset cursor for statements.

46.3.5 Thin gRPC handlers over the unchanged ledger services

`internal/grpcserver` implements the generated `LedgerServiceServer` by translating proto to domain, calling the same ledger services the REST layer uses, and translating back. The domain and the services do not change. Domain errors map to gRPC status codes in one `toStatus` helper, mirroring `toHumaErr`: not-found to `codes.NotFound`, a duplicate or idempotency conflict to `codes.AlreadyExists`, validation and invariant failures to `codes.InvalidArgument`, an exhausted serialization conflict to `codes.Unavailable`, and anything unrecognized to `codes.Internal` without leaking internals.

46.3.6 A separate gRPC port with the same graceful-shutdown treatment

gRPC listens on its own port (`GRPC_ADDR`, default `:9091`), separate from REST (`:8080`) and metrics (`:9090`), added as a third serving goroutine with its own `GracefulStop` under the existing `SIGTERM` handling. Single-port multiplexing (cmux or h2c) was rejected: it adds connection-muxing complexity and muddies the clean split between HTTP/1.1 (chi) and HTTP/2 (gRPC) for no benefit on a single VPS.

46.3.7 Interceptors now, tracing deferred to Week 8

Chained unary interceptors: recovery (panic to `codes.Internal`), slog request logging (mirrors the REST middleware), and a tenant interceptor that injects the default tenant into the context (the same seam

as REST; real auth later replaces only this). Server reflection is registered so `grpcurl` works, and the standard gRPC health service reports `SERVING`. A tracing interceptor is deliberately deferred: OpenTelemetry is Week 8's scope. A clean interceptor seam is left, with no tracing code now.

46.3.8 Idempotency parity through metadata

`PostTransaction` reads an `idempotency-key` from the incoming gRPC metadata, mirroring the `REST Idempotency-Key` header, and threads it into the same `TransactionService.Post`. The response carries a typed `bool` `replayed`, the equivalent of the `REST Idempotent-Replayed` header. This is cheap parity because the service already supports idempotency.

46.4 Consequences

46.4.1 Positive

- One domain, two transports: REST and gRPC call the identical services, so they cannot drift, and the shared-domain claim is demonstrated, not asserted.
- `grpcurl` and a generated Go client both exercise the running service, satisfying the DoD, with reflection and a health check for easy operation.
- The write path keeps every guarantee it already had (exactly-once idempotency, atomic audit, `SERIALIZABLE` posting) because gRPC reuses the same service.

- Adding a second serving goroutine on its own port keeps the deploy and shutdown model unchanged.

46.4.2 Negative

- A second network surface to run, secure, and eventually observe. The tracing gap is explicit and closes in Week 8.
- Generated code is a new build input; `make proto` and a no-diff check must stay green, and the `buf remote-plugin fetch` needs network at generate time (not at build or run time).
- gRPC is unauthenticated for now, same as REST, guarded only by the default tenant and the VPS network posture.

46.5 Alternatives considered

- **ConnectRPC (connect-go)**: rejected for v1. One-port gRPC plus HTTP/JSON is attractive, but it is a larger opinionated dependency and a different model than the plan, and REST already serves the HTTP/JSON case.
- **Node and Python clients now**: deferred. The DoD needs only `grpcurl` and a Go client; three toolchains is the scope creep the plan warns about. A later `buf.gen.yaml` change adds them.
- **Single-port multiplexing (cmux / h2c)**: rejected. Adds complexity and blurs the HTTP/1.1 vs HTTP/2 split for no gain on one box; a separate port is simpler.
- **Local protoc instead of buf remote plugins**: rejected. Remote plugins keep `buf generate` hermetic and machine-independent, consistent with the locked `buf` decision.

- **Idempotency key as a request field instead of metadata:** rejected. Metadata mirrors the REST header semantics (a cross-cutting request attribute, not part of the transaction body), keeping the two protocols' contracts aligned.
- **A tracing interceptor now:** deferred to Week 8, which owns OpenTelemetry; a seam is left so it drops in without reshaping the chain.

CHAPTER 47

ADR-010: Observability with OpenTelemetry

47.1 Status

Accepted: 2026-07-07

47.2 Context

Through Week 7 the ledger had two network surfaces (REST on chi, gRPC) and two observability signals that did not talk to each other: native Prometheus metrics on a loopback `/metrics` server (ADR-004), and structured slog lines with a chi request id but no trace context. ADR-009 deliberately left a clean interceptor seam and deferred tracing to this week.

Week 8 closes that gap. The definition of done: a single transaction post produces one distributed trace spanning HTTP or gRPC, the domain service, and the SQL round-trips, with every log line for that request carrying the same `trace_id`. Traces run to Jaeger locally and to Honeycomb's free tier remotely.

The build plan flags this as a heavy week with an OpenTelemetry-

config rabbit hole risk, and says to time-box to eight hours and ship slog-correlation plus Prometheus RED (the Rate, Errors, and Duration metrics for each endpoint) if the remote export fights back. Several choices had no obvious default, and one early instinct (route every metric through OpenTelemetry) turned out to be the wrong call for a service that already has metrics tied to alerting baselines.

47.3 Decision

47.3.1 Hybrid metrics: native domain collectors, OTel meter for RED

The four existing domain collectors stay exactly as they are, native `client_golang` on the dedicated registry, with their current names: `transaction_post_duration_seconds`, `transaction_post_serialization_retries_total`, `transaction_idempotency_replays_total`, `transaction_idempotency_conflicts_total`. These are SLO metrics tied to the Week 4 latency baselines. Renaming them is how you silently break an alert and find out during an incident, so they do not move.

The Rate, Errors, Duration signals for the two transports come through the OpenTelemetry metric API instead: `otelhttp` emits `http.server.request.duration` and `otelgrpc` emits `rpc.server.duration`, both with status attributes that give rate and errors for free. Those flow through an OTel `MeterProvider` whose Prometheus exporter is registered into the same registry the native collectors use, so `/metrics` stays a single loopback endpoint. Runtime instrumentation is not enabled on the OTel side: the existing `NewGoCollector` and `NewProcessCollector` remain

the only source of `go_*` and `process_*`, avoiding a double registration.

The rejected alternative was routing all metrics through OpenTelemetry. It buys a single metric API, but the OTel Prometheus exporter mangles output (unit suffixes, `otel_scope_*` labels, a `target_info` series) and would have renamed the alert-bearing metrics for no operational gain. The hybrid keeps the invariant-critical metrics stable and still gets unified RED. A one-API purity win was not worth breaking working alerts in a payment service.

47.3.2 Tracing exporter selected by environment, loud when misconfigured

One tracer setup, three modes chosen at startup:

- `OTEL_EXPORTER_OTLP_ENDPOINT` set: an OTLP/HTTP exporter (`otlptracehttp`), which reads the standard OTLP environment variables for endpoint and headers. This is the only mode used in production and against Jaeger.
- Endpoint unset but `OTEL_TRACES_EXPORTER=console`: a stdout exporter, for eyeballing spans in local development without running a collector.
- Neither set: a no-op tracer and one `warn` log line at startup.

The stdout exporter is opt-in, not the silent default. On the VPS a missing or misconfigured endpoint must be a loud no-op, not a flood of span JSON dumped into the same stdout stream the logs are correlated on. OTLP/HTTP over gRPC because it is the lower-ops choice, firewall-friendly, and Honeycomb-native; the app already runs a gRPC server, so an OTLP/gRPC exporter would not be exotic, but there is no payoff over HTTP here.

47.3.3 Head sampling, and the noise paths excluded

The sampler is `ParentBased` with the root sampler read from the standard `OTEL_TRACES_SAMPLER` and `OTEL_TRACES_SAMPLER_ARG` variables, defaulting to always-on for local development. Production sets a ratio (documented as `parentbased_traceidratio` at 0.25) because the demo seeder writes about 285 transactions every four hours, each fanning out to per-query DB spans under `SERIALIZABLE` retries, and Honeycomb's free tier is twenty million events a month. Always-on plus that write volume burns the budget on demo noise.

Two classes of span are dropped regardless of sampler: health and metrics requests are filtered out of HTTP tracing (`otelhttp WithFilter` on `/healthz`, and the loopback metrics server is not wrapped at all), so traces are real request work and not a wall of health checks.

47.3.4 Spans at four layers, no money or PII in attributes

- HTTP: the chi router is wrapped with `otelhttp`; a small middleware upgrades the span name to the matched chi route pattern (not the raw path) so URL cardinality cannot explode the trace backend.
- gRPC: `otelgrpc.NewServerHandler` is added as a `StatsHandler` alongside the existing interceptor chain from ADR-009, which stays unchanged.
- Domain: `TransactionService.Post` and the key `AccountService` reads open manual spans. Failure paths call `RecordError` and set an error status, and the double-entry invariant rejection from `Transaction.Validate()` is recorded as a span error, because that is the event a reviewer actually wants to find.

- Database: `otelpgx` is the pool query tracer, one span per SQL statement.

Span attributes are restricted to safe identifiers: `tenant_id`, `transaction_id`, posting count, and whether an idempotency key was present. No amounts, no balances, no account identifiers as values, and `otelpgx` runs with query arguments off so bind values never leave the process. Honeycomb is a US SaaS processor, and shipping customer financial metadata to a third party is a decision that needs to be made on purpose, not leaked through a default. For a demo and portfolio service the rule is simply: identifiers and counts, never money.

47.3.5 Logs correlate through a wrapping slog handler

A thin `slog.Handler` wraps the existing JSON handler. On each record it reads the active span context and, when valid, injects `trace_id`, `span_id`, and a `sampled` flag, so every line logged with a request context correlates to its trace. It delegates `WithAttrs` and `WithGroup` to the inner handler and rewraps, so grouped and pre-attributed loggers keep working. This is a dozen lines and no new dependency.

The rejected alternative was the `otel slog` bridge, which turns log records into OTel log records shipped over OTLP. That is remote log export, a signal this week does not ship and the plan does not scope. The goal is correlation, not a third pipeline.

47.3.6 Service version from build info, not a hand-set string

The trace Resource carries `service.name`, `service.version`, and `deployment.environment`. The version is read from `runtime/debug.BuildInfo` (the VCS revision the binary was built from) rather than a hand-maintained constant, so every trace can be attributed to a release without a manual bump. The CI pipeline builds from a checked-out commit, so the revision is populated.

47.4 Consequences

47.4.1 Positive

- One transaction post yields one linked trace across transport, service, and SQL, and its log lines carry the same `trace_id`: the definition of done, verifiable in Jaeger locally and Honeycomb remotely.
- The alert-bearing domain metrics keep their exact names, so nothing built on the Week 4 baselines breaks, while RED for both transports arrives for free through the instrumentation libraries.
- Tracing is off by default with no endpoint, so local development and the VPS run clean without a collector, and a misconfiguration is a loud no-op rather than a silent log flood.
- No money, balances, or bind values leave the process, so enabling a third-party backend does not quietly export financial data.

47.4.2 Negative

- Two metric APIs now coexist: native `client_golang` for the domain metrics and the OTel meter for RED. That is a deliberate trade of purity for stability, and it means a contributor sees both styles in the codebase.
- OpenTelemetry adds several dependencies (`otel/sdk`, the OTLP/HTTP and stdout trace exporters, the Prometheus metric exporter, `otelgrpc`, `otelpgx`) and a startup path that must be shut down cleanly within the existing graceful-shutdown budget so a batch exporter flush cannot hang termination.
- Span attributes are deliberately thin. Anyone wanting richer trace data must first decide what is safe to send to a third party, which is friction by design.

47.5 Alternatives considered

- **All metrics through OpenTelemetry:** rejected. It renames alert-bearing SLO metrics and adds `target_info` and `otel_scope_*` noise for a single-API win that does not pay for breaking working alerts. Hybrid keeps the domain metrics native and still unifies RED.
- **stdout as the silent no-endpoint default:** rejected. A misconfigured endpoint in production would dump span JSON into the correlated log stream. Console export is opt-in; the real default is a loud no-op.
- **OTLP over gRPC (port 4317):** not chosen. HTTP/protobuf is the lower-ops, firewall-friendly path and Honeycomb-native; running gRPC elsewhere does not make it the better exporter here.

- **Always-on sampling:** rejected for production. The seeder plus per-query DB spans would exhaust the Honeycomb free tier on demo traffic; a parent-based ratio plus dropping health and metrics paths keeps the signal and the budget.
- **otel slog log bridge:** deferred. It ships logs over OTLP, a signal this week does not export. A wrapping handler gives the correlation the definition of done asks for without a new pipeline.
- **otelchi for route-named HTTP spans:** not adopted. A few lines of chi middleware over the already-present `otelhttp` set the route pattern without another dependency.

ADR-011: Testing strategy: unit, property, integration, chaos, load

48.1 Status

Accepted: 2026-07-07

48.2 Context

Through Week 8 the ledger accumulated tests package by package as each feature landed: table-driven unit tests in `internal/domain`, test-containers-backed integration tests against real Postgres in `internal/postgres` and `internal/ledger`, a stress test that throws concurrent transactions at the service, and one property test on the balance invariant. What it did not have was a strategy: a stated coverage bar, a way to enforce it, a load profile with a number attached, or any test that asks what happens when Postgres dies in the middle of a commit.

Week 9 is the testing week. The definition of done from the build plan is CI green on a clean push and a load test that sustains 500 RPS at p99 under 100ms locally. That is the visible target. The harder and more valuable goal is that the test suite actually protects the money invariant under the conditions that break payment systems in pro-

duction: concurrency, partial failure, and retries after an ambiguous outcome.

Coverage percentage is a weak proxy for that. Eighty percent line coverage on a ledger can miss every branch that matters (rollback, overflow, currency mismatch, double-post on retry) while padding the number with getters. So the decisions here are less about hitting a percentage and more about which invariants get tested and how the failure injection stays deterministic instead of flaky. A flaky chaos test or a load test that secretly measures the wrong path is worse than none: both ship a false “tested” signal, which is the last thing a payment service wants.

48.3 Decision

48.3.1 A five-layer test pyramid, each layer with a distinct job

- **Unit** (fast, no Docker): domain types, money arithmetic, API and gRPC error mapping, paging cursors. Table-driven. These already dominate the suite and stay the default.
- **Property** (fast, no Docker, pgregory.net/rapid): invariants that must hold across a large input space, not just hand-picked cases. See below.
- **Integration** (Docker via testcontainers): the service and repository against real Postgres, so the schema, triggers, CHECK constraints, and SERIALizable retry behaviour are exercised, not mocked.
- **Chaos** (Docker via testcontainers plus toxiproxy): partial-failure

behaviour when the database connection dies mid-transaction. See below.

- **Load** (k6 against a Compose stack): throughput and tail latency under sustained traffic, in two contention profiles.

48.3.2 Coverage: an 80% global floor, higher on the money path, generated code excluded

The gate is enforced by a `make cover` target and run in CI. It fails the build below the floor rather than only reporting a badge, because a coverage number no one blocks on is a number that silently rots.

The global floor on `internal/` is 80%. The money-critical packages carry higher per-package floors, because that is where a missed branch costs real money: `internal/domain` at 90%, `internal/ledger` at 85%, `internal/postgres` at 80%. Transport and plumbing packages (`grpcserver`, `api`, `metrics`) count toward the global floor but do not carry their own higher bar.

Generated code is excluded from the measurement: `internal/genproto` (protoc output) and `internal/postgres/sqlc` (sqlc output). Testing generated code measures the generator, not our work. The mechanics matter and are easy to get wrong: the target emits a single merged coverage profile from one `go test ./internal/... -coverprofile` run, strips the generated paths out of the profile file, then reads the statement-weighted total from `go tool cover -func`. Averaging per-package percentages would be a lie, because it weights a 20-line package the same as a 2000-line one.

48.3.3 Property tests target invariants, not just `Validate()`

The existing property test checks that `Transaction.Validate()` accepts a balanced set and rejects an unbalanced one. That is the easy part. Three more properties carry the real weight:

- **Money round-trip and bounds:** minor-unit `int64` amounts survive string-to-value-to-string round-trips, addition does not overflow silently, and zero and negative amounts are rejected where the domain forbids them. Money representation bugs are the classic ledger failure, so they get direct randomized coverage.
- **Stateful model check** (rapid state machine): a random sequence of transactions is applied, and after every step two invariants hold: each account balance equals the sum of its own postings, and the signed total across all accounts is zero. This catches an error that unit tests structurally cannot: a sequence of individually valid operations that corrupts the aggregate.
- **Concurrency invariant:** many goroutines post concurrently and the sum-of-postings invariant still holds with no lost updates, run under `-race`.

48.3.4 Chaos uses toxiproxy for deterministic injection, and covers the ambiguous-commit case

Killing the Postgres container with `docker kill` at the right instant is timing racy and slow: you usually land after the commit or before the write is in flight, and then the test proves nothing while still occasionally going red on

CI. Instead a toxiproxy container sits between the app and Postgres, and the test cuts the connection at a controlled point. That is repeatable, fast, and needs no image restart.

Two distinct failures are tested, because they have different correct outcomes:

1. **Connection lost after BEGIN, before COMMIT:** the post must fail and roll back cleanly, leaving zero partial postings. The append-only invariant means a half-written transaction is not allowed to exist.
2. **Connection lost after COMMIT is sent but the acknowledgement is lost:** the client cannot tell whether the transaction committed. This is the scenario that loses money, because the natural client reaction is to retry. The test replays the same idempotency key and asserts exactly one transaction exists, not two.

This also pins down an invariant the integration tests take for granted: the idempotency-key write and the transaction commit are one atomic database transaction. If they were separate, a crash between them would either double-post or wedge the key, and the ambiguous-commit test is what would catch a regression that split them.

48.3.5 Load: two contention profiles, unique keys, durability left on

The k6 script runs against a Compose stack (Postgres plus the app plus the existing Jaeger) under a dedicated `load-test` profile. Two scenarios, because they measure different ceilings:

- **Fan-out:** transactions spread across many accounts. This mea-

sures raw write throughput with minimal row-lock contention, the number the 500 RPS target is about.

- **Hot account:** many transactions against one account. This serializes on the per-account row lock and is where p99 blows up. The service already has a hot-account path; the load test exercises it on purpose rather than pretending contention does not happen.

Two rules keep the load test honest:

- **Every request carries a unique idempotency key**, with a small deliberate slice of duplicates mixed in. Without this the test would hammer the idempotency short-circuit (a cheap replay lookup) and report a throughput number for the wrong code path.
- **Durability stays on.** p99 on a laptop is dominated by fsync latency, and the tempting way to hit 100ms is to turn off `synchronous_commit`. On a ledger that is cheating: it trades the durability guarantee for a benchmark number. The target is reported as machine-dependent, measured with durability intact, not treated as a hard SLO.

The `load-test` Compose profile sets `SEED_ENABLED=false`. The demo seeder resets the demo tenant every four hours and would collide with a load run, so the load test uses its own tenant against a stack with the seeder off.

48.3.6 CI: parallel test jobs, a non-gating smoke-load, deploy unchanged in intent

The existing `deploy.yml` runs one test-and-lint job before deploy. Week 9 splits the pre-deploy work into jobs that run in parallel rather than chained, so a PR is not paying for artificial serialization:

- `lint`: `golanci-lint`.
- `test`: the race-enabled suite plus the `make cover` gate. This one job runs the unit, property, integration, and chaos tests together, because the suite is not separated by build tags: the integration and chaos tests skip themselves when no Docker is present and run for real when it is. The GitHub runner has Docker, so the full suite runs and coverage reflects the real numbers. The `testcontainers` tests wait on the Postgres readiness log ("ready to accept connections" seen twice), not on the port opening, because port-open races with the `initdb` restart and produces connection resets on CI. Splitting unit from integration would mean either running the suite twice or inventing build tags the codebase does not use, so one honest `test` job is the better trade. The coverage profile is scoped to `internal/` only: `cmd/main.go` is wiring with no unit tests, and folding its zero into the number would drag the gate down for no signal, so `cmd/` is compiled and `smoke-run` as a build check but kept out of the coverage measurement.
- `smoke-load`: boots the Compose stack and runs a short low-RPS k6.

`deploy` needs `lint` and `test`, and still only runs on a push to `main`. PR test runs get their own cancelable concurrency group so a force-push cancels the stale run; the `deploy` concurrency group keeps `cancel-in-progress: false` so a release is never interrupted mid-flight.

The `smoke-load` is deliberately not gated on the 500 RPS or 100ms figures, which are laptop numbers and would flake on a shared runner. It is gated on the regression signals that are stable across machines: a zero error rate and a loose p99 ceiling (around 500ms). That catches a server that fell over or a ten-times latency regression without going red because a CI runner was slow.

48.3.7 Badges without a standing credential

The coverage badge is produced by writing a shields.io endpoint JSON to a dedicated `badges` branch using the built-in `GITHUB_TOKEN`, and pointing shields at the raw file. This avoids a long-lived personal access token with gist scope sitting on a public repository: the built-in token is scoped to the run and needs no manual secret. The Go Report Card badge is a plain URL to `goreportcard.com`, which generates on first request and needs no setup.

48.4 Consequences

48.4.1 Positive

- Coverage is enforced, not decorative, with a higher bar where money moves and generated code excluded so the number reflects hand-written work.
- The invariant that defines the whole service is checked across a large random input space, including the aggregate-over-a-sequence case that example tests miss, and under concurrency with the race detector.
- The two failure modes that actually lose money in a payment system, a rollback after mid-transaction failure and a double-post after an ambiguous commit, have explicit deterministic tests rather than a hope that it works.
- The load test measures the real write path in both the throughput and the contention regime, with durability intact, so the number means something.

- CI stages run in parallel with a stable, non-flaky load gate, and the coverage badge needs no third-party account or standing token.

48.4.2 Negative

- Two more infrastructure dependencies enter the test path: toxiproxy for chaos injection and a fuller Compose stack plus k6 for load. Both are Docker-gated and skip cleanly when Docker is absent, but they lengthen a full local run.
- Per-package coverage floors add friction: a change that drops `internal/ledger` below 85% fails CI even if the global number is fine. That is the intended pressure, but it is pressure.
- The load numbers are machine-dependent and not a portable SLO, so the DoD figure is a local measurement, not a guarantee that holds on a different box.
- toxiproxy is one more container image to pull and pin, and the ambiguous-commit test depends on injecting failure at a precise protocol point, which is more intricate than a plain integration test.

48.5 Alternatives considered

- **`docker kill` for chaos injection:** rejected. Timing-racy and slow, it usually fires before the write or after the commit and proves nothing, while still flaking on CI. toxiproxy cuts the connection at a controlled point, repeatably and without an image restart.
- **Testing only the pre-commit failure:** rejected as incomplete. The ambiguous-commit case (commit sent, acknowledgement lost, client retries) is the one that double-posts, so it is the case worth

writing.

- **A flat 80% coverage floor with no per-package bar:** rejected. It lets the money-critical packages sit at the floor while transport code carries the average. Higher floors on `domain`, `ledger`, and `postgres` put the pressure where a missed branch costs money.
- **Averaging per-package coverage percentages:** rejected as arithmetically wrong. It weights a tiny package equally with a large one. A single merged, statement-weighted profile is the honest number.
- **Load testing with a fixed idempotency key or a single account:** rejected. Fixed keys measure the replay short-circuit, and a single account measures only the contended path. Unique keys plus both a fan-out and a hot-account scenario measure the real write path and the real tail.
- **Relaxing `synchronous_commit` to hit the latency target:** rejected outright. It trades durability for a benchmark number, which is not a trade a ledger makes.
- **Gating the smoke-load on the 500 RPS / 100ms figures:** rejected. They are laptop numbers and would flake on shared CI. Gating on zero errors and a loose p99 ceiling catches real regressions without machine-dependent flakiness.
- **A gist-plus-PAT coverage badge (`schneegans/dynamic-badges-action`):** rejected. It puts a long-lived gist-scoped personal access token on a public repo. Writing the badge JSON to a `badges` branch with the built-in `GITHUB_TOKEN` needs no standing secret.
- **Codecov for coverage:** not adopted. It adds an external SaaS dependency and a token for a portfolio repo whose whole ethos is self-hosted and dependency-light. A self-computed badge fits better.

ADR-012: API authentication, mandatory idempotency, input hardening, and a tamper-evident audit chain

49.1 Status

Accepted: 2026-07-08

49.2 Context

A security and correctness audit of the service (performed against the premise “assume real money flows through this”) found the accounting core sound but the service perimeter wide open. The double-entry invariant is enforced twice, money is integer minor units with no float, balances are derived from immutable postings, and posting is atomic under `SERIALIZABLE` with a correctly-scoped idempotency mutex. None of that is the problem. The problem is everything in front of it.

The audit’s top five findings:

1. **No authentication or authorization.** Every request acted as a single tenant read from config (`DEFAULT_TENANT_ID`). Anyone who could reach `/v1` could move money and read every balance.

2. **Idempotency was opt-in.** A client that omitted the `Idempotency-Key` header and retried after a dropped response would double-post.
3. **Unbounded input.** The `postings` array had a minimum but no maximum, and there was no request body-size limit, so one request could become an enormous transaction.
4. **No rate limiting, incomplete server timeouts.** Only `ReadHeaderTimeout` WAS SET.
5. **The audit log was guarded but not tamper-evident.** An immutability trigger rejected UPDATE and DELETE, but the rows were not cryptographically chained, so a sufficiently privileged database role could rewrite history.

The hard constraint on any fix: the public try-it console at `/console` and the Scalar playground must keep working with no login, and the demo tenant must keep resetting every four hours (see the demo seeder). A naive “require auth everywhere” breaks the demo, which is the point of the public deployment.

This ADR records the decisions that close all five findings while keeping the demo intact.

49.3 Decision

49.3.1 API-key authentication, keys stored hashed in the database

Authentication is a bearer API key: `Authorization: Bearer glk_<random>`. A new `api_keys` table holds one row per key: `id`, `tenant_id`, `name`, `key_hash` (unique), an optional `rate_limit_rpm`, `created_at`, and a nullable `revoked_at`

. Only the SHA-256 hash of the key is stored; the plaintext is shown once at creation and is never recoverable from the database. A leaked database dump does not leak usable keys.

An authentication middleware reads the bearer token, hashes it, looks up an unrevoked row, and puts the resolved `tenant_id` (and the key's rate limit) into the request context. A missing or unknown or revoked key is a 401. To keep the hot path off the database on every request, resolved keys are cached in memory by hash with a short TTL; revocation is therefore effective within that TTL, which is an acceptable trade for a service at this scale.

The tenant is derived **only** from the key. No request field, header, or body can set or override it. That is what makes tenant scoping the authorization boundary: a key for tenant A can only ever act on tenant A, and the composite foreign keys from Week 3 already make a posting into another tenant's account impossible at the database. So "can this principal touch this account?" reduces to "is this account in the key's tenant?", which the schema enforces for free. We deliberately did not add per-account access-control lists: they would be redundant with the tenant foreign keys and add a whole authorization surface for no gain at this scope.

Only `/v1/*` requires a key. Liveness (`/healthz`), the landing page (`/`), the console, the playground, static assets, the OpenAPI documents, and the loopback metrics endpoint stay unauthenticated: they are either public by design or already off the public interface. The gRPC surface moves the same money, so it gets the same key check through its existing interceptor chain (ADR-009), reading the token from request metadata. Leaving gRPC open would make the whole exercise a REST-only speed bump.

49.3.2 A public demo key keeps the console open, with one auth path

Rather than special-case the demo tenant as unauthenticated (two code paths, and a permanently open write surface), authentication is uniform and the demo is reached with a real, low-privilege **demo key**. It is provisioned at startup from `DEMO_API_KEY` (a known, public value with a safe default), scoped to the demo tenant, and carries a tighter rate limit than a normal key. The console and the playground ship it. Exposing it is fine on purpose: it can only touch the demo tenant, it is rate limited, and that tenant is wiped every four hours.

The demo key survives the wipe because the seeder resets tenant **data** (accounts, transactions, postings, audit rows, idempotency keys) and never touches the `api_keys` table. So after each four-hour reset the console keeps working with the same key against a fresh ledger, exactly as before.

49.3.3 Idempotency is mandatory on money-moving POSTs

`POST /v1/transactions` now requires an `Idempotency-Key`; its absence is a 400 with a clear message. We rejected auto-deriving a key from the request fingerprint when the header is missing: that would silently collapse two genuinely separate but identical payments (same accounts, same amount) into one, turning a real second payment into a false replay. Making the client name the key keeps “these are the same request, retried” distinct from “these are two payments that happen to look alike.” The console generates a fresh UUID per post.

49.3.4 Input hardening: bounded arrays, bounded bodies, complete timeouts

The `postings` array gets a maximum (100 legs), and the HTTP handler is wrapped with a request body-size limit, so one request can no longer become an arbitrarily large transaction or exhaust memory before validation. The HTTP server gains the timeouts it was missing: `ReadTimeout`, `WriteTimeout`, and `IdleTimeout`, alongside the existing `ReadHeaderTimeout`, so a slow client can no longer hold a connection open indefinitely.

49.3.5 Per-key rate limiting

Each key is rate limited independently: an in-memory token bucket per key hash, with the limit taken from the key's `rate_limit_rpm` (a default applies when the column is null). Over the limit is a 429 with `Retry-After`. The demo key is set lower; a normal key uses the default; and the local load-test stack provisions a high-limit key so the 500 RPS load test is exercising the ledger, not the limiter. The default is configurable so production and the load stack can differ without code changes.

49.3.6 A per-tenant, tamper-evident audit chain

The audit log gains two columns, `prev_hash` and `row_hash`. Each row's hash is SHA-256 over its own content (tenant, action, transaction id, actor, before, after, `created_at`) plus the previous row's hash, with every field length-prefixed so no field's bytes can be mistaken for a boundary (the same framing the idempotency fingerprint already

uses). `prev_hash` is the previous audit row's `row_hash` **for that tenant**, or a fixed genesis constant for a tenant's first row. The chain is extended inside the same database transaction that posts the ledger transaction, so a committed transaction always leaves the chain consistent, and `created_at` is set by the application (not the database default) so the hash is deterministic and verifiable.

The chain is per tenant, not global, for two reasons: it keeps tenants decoupled, and it means the four-hour demo wipe restarts only the demo tenant's chain from genesis without touching or invalidating any other tenant's history.

A new `GET /v1/audit/verify` endpoint walks the caller's tenant chain oldest first, recomputes every row hash, and returns `{valid, checked, first_break_id}`, so tamper-evidence is not just stored but checkable. This sits on top of, not instead of, the existing immutability trigger: the trigger prevents casual mutation, and the chain detects a privileged rewrite that bypasses it.

49.3.7 Same-tenant posts serialize with an in-process mutex

The audit chain's read-then-insert above is a genuine same-tenant conflict. Every post reads the tenant's latest `row_hash` and then inserts the next row, in the same `SERIALIZABLE` transaction as the ledger posting, so two concurrent same-tenant posts reading the same chain tail is a real read-write antidependency. PostgreSQL aborts the loser with a serialization failure (`SQLSTATE 40001`), and under sustained same-tenant concurrency the repeated abort can exhaust the retry budget (25 attempts) and surface to the caller as a `503`.

We first tried closing this with a per-tenant PostgreSQL session advisory lock (`pg_advisory_lock`), taken on a connection checked out from the pool before the `SERIALIZABLE` transaction began, so a blocked waiter's snapshot was not fixed until the lock holder had committed. A review found this had two problems specific to this service's own configuration, serious enough to replace rather than patch:

1. The connection pool sets `lock_timeout` to 3 seconds. `pg_advisory_lock` waits are subject to `lock_timeout`, so a waiter under sustained contention could be aborted by Postgres with `SQLSTATE 55P03`. That code is not a serialization failure, was not retried, and was not mapped to `domain.ErrConflict`, so it surfaced as an opaque 500 instead of the intended 503.
2. The lock was acquired on a connection checked out from the pool before the wait began, and held for the whole call, including every retry's backoff. A burst of same-tenant posts could check out and hold most or all of the pool's connections while merely waiting on the lock, starving every other tenant's posts of a connection. That defeats the entire point of scoping the lock per tenant: different tenants are supposed to stay fully parallel.

The fix, since go-ledger runs as a single VPS instance rather than a fleet, is an in-process keyed mutex in the repository adapter (`internal/postgres/repository.go`): one `sync.Mutex` per tenant id, held for the whole `RunInTx` call but never around a checked-out database connection. A post for a tenant that already has one in flight blocks on that Go mutex, holding no connection while it waits; once unblocked it begins its own attempt exactly as before the advisory lock existed, acquiring a connection from the pool only when it actually runs, and releasing it between attempts (including during backoff). Different tenants use different mutexes and never wait on each other. The map of

per-tenant mutexes grows with the number of distinct tenants ever seen and is never evicted; at this service's tenant count that stays small and cheap, so eviction was not built.

This closes both problems above: there is no database lock wait, so `lock_timeout` and `SQLSTATE 55P03` do not apply, and a waiting goroutine never holds a pool connection, so a hot tenant's backlog cannot starve other tenants of connections. The `SERIALIZABLE` retry loop is unchanged and remains the correctness backstop, not the primary serialization mechanism for same-tenant posts: on today's single instance it now runs only after the in-process mutex has already made same-tenant execution one at a time, so it should rarely see a same-tenant conflict at all. If go-ledger is ever run as more than one instance, the in-process mutex only serializes posts within one instance; the retry loop is what still guarantees correctness across instances, since a same-tenant race between two different instances remains possible (rare) and would retry rather than corrupt the chain.

This supersedes ADR-004's negative consequence "conflicts cost retries, not blocked connections," specifically for same-tenant posting. That trade still holds for the `SERIALIZABLE` mechanism itself and for any cross-instance conflict, but for same-tenant posts on today's single instance the practical cost is now waiting on an in-process mutex, not a retry, and not a blocked database connection.

49.4 Consequences

49.4.1 Positive

- `/v1` and gRPC both require a key, the tenant comes only from the key, and cross-tenant access is impossible by construction. The perimeter is real.
- Retrying a payment is safe by default: a missing idempotency key is rejected up front rather than silently double-posting.
- One request can no longer exhaust memory or hold a connection open, and a single key cannot flood the service.
- The audit log is now cryptographically tamper-evident and verifiable through the API, not merely trigger-guarded.
- The public demo and its four-hour reset are unchanged: one uniform auth path, a public demo key that survives the wipe, no special-casing.

49.4.2 Negative

- Every `/v1` request now does a key lookup; the in-memory cache keeps that off the database on the hot path but means revocation lags by up to the cache TTL.
- The audit chain requires same-tenant posts to serialize: one at a time, in the order they arrive. On today's single-instance deployment this is enforced by an in-process per-tenant mutex (see the Decision section above), not by a database lock, so different tenants stay fully parallel and a hot tenant's queued posts hold no database connection while they wait. It is still real coupling that a very high-throughput single tenant would feel as added latency, just not as blocked connections or a database lock timeout.
- Key management for real tenants is still manual this pass (insert a

row, or a small CLI): there is no self-service key issuance UI, which is out of scope.

- The demo key is public by design. That is safe only because it is tenant-scoped, rate limited, and wiped, and those three properties must stay true.

49.5 Alternatives considered

- **API keys in config instead of a table:** rejected. Config keys are not revocable or provisionable without a redeploy, and a hashed table is barely more code while supporting rotation and per-key rate limits.
- **JWT bearer tokens:** rejected for v1. Stateless tokens need an issuance path and a signing-key rotation story that a ledger with a handful of tenants does not need yet. API keys are the lower-ops fit.
- **Leaving the demo tenant unauthenticated:** rejected. It means two code paths and a permanently open write surface. A uniform auth path with a weak public key is simpler and safer.
- **Auto-deriving an idempotency key from the fingerprint:** rejected. It rejects two legitimately-identical separate payments as replays, which on a payment system is a correctness bug, not a safety feature.
- **Per-account access-control lists:** rejected as redundant. The tenant foreign keys already make cross-tenant access impossible, and the key already resolves to exactly one tenant.
- **A single global audit chain:** rejected. It couples all tenants into one hash sequence and makes the per-tenant four-hour wipe impossible without breaking the chain. Per-tenant chains keep the demo reset clean.

- **Cryptographic signing of each audit row (HMAC or asymmetric) instead of a hash chain:** deferred. A hash chain detects reordering, insertion, and deletion, which is the property the audit needed. Signing adds authenticity of the writer on top, which matters once there is more than one writer identity; that is a later concern.
- **A per-tenant PostgreSQL session advisory lock, to serialize same-tenant posts:** tried and reverted. It closed the audit-chain serialization storm but introduced two problems of its own: the lock wait was subject to the pool's `lock_timeout` and could abort with an unmapped SQLSTATE 55P03 (an opaque 500 instead of a 503), and the lock was held on a connection checked out before the wait began, so a same-tenant burst could hold most or all of the pool's connections purely waiting, starving other tenants. An in-process per-tenant mutex has neither problem, since it never touches a database connection while waiting.

ADR-013: VPS infrastructure-as-code with Ansible, and Docker as a dev-only artifact

50.1 Status

Accepted: 2026-07-09

Supersedes the Week 10 framing in the (gitignored) build plan, which still describes Terraform modules and an AWS ECS/RDS deploy. That framing was overtaken by the deployment decision recorded when the service went live.

50.2 Context

The 14-week plan's Week 10 targets AWS: a multi-stage Dockerfile plus Terraform modules (VPC, ECS Fargate, RDS Postgres, ALB, IAM, ECR) and a `make deploy` that stands the ledger up on AWS in one command. Two things have made that plan stale:

1. The locked deployment decision is a single VPS driven by GitHub Actions, not AWS. The service has run in production at <https://go.sohag.pro> since 2026-06-12, and the CI/CD pipeline the plan sched-

uled for Week 11 already ships every push to `main`.

2. How prod actually runs is settled and deliberately un-containerized. The VPS is a 1 CPU / 1 GB RAM Virtuozzo container on Ubuntu 24.04, shared with the portfolio at `sohag.pro`. The ledger runs as a **bare prebuilt binary** under a hardened `go-ledger.service` systemd unit. Postgres 16 is installed on the same box, memory-tuned for 1 GB, and backed up with `pg_dump`. Docker is not installed on the server; all building happens in CI, which ships the binary to `/opt/go-ledger`.

So the AWS half of the planned Week 10 is dead on arrival, and the deploy half is already done. What genuinely remains, and fits the VPS decision, is two gaps:

- The Dockerfile is still a skeleton (its own comment says “fleshed out in Week 10 (distroless, <20MB target)”).
- The VPS was provisioned by hand as root over SSH and captured only as prose in the gitignored `docs/ops/server-setup.md`. There is no executable, version-controlled way to reproduce or audit the box.

This ADR records how Week 10 closes those gaps without relitigating the VPS decision.

50.3 Decision

50.3.1 1. No Terraform, no AWS

The Terraform modules and the AWS ECS/RDS/ALB/ECR deploy are dropped, not deferred. Writing Terraform for infrastructure that will

never be provisioned is throwaway work that would also invite drift between a fictional AWS topology and the real box. The plan file's Week 10 is treated as superseded by this ADR.

50.3.2 2. Docker is a dev-and-CI artifact, never prod

The multi-stage Dockerfile produces a distroless image under 20 MB, used for local development and CI (build and load test). Prod is unaffected: it stays a bare systemd binary against a co-located Postgres. We do not add a Docker daemon to the 1 GB shared box, and we do not run compose in prod.

Rationale: the box has 1 GB of RAM split between the app, Postgres, and the portfolio. A container runtime is pure overhead there, and the bare-binary + systemd model already gives strong isolation (NoNewPrivileges, ProtectSystem= strict, the full hardening block) at zero memory cost. Docker earns its keep for reproducible local dev and for the load-test stack, so that is where it lives.

The Dockerfile is hardened to be real rather than skeletal: `go.sum` is copied before `go mod download` so the dependency layer is pinned and cacheable; BuildKit cache mounts speed rebuilds; `-trimpath -ldflags "-s -w"` shrink the binary; the distroless base is pinned by digest and runs non-root. A `make image-size` target asserts the image is under 20 MB. The target passes on merit: the binary is ~9 to 10 MB (it embeds the Scalar playground bundle) and distroless-static adds ~2 MB.

50.3.3 3. The local dev stack is compose

`docker compose --profile dev up` brings up the full local stack: app, Postgres, Jaeger (traces), and Prometheus (scraping the app's existing `/metrics`). It carries a `dev` profile, kept separate from the `load-test` profile (tuned for the multi-tenant audit-chain k6 run), because Docker Compose always starts profile-less services: without its own profile the dev stack would boot during a `--profile load-test` run too and collide on ports. This is local-only; nothing here reaches prod.

50.3.4 4. VPS provisioning is codified as an idempotent Ansible playbook

The prose in `server-setup.md` becomes an executable, re-runnable Ansible playbook under `infra/ansible/`, split into roles that mirror the runbook: `base` (`ufw`, `fail2ban`, unattended upgrades), `postgres` (Postgres 16, role and database, 1 GB memory tuning, `pg_dump` backup cron), `app` (`/opt/go-ledger`, root-owned env file, deploy user, restricted sudoers), `systemd` (the hardened unit), `nginx` (the `go.sohag.pro` vhost with `gzip`), and `tls` (`certbot`).

Ansible over the alternatives:

- **Over a plain bash provision script:** Ansible is idempotent and re-runnable by construction, and its roles document the box's desired state more clearly than an accretion of `if not exists` shell. The box was built by hand once; the value now is a state description that stays true, not a replay of the original keystrokes.
- **Over Terraform:** Terraform provisions cloud resources. There are

none. The work here is configuring an existing host, which is configuration management, Ansible's job, not infrastructure provisioning.

50.3.5 5. The public repo leaks nothing about the live box

The repo is public. The roles and playbook are tracked and generic: no IP, no secrets, no portfolio-specific detail beyond what is already public. The real inventory (the VPS IP), the vault (the Postgres password and the deploy private key), and any host-specific vars are gitignored, exactly as `server-setup.md` is. Committed `*.example` files show the shape without the secrets. The public repo gets reproducible IaC; the live box's address and credentials stay out of it.

The `nginx` role runs on a host shared with the portfolio, which uses HSTS preload (every `sohag.pro` subdomain must always serve valid HTTPS). The role therefore validates with `nginx -t`, reloads rather than restarts, and asserts that `https://sohag.pro/` still returns 200 after any change. Re-running the playbook against the live box is deliberate, not casual: the README documents a check-mode-first workflow.

50.4 Consequences

- Week 10 produces a real container image and a reproducible, auditable description of the production host, both consistent with the VPS decision.
- The plan file's Week 10 and its AWS blog title are formally void; the actual blog documents Docker plus Ansible IaC on a VPS.
- Prod remains un-containerized. If the service ever outgrows one

box, the bare-binary model is what would be revisited, and the Ansible roles are the starting point for provisioning additional hosts.

- The Ansible playbook is a control-machine dependency (Ansible must be installed to run it) and is validated in check mode and by idempotent re-runs; a full from-scratch provision is exercised manually, never against a throwaway host in CI.
- Anyone with the repo can read exactly how the box is built, but not where it is or how to log in.

CHAPTER 51

ADR-014: Multi-currency accounts and FX conversion

51.1 Status

Accepted: 2026-07-09

Supersedes the v1 scope note (CLAUDE.md) that listed multi-currency and FX as out of scope. The public roadmap was extended from 12 to 14 weeks, and Week 11 brings multi-currency and FX into scope deliberately.

51.2 Context

Until now the ledger is single-currency per transaction. Money carries a Currency (ISO 4217), every Account has a currency, and a transaction stores one currency shared by all its postings. Two database triggers enforce this: `assert_txn_balanced` (all postings of a transaction sum to zero) and `assert_posting_currency`, from ADR-005 (every posting's account currency must equal the transaction's currency). So different accounts can hold different currencies, but a single transaction cannot span them.

Week 11 adds cross-currency (FX) transactions: one transaction that moves value between accounts of different currencies while double-entry still holds. A plain USD to EUR transfer (debit a USD account, credit a EUR account) does not sum to zero within either currency, so the model has to change.

The hard constraint this project has held since ADR-002: money is integer minor units, never floating point, because a rounding ghost in the money path is exactly the class of bug that destroys value silently. FX conversion multiplies by a rate, which is where float usually creeps back in. It must not.

51.3 Decision

51.3.1 1. Currency moves onto the posting; the invariant becomes per-currency

Every posting carries its own currency (denormalized from its account). The double-entry invariant changes from “all postings sum to zero” to “for each currency in the transaction, its postings sum to zero.” A single-currency transaction is the special case with one currency group.

- `Transaction.Validate()` groups postings by currency and checks each group nets to zero.
- `assert_txn_balanced` is rewritten to `GROUP BY` currency, each summing to zero.
- `assert_posting_currency` now checks `posting.currency = its account.currency` (it used to compare against the transaction’s currency).

- The transaction-level currency column is dropped: a transaction can now span currencies, so a single transaction currency is no longer meaningful.

51.3.2 2. FX clearing accounts make each currency net to zero

A cross-currency move routes each currency leg through a system clearing account, so every currency nets to zero on its own and the clearing accounts carry the open FX position:

1	convert 100.00 USD to EUR, applied rate 0.9200 EUR per USD				
2	user_USD	-10000 USD	fx_clearing_USD	+10000 USD	(USD sum = 0)
3	fx_clearing_EUR	-9200 EUR	user_EUR	+9200 EUR	(EUR sum = 0)

Because an account is single-currency but an FX position spans currencies, the clearing is a set of per-tenant, per-currency system accounts (one per currency, auto-created on first use). They use a distinct **system** account type: excluded from user-facing balance listings, and expected to carry a permanent, often negative, open position (that position, revalued at current rates, is the FX exposure, and its drift is FX gain or loss). This is standard nostro-style FX accounting, not a workaround. Clearing accounts are created lazily and concurrency-safely: INSERT ... ON CONFLICT DO NOTHING against a UNIQUE (tenant_id , name) constraint, so two concurrent first-time converts cannot create duplicates.

51.3.3 3. The convert endpoint applies the rate server-side

POST /v1/transactions/convert (and the gRPC equivalent) takes { from_account, to_account, source_amount} plus a mandatory idempotency key. The target currency is derived from the to account, never from client input. Both accounts must belong to the caller's tenant. The server looks up the rate, applies the spread, computes the converted amount, and posts all four legs in one atomic transaction. The client never supplies a rate: a client-controlled rate is a money-theft vector.

Rejected at validation: same from and to account, a “conversion” where both accounts share a currency, a missing rate pair, a non-positive rate, and a conversion whose converted amount rounds to zero (dust: taking source and crediting nothing is not a valid trade).

51.3.4 4. Rates live in an append-only table behind a provider seam

A new `fx_rates` table stores rates for reference and history: `id`, `base`, `quote`, `mid_rate_e8` (BIGINT, mid scaled by 10^8), `spread_bps` (INT), `source`, `effective_at`, `created_at`. It is **append-only**: env seeding and any future provider insert a new row with a new `effective_at`; nothing is updated in place. “The current rate” for a pair is the row with the greatest (`effective_at`, `id`) $\leq$ now, ordered `effective_at` DESC, `id` DESC so two rows sharing an `effective_at` (a re-seed within the same second) resolve deterministically to the last inserted. This preserves the history the DB store exists to give: what rate was live at any past time is reproducible.

A `RateProvider` interface decouples rate origin from the conversion logic:

```

1 type RateProvider interface {
2     // Rate returns the current MID rate (quote per base, in the FXQuote,
3     // scaled by
4     // 1e8) and the configured spread in basis points for that pair.
5     Rate(ctx context.Context, base, quote domain.Currency) (domain.FXQuote,
6         int32, error)
7 }

```

v1 is a `dbRateProvider` that reads the current row. `FX_RATES` in the environment seeds the table at boot (inserting new effective rows). A future `apiRateProvider` pulls mid rates from an external provider and inserts into the same table: one interface, no change at the call sites.

The spread is the **ledger's own policy** (its markup), not the provider's data. A real rate API returns a mid; the markup is a business decision. For v1 the spread is stored alongside the mid in `fx_rates` (seeded from env), but the conversion service, not the provider, is what applies it.

51.3.5 5. Spread is applied so the customer always gets the worse side

The spread is a bid/ask widening around the mid, and it must disadvantage the customer in **both** directions, including when a pair is only stored one way and the reverse is derived. The rule, order-of-operations exactly:

1. Normalize to quote-per-base: if the base/quote pair is stored, use its mid directly; if only quote/base is stored, invert it ($\text{mid_qpb} = 10^{16} / \text{mid_bpq}$, integer) to get quote-per-base.

2. Apply the spread as a reduction of the quote the customer receives:

$$\text{applied_e8} = \text{mid_qpb_e8} * (10000 - \text{spread_bps}) / 10000.$$

Reducing quote-out is always worse for the customer regardless of direction, so a round trip (A to B to A) loses roughly two spreads plus rounding, and that loss is exactly what accumulates in the clearing accounts.

One provenance subtlety for inverted lookups: the FX snapshot's `mid_rate_e8` records the *inverted* mid actually applied, while its `fx_rate_id` points at the reverse-direction `fx_rates` row, whose stored `mid_rate_e8` is the *non-inverted* value. The conversion stays fully reproducible from the snapshot alone (`mid + spread + source` through the decision-6 formula); the `fx_rate_id` link is provenance to the source row, not the applied number. An auditor joining on `fx_rate_id` should expect the stored row's mid to be the reciprocal of the applied mid for an inverted pair. Both directions are unit tested, and the round-trip reconciliation test asserts the clearing position equals the expected spread-plus-residual.

51.3.6 6. Conversion is integer-only, single-step, banker's rounded, sign-symmetric

The rate and the amount are combined in a **single rounding step**, not rate-round then amount-round, so no double-rounding bias creeps in:

```
1 converted_minor = bankers_round( source_minor * mid_e8 * (10000 -
2                               spread_bps)
                               / (10^8 * 10000) )
```

The reproducible truth of a conversion is (`mid_e8`, `spread_bps`, `source`)

run through this formula. `applied_e8` is stored too, but as an informational display value (`bankers_round(mid_e8 * (10000 - spread_bps) / 10000)`), not the thing the converted amount is derived from.

The intermediate `source_minor * mid_e8 * (10000 - spread_bps)` can reach $\sim 10^{30}$ and overflow `int64`, and even `mid_e8 * (10000 - spread_bps)` overflows for a large-magnitude rate, so the whole computation is done in `math/big.Int`. This also sidesteps the `math.MinInt64` negation trap that a `uint64(-a)` 128-bit path would hit. `math/bits.Div64` is deliberately not used: its `hi < divisor` precondition is easy to violate and get an arithmetically wrong quotient. There is a database round trip on either side of this call, so the allocation cost of `big.Int` is irrelevant. No `float64` anywhere in the money path, including rate parsing (`env.rates` are scaled to integers by string manipulation, never `parseFloat`).

Rounding is round-half-to-even (banker's), implemented on the integer quotient and remainder and **symmetric across sign** (postings are frequently negative): -2.5 to -2, -3.5 to -4, 2.5 to 2, 3.5 to 4. The tie boundaries, both signs, the `MinInt64` source, and a result that overflows `int64` (rejected, not wrapped) are all unit tested. Banker's rounding is chosen over half-up because half-up carries a systematic upward bias that accumulates directionally over many conversions. A bad spread (outside `[0, 10000)` bps) is `ErrInvalidSpread`, a non-positive rate `ErrNonPositiveRate`, and a conversion that rounds to zero `ErrConversionDust`.

51.3.7 7. The applied rate is recorded immutably

Each FX transaction snapshots, immutably, the numbers actually used: `source_amount`, `converted_amount`, `mid_rate_e8`, `spread_bps`, `applied_e8`,

source, effective_at, plus a foreign key to the fx_rates row for provenance. The snapshot, not a later join to a mutable table, is the truth for a dispute: what rate we applied, from where, at what time. The audit log (ADR-007) records the conversion with the same rate detail.

51.3.8 8. New-account default currency is env-configured

Accounts already carry a non-null currency, so the migration backfills the new `postings.currency` column from each posting's own account, not from a global default. What `DEFAULT_CURRENCY` (env, default USD) governs is the default currency for a newly created account when the caller does not specify one, and it is what the demo seeder stamps on its seeded accounts. Operators set it to whatever the deployment's data should default to.

The migration is ordered so the balanced trigger never sees a null or mixed grouping: add `postings.currency` nullable, backfill from each posting's account, set NOT NULL, then swap `assert_txn_balanced` to the per-currency version.

51.3.9 9. The idempotency fingerprint changes, and that is a breaking change

Dropping the transaction currency means the idempotency request fingerprint (ADR-006), which hashed the transaction currency plus every posting, moves to hashing each posting's currency. This is a breaking change: a client retrying a request created *before* this deploy would produce a different fingerprint and be rejected as “same key,

different body” (409).

We accept this now without a migration. The service is still being built, no real money flows through it, and the demo tenant is wiped every four hours, so there are no durable in-flight keys to protect. A fingerprint-scheme version id (store the scheme with the key, accept old-scheme keys under their old hash) is the correct fix once real traffic exists; it is deferred to that point, recorded here so the debt is explicit.

51.4 Amendment (audit remediation, task 0.2, findings A1.1 and A8.3)

Decision 6’s formula was missing a factor and has been corrected. `mid_rate_e8` is, and always was intended to be, a **major-unit** ratio (quote major per one base major, scaled by `1e8`; a rate of “150.0” seeds as `150e8`). `Convert`, however, operates on minor units, and the original implementation treated `source_minor * mid_e8` as if minor units and major units used the same scale for every currency. That is only true when the base and quote currency share the same minor-unit exponent (for example USD and EUR, both 2 decimal places), which is why the existing USD/EUR test suite did not catch it. For a pair with differing exponents (JPY at 0 decimals, BHD/KWD/OMR and others at 3) the result was wrong by a power of ten: converting 100.00 USD to JPY at mid 150.0 produced 1,500,000 instead of the correct 15,000 yen.

The fix adds one more factor to the single rounding step, folding in each currency’s minor-unit exponent (`Currency.MinorUnits()`, a new

registry covering the common 0-decimal and 3-decimal currencies, defaulting to 2 for everything else):

```

1 converted_minor = bankers_round( source_minor * mid_e8 * (10000 -
2                               spread_bps)
3                               * 10^(exp(quote) - exp(base))
                               / (10^8 * 10000) )

```

If $\text{exp}(\text{quote}) - \text{exp}(\text{base})$ is positive the factor multiplies the numerator; if negative, its reciprocal multiplies the denominator. Either way it is folded into the same `math/big` numerator and denominator used for the mid and spread, so the whole thing is still one `bankersDiv` call: no intermediate rounding is introduced by this fix. `applied_e8` is unaffected and stays a major-unit display rate, per decision 6.

This does not change rate storage, `internal/fx`, or how `env` rates are seeded: `mid_rate_e8` was already being seeded and stored correctly as a major-unit ratio. The bug was entirely in how `convert` consumed that ratio against minor-unit amounts.

51.5 Consequences

- The ledger models real cross-currency movement with double-entry intact per currency, and the FX position and its gain or loss live in auditable clearing accounts.
- Every aggregate is now per-currency; nothing may sum across currencies. A tenant's "total" is a vector of per-currency balances, not a scalar.
- The money path stays integer-only; the FX rate never introduces float, and the rounding residual is accounted for (it lands in clear-

ing) rather than lost.

- Rate history is queryable and reproducible; provenance is on every FX transaction; the origin of rates is swappable without touching conversion code.
- The clearing accounts are write-hot per tenant, but same-tenant posts already serialize (ADR-012), so this adds no new contention class.
- The idempotency fingerprint change is breaking across this one deploy, accepted deliberately (see decision 9).
- Dropping `transactions.currency` ripples to every reader of it: the transaction sqlc queries, the REST and gRPC transaction response shapes (which move from one transaction currency to a currency per posting), the audit payload, the demo seeder, and the console. All are updated in the same change; none may still reference a transaction-level currency afterward.

51.6 Alternatives considered

- **Rate-annotated two-leg transaction (no clearing account):** store the rate and validate the two legs as balanced *by the rate* instead of per-currency zero-sum. Rejected: it weakens the invariant from “sums to zero” to “balanced under the recorded rate,” an FX-specific rule that is harder to enforce in the database and easier to get wrong. The clearing model keeps the strong invariant literally true.
- **Applying the rate in float64:** simplest to write. Rejected outright: it reintroduces floating point into the money path, the exact thing ADR-002 removed.
- **Round-half-up:** simpler than banker’s. Rejected: systematic directional bias.

- **Upserting rates in place:** simpler table. Rejected: destroys the rate history the DB store is meant to provide.
- **Keeping `transaction.currency` nullable** (null for FX txns): lower blast radius. Rejected in favor of dropping it for a single clean representation, accepting the fingerprint change (decision 9).
- **Client-supplied rate or client-built FX legs:** more flexible. Rejected: a client-controlled rate is a theft vector; the server owns the rate.

51.7 Out of scope (v1)

Live rate-provider integration (the seam is built, the implementation is not), FX gain-or-loss *reporting* (the position sits in clearing accounts; reporting is Week 12), currency triangulation beyond direct and single-inverse lookup, per-rate historical revaluation, bid/ask sourced from a real market (v1 is a single configured spread around a mid), the idempotency fingerprint-scheme versioning (decision 9), a rate max-age / staleness check (v1 env rates do not expire; the current-rate query has no freshness bound), a database-level guard making the FX snapshot columns immutable (v1 relies on the append-only, never-updated convention rather than an enforced trigger), and surfacing the FX rate detail on the transaction read path (GET `/v1/transactions/{id}`): the applied rate is returned on the convert response and recorded in the audit log, but the read-back of an existing transaction reports per-posting currency only, not the `fx_*` snapshot.

ADR-015: Audit remediation, white-label hardening, durability, and scale

52.1 Status

Accepted: 2026-07-10

Basis: the fintech / white-label audit at `docs/audit/2026-07-10-fintech-white-label-audit.md` (3 Blocker, 10 High, 15 Medium, 7 Low system findings; 6 must-fix and 7 nice-to-have book findings). This ADR records the remediation decision for each area and the order the work lands in. Two of the Blockers (durability/DR and multi-instance scaling) are deep enough that each gets its own detailed ADR authored at the start of its phase; this ADR fixes the direction so the phasing is committed.

52.2 Context

The accounting core is sound: the zero-sum invariant is enforced in three layers, money is integer minor units with no float, FX is single-step banker's-rounded `big.Int` with immutable rate snapshots, idempotency is database-refereed, and the audit log is hash-chained per tenant. The audit confirmed the ledger itself is not the risk. The

distance to “another company runs this for real money” is the shell: no tenant entity, a daily same-disk `pg_dump` as the whole disaster-recovery story, correctness pinned to a single instance by the per-tenant in-process mutex, demo-shaped defaults, one latent FX money bug, an unhardened gRPC surface, and an absent compliance / eventing / reporting layer. This ADR decides how each of those is closed and in what order.

The goal is a production-grade, multi-tenant, white-label money core, and a premium printable book. The work is phased by leverage and dependency, cheapest-highest-risk first, so the disqualifying risks fall before the product features.

52.3 Decision

52.3.1 Phase 0: stop the bleeding (safe-by-default and the money bug)

Safe-by-default deployment (A2.1). Invert the demo-shaped defaults so a plain deployment is production-safe. `SEED_ENABLED` defaults to `false`. The demo API key is provisioned only when `DEMO_MODE=true` is set explicitly. The server refuses to boot if `DEMO_API_KEY` equals the published public constant while `APP_ENV=production`. The seeder refuses to run against any tenant that holds an API key other than the demo key. The public key stays exactly what it is for `go.sohag.pro` (which sets `DEMO_MODE=true`), and becomes impossible to enable by accident anywhere else.

Currency minor-unit exponents (A1.1), the one latent money bug.

Introduce a currency registry mapping each ISO code to its minor-unit exponent (USD 2, JPY 0, BHD/KWD 3). `mid_rate_e8` is redefined explicitly as a major-unit ratio (quote per base, both in major units), and `domain.Convert` applies the exponent factor $10^{(\text{exp_quote} - \text{exp_base})}$ inside the integer computation so a USD to JPY conversion is correct, not off by a power of ten. `Money.String()` formats to the currency's real exponent. JPY and BHD test cases are added. This lands before any non-2-decimal currency is ever configured.

52.3.2 Phase 1: durability (the single disqualifying risk)

Backup and disaster recovery (A4.1), Blocker. A daily same-disk `pg_dump` is not a money-grade recovery story. Decision: adopt continuous WAL archiving plus periodic base backups shipped to encrypted offsite object storage, giving point-in-time recovery, and add a scheduled automated restore-and-verify job that restores into a throwaway environment and runs the balance invariant and `audit/verify` walks over the restored data. Write RPO and RTO into the runbook. Tool and topology (`pgBackRest` vs WAL-G; DB co-located with WAL shipping vs moving to managed Postgres) are decided in the dedicated **ADR-016 (durability and DR)** authored at the start of this phase. Default lean: `pgBackRest` to encrypted S3-compatible storage, DB co-located for now, managed Postgres named as the growth path. Nothing else in this remediation matters if this is not done.

52.3.3 Phase 2: the tenant, the white-label MVP

Tenant entity (A3.1) and key lifecycle (A3.2, A2.3), Blocker. Introduce a `tenants` table (`id`, `name`, `status`, `settings jsonb`, `created_at`) with a foreign key from `api_keys`. Posting and reads gate on tenant status (active / suspended / closed). Per-tenant settings hold what is global today: default currency, rate limits, FX spread policy. API keys gain scopes (`read`, `post`, `admin`), optional `expires_at`, and a `last_used_at` touch; the SHA-256-hashed, `glk_`-prefixed storage stays. An operator-authenticated admin surface (an admin-scoped API, with a thin CLI wrapper) provides: create tenant, issue key (plaintext shown once), rotate with an overlap window, revoke, list. This replaces manual SQL and is the line between a demo and a product. The fingerprint scheme id (A1.6) lands here too: store a scheme version with each idempotency key so the next breaking fingerprint change is free.

Per-tenant FX and policy (A3.3, A3.4). `fx_rates` gains a nullable `tenant_id` (null = global default), resolved tenant-first in the provider; spread policy moves into tenant settings. A per-tenant policy (max amount per transaction, daily volume, currency allowlist) is enforced in the posting path.

52.3.4 Phase 3: scale past one process

Multi-instance audit-chain scaling (A3.6, A5.1), Blocker. The per-tenant in-process mutex is correct for one process and a documented cliff beyond it. Decision: make the audit-chain extension asynchronous. A transaction commits its postings without holding the chain; a single per-tenant chainer consumes an outbox in commit

order and appends audit rows, so the hot-path posting no longer serializes on the chain read-then-append and multiple app instances stop fighting over it. The detailed design (outbox schema, the chainer's leader-election / single-runner guarantee, ordering, backpressure, and how `audit/verify` reads a possibly-lagging chain) is recorded in the dedicated **ADR-017 (multi-instance audit chain)** at the start of this phase. A two-instance same-tenant contention test (A8.2) is written first so the current 40001 / 503 failure mode is measured, not guessed. Migrations move to a CI step gated before the binary swap once instance count exceeds one (A4.3).

52.3.5 Phase 4: the integration surface (what makes integrators say yes)

- **Webhooks and eventing (A7.1).** Signed, retrying webhook delivery driven from the audit outbox (the same outbox as Phase 3), per-tenant subscriptions, a delivery log, at-least-once from the outbox. (This is the planned Week 13/14 work, pulled forward under the remediation.)
- **Reversal primitive (A1.2).** `POST /v1/transactions/{id}/reverse` posts the negated legs atomically, links both directions (`reverses_transaction_id`), is idempotent, and forbids reversing a reversal. The technical prerequisite for disputes.
- **External reference and value dating (A1.3).** Optional unique-per-tenant reference on transactions and an `effective_at` (value date) distinct from `created_at`; both are reconciliation prerequisites.
- **List, search, export (A7.2).** `GET /v1/transactions` with date-range and reference filters on the existing keyset pattern, plus CSV/JSON export.

- **Idempotency TTL (A1.4).** `expires_at` on idempotency keys (default 24h, config up to 7d), a sweep job, documented in the OpenAPI description.

52.3.6 Phase 5: security depth and operations

- **gRPC parity (A2.2).** A rate-limit interceptor reusing `auth.Limiter`, a postings-count clamp to the same 100 as REST, an intentional `grpc.MaxRecvMsgSize`, and an explicit decision to either terminate TLS for gRPC or document it as a private-network-only surface.
- **Negative-lookup and edge throttling (A2.5).** `nginx limit_req` per IP, plus a small in-process per-IP negative-lookup throttle ahead of the auth DB lookup, and trust `X-Forwarded-For` from localhost only (A6.4).
- **Audit-chain anchoring and streaming verify (A2.4).** Periodically anchor each tenant's head `row_hash` off-box (a shipped log line or object-store write) so a privileged DB rewrite is detectable; make `audit/verify` stream/page with a stored checkpoint instead of loading the whole chain.
- **Composite tenant FKs (A4.4).** `idempotency_keys` and `audit_log` reference transactions(`tenant_id`, `id`) compositely, matching postings.
- **RLS defense in depth (A3.5).** Postgres row-level security keyed on a per- transaction GUC (`SET LOCAL app.tenant_id`), so a future missed `WHERE tenant_id` cannot leak across tenants.
- **Account state and balance policy (A1.5).** Account status (active/frozen/closed) and an optional `min_balance` enforced in the SERIALizable, per-tenant-serialized posting path; the first compliance-hold and overdraft control.
- **Alerting and SLOs (A6.1).** Commit `deploy/alerts.yml`: `balance-`

invariant canary, serialization-retry rate, 5xx rate, p99 post latency, scheduled `audit/verify`, cert expiry, disk space, backup success/age. Add a dashboard, an uptime monitor, a paging channel, and written SLOs.

- **Deploy safety (A6.2), off-box logs (A6.3), secrets and TLS (A2.6).** Automated rollback on failed health check, a build-SHA field in `/healthz` so the gate confirms the new binary, off-box journald shipping with a retention policy, encrypted backups, a secrets story, and `sslmode=verify-full` when the DB moves off-box.

52.3.7 Phase 6: compliance scaffolding

Enough hooks that a compliance stack bolts on without forking the core: account freeze status (from A1.5), a pre-post policy hook interface where a screening / monitoring decision can gate a post, party / customer reference fields on accounts, a PII and retention policy that keeps money data immutable while making description fields cryptoshreddable (resolving the immutability-vs-erasure tension), and the statement/reporting/dispute data model (statement documents, per-tenant trial balance and per-currency totals, dispute records built on the reversal primitive). Much of this is the planned Week 12 reporting work, named here against the white-label bar.

52.3.8 Phase 7: the premium book pass (interleaved, cheap wins pulled earlier)

- **B1 colophon drift (must-fix).** The edition and support pages say “Weeks 1 to 10, ADRs 001 to 013, Weeks 11 to 14 coming soon”

while the book contains Week 11 and ADR-014. Derive those lines from the build manifest so they can never drift again. (This is cheap and pulled forward to Phase 0.)

- **B2 back-matter numbering (must-fix).** Further Reading renders as sections 40.7+; switch the back matter to unnumbered sectioning.
- **B3 print production spec (must-fix).** Decide the physical product: a real trim (170x240 mm or 6x9in, not A4), add bleed to the full-bleed dark pages, produce a separate cover file with computed spine width; until then label the artifact “digital edition.”
- **B4 grayscale (must-fix).** Add redundant, non-hue encoding to the zero-sum motif and the yes/no and pass/reject diagrams, then do a full grayscale proof pass.
- **B5 figure placement (must-fix).** Audit every colon-introduced figure so the deictic “here is the picture” points at the picture (non-floating placement).
- **B6 index quality (must-fix).** Rebuild the index with subentries and bolded defining pages instead of 30-locator concordance runs; consider retitling to the conventional “Index.”
- **Nice-to-have (B7 to B13).** ISBN and edition apparatus, tagged-PDF / EPUB accessibility with diagram alt text, split or number the two special editions, captioned/numbered listings with a List of Listings, epubcheck in CI, a typographic proof sweep, and explicit early-access completeness framing.

52.4 Consequences

- The disqualifying risks (durability, safe defaults, the FX money bug) fall first, in Phases 0 and 1, so the system is safe to run for real

money early, before the product features are complete.

- Introducing a `tenants` table and, later, RLS and composite FKs are schema migrations touching the hot tables; each is an ordered, tested migration in the style of 0010, with the multi-instance migration-on-boot change (A4.3) landing alongside Phase 3.
- The outbox-chainer (Phase 3) is the deepest change: it moves the audit chain off the synchronous posting path, which changes `audit/verify` semantics (the chain may briefly lag a committed transaction) and requires a single-runner guarantee. ADR-017 records that design; it is not hand-waved here.
- Per-finding severity and file references stay in the audit report; this ADR is the decision and sequencing record, and the implementation plan (`docs/superpowers/plans/2026-07-10-audit-remediation.md`) maps every finding to a task within these phases.
- Two Blockers (DR, multi-instance) and the largest features (web-hooks, compliance) are multi-week; this ADR commits the direction and order, not a promise that all of it lands in one week. The cheap, high-leverage fixes (Phase 0, the book must-fixes, gRPC parity, composite FKs, reversal, refs) can land quickly; the Blockers are scheduled, not skipped.

52.5 Alternatives considered

- **Advisory-lock or per-partition sharding for multi-instance (A3.6):** rejected as the primary path in favor of the outbox-chainer, because a database advisory lock under `SERIALIZABLE` was already shown to fail (ADR-012), and sharding the chain complicates verification. Recorded fully in ADR-017.
- **Managed Postgres now (A4.1/A4.2):** the cleaner durability an-

swer, deferred as the growth path rather than the immediate step, because WAL archiving off the current box removes the disqualifying data-loss risk at far lower cost and change; ADR-017 decides the trigger for the move.

- **Per-tenant RLS as the only isolation:** rejected as a replacement; adopted as defense in depth on top of the existing composite-FK and tenant-scoped-query isolation, which stays the primary guarantee.
- **Fixing everything in one pass:** rejected as dishonest scheduling. The work is phased; the Blockers are named, ordered, and given their own detailed ADRs at the point they are built.

52.6 Out of scope (even for this remediation)

Obtaining a money-transmitter license or partner-bank sponsorship (a business, not an engineering, task), building the compliance decision engine itself (only the hooks), Kafka or an external broker (the outbox covers eventing), event sourcing, and a product web UI beyond the developer console.

ADR-016: Durability and disaster recovery (WAL archiving, offsite encrypted backups, PITR)

Status: Accepted Date: 2026-07-10 Supersedes the backup portion of the Week 10 VPS setup (the same-disk daily `pg_dump`). Referenced by ADR-015 (audit remediation, Phase 1) and closes audit finding A4.1 (Blocker), with A8.1 (restore drill).

53.1 Context

The ledger is the system of record for money. The Week 10 deployment backs it up with a single mechanism: a `cron.daily` job that runs `pg_dump` | `gzip` into `/var/backups/go-ledger` on the same VPS disk as the database, keeping 14 days.

For a hobby service that is fine. For a production, white-label money core it is disqualifying, and the audit flagged it as a Blocker:

- **Same disk.** If the disk or the VPS is lost, the database and every backup are lost together. There is no offsite copy.
- **No point-in-time recovery.** A logical dump is a snapshot at dump time. Any write between the nightly dump and a failure is gone: up to ~24 hours of posted transactions. For a ledger that is unbounded

data loss.

- **Not encrypted.** The dumps are plaintext money data at rest.
- **Never restored.** A backup that has never been restored is a hope, not a recovery plan. There is no proof the dumps are usable.

A ledger's durability bar is specific: no committed transaction may ever be silently lost, and recovery must be a rehearsed, bounded procedure, not an improvisation during an outage.

53.2 Decision

53.2.1 1. Tool: **pgBackRest**

Adopt **pgBackRest** as the backup and recovery system, replacing the same-disk `pg_dump` as the durability mechanism. `pgBackRest` gives us, in one tool: continuous WAL archiving, full plus differential physical base backups, point-in-time recovery, repository-level AES-256 encryption, retention management, integrity checksums, and a single-command restore.

The alternative considered was WAL-G. Both are solid. `pgBackRest` wins here for its simpler configuration, first-class differential backups, built-in encryption and retention, and a restore path that is one command rather than a scripted sequence. Neither choice is load-bearing on the rest of the system; the ledger does not know how it is backed up.

53.2.2 2. Topology: co-located archiving to encrypted offsite object storage

Now: PostgreSQL on the VPS ships WAL and base backups to an S3-compatible object store in a **different failure domain** (a separate provider or region from the VPS), with pgBackRest repository encryption on, so the offsite copy is ciphertext at rest. WAL archiving is asynchronous (`archive-async`) so archiving never stalls a commit.

The growth path, explicitly out of scope for this ADR, is a managed Postgres service (the provider owns WAL archiving, PITR, and replicas) when the service outgrows a single VPS. ADR-015's Phase 3 (multi-instance) is the trigger to revisit; a managed primary with a read replica also addresses availability (A4.2), which this ADR does not.

53.2.3 3. Recovery objectives

- **RPO (recovery point objective): ≤ 5 minutes.** Continuous WAL archiving with `archive_timeout = 60s` bounds the worst-case loss to roughly the last minute of WAL plus archive latency. In practice a busy ledger fills and ships WAL segments continuously, so the real RPO is seconds.
- **RTO (recovery time objective): ≤ 1 hour.** The database is small (a 1 GB shared box). A restore of the latest base backup plus WAL replay to the target time, followed by the invariant verification (objective 5), completes well inside an hour. The runbook step sequence is written down, not improvised.

53.2.4 4. Schedule and retention

- **Full backup weekly, differential backup daily, WAL archived continuously** via `archive_command = pgbackrest ... archive-push`.
- **Retention:** keep 2 full backups (a two-week PITR window) with their differentials and the WAL needed to recover to any point within that window; `pgBackRest` expires older backups and their WAL automatically.
- Schedule via systemd timers (or cron); the timers run `pgbackrest backup` with `--type=full` weekly and `--type=diff` daily.

A local logical `pg_dump` is retained as a convenience for quick, small, same-box restores and inspection, but it is explicitly **not** the disaster recovery path and is documented as such. The offsite encrypted `pgBackRest` repository is the system of record for recovery.

53.2.5 5. Automated restore-and-verify

A backup is not trusted until a restore has been proven, so a scheduled job **restores the latest offsite backup into a throwaway PostgreSQL instance and verifies the ledger's own invariants against the restored data:**

- every account's balance derived from its postings is internally consistent and every transaction still sums to zero per currency (the core invariant), and
- every tenant's tamper-evident audit hash chain verifies end to end (`audit/verify`).

The job runs **weekly in CI** (GitHub Actions), pulling from the offsite

repository with a **read-only** credential, so it exercises the real offsite copy from a different machine than the one that wrote it, and it fails loudly (red build, alert) on any mismatch or any inability to restore. Running it off-box is deliberate: it proves the copy that would survive losing the VPS is actually restorable, which is the only thing that matters in a disaster.

The RPO and RTO, the restore runbook, and the verify job are documented in `docs/ops/server-setup.md`.

53.3 Consequences

- The single worst production risk, unbounded data loss on disk failure, is removed. Recovery becomes a bounded, rehearsed, off-box procedure.
- **Operational prerequisites the code cannot provide** (owner action): provision an S3-compatible bucket in a different failure domain from the VPS; set the pgBackRest repository credentials and the AES-256 encryption passphrase as secrets on the box (not in git); set a read-only repository credential as a CI secret for the restore-verify job. Until the bucket and secrets exist, the Ansible role and scripts are inert configuration. This is called out in the Phase 1 plan and the runbook.
- Cost: a few dollars a month of object storage and egress, and the CI minutes for the weekly restore-verify. Negligible against the risk removed.
- WAL archiving adds a small, continuous write and network load on the box; the asynchronous archiver keeps it off the commit path.
- The encryption passphrase becomes a recovery dependency: losing

it makes the offsite repository unrecoverable, so it is stored in the operator's secret manager alongside the object-store credentials, documented in the runbook.

- Availability (a hot standby, automated failover) is still out of scope; this ADR is about not losing data, not about staying up. A4.2 is deferred to the managed-Postgres growth path.

ADR-017: Multi-instance audit chain (transactional outbox + single chainer)

Status: Accepted Date: 2026-07-10 Referenced by ADR-015 (audit remediation, Phase 3). Closes audit finding A3.6 (Blocker, single-instance correctness cliff), with A5.1 (audit chain on the hot path), A8.2 (two-instance contention test), and A4.3 (migrations to CI).

54.1 Context

Every posted transaction extends its tenant's tamper-evident audit hash chain: each `audit_log` row stores `prev_hash` (the previous row's `row_hash`) and its own `row_hash = H(tenant, row, prev_hash)`. Verification walks the chain from the genesis hash and recomputes each link, so any after-the-fact mutation of a past row breaks every link after it (ADR-012, migration 0009).

Today that chain is extended **synchronously, inside the posting transaction**: the post reads the tenant's current chain head, computes the new link, and inserts the `audit_log` row in the same transaction that writes the postings. Correctness under concurrency rests on two things: `SERIALIZABLE` isolation, and an **in-process per-tenant mutex** (ADR-012) that serializes same-tenant posts so two of them cannot read the same chain head and fork the chain.

That mutex lives in one process's memory. It is a **single-instance correctness cliff** (audit A3.6, a Blocker): the moment a second app instance runs, two instances can post the same tenant concurrently, both read the same head, and write two rows that both claim the same `prev_hash`, forking the chain. `SERIALIZABLE` alone does not save us, because the two inserts touch different new rows and need not conflict on a serialization dependency the database can see. The service therefore cannot be run as more than one instance without risking a corrupt audit chain, which caps availability and throughput and blocks horizontal scaling.

We need the audit chain to stay correct with N app instances, and we would also like the chain off the posting hot path (audit A5.1): today a hot tenant's throughput is bounded by serialized chain extension.

54.2 Decision

54.2.1 1. Decouple the chain with a transactional outbox and a single chainer

Stop extending the hash chain inside the post. Instead:

- **The post writes an outbox row, not a chain link.** Inside the same transaction that writes the postings, the service inserts an append-only `audit_outbox` row describing the event (tenant, action, transaction id, actor, before/after snapshot). This is atomic with the post: the event is recorded if and only if the transaction commits. No chain head is read, no `row_hash` is computed, so **the per-tenant mutex is removed from the hot path** and multiple instances can

post the same tenant concurrently.

- **A single asynchronous chainer builds the chain.** One background worker drains `audit_outbox` in a well-defined total order, computes each tenant's hash chain, inserts the `audit_log` rows (the same schema and hashing as today), and marks the outbox rows processed. Because exactly one consumer ever extends the chain, there is no fork, regardless of how many instances produce events.

The audit chain becomes **eventually consistent**: a committed transaction is durable immediately (postings + outbox row), and its audit-chain link appears a short time later when the chainer processes it. This lag is bounded and monitored (see 5).

54.2.2 2. Ordering: process only settled rows, in transaction-commit order

The hard part of any outbox is ordering. `audit_outbox.id` is a bigserial assigned at insert time, but transactions commit out of order, so a naive “process id greater than the last processed” can permanently skip a row that was assigned a lower id but committed later. That would leave a committed event out of the chain forever.

We solve it with transaction visibility, the standard correct approach:

- Each outbox row records the inserting transaction id: `txid bigint NOT NULL DEFAULT pg_current_xact_id()`.
- The chainer reads the oldest transaction still in flight, `pg_snapshot_xmin(pg_current_snapshot())`, and processes **only rows whose txid is below that xmin**. Such rows are guaranteed committed, and no still-running transaction can later reveal an

earlier-ordered row that is not yet visible. It processes them ordered by (txid, id).

This gives a single, deterministic total order over all committed events, with no skipped-then-resurfaced row. Rows from aborted transactions simply never appear below xmin as unprocessed work that matters (their txid is settled and they either committed or rolled back; a rolled-back insert leaves no row). The chain records a consistent total order over exactly the committed events, which is all tamper-evidence requires (it does not need the one “true” real-time order of concurrent posts, only a fixed order it can recompute).

The chained rows are ordered by a database-assigned `chain_seq` (a sequence the single chainer writes in insert order), not by their UUID primary key: a UUIDv7 id is monotonic only within one process, so ordering the verify walk by it would let a leader failover to a host with a skewed clock mint a lower id than the current head and read as a fork. A database sequence, assigned by the one writer in processing order, is monotonic and clock-skew-proof. As a defense in depth, `audit_log` also carries the source `outbox_id` under a UNIQUE constraint, so if two writers ever did run at once (the failure this ADR exists to prevent), the second attempt to chain the same event fails the insert instead of forking the chain silently. The chainer runs all of its work on the same connection that holds the leader advisory lock, so losing that lock session fails the very next query and drops leadership rather than draining blind against a lock it no longer holds.

54.2.3 3. Exactly one chainer: leader election via advisory lock

The single-consumer guarantee is enforced with a **session-level Postgres advisory lock** on a fixed key. On startup every instance runs a chainer loop that first tries `pg_try_advisory_lock(key)`; the one that gets it is the leader and does the work, the others idle and retry periodically. If the leader crashes or disconnects, Postgres releases the session lock automatically and another instance acquires it on its next attempt. This needs no external coordinator (no ZooKeeper, no etcd): the database we already depend on is the coordinator. A single global chainer is more than sufficient for this service's volume; per-tenant sharding of the chainer is a future option the outbox order already supports, not something we build now.

54.2.4 4. Remove the hot-path mutex; keep SERIALIZABLE as the backstop

The in-process per-tenant mutex existed to serialize chain extension. With the chain gone from the post, it is removed from the posting path. SERIALIZABLE isolation stays: it still protects the balance and idempotency invariants (the idempotency primary key remains the exactly-once mutex for duplicate posts, and the per-currency balance trigger still fires in-transaction). Concurrent same-tenant posts now proceed in parallel up to what SERIALIZABLE and the idempotency key allow, across any number of instances.

54.2.5 5. Verification and lag semantics

`audit/verify` walks `audit_log`, the chained rows, exactly as before, and its tamper-evidence guarantee is unchanged for everything the chainer has processed. A transaction committed but not yet chained is **pending**: it is in `audit_outbox`, not yet in `audit_log`, so it is not yet covered by the chain. We make this explicit rather than pretend it away:

- Verify reports the chained head and, alongside it, the count of pending (unprocessed) outbox rows, so a caller can see the chain is current or lagging.
- The outbox lag (oldest unprocessed row age, and unprocessed depth) is a metric and an alert (ADR-015 Phase 5 observability). A growing lag means the chainer is down or behind, which is an operational signal, not a data-loss event: the events are durable in the outbox and will be chained when it recovers.
- The restore-verify job (ADR-016) additionally checks that every committed transaction is eventually represented in the chain (no outbox row left unprocessed indefinitely), catching a chainer that silently stopped.

54.2.6 6. Migrations run in CI before deploy (A4.3)

With multiple instances, a schema change must land before the new code that needs it, and no instance may run migrations racing another. Migrations move to a dedicated pre-deploy CI step that runs `goose up` once against the database before any instance rolls over, gated and ordered in the pipeline, rather than each instance migrating on boot. This is recorded here because it is a direct consequence of going

multi-instance.

54.3 Consequences

- The single-instance correctness cliff is removed: the service can run N instances without forking any tenant's audit chain. Horizontal scaling and rolling deploys become safe.
- The audit chain is now **eventually consistent** with a bounded, monitored lag. Consumers that need “is this transaction in the tamper-evident chain yet” must treat chaining as asynchronous. This is a real semantic change, called out in the API docs for `verify`.
- New moving parts: the `audit_outbox` table, the chainer worker, the leader advisory lock, and the `xmin`-based ordering. Each is simple on its own; together they are more than the old synchronous write. The complexity buys multi-instance correctness, which the old design could not provide at any complexity within one process.
- Backpressure is on the outbox, not the client: a slow or stopped chainer grows the outbox but never blocks or fails a post. Monitoring the outbox depth is now an operational must.
- The chainer is a single writer to `audit_log`; its throughput must exceed the aggregate post rate. For this service's volume one worker is ample; if it ever is not, the `(txid, id)` order supports partitioning the chainer by tenant without changing the model.
- A two-instance, same-tenant contention test (A8.2) is written first, against the current design, to record the failure it removes, and then to prove the new design sustains concurrent same-tenant posts across instances without chain forks. That test is the acceptance gate for this ADR.
- This ADR is about correctness under multiple instances, not about

availability (a hot standby, failover). Availability remains the managed-Postgres growth path in ADR-016. Running multiple app instances does improve app-tier availability as a side effect, but the single Postgres remains the availability floor.

ADR-018: PII crypto-shredding (reconciling immutability with the right to erasure)

Status: Accepted Date: 2026-07-11 Referenced by ADR-015 (audit remediation, Phase 6). Closes audit finding A9.3.

55.1 Context

A ledger has two obligations that pull in opposite directions.

- **Immutability.** Postings are append-only, and every posted transaction extends a per-tenant tamper-evident hash chain (ADR-012, ADR-017). A row, once written, must never change, or the chain stops verifying. Money records are retained immutably for regulatory and audit reasons.
- **The right to erasure.** A data subject can ask for their personal data to be deleted. The free-text `description` on a posting is the field most likely to carry personal data (“rent to Jane Doe, 12 Elm St”).

You cannot satisfy an erasure request by deleting or rewriting the row: that breaks the append-only invariant and the hash chain. The `description` also lives a second time inside the audit snapshot (`audit_log.after`), whose bytes are what the `row_hash` is computed over, so scrubbing the

plaintext there would invalidate the chain.

55.2 Decision

55.2.1 1. Crypto-shredding: erase the key, not the row

Encrypt the PII (posting descriptions) at rest with a key that can be destroyed. “Erasing” a subject is destroying the key, which makes the ciphertext permanently unreadable while every byte on disk stays exactly where it was. The row is never mutated, so the append-only invariant and the hash chain are untouched.

- The description is encrypted **once** at post time (AES-256-GCM, a fresh random nonce), and the **same ciphertext string** is stored in both `postings.description` and the audit snapshot. The `row_hash` is therefore computed over ciphertext, and because verification recomputes the hash over the **stored bytes** and never decrypts, destroying the key leaves the chain fully verifiable. This is the load-bearing property: the money-critical test posts, chains, verifies (Valid), shreds the key, and verifies again (still Valid), with balances byte-identical.
- Money data (amounts, currency, account and transaction ids, timestamps) is **never** encrypted: it is immutable and required to derive balances and to verify the chain.
- The idempotency fingerprint is **unchanged**. It is a SHA-256 of the live request computed at post/retry time and stored only as an irreversible hash; it reveals no plaintext and is unaffected by a shred.

55.2.2 2. Envelope encryption with versioned per-tenant keys

- A master key (from the environment) wraps a per-tenant Data Encryption Key (DEK). The wrapped DEK lives in `crypto_keys`; the master key never touches the database.
- **DEKs are versioned.** A tenant can hold a sequence of DEK versions over time. A ciphertext is self-describing (`enc:v1:<version>:<base64( nonce||ct)>`), so a reader knows which DEK version to unwrap, and legacy plaintext (no `enc:` prefix, from before this feature) is passed through unchanged.
- **A shred destroys the current version's key and opens a new one.** Shredding stamps the current DEK version destroyed (its wrapped bytes removed) and lets the next write mint a fresh version. All data encrypted under the destroyed version is permanently unreadable (erased); the tenant keeps operating, with new writes protected by the new version. This is what makes a shred an *erasure of past PII* rather than a *bricking of the tenant*: system-generated narration (a conversion leg's label, a reversal's "reversal of X") is not personal data, and a tenant that erased one subject's history must still be able to post, convert, and reverse.
- Reading a description whose DEK version was shredded returns a redacted marker ("`[redacted: erased]`") without error, so reads keep working after an erasure.
- Cross-tenant isolation: each tenant has its own DEK, and `crypto_keys` carries row-level security (ADR-015 Phase 5, ADR / migration 0024's `FORCE + allow-when- unset` pattern), so one tenant can never decrypt another's data.

55.2.3 3. Granularity: per-tenant in v1, per-party as the growth path

v1 shreds at the **tenant** grain (one DEK sequence per tenant). This demonstrates and delivers the crypto-shred mechanism, but a real GDPR erasure targets one customer, not a whole tenant. The growth path is a per-party (per-subject) DEK, keyed off the party reference on accounts (ADR / Phase 6.1), so a single subject's descriptions can be erased without touching anyone else's. The versioned-envelope design above extends to that grain without changing the hash-chain reasoning.

55.2.4 4. Retention

Money and ledger data are retained immutably (regulatory). PII (descriptions) is crypto-shreddable on an erasure request. The hash chain remains verifiable after erasure (it hashes ciphertext). A shred is irreversible. The operation is admin- scoped and requires an explicit confirmation.

55.3 Consequences

- The immutability-vs-erasure tension is resolved without weakening either side: no row is ever mutated, the chain always verifies, and PII can still be erased.
- Operational prerequisites: a `LEDGER_MASTER_KEY` must be set in production; losing it makes all descriptions unreadable (it is a recovery

dependency, stored with the other operator secrets). When the key is unset (dev/CI without it), descriptions are stored plaintext and the feature is inert, logged as a warning.

- Master-key rotation (re-wrapping DEKs under a new master key) is out of scope for v1; the wrapped-DEK indirection makes it a future operation that never touches ciphertext.
- A shred is coarse in v1 (whole tenant). The versioned design keeps the tenant operational after a shred, but per-subject erasure needs the per-party DEK grain noted above.
- `ErrTenantKeyShredded` should no longer reach the post path now that a shred opens a new version; it remains a mapped client error for any residual case rather than a generic 500.

ADR-019: Operator console, public-demo admin, and one-command onboarding

Status: Accepted Date: 2026-07-11

This ADR records a deliberate reversal of an earlier scope rule and the design of the developer-experience work that follows from it: turning the thin developer console into an operator console with admin panels, exposing admin publicly in demo mode, a one-command run experience, an interactive first-run setup for the binary, and cross-platform release binaries.

56.1 Context

The remediation (ADR-015 through ADR-018) turned go-ledger into a genuine multi-tenant, white-label money core: a tenant entity, API-key lifecycle, an admin REST surface plus a `ledgerctl` CLI, webhooks, per-tenant policy, RLS, disputes, and reporting. None of that is discoverable to a newcomer. The README is a four-line `make run` quickstart. The `/console` is a thin developer tool that hardcodes the public demo key and only does accounts and transactions. There is no packaged way to run the system (it needs Postgres), and no released binaries.

The original scope discipline (in CLAUDE.md) explicitly listed “prod-

uct web UI / admin dashboard” as out of scope and said to keep the console “thin and developer-facing.” That rule made sense while the ledger was single-tenant. Now that the system is white-label and multi-tenant, the lack of any browseable way to onboard a tenant, issue a key, or set up a webhook is the main barrier to anyone actually running it. The rule has outlived its purpose.

56.2 Decision

56.2.1 1. The console becomes an operator console (reverses the “no admin dashboard” rule)

`/console` gains admin and management panels on top of the existing ledger views: tenants (create, list, suspend/close), API keys (issue, list, rotate, revoke), webhook subscriptions, per-tenant policy, and read-only reporting (trial balance, transaction list, disputes), all scoped to a selected tenant. This is a deliberate, recorded reversal of the earlier “keep the console thin, no admin dashboard” rule: the operator console is now an in-scope product surface. It stays a thin client over the existing public `/v1` and `/v1/admin` APIs (no server-side business logic moves into it); it is a browseable front end for capabilities that already exist, not a new capability.

56.2.2 2. Admin auth: public in demo, key-gated in prod

The console’s admin panels unlock based on the deployment mode:

- **Demo mode** (`DEMO_MODE=true`, the public `go.sohag.pro` deployment): admin is **public, no key required**. The whole database resets every four hours and the demo key is rate limited, so there is nothing durable to protect and no privilege worth stealing. To make the console's admin calls work with the public demo key, the demo key is elevated to include the `admin` scope in demo mode only. The accepted risk is that anyone can create tenants and keys on the demo between resets; it is bounded by the demo key's low rate limit and the four-hour wipe, and it never touches a real deployment.
- **Production mode** (`DEMO_MODE` unset/false): admin panels stay hidden until the operator enters an **admin-scoped API key** in the console (stored in the browser's `localStorage`). The UI gate is convenience only; the server already enforces scope on every `/v1/admin` route, so a non-admin key cannot perform admin actions regardless of what the UI shows.

The console learns which mode it is in from a small unauthenticated, read-only endpoint `GET /console/config` returning `{demo_mode, default_tenant_id}`.

56.2.3 3. First-boot admin provisioning

So a self-hoster is not locked out of their own admin surface, the server provisions an admin credential on first boot:

- In demo mode: the demo key is provisioned with `admin` scope (as above).
- In production mode: if no admin-scoped key exists for the default tenant, the server generates a random admin-scoped key, stores it (hash only), and prints the plaintext **once** to the logs with a clear

“save this now” notice. If an admin key already exists, nothing is printed. `ledgerctl` remains the alternate path to mint admin keys.

56.2.4 4. One-command run: docker compose with two profiles

The primary newcomer experience is `docker compose up`:

- A demo profile: `DEMO_MODE=true`, the seeder on, so a newcomer immediately sees a populated demo tenant with public admin.
- A default `local` profile: an empty, production-like ledger with a printed random admin key.

Both bring up Postgres and the app and apply migrations as an init step (the `migrate` subcommand from ADR-017’s pre-swap step, reused). The README documents both, plus the from-source and release-binary paths.

56.2.5 5. Interactive first-run setup for the binary

When the server binary is run directly with `no DATABASE_URL` **and a terminal is attached (stdin is a TTY)**, it runs an interactive setup: it prompts for the Postgres connection (host, port, database, user, password, or a full URL, and `sslmode`), tests the connection, and offers to save it to a config file for next time, then boots. When there is no TTY (docker, systemd, CI), it keeps today’s fail-fast behavior: a missing `DATABASE_URL` is a clear fatal error, never a hang waiting on input. This makes “download the binary and run it” work for a newcomer without making the containerized/service path interactive.

56.2.6 6. Cross-platform release binaries via GoReleaser

Releases publish prebuilt binaries with GoReleaser, triggered by a version tag in GitHub Actions: the **server** and **ledgerctl**, for darwin (amd64 and arm64), linux (amd64 and arm64), and windows (amd64), with checksums and a generated changelog, attached to the GitHub Release. The download-and-run instructions live in the refreshed README.

56.3 Consequences

- A newcomer can go from zero to a running, populated, browseable ledger with one command, and from a downloaded binary with a guided setup. That is the point.
- The console is no longer thin or purely developer-facing; it is an operator admin UI. This is a real scope expansion, recorded here so the reversal is explicit and not an accident. The corresponding CLAUDE.md scope note is updated.
- Demo mode now exposes admin publicly. This is safe only because of the demo's four-hour reset and rate limits; it must never be enabled on a deployment that holds real data. The DEMO_MODE-in-production guard (ADR-015 Phase 0) already refuses that combination at boot, which is what makes this safe to adopt.
- The console remains a thin client with no server-side logic of its own, so it cannot become a second, divergent implementation of any rule; it can only call the same authenticated, scope-checked, RLS-protected APIs everything else uses.
- Interactive setup adds a TTY-gated code path to the server's startup;

it must be strictly gated so the non-interactive path (the one that runs in production) is byte-for-byte the current fail-fast behavior.

- GoReleaser and a tag-triggered workflow add a release process; a bad release is contained to the artifacts and does not touch the running VPS deploy (a separate workflow).
- The work is phased (run foundation, then console, then README and playground, then release binaries) so each phase is independently shippable and the README documents capabilities that are already real when it is written.

CHAPTER 57

ADR-020: FX rates and markup as live admin config

Status: Accepted Date: 2026-07-11

This ADR records moving FX rate configuration from a boot-time environment variable to a live admin API, and adding a per-tenant and global markup default that a conversion falls back to when a rate carries no explicit spread. It builds directly on ADR-014 (multi-currency and FX) and reuses its append-only rate history and provider seam.

57.1 Context

ADR-014 introduced FX conversion. Rates live in an append-only `fx_rates` table: each row is a full quote for a directed pair (base to quote), carrying a mid rate (`mid_rate_e8`, integer hundred-millionths of a quote unit per base unit) and a spread (`spread_bps`, basis points widened against the customer). The only way to put a rate in that table is the `FX_RATES` environment variable, parsed once at boot by `fx.seed`, which inserts one row per entry. A provider (`fx.Provider`) resolves the current rate for a conversion: it prefers a tenant-specific row over the global default (`tenant_id IS NULL`, added in migration 0014) and derives the inverse pair by inverting the mid when only the reverse

direction is stored.

Two gaps follow from that design. First, an operator cannot change a rate without editing the box's environment and restarting the service, which is slow, needs shell access, and is invisible to anyone using the API or console. Second, the spread is the operator's markup, their revenue on a conversion, but it is welded to each rate row: to run "half a percent on everything" an operator has to repeat the same `spread_bps` on every pair, and to change it they must re-enter every pair. There is no notion of a default markup that applies across pairs.

The console (ADR-019) is now an operator surface with admin panels, so live FX config is the natural next step: an operator should set rates and markup from the same place they manage tenants, keys, webhooks, and policy.

57.2 Decision

57.2.1 1. Rates and markup are set through the admin API, not only the environment

A new admin surface under `/v1/admin/fx` writes to the FX tables, using the same `admin` scope as the rest of the operator API:

- `POST /v1/admin/fx/rates` inserts a rate row for a directed pair.
- `GET /v1/admin/fx/rates` returns the current effective rates.
- `POST /v1/admin/fx/markup` inserts a markup-default row.
- `GET /v1/admin/fx/markup` returns the current markup defaults.

`FX_RATES` is kept as a boot-time bootstrap. `fx.Seed` still runs at every start and appends any changed rows, so a fresh deploy comes up with sane defaults and an operator can still pin rates in config if they prefer. The API is purely additive: it appends more rows to the same append-only history, it does not replace the env path. This is why keeping the env var costs nothing and removing it would only take a working fresh-deploy default away.

57.2.2 2. Markup gets a precedence chain, resolved at conversion time

The markup is no longer forced onto every rate row. `fx_rates.spread_bps` becomes nullable: a non-null value is a per-pair override, and null means “use the applicable default markup.” A new append-only table, `fx_markup_defaults`, holds one default per scope: (`id`, `tenant_id` NULL for global, `default_spread_bps`, `source`, `effective_at`, `created_at`), mirroring `fx_rates` exactly (server-stamped `effective_at`, a `[0, 10000)` check on the bps, a current-row index).

When a conversion runs, the effective spread is resolved in this order:

1. the pair’s `fx_rates.spread_bps`, if non-null (per-pair override);
2. the tenant’s current `fx_markup_defaults` ROW;
3. the global `fx_markup_defaults` ROW (`tenant_id` IS NULL);
4. zero, if nothing above is set.

Resolution happens at conversion time, not at rate-insert time. That is the central choice here. The alternative, freezing the default into each rate row when the row is written, is simpler (no nullable column, no second lookup) but it makes a standalone markup page a lie: setting

a new default would change nothing until the operator re-entered every rate. Convert-time resolution means “set 50 bps as the default” immediately governs every pair that does not override it, which is the whole point of a default.

Reproducibility is preserved the same way ADR-014 preserves it. `Convert` still takes a single concrete `spreadBps`, and `FXDetail` still snapshots the exact mid and spread a conversion used. The precedence chain only decides which concrete spread is handed to `Convert`; once a conversion is recorded, later changes to a default cannot rewrite what that conversion did. Mid-rate precedence (tenant row, then global, then inverse) is unchanged.

57.2.3 3. Both rates and markup are settable at global and per-tenant scope

The API takes a scope: a global write leaves `tenant_id` null, a tenant write sets it. This mirrors the resolution the provider already does (a tenant row wins over the global default) rather than inventing a new model. The console exposes this with the admin-tenant selector it already has, plus a Global/Tenant toggle, so the same page sets a platform default and a specific tenant’s override.

57.2.4 4. The console gets FX config in Settings

Two admin-gated cards on the console Settings view, alongside the existing admin panels:

- **Exchange rates:** the current pairs with their mid and effective

spread, and a form to add or update a pair (base, quote, mid rate as a decimal, an optional spread override). The console converts the decimal mid to `mid_rate_e8` for the API and back for display; no float ever reaches the money path, the API still takes and stores integers.

- **Markup fee:** the current global and tenant defaults, and a form to set a default in basis points (shown with a percent hint).

The console stays a thin client: it only calls `/v1/admin/fx`, holds no FX logic, and the server remains the gate.

57.3 Consequences

- An operator changes rates and markup live, from the API or console, with no redeploy and no shell access. The change is an append to history, so the full trail of what a rate was and when is preserved, exactly as ADR-014 intended.
- A default markup is set once and applies across pairs. Per-pair overrides still work for the pairs that need a different number.
- `fx_rates.spread_bps` is now nullable. Every pre-existing row keeps its concrete value and is treated as an explicit override, so no historical conversion changes meaning. New rows written without a spread store null and pick up the default.
- Conversions do a second small lookup (the markup default) only when a rate row's spread is null. The current-row lookups are single-row indexed reads on append-only tables, the same shape as the existing rate lookup.

57.4 Alternatives considered

- **Keep FX in the environment only.** Rejected: it was the problem. No live update, needs shell access, invisible to API and console users.
- **Freeze the default markup into each rate row at insert time.** Rejected as the primary model (see decision 2): it defeats a standalone markup default. Kept only as the mental model for a per-pair override, which is exactly a frozen spread on one row.
- **A separate markup table keyed per pair.** Rejected as over-built: the default is meant to span pairs, and per-pair precision is already available through the nullable `spread_bps` override on the rate row itself.
- **Mutable rate rows (UPDATE in place).** Rejected: it breaks ADR-014's append-only history and the immutable provenance that FX conversions snapshot.

57.5 Security note

The admin FX endpoints reuse the existing `admin` scope. There is no platform-superadmin tier distinct from a tenant admin, so any admin key can write global rates and the global markup default. For the single-operator v1 deployment (one operator running the whole system) that is acceptable, and it matches how the other global-ish admin actions already behave. A future multi-operator deployment would want a distinct platform-admin scope for the global writes; that is out of scope here and recorded so the gap is deliberate, not forgotten.

57.6 Out of scope (v1)

- A platform-superadmin scope separate from tenant admin (see the security note).
- Live external rate feeds. `source` still records provenance (“env” or “api”), so a future feed slots in as another source without a schema change.
- Scheduling a rate or markup to take effect in the future. `effective_at` is server-stamped at write time; future-dating is possible in the schema but not exposed by the API here.

ADR-021: Admin act-as-tenant for cross-tenant operator access

Status: Accepted Date: 2026-07-12

This ADR records letting an admin-scoped API key operate against a tenant other than the one its key belongs to, by sending an `X-Act-As-Tenant` header, so the operator console's tenant switcher can actually isolate the ledger and reporting views to the selected tenant. It builds on ADR-012 (auth and scopes), ADR-019 (the operator console), and the row-level security added during the remediation.

58.1 Context

Every `/v1` request resolves its tenant from the API key, not from any request field. The auth middleware hashes the bearer token, looks up the key, and puts the key's `tenant_id` into the request context; `tenantFromCtx` reads only that, and the write path sets the `app.tenant_id` GUC from it, which row-level security then enforces. This is the right default: the tenant comes from the credential, so a caller can never read or write another tenant's data by lying in a body or query.

The operator console (ADR-019) has a tenant switcher in its top bar. It works for the admin panels (keys, webhooks, policy) because those

endpoints take an explicit `tenant_id`. It does nothing for the ledger and reporting views (accounts, transactions, balances, statements, trial balance, disputes), because those endpoints take no tenant parameter at all: they are bound to the key's tenant. So an operator using the console with one admin key selects "tenant B" and still sees tenant A's accounts and transactions. The switcher looks broken.

The important observation is that an admin key is already effectively platform-level. The `/v1/admin` surface lets any admin key create tenants, issue a key for any tenant, and manage every tenant's policy and webhooks. An operator who wants to read tenant B's ledger can already do it in two steps: issue a read key for B via `POST /v1/admin/keys`, then call the ledger endpoints with that key. So cross-tenant access is not a new capability. What is missing is a one-step, ergonomic way to do the same thing the console can drive from its switcher.

58.2 Decision

58.2.1 1. An admin key may act as another tenant via a request header

A `/v1` request may carry `X-Act-As-Tenant: <tenant uuid>`. The auth middleware, after it resolves the key and checks scope, computes the effective tenant:

- If the header is present and non-empty AND the resolved key has the `admin` scope, the effective tenant is the header value.
- Otherwise the effective tenant is the key's own tenant, exactly as before.

The effective tenant is what goes into the request context, so `tenantFromCtx`, the `app.tenant_id` GUC, and row-level security all use it. Every `/v1` endpoint, read and write, then operates on the acted-as tenant with no per-endpoint change.

A malformed header (not a uuid) is a 400, so a typo fails loudly rather than silently reading an empty tenant. A non-admin key that sends the header is ignored and stays scoped to its own tenant: the gate fails safe to less access, never more.

58.2.2 2. Read and write both, not read-only

The override applies uniformly to all `/v1` operations, including posting transactions and creating accounts, not just reads. This matches what an operator console is for (select a tenant, then operate on it) and avoids a fragile per-endpoint carve-out. It grants no capability an admin key did not already have through the two-step key-issuing path, so the blast radius is unchanged: an admin key was always able to write to any tenant by first minting a key for it.

The `/v1/admin` endpoints are unaffected in practice: they target the tenant named in their own `tenant_id` body or query, not the context tenant, so overriding the context tenant does not change what they act on.

58.2.3 3. The acted-as tenant is not re-gated on status

The resolver already refuses a key whose OWN tenant is suspended or closed. The act-as override does not re-check the acted-as tenant's

status, because an operator legitimately needs to view and act on a suspended or closed tenant (that is often exactly why they are looking). Row-level security still isolates the data to that tenant; a non-existent tenant id simply resolves to an empty result set rather than an error, which is acceptable for a browse action.

58.2.4 4. The console uses one selected tenant for everything

The console's top-bar switcher now drives a single selected tenant that scopes both the admin panels (via `tenant_id`) and the ledger and reporting views (via `X-Act-As-Tenant`, sent on every `/v1` call when a tenant is selected). Switching tenant re-renders the current view, so the whole console isolates to the selected tenant at once. In demo mode the shared demo key is admin-scoped, so the switcher works for an anonymous demo visitor; in production it works when the operator has entered an admin key, and is inert (own tenant only) for a non-admin key.

58.3 Consequences

- The console's tenant switcher isolates the ledger and reporting views, not just the admin panels. Selecting a tenant shows that tenant's accounts, transactions, balances, and reports.
- The tenant an operator acts on is now explicit in the request (the header) and in the access log (the effective tenant is logged), so "who did what, as which tenant" stays reconstructible.

- Cross-tenant access is gated on the `admin` scope in exactly one place (the auth middleware), rather than spread across endpoints, so the security-relevant decision is easy to audit.
- Row-level security remains the backstop: even the acted-as path sets the GUC and goes through the same policies, so a bug in the override cannot leak across tenants past RLS.

58.4 Alternatives considered

- **A per-tenant key issued by the console on switch.** The console would mint a read key for the selected tenant and use it for ledger calls. Rejected: it creates keys as a side effect of browsing, leans on the rate-limited demo key to do the issuing, and litters each tenant with console-created keys. The header is stateless and leaves no residue.
- **A `tenant_id` query parameter on every read endpoint.** Rejected: it changes every operation's schema, is easy to apply inconsistently, and puts the cross-tenant decision in each handler instead of one gate. A single header handled in the middleware is one code path to reason about.
- **Honest UI, no switching.** Label the switcher admin-only and tell operators to paste a tenant's own key to browse it. Rejected: it is accurate to the old model but gives up the switching an operator obviously wants, and the two-step key path it points at is strictly more work than the header.

58.5 Security note

The override is deliberately gated on the `admin` scope, which in this system is already platform-level (it manages every tenant through `/v1/admin`). There is still no platform-superadmin tier distinct from a tenant admin (see ADR-020's security note), so any admin key can act as any tenant. For the single-operator v1 that is acceptable and matches the existing admin power. A future multi-operator deployment that wanted per-operator tenant scoping would gate the act-as override on a narrower, explicitly-granted set of tenants rather than on the blanket admin scope; that is out of scope here and recorded so the boundary is deliberate.

58.6 Out of scope (v1)

- Restricting which tenants a given admin key may act as (per-operator scoping).
- Re-checking the acted-as tenant's active status on the override path.
- An audit-log field distinguishing "acted as" from "own tenant" beyond the effective tenant already recorded.

ADR-022: USD-hub FX triangulation for cross-currency pairs

Status: Accepted Date: 2026-07-12

This ADR reverses one narrow decision from ADR-014: that FX conversion never routes through a third currency. It adds a single-hop triangulation through a fixed hub currency (USD) so a conversion between two non-USD currencies works when only each side's rate against USD is configured.

59.1 Context

ADR-014 built FX conversion around directly-stored rate pairs. The provider resolves a rate for base to quote by looking up the stored pair, or inverting the reverse pair, and it deliberately stops there: “this is deliberately not a multi-hop search through a third currency; v1 stores and inverts exactly the pairs the ledger needs.”

That was the right call when an operator hand-configured every pair they needed. It is the wrong call now that the demo (and the natural way an operator sets rates) is USD-based: rates are configured as USD to EUR, USD to BDT, USD to MYR, and so on. With only those, a conversion from EUR to BDT fails with “no rate for the pair,” even

though the two rates needed to compute it are both present. The operator sees a dead end for a conversion the system clearly has enough information to price.

59.2 Decision

59.2.1 1. When no direct or inverse pair exists, triangulate through USD

The provider gains a third fallback, tried only after the direct pair and the inverse pair both miss. To resolve base to quote where neither is USD:

1. Find the base to USD rate (a stored base to USD row, or the inverse of a stored USD to base row). Call its mid “USD per base.”
2. Find the USD to quote rate (a stored USD to quote row, or the inverse of a stored quote to USD row). Call its mid “quote per USD.”
3. The cross mid is $\text{USD_per_base} * \text{quote_per_USD} / \text{RateScale}$, computed in `big.Int` and range-checked, so it stays exact integer arithmetic and cannot overflow.

If either leg is missing, the fallback declines and the conversion still returns the same “no rate” error as before. So triangulation only ever adds successful conversions; it never changes an existing one.

USD is a fixed hub for v1, not configurable. That matches how rates are actually set here (USD-based) and keeps the fallback a single, well-understood hop rather than a general shortest-path search across

an arbitrary rate graph, which ADR-014 rightly did not want.

59.2.2 2. The markup is the base-to-USD leg's spread

A hub conversion applies one spread, resolved from the base to USD leg (the “sell side” the customer is leaving). This is a deliberate, simple rule: the customer converting EUR to BDT is charged the markup configured on EUR against USD, not some composition of two spreads. Composing spreads would double-charge the markup and is not what an operator setting “50 bps on EUR” expects. The resolved spread still runs through the ADR-020 precedence chain (per-pair override, then tenant default, then global default, then zero) on that base leg.

59.2.3 3. Provenance points at the base leg

`FXDetail` records a single `rate_id`. For a hub conversion it is the base to USD row's id, and the source and effective time are that row's. There is no single stored row for the cross pair, so the base leg is the honest anchor: it is the row whose rate and spread most directly shaped the result. The snapshot still records the concrete composed mid and the concrete spread applied, so the conversion remains fully reproducible from `FXDetail` alone regardless of later rate edits.

59.2.4 4. The console previews and labels the hub route

The convert page computes the same cross rate client-side for its live estimate, and when a conversion is routed through USD it shows a

short notification saying so, so the operator understands why the rate looks like a composition rather than a directly-configured pair.

59.3 Consequences

- A conversion between any two currencies that each have a USD rate now works, with no extra configuration. EUR to BDT prices off USD to EUR and USD to BDT.
- Nothing changes for a pair that has its own direct or inverse rate: that path still wins, so an operator who wants a bespoke cross rate can still set one and it takes precedence over the hub.
- A hub conversion rounds twice: once when the two mids are composed into the cross mid, and once when `convert` applies it to the amount. This is a deliberate, bounded imprecision for a convenience route; an operator who needs exactness on a specific cross pair sets that pair directly. The single-rounding guarantee still holds for every directly-configured pair.
- Reproducibility is unchanged: the composed mid and applied spread are snapshotted, so a recorded hub conversion always replays to the same numbers.

59.4 Alternatives considered

- **Seed every cross pair.** Rejected: it pushes the composition onto whoever sets rates, multiplies the number of rows to keep current, and drifts out of sync the moment one USD leg changes. The hub composes from the current legs at conversion time, so it is always

consistent with them.

- **A general multi-hop shortest-path search.** Rejected as over-built and exactly what ADR-014 warned against: it invites cycles, ambiguous routes, and arbitrage between paths. A single fixed USD hop is predictable and matches how rates are configured.
- **Composing both legs' spreads.** Rejected: it double-charges the markup and surprises an operator who set one number. One spread, from the base leg, is what “the markup on this currency” means.
- **A configurable hub currency.** Deferred: USD is the hub every demo and operator rate set uses today. A configurable hub is a small addition later if a non-USD-based deployment ever needs it; hardcoding USD now keeps the change minimal and the behavior obvious.

59.5 Out of scope (v1)

- A configurable or multiple hub currency.
- Multi-hop routes longer than one intermediate currency.
- Choosing the cheaper of several possible routes (there is exactly one: USD).

CHAPTER 60

ADR-023: Account hierarchy and rolled-up reporting

Status: Accepted Date: 2026-07-12

This ADR records adding a parent/child account hierarchy and rolled-up balances to go-ledger (Week 12: account hierarchy and reporting). It keeps the core invariant intact: balances stay derived from postings, never stored, and a rollup is a query, not a maintained number.

60.1 Context

An account is flat today: identity plus classification (name, type, currency, status), with its balance derived by summing its postings. Real charts of accounts are trees. “Assets” contains “Cash” and “Bank”; “Bank” contains “Checking” and “Savings”. An operator wants to read the balance of “Bank” and get the total across everything underneath it, not just its own direct postings.

The ledger is multi-currency with a per-currency zero-sum invariant, and its first principle (ADR-001, ADR-003) is that a balance is never a stored, mutable number: it is the sum of an append-only posting history. Any hierarchy feature has to respect both.

60.2 Decision

60.2.1 1. A self-referential parent_id, same-tenant and same-currency

`accounts` gains a nullable `parent_id` uuid. Same-tenant parentage is enforced at the database level by a composite foreign key (`tenant_id`, `parent_id`) REFERENCES `accounts` (`tenant_id`, `id`), reusing the UNIQUE (`tenant_id`, `id`) the table already has for postings. A cross-tenant parent simply cannot be inserted, the same guarantee postings already rely on.

A child must share its parent's currency. A subtree is therefore single-currency, which is what makes a rolled-up balance a single number rather than a map of currency to amount. This matches the per-currency invariant: you cannot meaningfully sum USD and EUR, so a tree that rolls up to one figure must be one currency. Mixed-currency grouping is deliberately out of scope (see alternatives).

60.2.2 2. Cycle prevention by a trigger

A BEFORE INSERT OR UPDATE OF `parent_id` trigger on `accounts` rejects three things: a self-parent (`parent_id = id`), a cycle (walking the ancestor chain from the proposed parent and finding the row itself), and a currency mismatch against the parent. The trigger is the guarantee; the service also checks and returns a clean error, but the database is the backstop that no code path can bypass. The cycle walk also bounds hierarchy depth in practice, so no separate depth cap is needed.

60.2.3 3. Rollup is a recursive CTE at query time, not a stored column

A parent's rolled-up balance is computed on demand: a `WITH RECURSIVE` query gathers the account and all of its descendants through `parent_id`, then sums the postings of that whole set. Nothing is denormalized.

This is the central choice. The alternatives, a materialized rollup column updated on every post and re-parent, or a closure table maintained on every parent change, are both faster to read and both wrong for this codebase. A stored rollup reintroduces exactly the mutable-balance state the whole ledger was built to avoid, and it drifts the moment a post or a re-parent misses an update. The recursive CTE keeps the balance derived and always correct, at a query cost that is negligible at this scale (indexed reads over a tenant's postings, the same shape as an ordinary balance read).

60.2.4 4. A parent can also carry its own postings

There is no rule that a parent must be an empty grouping node. A parent's rolled-up balance is its own postings plus every descendant's. This keeps the posting rules unchanged (any account can be posted to) and the rollup definition simple (sum the whole subtree, root included). An operator who wants a pure grouping node just does not post to it.

60.2.5 5. Rollups are additive display; the zero-proof stays on own balances

The trial-balance report gains a rolled-up balance per account alongside each account's own balance. But the per-currency net that proves the books balance is still computed from own (leaf-level) balances, because rollups double-count: a parent's rollup already includes its children, so summing every account's rollup would not be zero. The invariant proof is unchanged; the rollup is an extra, convenience figure for reading the tree.

60.3 API surface

- `POST /v1/accounts` accepts an optional `parent_id`.
- `POST /v1/accounts/{id}/parent` sets, changes, or clears an account's parent (re-parenting), cycle- and currency-guarded like creation.
- `GET /v1/accounts/{id}/balance?rollup=true` returns the rolled-up balance (own plus descendants); without the flag it returns the account's own balance exactly as before.
- `GET /v1/accounts/tree` returns the tenant's accounts as hierarchy rows (`parent_id`, `depth`, `own balance`, `rolled-up balance`), so a client can render the chart of accounts without walking it itself.
- `GET /v1/accounts NOW` returns `parent_id`.
- The trial-balance report account rows carry `rolled_up_balance`.

60.4 Consequences

- An operator reads a parent balance and gets the whole subtree, with no stored state to drift and no maintenance on posting or re-parenting.
- The core invariant is untouched: balances remain derived, and the zero-proof still holds on own balances.
- A re-parent is a single `parent_id` update, guarded against cycles and currency mismatch by the trigger; rollups reflect it immediately because they are recomputed on read.
- Deep trees pay a recursive-CTE cost on a rollup read. At demo and single-operator scale this is negligible; a future high-volume deployment that needed constant-time rollups could add a closure table behind the same repo method without changing the API.

60.5 Alternatives considered

- **Materialized rollup column.** Rejected: reintroduces stored mutable balance (against ADR-001/003) and drifts on any missed update.
- **Closure table.** Rejected for v1 as more moving parts than the scale needs; noted as the escape hatch if constant-time rollups ever matter.
- **Mixed-currency parents with per-currency rollups.** Rejected: a rollup would become a map of currency to amount, complicating every reader and the console, for a case the single-currency-subtree rule handles more simply.
- **Parents as pure grouping nodes (no direct postings).** Rejected:

it adds a posting-time rule and a re-parenting rule for no real gain; an empty parent is just a parent nobody posts to.

60.6 Out of scope (this week)

- Time-series analytics (transaction volume, balance-over-time). A follow-up.
- Mixed-currency grouping and multi-currency rollups.
- A closure table or any denormalized rollup.

ADR-024: Demo seeder writes audit events and purges visitor tenants

Status: Accepted Date: 2026-07-13

This ADR records two changes to the demo seeder (`internal/seed`), the in-process tool that resets and repopulates the public demo on a schedule. Both close inconsistencies a visitor could see at `go.sohag.pro`. Neither touches the core service path; the seeder remains a demo-only tool.

61.1 Context

The demo seeder writes rows directly (with backdated `created_at`, which the service does not allow) so a statement reads like real history. Two gaps surfaced in use:

1. **Seeded data had no audit trail.** A transaction posted through the API writes an `audit_outbox` row in the same transaction (ADR-017); the single background chainer later drains that into the tamper-evident `audit_log`. The seeder inserted transactions and postings but wrote nothing to the outbox, so every seeded transaction was invisible in the audit view, and the audit chain was blank for the prefilled data a visitor sees first. Live posts had a chain; seeded

posts did not. An inconsistency in the one feature the demo is meant to showcase.

2. **Visitor-created tenants accumulated forever.** In demo mode the admin panel is public (ADR-019), so any visitor can create tenants. The reset only ever touches the three fixed demo tenants (the personal budget, plus a bank and a company on fixed ids). Nothing removed the tenants visitors created, so they piled up across resets, and the safe-by-default api-key guard (ADR-015) actively refused to wipe any tenant holding its own key, which visitor tenants do.

61.2 Decision

61.2.1 1. The seeder emits the same audit event a live post does

For every seeded transaction the seeder inserts one `transaction.created` `audit_outbox` row, in the same seed transaction that writes the postings. Its `occurred_at` is the transaction's backdated time, which the chainer copies into `audit_log.created_at`, so the audit row lines up with the transaction it records. The `after` snapshot mirrors the shape the service's `auditSnapshot` produces (the transaction id plus a postings array of account, amount, currency, description), so the console renders amount and account for seeded rows exactly as it does for live ones.

The chainer then builds the chain for seeded data through the ordinary path. No new code path hashes or chains anything; the seeder only feeds the existing outbox. Seeded data is now indistinguishable from live data in the audit view and verifies as one continuous chain.

61.2.2 2. The demo reset purges every non-demo tenant, deliberately bypassing the ADR-015 guard

Each reset now deletes every tenant that is not one of the three demo ids, along with all of its data, before reseeding the demo tenants. The delete runs in one transaction across every tenant-scoped table in foreign-key-safe order (rows that reference `transactions` first, then `transactions`, then `accounts`, then the independent tables, then the `tenants` row last), with the append-only `audit_log` cleared under the same `audit.allow_purge` GUC the single-tenant reset already uses. The nullable-`tenant_id` FX tables keep their global rows.

This purge does **not** honor the ADR-015 api-key guard. That guard exists so a misconfigured `DEFAULT_TENANT_ID` pointed at a real tenant can never be wiped by a demo reset. But visitor tenants hold their own api keys, and removing them is the entire point here, so the guard would defeat the feature. The safety instead lives at the call site: the purge runs only from `runSeeder`, which starts only when `DEMO_MODE` and `SEED_ENABLED` are both on. It is never called from any non-demo path, and it refuses to run with an empty keep set (which would match every tenant), as a backstop against wiping the whole table by mistake.

61.3 Consequences

- The audit view and chain now cover seeded data, so the demo's headline feature is consistent from the first page load, with no special-casing in the reader.
- The public demo stays clean: visitor-created tenants live at most

until the next reset (default hourly, see `SEED_INTERVAL`), then vanish with all their data.

- The demo reset is now genuinely destructive to any tenant outside the demo set. Its blast radius is bounded entirely by the `DEMO_MODE + SEED_ENABLED` gate and the fixed keep set; a production deployment (demo mode off) never reaches the purge.
- The single-tenant `seed` path and its api-key guard are unchanged. The relaxed guard applies only to the new whole-database purge.

61.4 Alternatives considered

- **Write `audit_log` rows directly from the seeder.** Rejected: it would duplicate the chainer's per-tenant hashing and ordering logic (ADR-012, ADR-017) in a second place that could drift. Feeding the outbox reuses the one real implementation.
- **Purge with a grace period (delete only tenants older than one interval).** Rejected as needless complexity for a demo that resets frequently; a visitor's tenant surviving one extra cycle has no value.
- **Keep the api-key guard and skip tenants that hold keys.** Rejected: it would make the purge a no-op for exactly the tenants it exists to remove, since every visitor tenant created through the admin panel has a key.
- **Leave visitor tenants in place and just document it.** Rejected: the demo is a shared, public surface, and an ever-growing tenant list degrades it for the next visitor.

61.5 Out of scope

- Any change to the production service path. Both decisions are demo-tooling only, gated behind demo mode.
- Per-tenant deletion as a first-class API operation. The purge is a bulk demo-reset primitive, not a `DELETE /v1/tenants/{id}` endpoint.

ADR-025: Approval workflows and a lifecycle event stream

Status: Accepted Date: 2026-07-13

This ADR records adding an env-configured approval gate to go-ledger (Week 13: approval workflows and event streaming). An over-threshold transaction is held as pending and must be approved before it posts. Approval lifecycle transitions emit events onto the existing tamper-evident chain, which the webhook fanout already delivers. The core invariant is untouched: balances stay derived from postings, and nothing an approver has not cleared ever reaches postings.

62.1 Context

Every write path (post, convert, reverse) resolves its intended postings and then, in one database transaction, writes `transactions + postings` and an `audit_outbox` row that a background chainer later drains into the tamper-evident `audit_log` (ADR-012, ADR-017). There is no notion of a transaction that is authorized but not yet posted, and no control that holds a large movement for a second pair of eyes.

Two things have to be true for an approval feature to fit this codebase.

A balance is never stored, only summed from an append-only posting history, so a pending (unapproved) transaction must not create postings, or every balance read would have to learn to exclude them. And the audit chain is the ledger's integrity record: whatever carries approval events must not weaken the guarantee that the transaction history verifies bit-for-bit.

The plan also asks for “event streaming.” That backbone already exists: the webhook fanout worker reads `audit_log` by `chain_seq` and delivers events to subscribers. What is missing is events for the approval lifecycle, especially a rejection, which never becomes a transaction and so has no transaction id to hang off the existing transaction-scoped chain.

62.2 Decision

62.2.1 1. The gate: largest leg per currency, env-configured, off by default

`APPROVAL_ENABLED` (default off) turns the feature on. `APPROVAL_THRESHOLDS` is a per-currency map of minor-unit amounts (for example `USD:100000`, `EUR:90000`). After screening and before persistence, a shared gate computes the largest absolute posting amount per currency; if any currency's maximum exceeds its configured threshold, the transaction is held. A currency with no configured threshold is never gated. Judging per currency, on the single largest leg, matches the per-currency zero-sum invariant: there is no cross-currency total to compare against a single number.

62.2.2 2. Held as intent in a separate table, replayed on approval

A held transaction is written to a new `pending_transactions` table as its intended request (the legs, reference, effective time, and any convert/reverse parameters) in a `payload JSON` column, with `status = 'pending'`. Nothing touches postings or transactions. On approval the normal `CreateTransaction(payload)` path runs, so validation, the balance and currency triggers, and the ordinary `transaction.created` audit event all happen in exactly one place. Balances never reflect unapproved money, and there is no second posting path to keep correct.

Re-validation happens at approval, against current balances, not at creation. The pending stores intent; correctness is checked when it actually posts, so an approval that would now overdraw fails and leaves the pending untouched rather than posting stale, no-longer-valid money.

62.2.3 3. A dedicated approve scope, with an optional four-eyes flag

Authority is an api-key scope, not a new role. `approve` joins `read`, `post`, and `admin`, with `admin` a superset as before. A separate scope keeps “approve a large movement” distinct from “operate the tenant,” which is the point of the control. Self-approval is allowed by default so a single-key deployment (the demo) works; `APPROVAL_REQUIRE_DIFFERENT_ACTOR` (default off) enforces maker-checker (the approver’s actor must differ from the creator’s) when a deployment wants it. Shipping the flag, off, keeps the four-eyes control real and documented without breaking

the demo.

62.2.4 4. One tamper-evident stream, extended to carry lifecycle events

Rather than add a second event outbox, the existing audit chain is extended to carry non-transaction events. `audit_outbox` and `audit_log` gain a nullable `transaction_id`, a `subject_type/subject_id` pair, and a `hash_version` column. Existing transaction rows stay `hash_version=1` and hash exactly as before; approval lifecycle events are `hash_version=2`, whose hash preimage folds in the subject and tolerates a null transaction id. `ComputeAuditRowHash` and chain verification branch on the row's version, so a chain mixing v1 transaction rows and v2 lifecycle rows verifies end to end, and every existing row still recomputes to its stored hash.

This is the load-bearing risk of the week: the chain is the crown-jewel integrity feature, and versioned hashing is a new way it could break. The trade accepted here is one stream (one consumer, one fanout, one place to verify) in exchange for mixing lifecycle events into the integrity record and taking on a heavy verification-test burden (mixed-version chains, tampered v2 rows, and an all-v1 regression guard on existing data).

62.2.5 5. Gated paths, with a reverse exemption

Post, convert, and reverse are all gated by the threshold. A reversal is exempt in one case: when the transaction being reversed already cleared the gate (it has a linked `pending_transactions` row with `status='`

approved'). That money was approved once; forcing its correction to wait for a second approval would let a large erroneous posting trap the very reversal that fixes it. A reversal of a directly-posted large transaction is still gated.

62.2.6 6. Full lifecycle: cancel, expiry, idempotent decisions

pending is the only non-terminal state. Beyond approve and reject, the creator can cancel a pending (a distinct terminal state from an admin reject), and an untouched pending expires after `PENDING_TTL` (default 72h) via a background sweep that mirrors the idempotency sweep. Every decision takes a row lock, so two racing decisions cannot both win; the loser sees a terminal state and gets a

409. Approving an already-approved pending returns the same transaction id (idempotent). A gated create consumes its idempotency key against the pending, so a replay returns the same pending rather than creating a second one.

62.3 Events

All lifecycle events are v2 chain rows with `subject_type='pending_transaction'` and `subject_id` the pending id, written to `audit_outbox` in the same transaction as the state change and drained by the existing chainer, exactly once per committed transition:

- `approval.requested` (gated create), `approval.approved` (also carries the

posted transaction id), `approval.rejected`, `approval.cancelled`, `approval.expired`.

An approved over-threshold transaction produces two chain rows: the `approval.approved` lifecycle event and the ordinary `transaction.created` event. Webhooks fan these out with no new source; the payload builder learns to render a subject-based (non-transaction) event.

62.4 API surface

- Create paths keep their request shape; the response is 201 with the posted transaction when under threshold, or 202 with the pending resource when gated.
- `GET /v1/pending`, `GET /v1/pending/{id}` (read scope).
- `POST /v1/pending/{id}/approve` and `/reject` (approve scope; admin satisfies it).
- `POST /v1/pending/{id}/cancel` (creator only).
- The console gains a thin-client Approvals panel over these endpoints.

62.5 Consequences

- A large movement is held for a second pair of eyes (or the same eyes, by configuration), then posts against current balances, with the whole lifecycle on the tamper-evident stream and out to webhooks.
- The core invariant is intact: no unapproved postings exist, balances stay derived, and the transaction chain still verifies. The feature is

entirely opt-in (`APPROVAL_ENABLED=false` by default).

- The audit chain now carries non-transaction events. Every consumer that reads `audit_log` (verify, webhooks, the audit view) must tolerate a null transaction id and a subject reference. Chain verification is version-aware.
- The single largest risk is the versioned hash; it is mitigated by test coverage, not by design simplicity, and is called out as such.

62.6 Alternatives considered

- **A separate `event_outbox` for lifecycle events.** Cleaner separation and lower risk to the integrity chain, at the cost of a second event source the webhook fanout would have to union. Rejected in favor of one stream, with the test burden accepted as the price.
- **Status column on transactions instead of a pending table.** Rejected: it puts unapproved postings in the table and forces every balance and report query to filter by status, reintroducing exactly the kind of stored, status-dependent state the ledger avoids.
- **Reuse the `admin` scope for approval.** Rejected: it conflates operating the tenant with authorizing money movement, and a dedicated scope is cheap.
- **Enforce four-eyes always.** Rejected as the default: it would make the single-key demo unable to approve its own held transactions. Kept as a flag.
- **Gate reversals unconditionally.** Rejected: it lets a large erroneous posting block the reversal that corrects it; a reversal of already-approved money is exempt.
- **Total-debits-per-currency or a single global threshold as the gate.** Rejected: gross-debit obscures which leg is large, and a single

global number ignores that currencies differ in scale; largest-leg-per-currency is the clearest fit for the per-currency invariant.

62.7 Out of scope (this week)

- Approval hierarchies or N-of-M sign-off; four-eyes is a single actor-difference flag.
- `account.created` as a chained event (the chain can now carry it; it is not wired this week).
- Per-tenant configurable thresholds (env-global only).

ADR-026: Security and correctness hardening from an external audit

Status: Accepted Date: 2026-07-14

This ADR records a batch of hardening changes made in response to an external audit of the codebase (a professional-grade review by a Go/fintech engineer). The audit found the core double-entry invariant sound and unbreakable, but flagged a set of authorization-integrity, safety, and correctness gaps. This records the decisions behind fixing them. Nothing here changes the core invariant: balances stay derived from an append-only posting history, enforced per currency in the domain type and by the deferred database constraint trigger.

63.1 Context

The audit rated the system “would not trust it with real money today” not because money could be created or destroyed (it cannot) but because a few controls did not deliver what they claimed, and a few reads and error paths were not production-safe. The findings that drove code changes, and the decisions taken, are below. The changes are deliberately backward-compatible and default-off where a new guarantee needs an operator secret, so the demo deployment and any existing clone behave exactly as before until the operator opts in.

63.2 Decisions

63.2.1 1. The audit actor is the API key, not the tenant

Every audit event and every held pending's `CreatedBy` stamped the tenant id as the actor. That made two things impossible: attributing an action to an individual principal, and enforcing maker-checker. The four-eyes flag (`APPROVAL_REQUIRE_DIFFERENT_ACTOR`) compared tenant against tenant, so it was either a no-op (flag off) or a self-deadlock that blocked every approval (flag on), and a single admin key could create and approve the same over-threshold movement. ADR-025 had claimed the control was real; the code did not deliver it.

Decision: thread the individual API-key id (`auth.PrincipalID`) as the acting principal through the money paths, via a `ledger.WithActor` context value the API and gRPC layers set from the resolved key. `holdForApproval` stamps the creating key as `CreatedBy`; approve/reject/cancel record the deciding key; the transaction and lifecycle audit events record the acting key. Background paths (the pending sweep, the demo seeder) carry no principal and fall back to the tenant id, unchanged. With this, `APPROVAL_REQUIRE_DIFFERENT_ACTOR` compares two distinct keys and is a real maker-checker control. It stays off by default so the demo (a single key that both creates and approves for demonstration) is unchanged; a production deployment turns it on and issues separate maker and checker keys.

We chose per-key rather than introducing a separate user/role model: the API key is already the authenticated principal in this system, and a heavier identity model is out of scope for v1.

63.2.2 2. Audit anchors are signed with an app-held key

`VerifyFromLatestAnchor` trusts the latest `audit_anchors` row as a checkpoint and only re-walks the tail past it. But `audit_anchors` lives in the same database a privileged attacker controls, so a consistent rewrite of `audit_log` plus a matching rewrite of `audit_anchors` would pass verification. The tamper-evidence claim was only as strong as an off-box log-shipping setup the code did not enforce.

Decision: anchors carry an HMAC-SHA256 over (`tenant_id`, `chain_seq`, `row_hash`) keyed by `AUDIT_ANCHOR_SIGNING_KEY`, a secret the database role does not hold (migration 0037 adds the nullable `signature` column). The anchor job signs each anchor; `VerifyFromLatestAnchor`, when a key is configured, requires a valid signature before trusting the anchor. A forged `row_hash` the attacker cannot re-sign is reported as not verifiable rather than trusted; an unsigned anchor predating the key falls back to a full from-genesis verify. This closes the in-database forgery path against a DB-privileged attacker. A full consistent rewrite that also downgrades the anchor to unsigned is still ultimately caught only by the off-box anchor copy, which remains the external ground truth; the signature is defense in depth, not a replacement for it. Off by default and unset in the demo, so the console's audit-verify panel is unchanged there.

63.2.3 3. FX rate staleness guard plus a free live feed

Conversions priced against whatever the latest stored rate was, with no maximum age. With env-seeded v1 rates and no live feed, a long-running deployment would happily convert real money against a

weeks-old rate: a direct loss and arbitrage vector.

Decision: add `FX_MAX_RATE_AGE`. A conversion whose resolved rate (direct, inverted, or hub-composed) is older than this is refused with a stale-rate error instead of pricing against it; a hub cross is dated by its older leg. The guard is 0 (disabled) by default so nothing breaks silently. To keep the guard from starving conversions without a paid data provider, add an optional feed (`FX_FEED_ENABLED`) that polls a free, keyless, ECB-backed provider (Frankfurter, daily) and appends fresh global rows, deduping against the current stored mid so an unchanged rate does not append a row every interval. We chose Frankfurter specifically because it needs no API key and no account, which suits a portfolio-scale, open deployment; the provider URL is configurable so it can be pointed elsewhere.

While here, a related pricing bug: a USD-hub cross conversion applied only the base leg's spread, so a two-hop conversion was widened by one markup instead of two, underpricing cross pairs against the equivalent pair of direct conversions. Hub conversions now widen by both legs' spreads (summed, capped).

63.2.4 4. Webhook SSRF egress control and a signed timestamp

The webhook worker would POST to any address a tenant named, including internal ones (`localhost`, cloud metadata, RFC1918), and followed redirects.

Decision: deliveries dial through a transport whose control hook rejects loopback, link-local (including the metadata IP), private, unique-

local, CGNAT, unspecified, and multicast addresses. The check runs post-DNS on the concrete IP, closing the DNS-rebinding window, and re-applies on every redirect hop since each dials through the same transport. `WEBHOOK_ALLOW_PRIVATE_TARGETS` (default false) re-enables private delivery for a demo or self-hosted deployment whose receivers legitimately live on a private network. The signature now covers a send timestamp (`X-Ledger-Timestamp`, signed as `"<ts>.<body>"`) so a subscriber that bounds timestamp freshness is protected against replay of a captured delivery.

63.2.5 5. Smaller correctness and safety fixes

- **Bounded reads.** The account tree and trial-balance endpoints built a response over every account with no limit. Both queries now cap at `MaxReportRows+1` and the service refuses an over-large result rather than building an unbounded response in memory. The cap is far above any demo/portfolio tenant, so the console is unchanged.
- **Idempotency double-post windows.** A request held as a pending under an idempotency key could post a second transaction if the approval gate was reconfigured off before the client retried; Post and Convert now dedup against an existing pending for the key. The separate post-TTL late-retry window is a standard bounded-idempotency tradeoff, documented with the per-tenant reference mitigation.
- **gRPC held-transaction mapping.** An over-threshold write over gRPC returned a generic `Internal` that looked like a server fault; it now maps to `FailedPrecondition` naming the pending id.
- **Fail-fast config and safe shutdown.** The server now refuses to boot on a set-but-unparseable env value (rather than silently sub-

stituting a default), the graceful-shutdown budget is configurable (SHUTDOWN_TIMEOUT), and a server error drains the servers before returning instead of racing the pool close.

- **CSV formula injection.** Export cells that are free text and begin with a formula trigger are neutralized so a spreadsheet renders them literally.

63.3 Consequences

The controls the system advertises now hold: maker-checker is real when enabled, the audit anchor is tamper-evident against a DB-privileged attacker when signed, and conversions refuse stale rates when a max age is set. Every new guarantee is opt-in behind an operator secret or flag, so the demo and existing deployments are unchanged until configured. The audit's remaining items that were accepted as fine for a demo deployment (the seeder's blast radius, the public demo admin key, the absence of production Prometheus and offsite backups) are deliberately not addressed here: they are operational choices of the demo box, documented in the audit report, not defects in the service code.

CHAPTER 64

ADR-027: Webhooks

Status: Accepted Date: 2026-07-14

This ADR records go-ledger’s webhook delivery: how a tenant subscribes to ledger events, how deliveries are signed, and how they are delivered at least once off the tamper-evident event stream. It is written in Week 14, the final week, and it is deliberately retroactive: the webhook code shipped in an earlier week without its own ADR, breaking the project’s “an ADR before the code” rule. Writing it now, after the fact, is the honest correction, and the gap itself is one of the retrospective’s lessons.

64.1 Context

The plan’s Week 14 asked for “webhooks: per-tenant subscriptions, signed delivery, retry with backoff, delivery log,” consuming the Week 13 event stream. By the time this feature was built, the pieces it needed already existed. The audit chain (ADR-012, ADR-017) is an append-only, `chain_seq`-ordered, tamper-evident log of every ledger event, produced by a single-leader background chainer that drains the `audit_outbox` into `audit_log`. Approval lifecycle events (ADR-025) already ride that same chain. So “event streaming” was not a new system to stand up; it was a consumer to add.

The constraints a payment webhook has to satisfy shaped the design:

- A receiver must be able to verify a delivery came from the ledger and was not tampered with in flight, and must be able to reject a replayed capture.
- Delivery must survive a crash mid-send: a committed ledger event must eventually reach a healthy subscriber even if the process dies between the event and its delivery. That means at-least-once, and that means a receiver must be able to deduplicate.
- A slow or hostile subscriber URL must not be able to stall the ledger, exhaust it, or turn it into a proxy for reaching internal services.
- More than one app instance runs at a time, so exactly one of them must own the fan-out cursor, exactly as the chainer owns the chain.

64.2 Decisions

64.2.1 1. Fan out off `audit_log`, not the raw outbox

The webhook worker reads `audit_log` by `chain_seq`, the chained durable stream, not `audit_outbox` (the pre-chain buffer). Delivering off the chained log means webhooks see events in the same total order, and with the same durability, as the tamper-evident record: a webhook is never sent for an event that is not yet part of the verified chain. A per-worker fan-out cursor over `chain_seq` turns each new chained event into one `webhook_deliveries` row per matching subscription (migration 0021: `webhook_subscriptions`, `webhook_deliveries`).

64.2.2 2. Single leader, its own advisory lock

Running one worker per app instance is the intended shape. Like the chainer, the worker takes a Postgres session advisory lock and only the holder runs a fan-out-then-delivery pass; the rest wait. The web-hook lock key (4_921_018) is deliberately distinct from the chainer's (4_921_017): the two guard unrelated resources (the hash chain vs. the fan-out cursor), so they must never contend on one key. One leader means the fan-out cursor has a single writer and each event fans out once, regardless of how many instances run.

64.2.3 3. Per-tenant subscriptions with an optional event filter

A `WebhookSubscription` is a tenant's registered callback: a URL, plus an optional list of event types. An empty list means "every event"; a non-empty list delivers only matching actions (for example `transaction.created`). The signing secret is generated at creation, shown to the caller exactly once, and never returned again by any read path (the subscription type carries no secret field), so a leaked list response cannot reveal it.

64.2.4 4. Signed, timestamped deliveries; receiver dedup for at-least-once

Each delivery is a POST carrying:

- `X-Ledger-Signature: sha256=<hex HMAC> OVER "<unix-ts>.<body>"`, keyed by

the subscription secret.

- `X-Ledger-Timestamp`: the Unix-seconds send time, part of the signed content, so a subscriber that bounds timestamp freshness rejects a replayed capture (added in the audit-remediation pass, ADR-026).
- `X-Ledger-Delivery-Id`: the delivery row id, stable across every retry of the same event, so a receiver deduplicates repeat deliveries by it. This is what makes at-least-once safe for the receiver: the ledger guarantees delivery, the receiver guarantees idempotency.
- `X-Ledger-Event`: the event type.

The body is re-marshaled from a fixed Go type on every attempt (Postgres does not preserve a jsonb value's original bytes), so every retry of a row signs and sends byte-identical content.

64.2.5 5. Retry with exponential backoff, then dead-letter

A delivery is `pending`, then on a `2xx` it is `delivered`. Any other status or a transport error schedules the next attempt at `now + backoff` and leaves it `failed`; backoff is exponential from a 10s base, capped at 10 minutes. After `MaxAttempts` (8) the row is marked `dead` and never retried. The `webhook_deliveries` table is the delivery log: every attempt count, last error, and terminal state is queryable, so an operator can see what a subscriber missed.

64.2.6 6. SSRF egress guard

The delivery client dials through a transport that refuses to connect to a non-public address (loopback, link-local including the cloud meta-

data IP, private, unique-local, CGNAT, unspecified, multicast). The check runs post-DNS on the concrete IP, closing the DNS-rebinding window, and re-applies on every redirect hop. `WEBHOOK_ALLOW_PRIVATE_TARGETS` (default false) re-enables private delivery for a demo or self-hosted deployment whose receivers live on a private network. This was added in the audit-remediation pass (ADR-026); without it a tenant could name an internal URL and have the money service fetch it.

64.3 Consequences

Webhooks reuse the event backbone the ledger already had, so there is no second system to run (no Kafka, per the scope discipline): the same chained log that proves the ledger's integrity is the stream subscribers consume. Delivery is at-least-once, which pushes an idempotency requirement onto receivers, made tractable by the stable delivery id. The trade the design does not make is exactly-once or ordered-per-subscriber delivery: retries and the fan-out model mean a subscriber can see a duplicate or an out-of-order delivery, and must tolerate both. For a v1 that is the right cost: the alternative is per-subscriber ordering state and a distributed dedup the receiver is better placed to own.

Glossary

A quick reference for the terms this book leans on. Definitions are scoped to how the term is used in go-ledger, not the whole field.

Double-entry accounting. The rule that money never appears or disappears, it only moves. Every transaction is two or more postings that sum to zero.

Posting. A single signed entry against one account, part of a transaction. Postings are append-only and are never edited or deleted.

Transaction. A set of two or more postings that must sum to zero. The unit of atomic change in the ledger.

Balance (derived). An account's balance is the sum of every posting that ever touched it, computed on read, never stored as a mutable number. The history is the source of truth.

Running balance. The cumulative total shown next to each row of an account statement, recomputed from the postings on every read rather than stored: the same derived-balance rule applied row by row.

Minor units. Money stored as an integer in the smallest unit of the currency (for example cents), never as a floating point value, so no rounding error can creep in.

pgx and sqlc. pgx is the Postgres driver the data layer runs on; sqlc generates type-safe Go functions from hand-written SQL, so there is no ORM between the code and the database.

goose. The migration tool that applies the schema's SQL files in order. Integration tests run it against a fresh database container before exercising it.

chi. The lightweight, idiomatic Go HTTP router the REST API is built on.

huma. The Go framework the REST API is defined with, where each endpoint is a typed function and the OpenAPI spec is generated from that same code, so the docs cannot drift from the API.

Composite foreign key. A foreign key across a pair of columns, here (`tenant_id`, `id`), so Postgres itself rejects a posting that points at an account in a different tenant rather than trusting every query to filter correctly.

Deferred constraint trigger. A database trigger set to fire once at `COMMIT` rather than after each row, which is how the ledger checks that a whole transaction's postings sum to zero even though the rule spans multiple rows.

Idempotency key. A client-supplied identifier on a money-moving request. If the same key arrives twice, the server returns the first result instead of posting a second time, so a retry after a dropped response cannot double-post.

WAL (write-ahead log) and fsync. Postgres records every change to this log before applying it, and `fsync` is the disk flush that makes a commit durable. The ledger's write latency is dominated by waiting on that flush, not by application code, and that durability is never traded away for speed.

SERIALIZABLE. The strongest SQL isolation level. Concurrent transactions behave as if they ran one after another, which is what a correct ledger needs.

Serialization failure (SQLSTATE 40001). The error Postgres raises when it cannot safely order two concurrent **SERIALIZABLE** transactions. The application retries the transaction rather than returning an error.

SSI (Serializable Snapshot Isolation). The technique Postgres uses to provide **SERIALIZABLE** without heavy locking. A transaction's view is fixed at its first query, which is why a later conflict is detected and one side is aborted.

Predicate lock (and phantom conflict). Under **SERIALIZABLE**, an unindexed scan locks the whole range it read, not just the matching rows. Two transactions touching unrelated data can then collide on that wide lock and abort as if they had genuinely conflicted, a phantom conflict caused by a missing index rather than real contention.

Audit log. An append-only record of significant events, protected by a database trigger that rejects updates and deletes.

Hash chain (tamper-evident). Each audit row stores a hash of its own contents plus the previous row's hash. Changing any row breaks its hash and the next row's back-pointer, so tampering is detectable, not just discouraged.

Property-based testing. Tests that assert a property holds for many randomly generated inputs, rather than checking a few hand-picked cases. Used here to stress the balance invariant, and it found a real integer-overflow bug.

Chaos testing. Deliberately injecting failures (a killed connection, a lost acknowledgement) to prove the system recovers correctly. go-ledger uses toxiproxy to inject failures at exact moments.

testcontainers-go. Boots a real, disposable Postgres (and, for chaos tests, toxiproxy) in Docker for each test run, so tests exercise the actual database engine instead of a mock.

k6. The load-testing tool used to fire real HTTP traffic at the running service, both in the CI smoke test and the throughput runs.

Race detector. The `-race` flag built into the Go toolchain, which turns a data race from an occasional flaky failure into a reproducible one. CI runs the whole suite with it on.

Coverage gate. A CI check that fails the build if test coverage falls below a floor, with generated code excluded so the number reflects hand-written code.

Tenant. The owner boundary for data. Every account and transaction belongs to a tenant, and the tenant is derived only from the caller's API key, never from a request field.

API key. A bearer credential (`Authorization: Bearer ...`) stored only as a SHA-256 hash, so a database dump leaks no usable key. It identifies the tenant and carries a per-key rate limit.

Token bucket. The rate-limiting algorithm behind the per-key limits: each key gets an allowance that refills over time, and a request over the limit gets a 429 instead of being served.

Keyspace pagination. A pagination style where each page's cursor is

the last row actually returned, not a row count, so new inserts never shift the pages underneath a client mid-scroll, unlike limit and offset.

RFC 7807. The “Problem Details for HTTP APIs” standard, a consistent JSON shape for error responses.

gRPC. A high-performance RPC framework over HTTP/2 with typed messages defined in protobuf. go-ledger exposes the same domain services over both REST and gRPC.

Protocol Buffers (protobuf) and buf. protobuf is the typed schema language gRPC messages are defined in; buf is the tool that lints that schema and generates the Go server and client code from it.

OpenTelemetry, trace, span. A vendor-neutral standard for telemetry. A trace follows one request end to end; a span is one timed step within it, such as a single SQL query.

OTLP. The OpenTelemetry Protocol, the wire format traces are exported in. go-ledger sends OTLP over HTTP rather than gRPC because it is the lower-ops, firewall-friendly choice.

RED method. A metrics convention that tracks three signals per endpoint: Rate (requests per second), Errors (how many fail), and Duration (how long they take). It is the shape of the service’s Prometheus metrics.

Prometheus. A metrics system that scrapes a `/metrics` endpoint and stores time series, used here for request and database counters and histograms.

slog. Go’s standard structured logging package. go-ledger logs JSON

only, no `fmt.Println`.

VPS (virtual private server). One rented Linux box administered directly, as opposed to managed cloud services. `go-ledger` deploys to a single VPS rather than AWS ECS or Terraform.

Distroless. A minimal container base image with no shell or package manager, only the application and its runtime, so the image is tiny and its attack surface is small.

Multi-stage build. A Dockerfile that compiles in a heavy build image and copies only the finished binary into a small runtime image, so the toolchain never ships.

Ansible, idempotent. A configuration-management tool that describes a server's desired state. Idempotent means running it again only changes what has drifted, so a re-run is safe and a second run reports no changes.

systemd unit. The service definition that runs the app on the server, with a hardened sandbox (no new privileges, read-only filesystem, and more).

Reverse proxy (nginx). A server that sits in front of the app and forwards requests to it. Here `nginx` also terminates TLS and routes two separate sites that share the same box.

certbot and Let's Encrypt. Let's Encrypt is the free certificate authority; `certbot` is the tool that requests and auto-renews its TLS certificates, keeping HTTPS valid without manual work.

HSTS preload. A browser rule that forces every subdomain of a site

to always serve valid HTTPS with no override. It is why a broken certificate on a shared box is dangerous.

Further Reading

The sources and standards behind the decisions in this book. Where a chapter or an ADR leans on an idea, this is where the idea comes from.

Accounting and money

- **Double-entry bookkeeping.** The 500-year-old idea underneath every ledger. Any solid accounting primer covers the debit-and-credit rule; the one that matters here is that postings sum to zero and balances are derived, never stored.
- **Martin Kleppmann, “Designing Data-Intensive Applications.”** The reference for thinking about correctness, replication, and consistency in data systems. The chapters on transactions and consistency map directly onto the ledger’s concerns.

Databases and concurrency

- **PostgreSQL documentation: Transaction Isolation.** The precise behavior of READ COMMITTED, REPEATABLE READ, and SERIALIZABLE, including what a serialization failure means and why the application must retry it.
- **Serializable Snapshot Isolation (SSI).** The technique Postgres uses to offer SERIALIZABLE without heavy locking, from the work

of Cahill, Rohm, and Fekete, later brought to Postgres by Kevin Grittner and Dan Ports. Explains why a waiting transaction can still abort.

- **pgx and sqlc.** The Go Postgres driver and the type-safe query generator used throughout the repository; their documentation covers pooling, tracing hooks, and generated query code.

APIs and protocols

- **RFC 7807, Problem Details for HTTP APIs.** The consistent JSON error shape the REST layer returns.
- **RFC 9110, HTTP Semantics.** The definition of idempotent methods, the backdrop for why a money-moving POST needs an explicit idempotency key.
- **gRPC and Protocol Buffers documentation.** The typed, HTTP/2 RPC layer, and buf for managing the protobuf schema.

Testing

- **The Go race detector.** Built into the toolchain with `-race`, it turns a data race from an occasional mystery into a reproducible failure.
- **pggregory.net/rapid.** The property-based testing library used to stress the balance invariant and the money type.
- **testcontainers-go.** Runs real Postgres (and toxiproxy) in Docker for integration and chaos tests, so tests run against the real database, not a mock.
- **toxiproxy.** A programmable network proxy for injecting failures

(latency, dropped connections, lost acknowledgements) at exact moments.

- **k6.** The load-testing tool used for the smoke load in CI and the multi-tenant throughput runs.

Observability

- **OpenTelemetry specification.** The vendor-neutral standard for traces, metrics, and logs, and the Go SDK used to instrument the service.
- **Prometheus documentation.** The metrics model, the exposition format, and how a `/metrics` endpoint is scraped.

Operations and deployment

- **Distroless base images (GoogleContainerTools/distroless).** Why a runtime image with no shell or package manager is smaller and safer.
- **Ansible documentation.** Roles, idempotency, and check mode, the basis for the infrastructure-as-code that reproduces the server.
- **systemd service and sandboxing options.** The unit directives (NoNewPrivileges, ProtectSystem, and the rest) that harden the running process.
- **Let's Encrypt and certbot.** Automatic TLS certificates and renewal.
- **The Twelve-Factor App.** The backdrop for treating configuration, logs, and processes the way this service does.

The build itself

- **The go-ledger repository:** github.com/sohag-pro/go-ledger. Every line of code, schema, migration, and ADR discussed in this book, running and tested.
- **The live service:** go.sohag.pro, with an interactive API playground.
- **The weekly series:** notes.sohag.pro/series/go-ledger, the posts these chapters are drawn from.

≡ go-ledger

BONUS ROUND: HARD MODE

01 The Interview That Never Ends

CHAPTER 65

The Interview That Never Ends

You found it: the bonus round. These are the questions a senior interviewer asks once you have explained every week on its own, the ones that live in the seams between weeks and down in the Go runtime. Every one is answerable from this repo's code, ADRs, and migrations. No warm-ups here.

65.1 Go internals and the runtime

65.1.1 1. RunInTx's retry backoff waits with `select { case <-ctx.Done(): ... case <-time.After(retryBackoff(attempt)): } instead of a plain time.Sleep. Why does the wait have to watch the context, and what does a cancelled request context do to a post mid-retry?`

What a strong answer covers:

- `RunInTx` in `internal/postgres/repository.go` replays a `SERIALIZABLE` unit of work up to `maxPostAttempts` (25) times, sleeping `retryBackoff(attempt)` between attempts; a bare `time.Sleep` would ignore a client that already hung up, so the server keeps burning a pool connection and retry budget on work nobody is waiting for.

- Selecting on `ctx.Done()` means a cancelled or timed-out request returns `ctx.Err()` immediately instead of finishing the backoff, and commit 6169ac2 made this same discipline apply to the per-tenant mutex wait that existed before ADR-017.
- The cleanup rollbacks use `context.WithoutCancel(ctx)` (see the `tx.Rollback` calls) precisely because the request context may already be dead but the connection still needs releasing.
- Ties to `pgx`: an in-flight query on that connection is itself bound to `ctx`, so cancellation propagates down to the database, not just the Go-side sleep.

The trap: Saying `time.Sleep` is fine because the backoff is short. Under a burst of serialization conflicts, 25 attempts of capped backoff plus a held connection per abandoned request is exactly how a small pool gets exhausted by clients who already left.

65.1.2 2. When a client's request context is cancelled while a posting query is running inside `pgx`, what actually happens to the in-flight statement, and why do the rollback paths deliberately detach the context?

What a strong answer covers:

- Every `pgx` call in `repository.go` takes `ctx`; cancelling it makes `pgx` send a cancel request for the running query and return a context error, so the transaction does not linger holding row locks.
- The rollbacks (`_ = tx.Rollback(context.WithoutCancel(ctx))`) in both `RunInTx` and `withTenant`) use a detached context so the ROLLBACK still reaches Postgres even when the original context is the very thing that was cancelled; otherwise cleanup would itself be cancelled

and the connection would be returned to the pool in a bad state.

- The GUC `set_config('app.tenant_id', $1, true)` is transaction-local, so an aborted attempt cannot leak a tenant id onto the next borrower of that pooled connection.
- A Go-level mutation done before the abort (for example `t.EffectiveAt` being resolved in `txRepo.CreateTransaction`) is NOT undone by the SQL rollback, which is why `Post snapshots before up front`.

The trap: Assuming a SQL ROLLBACK also reverts Go struct fields the closure mutated. The database state rolls back; the in-memory `*domain.Transaction` does not, and the fingerprint code in `service.go` has to account for that.

65.1.3 3. Walk the full goroutine lifecycle of the background audit chainer. Who starts it, how it decides it is allowed to write, how it stops on shutdown, and what happens to a posted transaction whose chain link does not exist yet.

What a strong answer covers:

- `cmd/server/main.go` builds `audit.NewChainer(...)` and runs it as `go chainer.Run(ctx)` with its own `context.WithCancel`, cancelled on shutdown; there is no `WaitGroup`, stopping is by context cancellation and Postgres releasing the session advisory lock when the connection closes.
- Run loops: try `pg_try_advisory_lock(4_921_017)` on a dedicated `pool.Acquired` connection (`leadWhileHeld`), and only the winner drains `audit_outbox`; a follower releases the connection and retries on the `interval` ticker without holding a connection while it waits.
- A committed-but-not-yet-chained transaction is durable in

`audit_outbox` but absent from `audit_log`; `AuditService.VerifyResult.Pending` (from `CountPendingOutbox`) reports how many such rows exist, which is a lag signal, not corruption (ADR-017 section 5).

- Graceful loss of leadership: if the lock session dies, the next drain query on that pinned connection fails and `leadWhileHeld` returns, re-contending like any follower.

The trap: Describing the chainer as a per-request or per-post goroutine. It is exactly one leader-elected worker draining an outbox; the post never waits on it, which is the whole point of decoupling the chain from the hot path.

65.1.4 4. The posting goroutine writes an `audit_outbox` row and the chainer goroutine later reads it and hashes it. There is no shared memory between them. In Go memory model terms, how is the write safely observed by the reader, and why is that not a data race?

What a strong answer covers:

- The handoff is through Postgres, not shared Go memory: `AppendAuditOutbox` inserts a row inside the poster's `SERIALIZABLE` transaction (`repository.go`), and the chainer reads it back with `ScanUnprocessedAuditOutbox` only after the poster's transaction commits.
- The happens-before edge is the database transaction boundary plus the `xmin` watermark: the chainer processes only rows whose `txid` is below `pg_snapshot_xmin(pg_current_snapshot())` (ADR-017 decision 2, migration 0015), so it never reads a value from a transaction that has not committed.

- `-race` sees no shared variable between the two goroutines because there is none; correctness rests on Postgres visibility rules, not on Go synchronization primitives.
- Even the in-batch per-tenant `lastHash` map in `chainOne` is confined to a single goroutine (the leader), so it needs no locking.

The trap: Reaching for a channel or a mutex to explain the safety. The synchronization boundary is the committed database transaction; the Go race detector would find nothing because the two goroutines share no memory at all.

65.1.5 5. At 500 RPS, allocation on the posting path matters. What escapes to the heap when a transaction is posted and converted, and how would you confirm it with the toolchain?

What a strong answer covers:

- `Transaction.Validate` allocates a `map[Currency]Money` per call (`internal/domain/transaction.go`); `auditSnapshot` builds a `map[string]any` and a slice of per-posting maps that escape because they are handed to `json.Marshal` (`service.go`).
- `domain.Convert` (`internal/domain/fx.go`) allocates several `big.Int` values per conversion (`new(big.Int).Mul, Exp, QuoRem`), which escape into the heap; that is the deliberate price of overflow-proof integer math on the FX path.
- The audit outbox insert marshals JSON, and each `slog.InfoContext` on a committed post allocates `attrs`; these are per-request heap traffic worth measuring.
- Confirm with `go build -gcflags=-m` to read the escape analysis and a

`go test -bench` with `-benchmem` (or `pprof` heap profiles) to see allocations per op rather than guessing.

The trap: Claiming the money path is allocation-free because it is integer-only. Integer-only rules out `float64`, but the overflow-safe `big.Int` arithmetic in `Convert` allocates, and the audit snapshot maps escape by design.

65.1.6 6. The balance invariant has table-driven and randomized property tests that run under `-race`. What does the race detector actually instrument here, what makes randomized posting tests a good fit, and what can neither catch?

What a strong answer covers:

- `-race` instruments memory accesses to flag two goroutines touching the same location without a happens-before edge; it is a runtime detector, so it only reports races on code paths a test actually exercises (see the concurrency property tests in `internal/ledger` and `internal/postgres`).
- Randomized balanced-posting generators (the `rapid`-style tests referenced from Week 2 and Week 9) explore many shapes of the per-currency zero-sum rule in `Transaction.Validate` that a handful of hand-written cases miss.
- What `-race` cannot catch: a logic error that is perfectly synchronized (a wrong sum is not a race), and a cross-process fork of the audit chain, which is why ADR-017 uses leader election and a `UNIQUE (outbox_id)` constraint instead of relying on in-process synchronization.

- The property tests must be race-clean by construction (each goroutine owns its own inputs) or the detector fires on the test harness itself.

The trap: Believing green `-race` means the concurrency is correct. It only means no data race occurred on the paths run; the single-instance-to-multi-instance chain fork (ADR-017's whole reason for existing) is invisible to `-race` because it happens across processes and through the database.

65.1.7 7. `log/slog` sits on the committed-post path (`s.log.InfoContext(...)` per success). What is the allocation and formatting cost of structured logging here, why do typed attrs beat `fmt.Sprintf`, and what does the custom trace handler add per line?

What a strong answer covers:

- Each `InfoContext` builds a `slog.Record` with typed attrs (`tenant_id`, `transaction_id`, `postings`); the JSON handler serializes without the reflection-and-parse overhead of `fmt.Sprintf` building a string first, and typed attrs avoid intermediate string allocations.
- `internal/observability/slog.go`'s `traceHandler.Handle` calls `rec.AddAttrs` to stamp `trace_id`, `span_id`, and `sampled` only when the context carries a valid span, so an uncorrelated line pays nothing extra.
- Logging is genuinely on the hot path for `Post/Convert`, so keeping it to one structured line per outcome (and using `WithLabelValues(...).Observe` on the Prometheus histogram, not a log line, for latency) keeps per-request cost bounded.
- The handler deliberately keeps attrs flat (its comment warns about

`WithGroup` nesting) so correlation ids stay at top level.

The trap: Treating logging as free. On a 500 RPS path, a `fmt.Sprintf`-built message plus an unconditional context lookup per line is measurable; the design keeps it to typed attrs and a conditional span stamp.

65.1.8 8. Trace how the three long-running background workers are started and stopped in `main.go`, and why the shape is per-goroutine context cancellation rather than a `WaitGroup` or `sync.Once`.

What a strong answer covers:

- `cmd/server/main.go` starts each worker (`audit.Chainer`, `audit.AnchorJob`, `webhook.Worker`, plus the ops collector, idempotency sweep, and demo seeder) as `go X.Run(ctx)` where each `ctx` comes from its own `context.WithCancel` with a deferred cancel.
- Shutdown cancels those contexts; the leader-elected workers additionally rely on Postgres releasing their session advisory lock when the pinned connection closes, so there is no explicit join needed for correctness.
- The three HTTP/RPC servers (`srv`, `metricsSrv`, `gRPC grpcSrv`) funnel startup errors into a buffered `errCh := make(chan error, 3)` and are drained in a specific order under a 10s `shutdownCtx`.
- Telemetry shutdown is deferred last so the OTel batch exporter drains after the servers stop (the Week 8 bug was shutting telemetry down too early).

The trap: Assuming graceful shutdown needs a `WaitGroup` to be correct.

Here the durability guarantees live in the database (committed outbox rows, advisory-lock release on disconnect), so cancelling contexts and letting the workers notice on their next query is sufficient; a missed join loses at most an in-flight drain that the next leader resumes.

65.1.9 9. The chainer holds one pooled connection for its entire leadership term and runs every drain query on it. Explain the Go and `pgxpool` mechanics, and why a follower must never hold a connection while it waits.

What a strong answer covers:

- `leadWhileHeld` calls `c.pool.Acquire(ctx)` to get a `*pgxpool.Conn`, takes `pg_try_advisory_lock` on it, and keeps that exact connection for every `drainOnce` query until leadership ends, then `deferS pg_advisory_unlock` and `conn.Release()`.
- ADR-017 CRITICAL 1: running all drain work on the lock-holding connection means a lost lock session (Postgres restart, failover, `pg_terminate_backend`) fails the very next query, so the instance drops leadership instead of draining blind on a healthy other connection and forking the chain.
- A follower releases the connection immediately after losing the `pg_try_advisory_lock` race and waits on `Run`'s ticker, so idle instances do not each pin a connection out of a small pool.
- The deferred unlock runs on `context.WithoutCancel(ctx)` so it still fires during shutdown when `ctx` is already cancelled.

The trap: Thinking any pooled connection will do for the drain queries. The lock is session-scoped, so drain work must run on the

same session that holds it; the earlier design (drain on `c.pool`) is exactly the fork bug this pinning fixes.

65.1.10 10. The read path wraps each tenant-scoped query in its own transaction (`withTenant`), and three background workers each hold a dedicated connection. How does this interact with `pgxpool` sizing, and where is the connection-budget landmine?

What a strong answer covers:

- `withTenant` in `repository.go` opens a real transaction (`BEGIN`, `set_config('app.tenant_id', ..., true)`, the query, `COMMIT`) for every tenant-scoped read, because a bare `set_config` on a pooled connection would evaporate before the next statement; that is one pooled connection per read for its duration.
- The `chainer`, `anchor job`, and `webhook fan-out` each hold one connection for their leadership term, subtracting from the same pool that `NewPool(ctx, url, 0)` sized (`0` = `pgx` default).
- `enforceTenantPolicy`'s doc comment (and the matching note in `Post/Convert`) warns that resolving `tenantPolicy` from inside `RunInTx`'s closure would take a second connection while the first is held, risking a pool deadlock under a small pool; that is why `policy` is resolved before `RunInTx`.
- Under load, the sum of in-flight request transactions plus the pinned worker connections must stay under the pool max, or requests block waiting to acquire.

The trap: Treating the RLS transaction wrapper as free. It costs a

connection and a round trip per read, and combined with the worker connections it sets a real floor on pool sizing that a naive “just raise concurrency” ignores.

65.1.11 11. Go randomizes map iteration order, yet the audit chain requires byte-identical hashes across processes and time. Where does the code depend on iteration order, where does it deliberately avoid it, and why does that matter for the hash chain?

What a strong answer covers:

- `Transaction.Validate` iterates a `map[Currency]Money` to check each group sums to zero (`transaction.go`); order does not matter there because it is an order-independent equality check, so map randomization is harmless.
- `auditSnapshot` builds a `map[string]any` and relies on `json.Marshal` sorting object keys deterministically, so the serialized bytes are stable regardless of Go’s map iteration order; those exact bytes are what `domain.ComputeAuditRowHash` COVERS.
- Migration 0009 stores `before/after` as `json` not `jsonb` precisely because `jsonb` re-formats bytes on read, which would break byte-exact rehashing; the chainer reads back the stored bytes verbatim.
- The chainer truncates `occurredAt` to microseconds (`chainOne`) so the hashed timestamp matches what Postgres stored, another determinism guard.

The trap: Assuming map iteration order could sneak into the hash. It cannot, because everything hashed goes through `json.Marshal` (sorted keys) or explicit field ordering; the risk is real for anyone who hashes

a map by ranging it directly, which this code carefully never does.

65.1.12 12. retryBackoff computes backoffBase << uint(attempt-1) and guards if exp <= 0 || exp > backoffCap. Explain the overflow concern, the jitter, and why math/rand/v2 is acceptable here.

What a strong answer covers:

- The left shift can overflow `time.Duration (int64)` at high attempt counts, wrapping to zero or negative; the `exp <= 0` guard catches that and clamps to `backoffCap`, so a wrapped shift never produces a zero or negative wait.
- Full jitter (`rand.Int64N(int64(exp) + 1)`) spreads a crowd of conflicting transactions so they do not retry in lockstep and re-collide, per the AWS exponential-backoff-and-jitter reference cited in the code.
- `math/rand/v2` is fine because this is scheduling jitter, not a security decision, hence the `//nolint:gosec` annotation; a CSPRNG would add cost for no benefit.
- Ties to `SERIALIZABLE`: the backoff exists because 40001/40P01 conflicts are expected and retried up to `maxPostAttempts`.

The trap: Using a crypto RNG “to be safe” or ignoring the shift overflow. The overflow guard is load-bearing at high attempt numbers, and crypto randomness for jitter is pure waste.

65.1.13 13. The chainer does

`row.OccurredAt.UTC().Truncate(time.Microsecond)` before hashing. Explain the `time.Time` subtleties this addresses and why they are essential to a reproducible chain.

What a strong answer covers:

- Postgres `timestampz` stores microsecond precision, but a Go `time.Time` can carry nanoseconds and a monotonic clock reading; truncating to microseconds and forcing UTC makes the in-memory value match exactly what the database stored and returns.
- `chainOne` in `internal/audit/chainer.go` hashes this normalized `CreatedAt`, so the `row_hash` recomputed at verify time (`domain.ComputeAuditRowHash`) matches the one written; a stray sub-microsecond component would make the stored hash unreproducible.
- This is the same determinism discipline as storing `json` (migration 0009) and not hashing `chain_seq` or `outbox_id` (both purely structural, ADR-017 IMPORTANT 2 / MINOR 3).
- It is also what let the `async chainer` produce byte-identical hashes to the old synchronous `AppendAudit` path.

The trap: Ignoring monotonic-clock and precision differences in `time.Time`. Hash a raw `time.Time` and the chain verifies on the writing process but breaks on reload, which is the kind of determinism bug the special editions call out.

65.1.14 14. AllAccountBalances returns a flat list and buildTree rolls it up in memory with recursive closures and memoization. Walk the Go mechanics: how it guarantees parent-before-child order, why it cannot infinitely recurse, and its complexity.

What a strong answer covers:

- `buildTree` in `internal/ledger/account_service.go` builds `own`, `children`, and `acctByID` maps in one pass, collects roots (`nil` parent, plus orphan promotion for a missing parent that the FK should make impossible), then walks from roots stamping depth.
- `rollup` is a memoized closure (`rolled` map) so each subtree total is computed once: `own[id] + sum(rollup(child))`, giving $O(n)$ over the tenant's accounts rather than a query per node.
- It cannot loop forever because migration 0032's `accounts_hierarchy_guard` trigger rejects cycles at write time (walking the ancestor chain, capped at 10000 hops), so the in-memory graph is always a forest.
- The single query (`AllAccountBalances`) plus in-memory rollup is why ADR-023 keeps balances derived and refuses a stored rollup column.

The trap: Worrying about stack overflow or infinite recursion in `buildTree`. The database trigger (0032) makes cycles impossible to persist, so the Go walk is always over a DAG-free forest; the guard in `buildTree` for a missing parent is belt-and-suspenders against an FK that already prevents it.

65.1.15 15. withTenant explains that a `set_config('app.tenant_id', ..., true)` issued as a separate statement on a pooled connection “would evaporate before the very next query ran.” Explain the connection-pooling and transaction semantics behind that sentence.

What a strong answer covers:

- A bare statement on a `pgxpool` connection runs in its own implicit transaction; a transaction-local GUC (`set_config(..., true)`) is scoped to that implicit transaction and is gone by the next statement, which may even land on a different pooled connection.
- Wrapping both the `set_config` and the read in one explicit `BEGIN/COMMIT` (`withTenant` in `repository.go`) is what keeps `app.tenant_id` set for the duration of the query, so the `FORCE RLS` policies (migration 0024) actually apply.
- `RunInTx` sets the same GUC transaction-local at the top of each attempt for the write path, for the same reason.
- Background workers deliberately do not set it, relying on the policy’s “allow when the GUC is unset or empty” branch for cross-tenant access.

The trap: Assuming session-level `SET` would work across a pool. Pooled connections are shared and reset between borrowers, so only a transaction-scoped GUC set inside the same transaction as the query is safe; a session `SET` would leak the tenant id onto the next request that borrows the connection.

65.1.16 45. Migration 0034 made

audit_log.transaction_id nullable so lifecycle events can carry no transaction. A pgtype.UUID scanned from that column has a .String() method. Why is calling it directly a silent, dangerous bug, and how does the code avoid it?

What a strong answer covers:

- `pgtype.UUID.String()` formats the 16 bytes unconditionally and ignores the `.Valid` flag, so a SQL NULL (an invalid `pgtype.UUID`) stringifies to the all-zeros UUID `00000000-...`, not an empty string, silently turning “no transaction” into a real-looking id.
- The chainer and the webhook fan-out both scan the now-nullable `transaction_id`, so both had to guard `.Valid` before formatting; the code centralizes this in helpers (`pgUUIDToString/stringFromUUID/optUUIDFromString`) with an explicit warning comment, and maps empty string to an invalid (NULL) UUID symmetrically on write.
- The symmetry matters for the hash chain: an empty `TransactionID` on a v2 `AuditEntry` must map to NULL on store and back to empty on read, or `ComputeAuditRowHash` would hash a different value than was stored and verification would fail.
- The mixed v1/v2 chain test would not catch a wrong-version hash, but a webhook delivering `"transaction_id":"00000000-..."` for a rejection is exactly the corruption the `.Valid` guard prevents.

The trap: Treating `pgtype.UUID` like a nullable string where the zero value is empty. Its zero value formats to a valid-looking UUID, so a compile-clean `.String()` call on a NULL column is the most likely silent-NULL bug in the whole change, and it only shows up in delivered

data, not in the type system.

65.2 Cross-cutting interactions

65.2.1 16. Trace one POST /v1/transactions from the header bytes to the audit chain link, naming every layer it passes through and every invariant enforced along the way.

What a strong answer covers:

- Auth first: `auth.Resolver` hashes the bearer token (`domain.HashAPIKey`, SHA-256), looks up the key, checks the required scope (`RequiredHTTPScope` maps a POST to `ScopePost`), and computes the effective tenant, honoring `X-Act-As-Tenant` only for an admin key (ADR-021).
- Idempotency is mandatory (ADR-012); `Post` in `service.go` prechecks the stored key (`GetIdempotencyKey`) and replays on a hit before writing anything, then validates the zero-sum-per-currency invariant (`Transaction.Validate`), resolves policy, and screens via the pre-post hook.
- `RunInTx` opens a `SERIALIZABLE` transaction, sets the `app.tenant_id` GUC for RLS (migration 0024), enforces policy and account constraints on the read side, inserts the transaction and postings (deferred `postings_balanced` trigger fires at COMMIT), inserts the idempotency key, and appends one `audit_outbox` row, all atomically.
- Later the leader chainer drains that outbox row and extends the tenant's hash chain (ADR-017); the post itself never touches the

chain.

The trap: “Idempotency is just the unique constraint.” The primary key on `(tenant_id, idempotency_key)` is necessary but not sufficient: two concurrent identical requests can both pass the precheck, so `Post` also catches `ErrDuplicateIdempotencyKey` from inside `RunInTx` and replays, which the constraint alone does not do.

65.2.2 17. RLS, the tamper-evident audit chain, mandatory idempotency, and `SERIALIZABLE` each protect something. Lay out which guarantee each provides and where they overlap.

What a strong answer covers:

- RLS (migration 0024, `FORCE`) is a backstop against a query that forgets its tenant filter: even a `WHERE`-less `UPDATE` cannot cross tenants once `app.tenant_id` is set, and the app also filters by tenant in every query, so they overlap deliberately as defense in depth.
- The audit hash chain (migration 0009, `ADR-012/017`) gives tamper-evidence: any after-the-fact mutation of a chained row breaks every downstream link; it does not prevent writes, it makes rewrites detectable.
- Mandatory idempotency (`ADR-012`) gives exactly-once effect from at-least-once delivery via the `(tenant_id, idempotency_key)` primary key plus the fingerprint check.
- `SERIALIZABLE` protects the balance invariant and the idempotency insert under concurrency (`ADR-017` decision 4), retried on 40001; it is the isolation floor the others assume.

The trap: Treating them as redundant. They protect different failure classes (accidental cross-tenant write, malicious rewrite, duplicate delivery, concurrent anomaly); the overlap between app-level tenant filtering and RLS is intentional, but no one layer subsumes another.

65.2.3 18. A EUR to JPY conversion routes through the USD hub (ADR-022). Show that the resulting transaction still satisfies the per-currency zero-sum invariant, and where the two roundings happen.

What a strong answer covers:

- The provider triangulates: EUR to USD then USD to JPY, composing the cross mid in `big.Int` (ADR-022 decision 1), and `Convert` in `internal/ledger/convert.go` posts four legs (debit source, credit source-currency clearing, debit destination-currency clearing, credit destination).
- `Transaction.Validate` groups postings by currency and requires each group sum to zero, so EUR nets through the EUR clearing leg and JPY nets through the JPY clearing leg independently (ADR-014, ADR-023's single-currency-subtree logic is the same principle).
- The per-currency exponent difference (EUR minor units vs JPY's zero) is folded into the single `big.Int` rounding step in `domain.Convert` (`internal/domain/fx.go`), not a separate rate-then-amount round, except that a hub route rounds twice by design: once composing the cross mid, once applying it (ADR-022 consequences).
- Provenance points at the base (EUR to USD) leg's `rate_id` and its spread (ADR-022 decisions 2 and 3), snapshotted in `FXDetail` so the conversion replays exactly.

The trap: Thinking a cross-currency transaction “does not balance”

because the two sides are different amounts. It balances per currency, not across currencies; the clearing accounts are what absorb each currency's leg so every currency group nets to zero.

65.2.4 19. VerifyFromLatestAnchor with a trusted anchor is cheaper than a full Verify. What exactly does it trust, and how does a divergence between the live head and an anchor at the same chain_seq reveal a rewrite of already-anchored history?

What a strong answer covers:

- Verify walks from genesis and recomputes every link; VerifyFromLatestAnchor (`internal/ledger/audit_service.go`) seeds prev with the anchor's row_hash and only walks rows with chain_seq greater than the anchor's, bounding work to growth since the anchor.
- The anchored prefix is trusted, not re-proven; that trust is meaningful only because AnchorJob (`internal/audit/anchor.go`) also emits the anchor as an off-box structured log line (Task 5.6), an append-only copy the database no longer controls (migration 0025).
- A privileged actor with full DB write can rewrite a whole suffix and recompute every downstream hash consistently, so an in-database from-genesis Verify finds nothing; comparing the live head (GetAuditHead) against the shipped anchor at the same chain_seq is what catches it, because the rewrite changed the anchored row's row_hash.
- chain_seq is a DB-assigned sequence the single chainer advances, so "same chain_seq, different row_hash" is a well-defined comparison.

The trap: Believing the hash chain alone proves history was never al-

tered. A chain proves internal self-consistency; a consistent privileged rewrite defeats it. Only the off-box anchor closes that gap, which is why `fast=true` verification explicitly trusts a checkpoint rather than claiming a free full proof.

65.2.5 20. X-Act-As-Tenant lets an admin key operate as another tenant. Explain how it changes the effective RLS GUC, why admin scope is required, and the one string-canonicalization detail that has to be right.

What a strong answer covers:

- The auth middleware (`internal/auth/middleware.go`, ADR-021) computes the effective tenant after the scope check: the header overrides the key's own tenant only when the key `HasScope(domain.ScopeAdmin)`; a non-admin sender is silently ignored (fail toward less access).
- The effective tenant flows into the request context, then into `app.tenant_id` via `set_config` in `RunInTx/withTenant`, so RLS (migration 0024) enforces the acted-as tenant with no per-endpoint change.
- The header UUID is `uuid.Parsed` and canonicalized to lowercase (`u.String()`) so it matches the `tenant_id::text = current_setting('app.tenant_id', true)` comparison in the RLS policy, which is lowercase; a malformed value is a 400.
- Admin scope is already platform-level (`/v1/admin` manages every tenant), so act-as grants no new capability, just a one-step ergonomic path (ADR-021 context and security note).

The trap: Assuming RLS would still catch a bug in the override. It only catches it if the GUC is set to a canonical lowercase UUID; a

non-canonical or unparsed value would either 400 or, if it slipped through, fail to match any row, which is why canonicalization is not cosmetic.

65.2.6 21. The demo seeder writes rows directly with backdated `created_at` while the database triggers are live. Precisely which invariants can it bypass and which still bind it?

What a strong answer covers:

- `internal/seed` inserts accounts, transactions, and postings with explicit backdated `created_at` (the public API forbids client-set timestamps), in one transaction per tenant.
- It bypasses append-only immutability on delete by setting the transaction-local GUC `audit.allow_purge = 'on'`, the one sanctioned exception `audit_log_reject_mutation` (migration 0006) honors, so it can wipe `audit_log` on reset.
- It cannot bypass the balance trigger (`postings_balanced`, migration 0002) or currency trigger (`postings_currency_matches`, migration 0003): seeded legs are signed to sum to zero and match account currency, or the insert fails.
- It also enforces an ADR-015 safety guard: it refuses to wipe a tenant that has any API key other than the demo key, so it can never destroy real data.

The trap: Assuming “writes rows directly” means it can create an unbalanced or mislabeled ledger. The deferred balance and currency triggers still fire on its inserts; only immutability and the timestamp default are deliberately relaxed, and only under an explicit GUC and

a safety guard.

65.2.7 22. Posting descriptions are encrypted before RunInTx opens a transaction, yet the audit chain has to stay verifiable after a crypto-shred. Explain how encrypt-once, the audit snapshot, and the hash chain compose.

What a strong answer covers:

- `Post` in `service.go` encrypts `t.Postings` into a new slice once, after screening (which needs plaintext) and before `RunInTx`, then restores the plaintext slice after the transaction returns, so the caller still sees readable labels.
- Because `auditSnapshot` runs inside `RunInTx` on the same `*t`, the audit after JSON captures the identical ciphertext that `CreateTransaction` persists into `postings.description`, so `ComputeAuditRowHash` covers the ciphertext bytes.
- Crypto-shredding (ADR-018, versioned keys) destroys the key, never the stored bytes, so the `row_hash` stays reproducible and the chain still verifies; a shredded description reads back as a redaction marker, not an error.
- `Verify` never decrypts (it must hash the exact stored bytes), while `ByTransaction/ByAccount` decrypt for display only via `WithAuditCipher`.

The trap: Encrypting twice or encrypting after the snapshot. If the snapshot captured plaintext but storage held ciphertext, the re-computed hash would not match; the encrypt-once-into-a-new-slice ordering is what keeps the snapshot and the stored row byte-identical.

65.2.8 23. Post captures before `:= *t` and computes the fingerprint before `RunInTx`. What in-flight mutation would corrupt the idempotency comparison if it did not, and how does the “v2” fingerprint scheme make this sharp?

What a strong answer covers:

- `txRepo.CreateTransaction` resolves `t.EffectiveAt`'s nil fallback to the row's `created_at` as a side effect on the shared `*t`, even on an attempt that later rolls back; a SQL ROLLBACK does not undo that Go-level mutation.
- The “v2” fingerprint scheme includes `EffectiveAt`, so recomputing the fingerprint from `*t` after that mutation would hash a resolved timestamp the client never sent, false-conflicting a legitimate retry that omitted `effective_at`.
- `service.go` snapshots before up front and `replay` recomputes from before, not from `*t`, keeping the comparison honest across retries.
- `replay` recomputes under the stored record's scheme (`rec.Scheme`), not the current scheme, so a scheme upgrade never false-conflicts an older key, and an unknown scheme fails closed with `ErrIdempotencyConflict`.

The trap: Recomputing the fingerprint from the live `*t` on replay. It looks equivalent but the `effective_at` fallback has already mutated the struct, so every retry that omits the value would spuriously 409 under the timestamp-aware scheme.

65.2.9 24. Convert deliberately does not call Post. Explain the two concrete reasons, and how idempotency for a conversion stays correct when the rate moves between a request and its retry.

What a strong answer covers:

- `convert.go` documents that `Post` fingerprints the built postings (`Transaction.Fingerprint`) and has no channel for the FX snapshot; reusing it would key idempotency on postings only known after a rate was applied, so a retry after the rate moved would rebuild a different converted amount, hash differently, and spuriously 409.
- Instead `Convert` fingerprints the request (from account, to account, source amount) via `ConvertFingerprint` before ever calling the rate provider, so a retry replays the stored transaction without re-quoting.
- The FX snapshot (`FXDetail`) is written alongside the transaction in `Convert`'s own `RunInTx` body, which `Post` could not do.
- On a concurrent-retry race it catches `ErrDuplicateIdempotencyKey` and replays via `convertReplay`, now an expected path since ADR-017 removed the per-tenant mutex.

The trap: “Just reuse `Post` for converts too.” The idempotency key would then depend on a rate-derived amount, turning a legitimate retry after a rate change into a false conflict; the request-based fingerprint is what makes a conversion replay stable.

65.2.10 25. Tenant policy is resolved before RunInTx, but the daily-volume and account-status reads happen inside it. Why the split, and what consistency property does the in-transaction read buy?

What a strong answer covers:

- `tenantPolicy` is resolved on its own connection before `RunInTx` (`service.go, convert.go`) because a second `Repository` call from inside the transaction closure would take another pool connection while the first is held, risking a pool deadlock under a small pool (`enforceTenantPolicy`'s doc comment).
- The daily-debit totals (`TenantDailyDebits`) and account states (`AccountPostingStates`) are read inside the same `SERIALIZABLE` transaction as the write, so the check is consistent with the insert that follows: no window where a just-frozen account or an already-exhausted daily cap is missed.
- Account status changes take effect on the next post because they are read fresh in-transaction, never cached (`AccountService.SetStatus` doc comment).
- `SERIALIZABLE` plus the in-tx read is what makes the policy decision and the posting atomic.

The trap: Reading the daily-volume total outside the transaction “to save a round trip.” Then two concurrent posts could each see the cap as not-yet-reached and both commit, blowing the limit; the read has to share the write’s transaction to be safe.

65.2.11 26. The idempotency record stores the fingerprint scheme name next to the fingerprint. Walk through why that is necessary and what breaks without it during a scheme migration.

What a strong answer covers:

- `InsertIdempotencyKey (repository.go)` stores `fingerprint_scheme` alongside the fingerprint; `replay/convertReplay` recompute under `rec.Scheme`, not `CurrentFingerprintScheme`.
- Without the stored scheme, upgrading from “v1” to “v2” (which adds `effective_at`, `reference`) would make every pre-upgrade key recompute under the new scheme and false-conflict, because the stored fingerprint was produced by the old rules.
- An unknown stored scheme fails closed with `ErrIdempotencyConflict` rather than replay a body it cannot verify (for example a key written by a newer binary then read after a downgrade).
- This is the same versioning discipline the crypto keys use (ADR-018): record which scheme produced a value so it can always be recomputed under its own rules.

The trap: Comparing the stored fingerprint against one computed with today’s scheme. That silently breaks every in-flight idempotency key the moment the scheme changes; the fix is to recompute under the scheme the row was written with.

65.2.12 27. Two independent leader-elected workers (the chainer and the webhook worker) both extend from the audit stream. Explain how their advisory-lock keys, connections, and cursors are kept from interfering.

What a strong answer covers:

- The chainer holds `pg_try_advisory_lock(4_921_017)`, the webhook worker `4_921_018`, and the anchor job `4_921_019`, all distinct fixed keys (documented in `chainer.go`, `webhook/worker.go`, `anchor.go`) so winning one lock never implies holding another.
- The chainer writes `audit_log` from `audit_outbox` in `(txid, id)` order; the webhook worker reads the already-chained `audit_log` by `chain_seq` and advances a fan-out cursor, so it never re-solves ordering.
- Fan-out and delivery are split: fan-out runs on the leader connection, delivery runs on the general pool because an outbound HTTP call must not pin the leader connection.
- Each worker's drain/fan-out work runs on its own lock-holding connection (CRITICAL 1) so a lost session drops leadership rather than running blind.

The trap: Reusing one advisory-lock key or one connection across workers. Shared keys would let one worker's leadership falsely satisfy another's election; the distinct keys are a correctness requirement, not tidiness.

65.2.13 46. Approvals gate reversals too, but a reversal of an already-approved transaction is exempt. That exemption reads `pending_transactions` outside the reversal's own transaction. Why is that past-fact read safe here when a check-then-act across transactions usually is not?

What a strong answer covers:

- The gate holds a reversal unless `PendingApprovedForTransaction(reversedID)` is true, meaning the transaction being reversed already cleared the gate once; forcing its correction to wait for a second approval would let a large erroneous posting trap the very reversal that fixes it (ADR-025).
- The read is safe because “this transaction has an approved pending” is a terminal, monotonic fact: the `pending_transactions CHECK (transaction_id IS NULL OR status='approved')` means a row with a linked transaction id is already approved, and an approved pending never transitions back, so a stale-but-true read cannot become false under it.
- It composes with the existing one-reversal unique index: even if the exemption misjudged, a reversal is idempotent on the original transaction id, so a second reversal collapses rather than double-posting.
- The exemption only skips the gate; screening and the normal post-validation still run on the reversal legs.

The trap: Pattern-matching “check in one transaction, act in another” to a TOCTOU bug. TOCTOU bites when the checked fact can change between check and act; an approved-pending fact is monotonic and

terminal, and the one-reversal index is a second backstop, so the cross-transaction read is deliberately safe, not an oversight.

65.3 System design and failure modes

65.3.1 28. A client times out and retries a POST. Explain how the system turns at-least-once delivery into exactly-once effect, and exactly what is stored and replayed.

What a strong answer covers:

- The `(tenant_id, idempotency_key)` primary key (migration 0006) is the exactly-once mutex; the stored row holds the fingerprint, the scheme, and the `transaction_id`.
- On retry `Post` prechecks `GetIdempotencyKey`, and on a hit `replay` recomputes the fingerprint over the original request (before snapshot) under the stored scheme; a match loads and returns the original transaction with `replayed=true`, a mismatch is `ErrIdempotencyConflict`.
- The concurrent-retry window (both requests pass the precheck) is closed by catching `ErrDuplicateIdempotencyKey` inside `RunInTx` and replaying, because the insert is atomic with the transaction.
- The stored key has a TTL (`expires_at` stamped from the DB server clock, migration 0019), so replay is bounded in time.

The trap: Assuming the response body is stored and returned verbatim. Only the transaction id (plus fingerprint and scheme) is stored; the replay re-reads and re-decrypts the transaction, which is why the fingerprint has to match the original request to avoid replaying the

wrong body.

65.3.2 29. A crash lands between writing the postings and recording the audit event. Is the event lost? Explain the transactional outbox guarantee precisely.

What a strong answer covers:

- `AppendAuditOutbox` inserts the `audit_outbox` row inside the same `SERIALIZABLE` transaction as the postings (`Post/Convert` in the `service.go/convert.go` closures), so the event is durable if and only if the transaction commits (ADR-017 decision 1).
- There is no window: a crash before `COMMIT` loses both the postings and the outbox row together; a crash after `COMMIT` keeps both, and the chainer picks up the outbox row later.
- The chainer then inserts the `audit_log` row and marks the outbox row processed in one transaction (`chainOne`), so a crash between those two is also atomic: a retried drain finds the row still unprocessed with no half-written chain row ahead of it.
- This is why the chain is eventually consistent but never loses a committed event (ADR-017 section 5).

The trap: Thinking a separate “write the audit row after the post” step could drop an event on crash. That is exactly the dual-write problem the transactional outbox exists to avoid; the outbox insert shares the post’s transaction, so there is nothing to lose.

65.3.3 30. There is exactly one chainer writing `audit_log`. Why one, what does that serialize, and how would you scale it without forking any tenant's chain?

What a strong answer covers:

- Exactly one writer is what makes the chain fork-proof: leader election via `pg_try_advisory_lock` (ADR-017 decision 3) guarantees a single consumer regardless of how many app instances produce outbox rows.
- The single chainer serializes chain extension across all tenants, but the post path does not wait on it, so aggregate posting throughput is not bounded by the chainer as long as its drain rate exceeds the post rate.
- ADR-017 says one global chainer is ample for this volume; the escape hatch is partitioning the chainer by tenant, which the `(txid, id)` total order already supports, without changing the model.
- Backpressure is on the outbox depth (a metric and alert), never on the client.

The trap: Adding a second concurrent chainer to “go faster.” Two writers on the same chain is the exact fork this design prevents; scaling means sharding by tenant so each shard still has a single writer, not running two writers over the same tenant.

65.3.4 31. After ADR-017 removed the per-tenant mutex, what still lets one tenant's burst affect another, and how does the load test hold 500 RPS across the change?

What a strong answer covers:

- With the mutex gone, same-tenant posts run fully concurrently, serialized only by whatever `SERIALIZABLE` detects (the balance trigger, the idempotency key) and retried on 40001 (`RunInTx`, ADR-017 decision 4).
- The remaining shared resources are the `pgxpool` connections and the single chainer; a hot tenant's retries consume connections and can raise conflict rates, so isolation is not perfect, it is bounded.
- Commit `2e38f32` spreads the load test across many tenants so the throughput number reflects realistic multi-tenant traffic rather than one tenant hammering a single hot account.
- The audit chain being off the hot path (outbox insert only) is what lets same-tenant concurrency scale at all, versus the old serialized chain extension.

The trap: Claiming the system is now perfectly isolated per tenant. Removing the mutex removed one serialization point, but the shared pool and single chainer remain; the honest framing is bounded noisy-neighbor impact plus a load test that spreads across tenants, not zero cross-tenant effect.

65.3.5 32. Right after a successful POST, a client reads the transaction and also asks whether it is in the tamper-evident chain. What are the two answers, and why do they differ?

What a strong answer covers:

- `GetTransaction` returns the transaction immediately: postings are durable at COMMIT, so read-after-write on the ledger itself is strongly consistent.
- The audit chain is eventually consistent (ADR-017): the event sits in `audit_outbox` until the chainer processes it, so `Verify` reports it under Pending (from `CountPendingOutbox`), not yet in `Checked`.
- `VerifyResult.Pending` is how a caller distinguishes “chain is lagging” from “nothing more to chain”; a growing pending count is an operational signal, not data loss.
- The API docs for `verify` call out this asynchrony explicitly.

The trap: Expecting the chain link to exist the instant the post returns. The chain is deliberately off the hot path; a consumer that needs “is it chained yet” must read the pending count, not assume synchronous chaining.

65.3.6 33. Compare ordering guarantees within a single tenant’s chain versus across tenants, and why the design does not need one global real-time order.

What a strong answer covers:

- Within a tenant, `chain_seq` (a DB sequence the single chainer ad-

vances in processing order, migration 0016) gives a strict, monotonic, clock-skew-proof order that verify walks; each row's `prev_hash` is the previous row's `row_hash`.

- Across tenants there is no meaningful shared order: each tenant's chain is independent, and the anchor job treats each tenant's head separately (`anchorOnce` continues past one tenant's failure).
- The chainer processes committed outbox rows in `(txid, id)` order (ADR-017 decision 2), which is a fixed, recomputable total order over committed events, not necessarily the wall-clock order of concurrent posts.
- Tamper-evidence needs only a fixed order it can recompute, not the one “true” real-time order.

The trap: Insisting the chain must reflect the exact real-time order posts happened. Concurrent posts have no observable true order; the design commits to a deterministic commit-visibility order per tenant, which is all a recomputable hash chain requires.

65.3.7 34. Walk the failure and recovery when the chainer leader loses its lock mid-drain (Postgres restart or `pg_terminate_backend`). Name the two independent defenses against a forked chain.

What a strong answer covers:

- Every drain query runs on the connection holding the advisory lock (`leadWhileHeld`, ADR-017 CRITICAL 1), so the moment the lock session dies that connection is gone and the very next query fails, dropping leadership; the instance re-contentends like a follower.
- The next instance to win the lock resumes from the outbox's own

processed_at state, with at most one instance ever mid-drain.

- Defense two: `audit_log.outbox_id` carries a `UNIQUE` constraint (migration 0016, `audit_log_outbox_id_key`), so if two writers ever did overlap, the second attempt to chain the same outbox row fails the insert instead of forking; `chainOne` treats that as a graceful no-op (mark processed, evict cached hash, move on).
- The deferred `pg_advisory_unlock` on a detached context releases the lock promptly on clean shutdown so the next leader does not wait for a dropped-connection timeout.

The trap: Relying on the unique constraint alone, or on same-connection pinning alone. Pinning prevents the overlap; the constraint catches anything the reasoning missed. Removing either turns a rare race into a silent chain fork.

65.3.8 35. `audit_outbox.id` is a bigserial, but the chainer does not process “id greater than last processed.” Explain the ordering hazard and the xmin-based fix.

What a strong answer covers:

- bigserial ids are assigned at insert time, but transactions commit out of order, so a lower-id row can become visible after a higher-id row was already processed; a naive id watermark would permanently skip it, dropping a committed event from the chain forever.
- The fix (ADR-017 decision 2, migration 0015): each row stamps `txid` from `pg_current_xact_id()`, and the chainer processes only rows whose `txid` is below `pg_snapshot_xmin(pg_current_snapshot())`, ordered by `(txid, id)` (`AuditOutboxWatermark + ScanUnprocessedAuditOutbox`).
- Rows below `xmin` are guaranteed settled, so no still-running trans-

action can later reveal an earlier-ordered row that was invisible; aborted transactions simply leave no committed row.

- This yields one deterministic, gap-free total order over exactly the committed events.

The trap: Ordering by the `bigserial` id or by `created_at`. Both let a slow-committing transaction's row be skipped and never revisited; only the transaction-visibility watermark guarantees no skipped-then-resurfaced row.

65.3.9 36. Describe the webhook delivery guarantees end to end: what “at-least-once” means here, how a subscriber deduplicates, ordering, retries, and dead-lettering.

What a strong answer covers:

- The webhook worker (`internal/webhook`) fans out from the chained `audit_log` by `chain_seq`, advancing a fan-out cursor and inserting one `webhook_deliveries` row per matching subscription, all in one transaction, so a crash replays the same rows (`ON CONFLICT DO NOTHING ON (subscription_id, audit_chain_seq)`, migration 0021).
- Delivery is at-least-once: a `2xx` marks delivered, otherwise it reschedules with deterministic tripling backoff (`backoffFor`) up to `MaxAttempts` (default 8), then dead-letters.
- The subscriber deduplicates on the stable `X-Ledger-Delivery-Id` header (the row id, constant across retries); the body is re-marshaled identically each attempt and signed with HMAC-SHA256 (`X-Ledger-Signature`).
- Ordering follows `chain_seq`, and only the single leader ever attempts

a given delivery, so no jitter is needed.

The trap: Promising exactly-once delivery to the subscriber. The system is at-least-once on the wire; exactly-once is the subscriber's job via the stable delivery id, which is precisely why that header is constant across retries.

65.3.10 37. Migrations moved to a pre-deploy CI step rather than running on each instance's boot. What multi-instance failure does that prevent, and what is the tradeoff?

What a strong answer covers:

- ADR-017 decision 6 (A4.3): with multiple instances, a schema change must land once, before the new code that needs it, and no instance may race another running `goose up`.
- On-boot migration per instance risks two instances migrating concurrently, or a new instance hitting an old schema during a rolling deploy; the dedicated gated CI step (`goose up once`) orders it in the pipeline.
- The tradeoff is operational: the pipeline now has an ordering dependency (migrate then roll instances), and a migration and the code that needs it must be compatible across the rollout window (expand-then-contract).
- `main.go` still exposes a `migrate` subcommand and an idempotent on-boot path for the single-instance case, but multi-instance relies on the CI step.

The trap: Keeping per-instance boot migrations “because `goose` is

idempotent.” Idempotency does not prevent two instances racing the same migration or a fresh instance running code against a not-yet-migrated schema; the ordering has to be enforced outside the instances.

65.3.11 38. The chainer being down is called a lag signal, not a data-loss event. Defend that, and describe what actually degrades if it stays down for an hour.

What a strong answer covers:

- Posts keep committing: they only write postings plus an `audit_outbox` row, which is durable independent of the chainer (ADR-017 decision 1), so backpressure is on the outbox, never on the client.
- What degrades: the tamper-evident `audit_log` stops advancing, so `Verify` shows a growing `Pending` count, the anchor job records stale heads, and the webhook worker (which reads the chained stream) stops fanning out new events.
- The outbox depth and oldest-unprocessed-row age are a metric and alert (ADR-017 section 5); the restore-verify job (ADR-016) additionally checks every committed transaction is eventually chained, catching a silently stopped chainer.
- Recovery is automatic: the next leader resumes from `processed_at`, in order, with no fork.

The trap: Treating a stopped chainer as an outage or data loss. The money path is unaffected and every event is durable in the outbox; only the audit chain, anchoring, and webhooks lag, and all catch up when a leader returns.

65.3.12 39. Why does the verify walk order by a DB-assigned `chain_seq` sequence rather than by the `audit_log` row's UUIDv7 primary key?

What a strong answer covers:

- UUIDv7 is time-ordered but monotonic only within one process; a leader failover to a host with a skewed clock could mint an id lower than the current head, which would read as a fork if verify ordered by id (ADR-017 decision 2, migration 0016).
- `chain_seq` is a Postgres sequence advanced by the single chainer in processing order, so it is monotonic and clock-skew-proof regardless of which instance is leader.
- `chain_seq` is purely structural and is never hashed, so ordering by it does not affect any stored `row_hash` (ADR-017 IMPORTANT 2); the hash covers content plus `prev_hash` only.
- `ListAuditForVerifyPage` and `GetLastAuditHash` key on `chain_seq` for exactly this reason.

The trap: Assuming UUIDv7 is globally monotonic “because it embeds a timestamp.” It is only monotonic within a single generating process; across a failover with clock skew it is not, which is why the ordering authority is a database sequence, not the id.

65.3.13 40. A hash chain proves internal consistency, so why build a separate off-box anchor job at all? Give the concrete attack it catches that a from-genesis Verify cannot.

What a strong answer covers:

- A privileged actor with full DB write access can rewrite a whole suffix of `audit_log` and recompute every downstream `row_hash` consistently, leaving even a complete from-genesis `Verify` with nothing to find (migration 0025 doc, `anchor.go`, ADR-012).
- `AnchorJob` periodically records each tenant's head (`chain_seq`, `row_hash`) into `audit_anchors` AND emits it as an off-box structured log line (Task 5.6); once shipped, that copy is outside the database's control.
- Comparing the live head against the last shipped anchor reveals a rewrite of anchored history, because rewriting the anchored row changes its `row_hash` while the shipped anchor still has the old one.
- The anchor job is leader-elected (4_921_019) but a lost race here is harmless (at worst a duplicate anchor row), unlike a forked chain.

The trap: Trusting the in-database chain as tamper-proof on its own. Self-consistency is not the same as immutability against a privileged rewrite; only an external, append-only copy of the head provides ground truth, which is the entire reason the anchor is shipped off-box.

65.3.14 41. The trial-balance zero-proof uses own balances, but the report also shows rolled-up balances. Why can the invariant proof not use the rollups, and what does that reveal about the rollup design?

What a strong answer covers:

- Rollups double-count by construction: a parent’s rolled-up balance already includes its children, so summing every account’s rollup would not net to zero (ADR-023 decision 5).
- The per-currency zero-proof therefore sums own (leaf-level) balances, which is the genuine double-entry invariant; the rollup is an additive display figure only.
- Rollups are computed on read (recursive CTE for one account, in-memory `buildTree` for the whole tree), never stored, so nothing can drift (ADR-023 decisions 3 and 5).
- A subtree is single-currency (enforced by the hierarchy trigger, migration 0032), which is what lets a rollup be one number rather than a currency map.

The trap: Summing rollups to “prove” the books balance. That double-counts every parent and will not be zero even on a perfectly balanced ledger; the proof must run on own balances, which is exactly why the report keeps both columns.

65.3.15 42. ADR-023 rejects a stored rollup column and a closure table in favor of a per-read recursive CTE. Where does that choice hurt at scale, and how would you fix it without breaking the API?

What a strong answer covers:

- The recursive CTE (`RolledUpBalance`) and the in-memory `buildTree` re-derive a subtree total on every read; a deep tree pays a recursive cost per rollup read (ADR-023 consequences).
- A stored rollup column was rejected because it reintroduces the mutable-balance state the whole ledger avoids (ADR-001/003) and drifts on any missed post or re-parent; a closure table was rejected as more moving parts than the scale needs.
- The escape hatch: add a closure table behind the same repo method (`RolledUpBalance`, `AllAccountBalances`) so the API and the derived-balance guarantee are unchanged; the rollup stays a query result, just a cheaper one.
- Correctness stays with derived balances; only the read cost changes.

The trap: Reaching for a maintained rollup column as the scale fix. That is the exact drift-prone mutable state ADR-001 forbids; the safe optimization keeps balances derived and hides a closure table behind the existing repo method.

65.3.16 43. An operator freezes an account while a concurrent post touches it. Is there a window where the post slips through against a stale status? Explain the mechanism.

What a strong answer covers:

- `AccountService.SetStatus` writes the new status and the next posting attempt reads it fresh inside its own `SERIALIZABLE` transaction via `AccountPostingStates (enforceAccountConstraints)`, never from a cache (`SetStatus` doc comment).
- Because the status read and the posting insert share one `SERIALIZABLE` transaction, a freeze that commits before the post's read is seen, and a freeze that races the post is resolved by serialization: one of them retries.
- System (clearing) accounts are exempt from the status and min-balance checks (`AccountPostingStates` skips the balance query for `is_system`), so an FX conversion's clearing legs are never blocked.
- A frozen or closed account returns `*domain.AccountNotActiveError`, a floor breach `*domain.MinBalanceBreachError`, rolling the whole post back.

The trap: Assuming a cached or pre-transaction status read is good enough. That would open a window where an in-flight post misses a just-committed freeze; reading the status inside the same `SERIALIZABLE` transaction as the write is what closes it.

65.3.17 44. FX clearing accounts can sit at a permanent, often negative, balance, and they are exempt from the min-balance check. Why is that correct rather than a bug, and what enforces the exemption?

What a strong answer covers:

- A conversion routes each currency through its per-currency clearing account (`GetOrCreateClearingAccount`, ADR-014); the clearing account is where the spread and the two-sided legs land, so its balance is expected to drift and can be negative.
- Clearing accounts are created as System, Liability accounts, and `AccountPostingStates` skips the balance-fetch and min-balance enforcement for `is_system` rows, so a clearing leg is never blocked by a floor (`repository.go`, `enforceAccountConstraints`).
- The per-currency zero-sum invariant still holds for every transaction; a clearing account running negative does not violate it, because the invariant is per transaction per currency, not per account balance.
- `GetOrCreateClearingAccount` `USES INSERT ... ON CONFLICT ... DO UPDATE` SO two racing first-uses resolve to the same row rather than duplicating or losing the race.

The trap: Treating a negative clearing balance as a broken ledger. Clearing accounts are internal float; the zero-sum invariant is about each transaction balancing per currency, and system accounts are deliberately exempt from customer-facing floors so conversions can always net.

65.3.18 47. Migration 0036 dedups a held create on the caller's idempotency key. A reviewer suggested filtering that lookup to `status='pending'` so a retry does not return an already-decided pending. Why would that “fix” reopen a money bug, and what is the actual trade being made?

What a strong answer covers:

- `holdForApproval` looks up an existing pending by `(tenant_id, idempotency_key)` with no status filter and returns it on a retry, so the caller gets the same pending back whatever its current status (ADR-025 idempotency guarantee).
- If the lookup filtered to `status='pending'`, a retry of a key whose original pending was already approved would find nothing, mint a fresh pending with the same payload, and that second pending could be approved again; the replay uses a per-pending key (`approval:<id>`), so two pendings would post the money twice.
- The status-blind behavior is therefore required for money-safety; the visible cost is that a retry of an already-terminal key returns a 202 “held” framing even though the request is resolved, though the response body carries the true `status` and `transaction_id`.
- The right follow-up is to improve the HTTP framing for a terminal replay (return the posted transaction or a resolved marker), not to narrow the dedup lookup; the dedup must stay status-blind.

The trap: Assuming “return the same pending only while it is still pending” is the safe, obvious rule. It reopens the double-post the whole migration exists to close; the safe design dedups across all statuses and treats the stale 202 framing as a presentation problem,

not a correctness one.

65.3.19 48. A webhook subscriber becomes a black hole: it accepts the TCP connection and then never responds, on every attempt. Trace what is pinned and what is bounded, across one delivery and across the retry lifetime.

What a strong answer covers:

- Each attempt is bounded by the client `HTTPTimeout` (10s default, `worker.go`): the connection is held for at most that long, then the attempt fails and the row goes to `failed` with `next_attempt_at = now + backoff`.
- Nothing is pinned between attempts: the delivery is a row, not a held goroutine, so a black-hole subscriber consumes one worker slot for up to 10s per attempt, not indefinitely.
- The retry lifetime is bounded by `MaxAttempts` (8) and the capped exponential backoff (10s base, 10min cap), after which the row is `dead` and never retried; the delivery batch is a fixed size, so one bad subscriber cannot starve others beyond its batch share.
- The blast radius is one tenant's deliveries lagging, not the ledger: fan-out and posting are upstream of delivery and never block on a subscriber.

The trap: Assuming a hung subscriber leaks connections or goroutines unboundedly. The per-attempt `HTTPTimeout` plus the row-based (not goroutine-based) retry model bounds it; the real cost is delivery latency for that subscription, and the `dead` state caps even that.

65.3.20 49. The four-eyes fix changed the audit Actor from the tenant id to the API-key id. Actor is part of ComputeAuditRowHash’s preimage. Does changing it break verification of transactions posted before the fix, and what would have broken if you had rewritten old rows to the new scheme?

What a strong answer covers:

- Verification recomputes each row’s hash from that row’s own stored fields, including its stored Actor, so a row posted before the fix stored Actor = tenant and still recomputes to its stored hash: old rows verify unchanged, new rows simply carry a different Actor value.
- The hash is over stored bytes, not over a global scheme, so mixing tenant-actor and key-actor rows in one chain is fine; each row is self-consistent (the same property the v1/v2 hash versioning relies on).
- Rewriting old rows to backfill the key-id would change their preimage and therefore their RowHash, breaking the chain link to every successor unless every downstream hash were recomputed, which is exactly the consistent-rewrite an append-only, hash-chained log exists to make detectable.
- The correct migration is no migration: change behavior going forward, never mutate history.

The trap: Wanting to “clean up” old rows to the new actor scheme for consistency. That is a rewrite of tamper-evident history; the append-only chain’s whole point is that you do not do that, and the signed anchor (ADR-026) would flag it if you did.

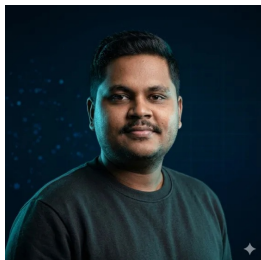
65.3.21 50. Webhook fan-out runs only on the advisory-lock leader. A rolling redeploy restarts the leader instance mid-fan-out. Walk the failover: what is the worst that happens to delivery, and why is nothing lost or double-fanned?

What a strong answer covers:

- The leader holds a Postgres session advisory lock; when its connection dies (restart), the lock is released automatically, and another instance acquires it on its next tick and resumes.
- The fan-out cursor is durable (a row/position in the database), so the new leader resumes from the last committed cursor: events not yet fanned out stay in the durable `audit_log` until processed, so nothing is lost.
- Fan-out inserts are idempotent against the cursor and the `webhook_deliveries` uniqueness, so a partially-completed pass that did not advance the cursor is redone without creating duplicate delivery rows; at worst an event is fanned out once by the new leader.
- Delivery in flight when the leader died is just a `pending/failed` row with a `next_attempt_at`; the new leader's delivery stage picks it up, so at-least-once still holds across the failover.

The trap: Assuming leader failover risks a forked or double fan-out. Leadership is a lock any instance can take, the cursor is durable and single-writer while held, and the chain is the source of truth, so failover degrades to bounded delay, never to loss or duplication of the fan-out itself.

About the Author



Sohag Hasan

Sohag Hasan is a software engineer and tech lead who has spent most of the past decade building for fintech and payments teams, on things like cross-border money transfers and integrations with banks. His day to day is mostly PHP and Laravel; go-ledger is where he set out to build the part he had always used but never owned, the ledger that decides whether money is real, and to build it in Go, where the concurrency he needed would fight back.

He works and writes in public from Dhaka, Bangladesh, publishing a running series about this build and other engineering notes. This book is one output of that habit, not a departure from it. He has been on both sides of the interview table for years, which is why every chapter here ends with the hard questions he would ask about the work.

Find him online

Portfolio: sohag.pro

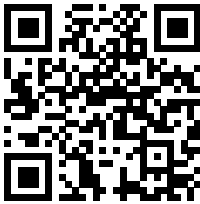
Series: notes.sohag.pro/series/go-ledger

Source: github.com/sohag-pro/go-ledger

Support: buymeacoffee.com/sohagpro

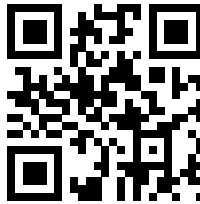
Support This Book

This book is free. It took a lot of evenings. If it saved you time, taught you something, or you just want more of it, the kindest thing you can do is buy me a coffee. and support is what keeps the series going.



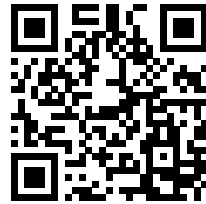
Buy me a coffee

buymeacoffee.com/sohagpro



My portfolio

sohag.pro



The source code

github.com/sohagpro/go-ledger

Scan a code with your phone camera, or tap it if you are reading the PDF. Either way, thank you for reading.

Index

- Ansible
 - ADR-013, 503
 - ADR-016, 532
 - Further Reading, 610
 - Glossary, **606**
 - Special Edition 2 Q&A, 373
 - Week 10, 238
 - Week 10 Q&A, 243
 - API key
 - ADR-012, 490
 - ADR-015, 519
 - ADR-019, 548
 - ADR-021, 560
 - ADR-024, 579
 - ADR-026, 591
 - Glossary, **604**
 - Hard Mode, 634
 - Special Edition 1, 341
 - Special Edition 1 Q&A, 350
 - Special Edition 3, 386
 - Week 14, 320
 - Week 8, 199
 - audit log
 - ADR-007, 456
 - ADR-012, 490
 - ADR-014, 513
 - ADR-015, 518
 - Glossary, **603**
 - Special Edition 1, 343
 - Special Edition 1 Q&A, 353
 - Week 0, 46
 - Week 1, 54
 - Week 11, 262
 - Week 13, 301
 - Week 5, 141
 - Week 6, 154
 - Week 6 Q&A, 166
 - Week 7, 175
 - Week 7 Q&A, 187
 - Who This Is For, 36
- authentication
 - ADR-012, 489
 - ADR-015, 521
 - ADR-019, 551
 - ADR-026, 591
 - Special Edition 1, 340
 - Special Edition 1 Q&A, 348
 - balance

A Note Before You Begin,
37

ADR-001, 425

ADR-002, 429

ADR-003, 432

ADR-004, 437

ADR-005, 444

ADR-006, 447

ADR-007, 456

ADR-008, 460

ADR-010, 475

ADR-011, 479

ADR-012, 489

ADR-014, 508

ADR-015, 520

ADR-016, 531

ADR-017, 538

ADR-018, 543

ADR-019, 548

ADR-021, 561

ADR-023, 571

ADR-025, 582

ADR-026, 590

Further Reading, 608

Glossary, **601**

Hard Mode, 618

Special Edition 1, 340

Special Edition 1 Q&A,
349

Special Edition 3, 385

Special Edition 3 Q&A,
398

Week 0, 43

Week 1, 50

Week 1 Q&A, 58

Week 11, 256

Week 11 Q&A, 266

Week 12, 278

Week 12 Q&A, 284

Week 13, 296

Week 13 Q&A, 307

Week 14, 324

Week 2, 69

Week 2 Q&A, 79

Week 3, 91

Week 3 Q&A, 99

Week 4, 111

Week 4 Q&A, 121

Week 5, 133

Week 5 Q&A, 142

Week 6, 158

Week 6 Q&A, 167

Week 7, 178

Week 7 Q&A, 183

Week 8, 196

Week 8 Q&A, 206

Week 9, 214

Week 9 Q&A, 226

Who This Is For, 36

chaos testing

- ADR-011, 480
- Further Reading, 609
- Glossary, **604**
- Week 0, 46
- Week 14, 326
- Week 14 Q&A, 337
- Week 9, 217
- Week 9 Q&A, 222
- chi
 - ADR-006, 447
 - ADR-009, 464
 - ADR-010, 471
 - Glossary, **602**
 - Week 0, 44
 - Week 1, 53
 - Week 1 Q&A, 62
 - Week 4, 120
 - Week 5 Q&A, 142
 - Week 7 Q&A, 182
 - Week 8 Q&A, 200
- CI/CD
 - ADR-013, 500
 - ADR-016, 531
 - ADR-019, 551
 - Special Edition 2, 359
 - Special Edition 2 Q&A, 367
 - Week 0, 44
 - Week 1, 53
 - Week 1 Q&A, 65
 - Week 10 Q&A, 246
 - Week 14, 324
 - composite key
 - ADR-005, 445
 - ADR-023, 572
 - Glossary, **602**
 - Week 12, 281
 - Week 12 Q&A, 289
 - concurrency
 - A Note Before You Begin, 37
 - ADR-001, 425
 - ADR-003, 434
 - ADR-004, 437
 - ADR-007, 454
 - ADR-011, 480
 - ADR-012, 494
 - ADR-014, 508
 - ADR-017, 534
 - Further Reading, 608
 - Hard Mode, 618
 - Special Edition 1 Q&A, 348
 - Special Edition 2 Q&A, 368
 - Special Edition 3, 383
 - Special Edition 3 Q&A, 395
 - Week 0, 42
 - Week 1, 51

- Week 1 Q&A, 60
- Week 13, 304
- Week 13 Q&A, 308
- Week 14, 324
- Week 2, 76
- Week 3, 96
- Week 3 Q&A, 103
- Week 4, 111
- Week 4 Q&A, 121
- Week 5 Q&A, 150
- Week 6 Q&A, 164
- Week 8, 199
- Week 8 Q&A, 209
- Week 9, 212
- Week 9 Q&A, 226
- coverage
 - ADR-008, 461
 - ADR-011, 479
 - ADR-025, 588
 - Glossary, **604**
 - Special Edition 2, 361
 - Special Edition 2 Q&A, 367
 - Week 0, 46
 - Week 2, 76
 - Week 2 Q&A, 86
 - Week 4 Q&A, 129
 - Week 9, 213
 - Week 9 Q&A, 222
- deployment
 - A Note Before You Begin, 38
 - ADR-006, 450
 - ADR-009, 469
 - ADR-011, 484
 - ADR-012, 490
 - ADR-013, 500
 - ADR-014, 513
 - ADR-015, 519
 - ADR-016, 528
 - ADR-017, 539
 - ADR-019, 548
 - ADR-020, 555
 - ADR-021, 565
 - ADR-022, 570
 - ADR-023, 575
 - ADR-024, 580
 - ADR-025, 584
 - ADR-026, 590
 - ADR-027, 600
 - Further Reading, 610
 - Glossary, **606**
 - Hard Mode, 650
 - How to Read This Book, 39
 - Special Edition 1 Q&A, 355
 - Special Edition 2, 359
 - Special Edition 2 Q&A, 367

- Special Edition 3, 379
- Special Edition 3 Q&A, 398
- Special Edition 4, 407
- Special Edition 4 Q&A, 411
- Week 0, 43
- Week 1, 51
- Week 1 Q&A, 62
- Week 10, 235
- Week 10 Q&A, 245
- Week 11 Q&A, 275
- Week 14, 324
- Week 14 Q&A, 332
- Week 5, 140
- Week 5 Q&A, 149
- Who This Is For, 36
- derived balance
 - Week 3 Q&A, 100
- distroless
 - ADR-013, 501
 - Further Reading, 610
 - Glossary, **606**
 - Week 0, 46
 - Week 1, 54
 - Week 1 Q&A, 65
 - Week 10, 236
 - Week 10 Q&A, 243
- Docker
 - ADR-003, 435
 - ADR-011, 480
 - ADR-013, 501
 - ADR-019, 550
 - Further Reading, 609
 - Glossary, **604**
 - Special Edition 2, 361
 - Special Edition 2 Q&A, 368
 - Week 0, 44
 - Week 1, 53
 - Week 1 Q&A, 62
 - Week 10, 235
 - Week 10 Q&A, 243
 - Week 3, 97
 - Week 3 Q&A, 107
 - Week 9, 218
 - Week 9 Q&A, 232
- double-entry accounting
 - ADR-001, 426
 - ADR-003, 433
 - ADR-004, 437
 - ADR-010, 474
 - ADR-012, 489
 - ADR-014, 507
 - ADR-026, 590
 - Further Reading, 608
 - Glossary, **601**
 - Hard Mode, 654
 - Special Edition 1, 340
 - Special Edition 1 Q&A,

- 349
- Special Edition 3, 378
- Week 0, 43
- Week 1, 51
- Week 1 Q&A, 58
- Week 11, 256
- Week 11 Q&A, 265
- Week 12, 282
- Week 12 Q&A, 290
- Week 2, 69
- Week 2 Q&A, 79
- Week 3, 91
- Week 3 Q&A, 100
- Week 4 Q&A, 131
- Week 5, 137
- Week 9 Q&A, 223
- Who This Is For, 36
- durability
 - ADR-004, 440
 - ADR-011, 483
 - ADR-015, 518
 - ADR-016, 529
 - ADR-027, 597
 - Glossary, **602**
 - Hard Mode, 621
 - Special Edition 3, 385
 - Special Edition 3 Q&A, 389
 - Week 10 Q&A, 249
 - Week 11 Q&A, 271
 - Week 14, 325
 - Week 14 Q&A, 329
 - Week 4, 118
 - Week 4 Q&A, 131
 - Week 9, 218
 - Week 9 Q&A, 231
- foreign key
 - ADR-003, 433
 - ADR-005, 444
 - ADR-012, 491
 - ADR-014, 513
 - ADR-015, 521
 - ADR-023, 572
 - Glossary, **602**
 - Special Edition 1, 342
 - Special Edition 1 Q&A, 350
 - Week 11 Q&A, 272
 - Week 12, 281
 - Week 12 Q&A, 289
 - Week 3, 94
 - Week 3 Q&A, 102
 - Week 6 Q&A, 169
- gRPC
 - ADR-009, 464
 - ADR-010, 471
 - ADR-011, 480
 - ADR-012, 491
 - ADR-014, 509

- ADR-015, 519
- ADR-026, 591
- Further Reading, 609
- Glossary, **605**
- Hard Mode, 620
- Special Edition 1 Q&A, 351
- Special Edition 3, 386
- Week 0, 44
- Week 1, 53
- Week 11 Q&A, 273
- Week 4 Q&A, 126
- Week 5, 134
- Week 5 Q&A, 151
- Week 6, 162
- Week 7, 175
- Week 7 Q&A, 182
- Week 8, 195
- Week 8 Q&A, 200
- Week 9, 212
- hash chain
 - ADR-012, 499
 - ADR-016, 531
 - ADR-017, 534
 - ADR-018, 542
 - ADR-027, 598
 - Glossary, **603**
 - Hard Mode, 623
 - Special Edition 1, 343
 - Special Edition 1 Q&A, 353
 - Special Edition 3, 382
 - Special Edition 3 Q&A, 395
- HSTS
 - ADR-013, 504
 - Glossary, **606**
 - Week 10, 239
 - Week 10 Q&A, 248
- huma
 - ADR-006, 447
 - ADR-009, 464
 - Glossary, **602**
 - Week 5, 139
 - Week 5 Q&A, 142
 - Week 6 Q&A, 172
 - Week 7 Q&A, 182
- idempotency
 - ADR-007, 453
 - ADR-009, 467
 - ADR-010, 475
 - ADR-011, 483
 - ADR-012, 489
 - ADR-014, 509
 - ADR-015, 518
 - ADR-017, 538
 - ADR-018, 543
 - ADR-025, 586
 - ADR-026, 594

- ADR-027, 599
- Further Reading, 609
- Glossary, **602**
- Hard Mode, 620
- Special Edition 1, 340
- Special Edition 1 Q&A, 348
- Special Edition 2 Q&A, 368
- Special Edition 3, 378
- Week 0, 46
- Week 1, 51
- Week 10 Q&A, 250
- Week 11 Q&A, 265
- Week 12 Q&A, 292
- Week 13, 300
- Week 13 Q&A, 310
- Week 14 Q&A, 330
- Week 5, 141
- Week 6, 154
- Week 6 Q&A, 163
- Week 7, 175
- Week 7 Q&A, 182
- Week 8 Q&A, 206
- Week 9, 212
- Week 9 Q&A, 222
- Who This Is For, 36
- idempotency key
 - ADR-007, 454
 - ADR-009, 470
 - ADR-010, 475
 - ADR-011, 483
 - ADR-012, 497
 - ADR-014, 509
 - ADR-015, 521
 - ADR-017, 538
 - ADR-025, 586
 - ADR-026, 594
 - Further Reading, 609
 - Glossary, **602**
 - Hard Mode, 629
 - Week 13, 300
 - Week 13 Q&A, 310
 - Week 6, 155
 - Week 6 Q&A, 164
 - Week 7, 178
 - Week 7 Q&A, 186
 - Week 9, 217
 - Week 9 Q&A, 227
- integer money
 - Further Reading, 609
 - Special Edition 1 Q&A, 349
 - Week 9, 215
 - Week 9 Q&A, 224
- k6
 - ADR-011, 481
 - ADR-013, 503
 - Further Reading, 610
 - Glossary, **604**

- Special Edition 2, 361
- Special Edition 2 Q&A, 368
- Week 0, 44
- Week 1, 53
- Week 9 Q&A, 222
- keyset pagination
 - ADR-006, 449
 - ADR-007, 457
 - ADR-008, 460
 - ADR-009, 466
 - ADR-015, 522
 - Glossary, **604**
 - Week 12 Q&A, 291
 - Week 5, 137
 - Week 5 Q&A, 142
 - Week 6, 160
 - Week 6 Q&A, 163
- load testing
 - ADR-011, 479
 - ADR-012, 493
 - ADR-013, 502
 - Hard Mode, 645
 - Special Edition 1, 339
 - Special Edition 1 Q&A, 348
 - Special Edition 2 Q&A, 368
 - Week 0, 46
 - Week 9, 218
 - Week 9 Q&A, 222
- metrics
 - ADR-004, 440
 - ADR-009, 467
 - ADR-010, 471
 - ADR-012, 491
 - Further Reading, 610
 - Glossary, **605**
 - Special Edition 2 Q&A, 376
 - Week 0, 44
 - Week 1, 53
 - Week 10, 236
 - Week 10 Q&A, 252
 - Week 4, 119
 - Week 4 Q&A, 121
 - Week 5 Q&A, 150
 - Week 7, 180
 - Week 7 Q&A, 187
 - Week 8, 194
 - Week 8 Q&A, 200
- migration
 - ADR-003, 433
 - ADR-004, 439
 - ADR-005, 444
 - ADR-006, 450
 - ADR-007, 459
 - ADR-008, 461
 - ADR-014, 513
 - ADR-015, 522

- ADR-017, 534
- ADR-018, 544
- ADR-019, 550
- ADR-020, 553
- ADR-026, 592
- ADR-027, 597
- Further Reading, 611
- Glossary, **602**
- Hard Mode, 613
- Special Edition 3, 386
- Special Edition 3 Q&A, 389
- Special Edition 4, 408
- Special Edition 4 Q&A, 410
- Week 0, 44
- Week 1, 53
- Week 12 Q&A, 289
- Week 13 Q&A, 307
- Week 14 Q&A, 329
- Week 3, 93
- Week 3 Q&A, 99
- Week 4, 115
- Week 4 Q&A, 124
- Week 5, 139
- Week 5 Q&A, 142
- Week 6, 160
- Week 6 Q&A, 163
- minor units
 - ADR-002, 429
 - ADR-006, 448
 - ADR-012, 489
 - ADR-014, 514
 - ADR-015, 518
 - Glossary, **601**
 - Hard Mode, 631
 - Special Edition 1, 340
 - Special Edition 3, 380
 - Special Edition 3 Q&A, 391
 - Special Edition 4, 404
 - Week 11 Q&A, 269
 - Week 13, 297
 - Week 2, 77
 - Week 2 Q&A, 79
 - Week 5, 140
 - Week 5 Q&A, 144
- multi-stage build
 - ADR-013, 500
 - Glossary, **606**
 - Week 1, 54
 - Week 10, 236
 - Week 10 Q&A, 243
- multi-tenant
 - ADR-003, 433
 - ADR-006, 449
 - ADR-013, 503
 - ADR-015, 519
 - ADR-019, 547
 - Further Reading, 610

- Hard Mode, 645
- Special Edition 3, 379
- Week 3, 93
- Week 3 Q&A, 109
- Week 5 Q&A, 144

nginx

- ADR-013, 503
- ADR-015, 523
- Glossary, **606**
- Week 10, 235
- Week 10 Q&A, 247

OpenTelemetry

- ADR-009, 468
- ADR-010, 471
- Further Reading, 610
- Glossary, **605**
- Week 0, 44
- Week 1, 53
- Week 7, 181
- Week 8, 194
- Week 8 Q&A, 202

OTLP

- ADR-010, 473
- Glossary, **605**
- Week 8 Q&A, 204

overflow

- ADR-002, 429
- ADR-011, 480
- ADR-014, 512

- ADR-022, 567
- Glossary, **603**
- Hard Mode, 617
- Week 11, 261
- Week 11 Q&A, 269
- Week 2, 70
- Week 2 Q&A, 82
- Week 9, 213
- Week 9 Q&A, 222

pgx

- ADR-003, 434
- Further Reading, 609
- Glossary, **601**
- Week 0, 44
- Week 1, 53
- Week 12 Q&A, 292
- Week 3 Q&A, 104
- Week 4 Q&A, 131
- Week 5 Q&A, 143
- Week 8, 195
- Week 8 Q&A, 201
- Week 9 Q&A, 228

phantom conflict

- Glossary, **603**

posting

- A Note Before You Begin,
37
- ADR-001, 426
- ADR-002, 429
- ADR-003, 432

- ADR-004, 437
- ADR-005, 443
- ADR-006, 449
- ADR-007, 453
- ADR-008, 460
- ADR-009, 466
- ADR-010, 475
- ADR-011, 482
- ADR-012, 489
- ADR-014, 506
- ADR-015, 521
- ADR-016, 531
- ADR-017, 534
- ADR-018, 542
- ADR-021, 562
- ADR-023, 571
- ADR-024, 577
- ADR-025, 582
- ADR-026, 590
- Further Reading, 608
- Glossary, **601**
- Hard Mode, 614
- Special Edition 1, 340
- Special Edition 1 Q&A, 349
- Special Edition 3, 378
- Special Edition 3 Q&A, 393
- Week 0, 43
- Week 1, 51
- Week 1 Q&A, 58
- Week 11, 256
- Week 11 Q&A, 265
- Week 12, 278
- Week 12 Q&A, 284
- Week 13, 296
- Week 13 Q&A, 307
- Week 14, 326
- Week 14 Q&A, 329
- Week 2, 69
- Week 2 Q&A, 79
- Week 3, 91
- Week 3 Q&A, 99
- Week 4, 111
- Week 4 Q&A, 124
- Week 5, 135
- Week 5 Q&A, 142
- Week 6, 157
- Week 6 Q&A, 163
- Week 7, 176
- Week 7 Q&A, 185
- Week 9, 214
- Week 9 Q&A, 226
- predicate lock
 - Glossary, **603**
 - Week 14, 325
 - Week 4, 117
- Prometheus
 - ADR-004, 439
 - ADR-010, 471

- ADR-013, 503
- ADR-026, 595
- Further Reading, 610
- Glossary, **605**
- Hard Mode, 619
- Week 0, 44
- Week 1, 53
- Week 10, 236
- Week 10 Q&A, 245
- Week 14, 325
- Week 4 Q&A, 121
- Week 7 Q&A, 187
- Week 8, 196
- Week 8 Q&A, 200
- property-based testing
 - ADR-011, 479
 - Further Reading, 609
 - Glossary, **603**
 - Week 0, 44
 - Week 1, 53
 - Week 11 Q&A, 274
 - Week 2, 75
 - Week 2 Q&A, 85
 - Week 9, 214
 - Week 9 Q&A, 224
- protobuf
 - ADR-010, 477
 - Further Reading, 609
 - Glossary, **605**
 - Week 7, 176
 - Week 7 Q&A, 182
- race detector
 - A Note Before You Begin, 37
 - ADR-011, 486
 - Further Reading, 609
 - Glossary, **604**
 - Hard Mode, 617
 - Special Edition 2, 361
 - Special Edition 2 Q&A, 368
 - Week 9 Q&A, 226
- rate limiting
 - ADR-012, 490
 - ADR-019, 549
 - Glossary, **604**
 - Special Edition 1, 346
 - Special Edition 1 Q&A, 348
 - Special Edition 3, 386
- RED method
 - ADR-010, 472
 - Glossary, **605**
- REST API
 - ADR-006, 447
 - ADR-007, 453
 - ADR-009, 464
 - Glossary, **602**
 - Week 0, 45
 - Week 1, 54

- Week 4, 120
- Week 5, 133
- Week 5 Q&A, 142
- Week 6, 154
- Week 7, 177
- retry
 - ADR-004, 438
 - ADR-007, 453
 - ADR-010, 474
 - ADR-011, 480
 - ADR-012, 490
 - ADR-015, 524
 - ADR-017, 538
 - ADR-018, 543
 - ADR-026, 594
 - ADR-027, 596
- Further Reading, 608
- Glossary, **602**
- Hard Mode, 613
- Special Edition 1, 340
- Special Edition 1 Q&A, 352
- Special Edition 2, 363
- Special Edition 2 Q&A, 370
- Week 0, 46
- Week 1, 52
- Week 11 Q&A, 272
- Week 13, 300
- Week 13 Q&A, 311
- Week 14, 323
- Week 14 Q&A, 328
- Week 3, 92
- Week 4, 113
- Week 4 Q&A, 121
- Week 5, 141
- Week 5 Q&A, 151
- Week 6, 154
- Week 6 Q&A, 164
- Week 7, 178
- Week 8 Q&A, 209
- Week 9, 216
- Week 9 Q&A, 227
- Who This Is For, 36
- reverse proxy
 - Glossary, **606**
- RFC 7807
 - ADR-006, 448
 - Further Reading, 609
 - Glossary, **605**
 - Week 0, 45
 - Week 1, 54
 - Week 4, 120
 - Week 5, 136
 - Week 5 Q&A, 148
- SERIALIZABLE
 - ADR-004, 438
 - ADR-005, 444
 - ADR-007, 454
 - ADR-009, 468

- ADR-010, 474
- ADR-011, 480
- ADR-012, 489
- ADR-015, 523
- ADR-017, 534
- Further Reading, 608
- Glossary, **603**
- Hard Mode, 613
- Special Edition 1 Q&A, 355
- Special Edition 3 Q&A, 393
- Week 0, 45
- Week 1, 54
- Week 1 Q&A, 60
- Week 14, 325
- Week 3, 98
- Week 4, 113
- Week 4 Q&A, 121
- Week 6 Q&A, 163
- Week 8 Q&A, 209
- Who This Is For, 36
- serialization failure
 - ADR-004, 438
 - ADR-012, 494
 - ADR-015, 522
 - Glossary, **603**
 - Hard Mode, 624
 - Special Edition 1 Q&A, 355
 - Week 4, 113
 - Week 4 Q&A, 121
 - Week 6 Q&A, 170
- slog
 - ADR-009, 467
 - ADR-010, 471
 - Glossary, **605**
 - Week 0, 44
 - Week 1, 53
 - Week 5 Q&A, 142
 - Week 7 Q&A, 188
- span
 - ADR-004, 442
 - ADR-010, 473
 - ADR-014, 506
 - ADR-020, 558
 - Glossary, **602**
 - Hard Mode, 619
 - Special Edition 4 Q&A, 412
 - Week 4, 115
 - Week 4 Q&A, 124
 - Week 8, 193
 - Week 8 Q&A, 200
- sqlc
 - ADR-003, 434
 - ADR-008, 461
 - ADR-011, 481
 - ADR-014, 516
 - Further Reading, 609

- Glossary, **601**
- Week 0, 44
- Week 1, 53
- Week 12 Q&A, 292
- Week 2, 78
- Week 3, 97
- Week 3 Q&A, 99
- Week 4 Q&A, 131
- Week 5, 138
- Week 5 Q&A, 142
- SSI
 - ADR-004, 438
 - Further Reading, 608
 - Glossary, **603**
 - Week 4 Q&A, 121
- structured logging
 - Glossary, **605**
 - Hard Mode, 619
- systemd
 - ADR-013, 501
 - ADR-016, 531
 - ADR-019, 550
 - Further Reading, 610
 - Glossary, **606**
 - Week 0, 44
 - Week 10, 235
 - Week 10 Q&A, 245
- tamper-evident
 - ADR-007, 453
 - ADR-012, 490
- ADR-016, 531
- ADR-017, 534
- ADR-018, 542
- ADR-024, 577
- ADR-025, 582
- ADR-026, 592
- ADR-027, 596
- Glossary, **603**
- Hard Mode, 630
- Special Edition 1, 343
- Special Edition 1 Q&A, 348
- Special Edition 3, 378
- Week 13, 301
- Week 13 Q&A, 306
- Week 14 Q&A, 328
- Week 6, 159
- Who This Is For, 36
- tenant
 - ADR-003, 433
 - ADR-006, 449
 - ADR-007, 456
 - ADR-008, 461
 - ADR-009, 467
 - ADR-011, 484
 - ADR-012, 489
 - ADR-013, 503
 - ADR-014, 508
 - ADR-015, 518
 - ADR-016, 531

ADR-017, 534
ADR-018, 542
ADR-019, 547
ADR-020, 553
ADR-021, 560
ADR-022, 568
ADR-023, 572
ADR-024, 578
ADR-025, 584
ADR-026, 591
ADR-027, 596
Further Reading, 610
Glossary, **602**
Hard Mode, 614
Special Edition 1, 340
Special Edition 1 Q&A,
 348
Special Edition 3, 379
Special Edition 3 Q&A,
 390
Special Edition 4, 404
Special Edition 4 Q&A,
 411
Week 11, 259
Week 11 Q&A, 267
Week 12, 281
Week 12 Q&A, 287
Week 13 Q&A, 312
Week 14, 320
Week 14 Q&A, 332

Week 3, 93
Week 3 Q&A, 99
Week 5 Q&A, 142
Week 6, 156
Week 6 Q&A, 167
Week 7 Q&A, 182
Week 8, 196

testcontainers

ADR-003, 434
ADR-011, 479
Further Reading, 609
Glossary, **604**
Week 0, 44
Week 1, 53
Week 3, 96
Week 3 Q&A, 99
Week 5 Q&A, 150
Week 6 Q&A, 169

TLS

ADR-013, 503
ADR-015, 523
Further Reading, 610
Glossary, **606**
Week 1 Q&A, 65
Week 10, 235
Week 10 Q&A, 247

token bucket

ADR-012, 493
Glossary, **604**

toxiproxy

- ADR-011, 480
- Further Reading, 609
- Glossary, **604**
- Week 9, 217
- Week 9 Q&A, 222
- trace
 - ADR-009, 467
 - ADR-010, 471
 - Further Reading, 609
 - Glossary, **605**
 - Hard Mode, 619
 - Special Edition 4, 407
 - Week 0, 46
 - Week 1, 54
 - Week 11 Q&A, 268
 - Week 7, 179
 - Week 8, 193
 - Week 8 Q&A, 200
 - Week 9, 212
- transaction
 - ADR-001, 426
 - ADR-003, 434
 - ADR-004, 437
 - ADR-005, 443
 - ADR-006, 447
 - ADR-007, 453
 - ADR-008, 461
 - ADR-009, 470
 - ADR-010, 471
 - ADR-011, 479
 - ADR-012, 490
 - ADR-014, 506
 - ADR-015, 521
 - ADR-016, 528
 - ADR-017, 534
 - ADR-018, 542
 - ADR-019, 547
 - ADR-021, 561
 - ADR-023, 576
 - ADR-024, 577
 - ADR-025, 582
 - ADR-026, 591
 - Further Reading, 608
 - Glossary, **601**
 - Hard Mode, 614
 - Special Edition 1, 339
 - Special Edition 1 Q&A, 349
 - Special Edition 3, 382
 - Special Edition 3 Q&A, 393
 - Special Edition 4 Q&A, 415
 - Week 0, 43
 - Week 1, 51
 - Week 1 Q&A, 58
 - Week 11, 256
 - Week 11 Q&A, 265
 - Week 12, 283
 - Week 13, 296

Week 13 Q&A, 306
Week 14, 319
Week 14 Q&A, 328
Week 2, 69
Week 2 Q&A, 79
Week 3, 91
Week 3 Q&A, 99
Week 4, 111
Week 4 Q&A, 121
Week 5, 133
Week 5 Q&A, 143
Week 6, 154
Week 6 Q&A, 163
Week 7, 176
Week 7 Q&A, 186
Week 8, 193
Week 8 Q&A, 200
Week 9, 213
Week 9 Q&A, 226

VPS

ADR-006, 450
ADR-008, 461
ADR-009, 467
ADR-010, 473

ADR-012, 495
ADR-013, 500
ADR-016, 528
ADR-019, 552
Glossary, **606**
Special Edition 2, 359
Special Edition 2 Q&A,
367
Special Edition 3 Q&A,
400
Week 0, 44
Week 1, 53
Week 10, 238
Week 10 Q&A, 243
Week 14, 324
Week 14 Q&A, 337
Week 7 Q&A, 190

WAL

ADR-004, 440
ADR-015, 520
ADR-016, 529
Glossary, **602**
Week 4, 118
Week 4 Q&A, 131

≡ `go-ledger`

Built in public, one week at a time.

Read, clone, follow along

> github.com/sohag-pro/go-ledger

> go.sohag.pro

> notes.sohag.pro/series/go-ledger

> sohag.pro

Free to read. If it helped, buy me a coffee

> buymeacoffee.com/sohagpro